



UK NCSC Cyber Assessment Framework 4.0

VMware Cloud Foundation 9.1

June 23, 2026

Table of Contents

Disclaimer.....3

Version.....4

Introduction.....4

Additional Resources4

Third Party Identifiers and Mappings4

Coverage Levels4

Controls..... 6

Disclaimer

This document is intended to provide general guidance for organizations that are considering Broadcom solutions. The information contained in this document is for educational and informational purposes only. This document is not intended to provide advice and is provided “AS IS.” Broadcom makes no claims, promises, or guarantees about the accuracy, completeness, or adequacy of the information contained herein. Organizations should engage appropriate legal, business, technical, and audit expertise within their specific organization for review of requirements and effectiveness of implementations.

Version

910-20260623-01

Introduction

This document describes how VMware Cloud Foundation (VCF) 9.1 and the separately licensed advanced services assessed alongside it, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, and VMware Avi Load Balancer, can support organizations working toward assessment against the UK NCSC Cyber Assessment Framework (CAF) 4.0. The CAF, published by the UK National Cyber Security Centre, provides a systematic approach to assessing the cyber security and resilience of organisations performing essential functions. It is organised into four objectives (managing security risk, protecting against cyber attack, detecting cyber security events, and minimising the impact of incidents) with principles and contributing outcomes assessed through indicators of good practice. Each assessed product is reported separately for every control, with VCF covering the full platform, including its consumption services and Private AI Services capabilities. The responsibility for assessment against the CAF remains with the organisation and its regulator.

<https://www.ncsc.gov.uk/collection/cyber-assessment-framework>

This guidance evolves. Please check the current revision at: <https://brcm.tech/vcf-compliance>

Additional Resources

This is one of a library of companion guides that map VMware Cloud Foundation and its advanced services to security and compliance frameworks. For each framework, the guide is published as a spreadsheet, a CSV data file, a Markdown document, and a PDF, together with a Security Configuration Guide crosswalk that identifies the VCF technical hardening settings relevant to that framework. The companion guide library, the VMware Cloud Foundation Security Configuration Guide, and related security documentation, sample scripts, and Q&A are available at <https://brcm.tech/vcf-security>.

Third Party Identifiers and Mappings

This document includes regulatory compliance and security control identifiers from external sources as a convenience to end users. This does not constitute endorsement, in either direction.

There is not a one-to-one mapping of product capabilities to third-party controls. A product capability, or set of capabilities, may be applicable to multiple controls. Conversely, a control may be satisfied with the use of multiple capabilities.

Control identifier numbers have been included from the Secure Controls Framework, version 2026.1, under the terms of the Creative Commons Attribution-NoDerivatives 4.0 International Public License. No modifications have been made to the control identifier numbers under the terms of the license.

<https://securecontrolsframework.com/>

Coverage Levels

Each control entry below carries the framework control text, the SCF control or controls it maps to, and an Aggregate Coverage line showing the strongest position any one of the assessed products holds for that control. Products that meet or contribute to the control follow as subsections, each with its own coverage level and response. Products the control does not apply to are listed together at the end of the entry, with a brief explanation. The coverage levels are:

- **Meets** -- the product directly provides the capability described in the control. No additional organizational process, external product, or human activity is needed beyond configuring the product itself.
- **Contributes** -- the product provides technical capabilities that help satisfy the control, but the control also requires something outside the product to be fully met, such as an organizational process, human activity, or an additional tool.

- **Not Applicable** -- the control does not apply to the product. Physical facility controls, staffing decisions, organizational governance processes, and domains the product does not operate in fall here.
- **Not Supported** -- the control is relevant to the product's domain (infrastructure, networking, security), but the product lacks the specific capability the control requires.
- **Not Assessed** -- the control has not yet been evaluated against the product.

Controls

Control A1

Principle A1 Governance: The organisation has appropriate management policies, processes and procedures in place to govern its approach to the security of network and information systems.

SCF Controls: GOV-02

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control A1.a

Board Direction: You have effective organisational security management led at board level and articulated clearly in corresponding policies.

SCF Controls: GOV-01.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control A1.b

Roles and Responsibilities: Your organisation has established roles and responsibilities for the security of network and information systems at all levels, with clear and well-understood channels for communicating and escalating risks.

SCF Controls: GOV-04, GOV-04.1, GOV-04.2

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control A1.c

Decision-making: You have senior-level accountability for the security of network and information systems, and delegate decision-making authority appropriately and effectively. Risks to network and information systems related to the operation of your essential function(s) are considered in the context of other organisational risks.

SCF Controls: GOV-01.1, GOV-04

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control A2

Principle A2 Risk Management: The organisation takes appropriate steps to identify, assess and understand security risks to network and information systems supporting the operation of essential functions. This includes an overall organisational approach to risk management.

SCF Controls: RSK-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control A2.a

Risk Management Process: Your organisation has effective internal processes for managing risks to the security and resilience of network and information systems related to the operation of your essential function(s) and communicating associated activities.

SCF Controls: RSK-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control A2.b

Understanding Threat: You understand the capabilities, methods and techniques of threat actors and what network and information systems they may compromise to adversely impact your essential function(s).

SCF Controls: THR-01, THR-09

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control A2.c

Assurance: You have gained confidence in the effectiveness of the security of your technology, people, and processes relevant to the operation of network and information systems supporting your essential function(s).

SCF Controls: CPL-01.4, GOV-19

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides built-in compliance measurement, scoring, and reporting capabilities that support an organization's conformity assessment activities. These tools allow operators to evaluate the state of their VCF environment against established security benchmarks and internal policies, producing quantitative results that can feed into broader compliance assessment programs. While conducting a full compliance program assessment is an organizational responsibility, VCF provides the technical instrumentation needed to assess and report on infrastructure conformity.

VCF Operations includes a compliance scoring engine that measures how well objects in the environment conform to industrial, governmental, regulatory, or internal standards, including the DISA STIG. The compliance score is calculated as the ratio of compliant objects to the total number of objects assessed by a given benchmark, expressed as a percentage. When an object violates multiple standards, the compliance score reflects the most critical violation, so the worst-case posture is visible. The compliance score card displays 100 when all objects are compliant, and shows the count of non-compliant symptoms when violations exist. The Badge|Compliance metric provides a per-object compliance percentage based on triggered symptoms versus total symptoms. Compliance scores are calculated for all objects in the environment regardless of the viewing user's object-level permissions, so the assessment reflects the true state of the environment rather than a filtered view.

VCF Operations compliance management detects violations, highlights risk areas, and provides actionable remediation recommendations. Compliance alerts appear as violations to the standard, and the triggered symptoms appear as violated rules. The Compliance Alert List displays alerts that caused compliance violations in a sortable table, allowing administrators to prioritize remediation efforts. These alerts, combined with remediation guidance, help administrators move from assessment findings to corrective action.

NSX provides a compliance report capability that allows administrators to compare their NSX networking configuration against IT policies and industry standards. This report identifies areas where the configuration deviates from the selected benchmark, supporting targeted remediation as part of an assessment cycle.

At the VMware vCenter level, the Compliance interface compares the desired configuration state against the current state of each host in a cluster and calculates drift. The ClusterCompliance or HostCompliance object returned by the compliance check API contains the per-host compliance status, notifications, and check duration, and administrators can retrieve cluster compliance status through the REST API by calling the Compliance.get endpoint. This mechanism checks conformity with the cluster's configured desired state rather than with a regulatory benchmark directly, but when the desired state profile is built to match a regulatory baseline, the drift check supports ongoing assessment against that baseline.

VCF's security configuration guidance, including the Security Configuration Guide and the DISA STIG, provides prescriptive baselines that organizations can use as the reference standard for their conformity assessments. VCF supports compliance measurement against guidelines for protecting controlled unclassified information. Administrators can automate assessment and remediation workflows through product interfaces, command-line tools, and APIs, reducing the manual effort involved in preparing for and responding to compliance assessments. VCF Operations also supports running workflows to remediate alerts or automate tasks, and maps out-of-the-box workflows to recommendations for automated remediation.

These capabilities allow organizations to run repeatable, evidence-based conformity assessments against their VCF infrastructure, but the broader assessment program, including determining which laws, regulations, and contractual

obligations apply, selecting assessment frameworks, scheduling assessment cycles, engaging independent auditors where required, and acting on assessment findings, remains an organizational responsibility.

VMware vDefend (Contributes)

VMware vDefend contributes to conformity assessments through Security Services Platform's Security Segmentation scoring and assessment capabilities, which provide measurable, evidence-based evaluation of an organization's network microsegmentation posture.

Security Services Platform calculates a Security Segmentation Score on a 100-point weighted scale distributed across five categories. Points are awarded only when firewall rules and configuration meet specified requirements, giving compliance officers a quantitative metric to track microsegmentation maturity over time. The scoring system supports Relaxed mode, useful for gauging progress during segmentation implementation, and Strict mode, which applies stricter penalties for unidentified or unsegmented traffic for more stringent posture assessment. These modes allow organizations to choose the assessment rigor appropriate to their compliance posture.

Environment Protection assessment evaluates whether workloads are protected by environment-specific segmentation policies, such as Dev, Prod, and Test. It measures the percentage of environment pairs operating in blocked mode and the percentage of all workloads covered by at least one environment rule, providing concrete metrics that can be presented during conformity assessments. The Security Segmentation Report includes an Inter-Environment Pair Protection Rule Action Summary section that provides a tabular summary of inter-environment communications, suitable for inclusion in audit evidence packages.

The Security Segmentation Score Breakdown report provides more granular detail, listing total environments and pairs, protection rule action summaries, and identifying environment pairs that lack inter-environment policies. This breakdown allows auditors to pinpoint specific gaps in microsegmentation coverage rather than relying solely on the aggregate score.

Rule Analysis, available within Security Services Platform, supports scheduled or on-demand analysis of the complete VMware vDefend (DFW) configuration. It detects contradictions where two rules have the same configuration with different actions, and identifies shadowed rules by comparing effective group memberships. Rule Analysis results can be exported as a CSV report for archival and review by external assessors. Role-based access control for Rule Analysis is enforced through Security Services Platform's platform roles; Enterprise Admin has full access to run, view, and download Rule Analysis reports. These capabilities help organizations demonstrate that their firewall policy is internally consistent and that analysis artifacts are available for auditor review.

Security Intelligence, integrated within Security Services Platform in VMware vDefend, provides policy recommendations that can be reviewed, modified, and published to enforce network security policies. The View Impacted Flows capability displays unprotected traffic flows used to generate policy recommendations, giving auditors direct visibility into unprotected network paths.

These vDefend capabilities address the network security dimension of conformity assessments. The broader compliance assessment program, including determining which regulations apply, selecting assessment frameworks, engaging assessors, and evaluating non-network controls, remains an organizational responsibility outside the scope of vDefend.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control A3

Principle A3 Asset Management: Everything required to deliver, maintain or support network and information systems necessary for the operation of essential functions is determined and understood. This includes data, people and systems, as well as any supporting infrastructure (such as power or cooling).

SCF Controls: AST-01, AST-01.1

Aggregate Coverage: Contributes

VCF (Contributes)

VCF contributes to IT Asset Management programs through built-in inventory, discovery, and integration capabilities that provide the technical foundation for asset tracking and governance.

VCF Operations groups discovered objects logically and provides detailed inventory lists across the environment, covering compute, storage, and networking resources. The inventory management interface supports sorting, searching, and object tagging to organize assets at scale. Custom object groups are containers that collect data from included objects and report on the data collected, allowing administrators to create dashboards and widgets that display resource information for grouped assets. VCF Operations also applies policies to newly discovered objects, such as objects added to an object group.

The Service Discovery adapter automatically discovers applications, services, and their associated metrics (CPU, memory) running on managed infrastructure. Discovery rules can be defined using object types including metrics, relationships, properties, object names, and tag-based criteria. Discovered applications can be exported in CSV format for use in external asset tracking systems.

For organizations using ServiceNow, VCF provides two integration paths. The Management Pack for ServiceNow in VCF Operations populates the ServiceNow CMDB with discovered resources through the ServiceNow Table API and CMDB Meta API, providing CMDB visibility within VCF Operations. VCF Automation also integrates with ServiceNow for ITSM and CMDB synchronization, configurable through extensibility action scripts or through VCF Operations Orchestrator Client hosted workflows. The ServiceNow ITSM Plug-in for VCF Automation provides a structured data source that captures extensive asset metadata, including resource name, operational status, project assignment, storage details, account and region information, endpoint type, zone, environment, and custom properties. The plug-in stores machine resource records in custom ServiceNow CMDB tables that track creation timestamps, deployment IDs, machine IDs, entitled users, and network schema. Deployment records similarly capture blueprint version, project ID, catalog ID, organization ID, operational status, owner, requester, and expiration tracking. The plug-in supports day-2 resource lifecycle actions such as Add Disk, Resize, Power On/Off, Create Snapshot, and Delete, and maintains CMDB accuracy through reconciliation.

VCF Automation adds governance through its project model, which controls who can deploy what resources and where those resources are deployed. Projects link users, catalog items, and IaaS resources together. Organizations in VCF Automation support policy-based governance on resource usage, allowing IT teams to monitor resource consumption, control permissions, and provide managed services with network isolation. Each organization maintains a secure boundary from other organizations. Resource quota policies can be defined through the Policies API to limit resources consumed by each user, project, or organization. Day 2 Action policies restrict which users have access to specific lifecycle operations on deployed resources.

Tags within VCF Automation express capabilities and constraints that define deployments. Cloud administrators can place constraint tags on projects to exercise governance over resource provisioning, supporting asset classification and controlled placement of workloads across the infrastructure.

The broader ITAM program responsibilities of establishing asset governance policies, defining ownership lifecycles, and maintaining organizational accountability remain outside VCF's scope.

VMware vDefend (Contributes)

VMware vDefend's Security Services Platform (SSP) organizes inventory assets into a defined hierarchy of region, zone, environment, application, and application tier, classifying them as either critical or regular applications. This hierarchy gives administrators a structured view of which assets support critical business functions and how they relate to each other within the environment.

Security Explorer's Applications View designates critical applications as high-priority types that receive enhanced security attention and monitoring, providing a focused view of business-critical workloads and their network security posture. The SSP Inventory monitoring function allows administrators to view the infrastructure hierarchy, including regions, zones, and virtual machines, and verify tag assignments for each infrastructure asset.

The SSP Segmentation Monitoring capability tracks application security posture over time and allows administrators to identify and address security risks surfaced through application monitoring. The SSP also identifies vulnerable workloads that could be exploited for lateral movement, supporting assessment of which assets pose elevated risk to critical business functions. Security Intelligence provides Infrastructure, Environment, and Application Monitoring capabilities that further aid in mapping asset relationships and security posture across the environment.

The SSP is a centralized repository that maintains the most current organizational IT assets, including servers, software, and network devices along with their configurations. These capabilities contribute to network-layer asset inventory and dependency mapping but do not replace an enterprise asset management system or provide the full business impact analysis and organizational security assessment processes that a TAAS identification program requires.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control A3.a (point 1)

Asset Management: All assets relevant to the secure operation of network and information systems supporting your essential function(s) are identified and inventoried (at a suitable level of detail). The inventory is kept up-to-date.

SCF Controls: AST-02

Aggregate Coverage: Contributes

VCF (Contributes)

VCF contributes to asset inventory processes by maintaining a detailed, real-time inventory of technology assets across compute, storage, and networking layers.

VMware vCenter maintains the authoritative inventory of all managed objects in the environment. The vSphere inventory organizes objects in a hierarchical structure beginning at the root folder and extending through datacenters, clusters, hosts, virtual machines, networks, and datastores. Each object carries metadata including configuration details, resource allocations, and operational state. Administrators can extend this metadata by defining custom attributes, which store organization-specific fields against any inventory object in vCenter. Custom attribute values are held centrally by vCenter rather than within the individual objects, allowing teams to annotate VMs, hosts, datastores, and other inventory items with organization-defined information such as ownership, classification, or business justification details. This inventory reflects the live state of the environment as objects are created, modified, or removed. Multiple vCenter instances can be linked for centralized inventory management across workload domains.

Programmatic access to the full inventory is available through the vSphere Web Services API. The Property Collector service uses Property Filter Specifications to identify inventory elements either directly or through object property traversal. The `RetrievePropertiesEx` method collects properties from inventory objects, allowing external systems and automation scripts to enumerate assets, gather configuration details, and build reports at whatever level of granularity is needed. The `SimpleClient` sample application demonstrates how to connect to a vCenter instance and obtain a listing of top-level inventory entities along with their properties and references.

VCF Operations extends inventory visibility by retrieving inventory details from each vCenter, including associated clusters, VMware ESX hosts, datastores, and virtual machines. Discovered objects are grouped logically in detailed inventory lists, and the inventory management interface supports sorting, searching, and object tagging to organize assets at scale. Custom object groups are containers that collect data from included objects and report on the data collected, allowing administrators to create dashboards and widgets that display resource information for grouped assets. VCF Operations also applies policies to newly discovered objects, such as objects added to an object group. `ResourceAttribute` elements define the metrics that appear in the monitoring interface, each identified by a Metric Key, providing continuous visibility into asset utilization, capacity, and health. The vSphere Compute Inventory Dashboard provides interactive views of clusters, hosts, and virtual machines associated with any selected object.

For application-level visibility, the VCF Operations Service Discovery adapter discovers running applications and services along with their CPU and memory metrics. Discovery rules can be defined using object types including metrics, relationships, properties, object names, and tag-based criteria. Discovered applications can be grouped by object type and selected attributes through Application Definition criteria, and the results can be exported in CSV format for use in external asset tracking systems.

VCF Automation adds a consumption-oriented layer to asset tracking. Projects link users, catalog items, and infrastructure resources where deployments are provisioned. The Overview tab displays infrastructure and consumption metrics across the organization. Resources visible in inventory views are scoped by the rights and project roles assigned to each user, providing role-appropriate visibility for audit and review. When catalog items are deployed, they are provisioned against the infrastructure available to the selected project, creating a traceable relationship between the request, the deployment, and the underlying resources. Provider accounts can create and track assets including virtual machines, catalogs, templates, and media. Organizations in VCF Automation support policy-based governance on resource usage, allowing IT teams to monitor

resource consumption, control permissions, and provide managed services with network isolation. Each organization maintains a secure boundary from other organizations. Resource quota policies can be defined through the Policies API to limit resources consumed by each user, project, or organization. Day 2 Action policies restrict which users have access to specific lifecycle operations on deployed resources. Tags within VCF Automation express capabilities and constraints that define deployments, and cloud administrators can place constraint tags on projects to exercise governance over resource provisioning, supporting asset classification and controlled placement of workloads across the infrastructure.

For integration with external asset registries, VCF provides multiple paths. The Management Pack for ServiceNow in VCF Operations discovers and synchronizes asset details including CPU count, CPU speed, CPU type, disk space, RAM, serial number, manufacturer, model ID, OS version, IP address, and vCenter reference through the ServiceNow Table API and CMDB Meta API. These properties are marked as required discovery fields, keeping the external CMDB aligned with the actual virtual infrastructure. VCF Operations for Networks supports adding ServiceNow as a CMDB data source to fetch configuration items and their relationships. VCF Automation also integrates with ServiceNow for ITSM and CMDB synchronization, configurable through extensibility action scripts or through VCF Operations Orchestrator Client hosted workflows. The ServiceNow ITSM Plug-in for VCF Automation captures extensive asset metadata, including resource name, operational status, project assignment, storage details, account and region information, endpoint type, zone, environment, and custom properties. The plug-in stores machine resource records in custom ServiceNow CMDB tables that track creation timestamps, deployment IDs, machine IDs, entitled users, and network schema. Deployment records similarly capture blueprint version, project ID, catalog ID, organization ID, operational status, owner, requester, and expiration tracking. The plug-in supports day-2 resource lifecycle actions such as Add Disk, Resize, Power On/Off, Create Snapshot, and Delete, and maintains CMDB accuracy through reconciliation.

Software asset tracking is supported through vSphere Lifecycle Manager, where software depots contain both the payloads and metadata for software updates. VCF Lifecycle Management tracks different versions of software components to help maintain compatibility across the infrastructure. The VCF Operations API includes methods to register associated products with their product name, version, and deployment details, contributing to a software-level view of the environment.

The Consumption layer of VCF extends asset inventory to containerized workloads running on VMware Kubernetes Service (VKS) and vSphere Supervisor. The Kubernetes API server maintains a live registry of every object within a cluster or Supervisor namespace, covering pods, deployments, services, ConfigMaps, Secrets, PersistentVolumeClaims, CustomResourceDefinitions, and other resource types. Every resource carries standard metadata including name, namespace, labels, annotations, creation timestamp, and owning references that administrators can query or export at any level of granularity. Labels and annotations allow teams to attach arbitrary metadata to any Kubernetes resource, such as application name, business unit, or data classification, and these fields are queryable via label selectors, supporting filtered inventory exports by category. Supervisor namespaces map to vCenter namespaces, associating Kubernetes workloads with the organizational units defined during provisioning, and resource quotas and limit ranges attached to each namespace record the allocated capacity and support tracking of resource consumption by application or team.

For workloads that consume specialized hardware such as accelerators or dedicated network devices, the Kubernetes Device Plugin framework provides hardware-level asset visibility within VKS clusters. Administrators or device owners use DeviceClasses to define sets of devices available in the cluster, and workloads claim specific hardware resources by creating ResourceClaims that filter for device parameters declared in a DeviceClass. Monitoring agents for device plugin resources discover which devices are in use on each node and collect metadata that associates each device allocation with the specific container consuming it, extending hardware asset tracking to the workload level.

The Harbor Registry Supervisor Service provides an inventory mechanism for container images and artifacts. Harbor organizes images in a Projects structure by team or application and secures them with policies and role-based access control, allowing administrators to track which container images are authorized for use within the environment. Container images deployed through VCF consumption paths should be scanned, signed, and approved according to organizational software supply chain policies before use; digital certificates and validation mechanisms support supply chain assurance of images and artifacts. Where GitOps practices are in use, the Argo CD Supervisor Service extends this inventory capability by recording application synchronization events with timestamps, capturing the resource group, kind, namespace, name, sync status, and health status

of each synchronized resource. Git repositories serve as the single source of truth for desired application and infrastructure state in a GitOps workflow, and infrastructure as code stored in version control creates a durable audit log of every authorized change to that state.

These capabilities give VCF a strong technical foundation for tracking virtual infrastructure assets with accurate, real-time data at multiple levels of granularity. However, the broader requirements of this control, including business justification tracking, organization-defined accountability information, and formal review and audit processes for the full scope of technology assets, applications, services, and data, require organizational policies and processes that operate alongside the platform's inventory capabilities.

VMware vDefend (Contributes)

VMware vDefend's Security Services Platform (SSP) maintains an inventory of network-visible workloads organized into a hierarchical asset collection spanning regions, zones, environments, applications, and application tiers. The Publish Inventory Assets tab in SSP displays infrastructure asset details including asset names, asset types, IP addresses, and total VM counts for assets sourced from imported CSV files, discovered services, or published infrastructure assets, providing accurate, granular records of network-visible assets.

Platform Inventory monitoring supports ongoing inventory accuracy through several mechanisms. Administrators can filter infrastructure assets by Name and Status, identifying assets that are timed out or out of sync. The inventory hierarchy view shows regions, zones, and VMs so administrators can verify correct definition. SSP Inventory displays assigned tags for each infrastructure asset, and environment rows can be expanded to view tag assignments and confirm hierarchy accuracy. The platform also collects and displays VM tags with their respective scopes, supporting classification and tracking. Published applications and their application types are verifiable in the Inventory > Applications interface.

SSP identifies and publishes application assets, classifying them as either critical or regular applications. Application Asset Collections represent groups of workloads delivering enterprise software functions. Security Intelligence within SSP displays application associations for compute entities, indicating the tiers within each application to which a given compute entity belongs. Administering compute entity classifications in Security Intelligence requires appropriate privileges, supporting access control over classification changes. Consistent naming conventions are recommended when preparing inventory data for import, and the Asset Prefix setting enables standardized naming during segmentation planning and monitoring.

In disconnected mode, usage files include an `asset_id` field providing a unique asset identifier, supporting asset tracking in environments without continuous connectivity.

vDefend's inventory scope is limited to network-visible workloads and does not replace enterprise-wide TAASD inventory tools, authorized software catalogs with business justification records, or data asset registries required for full AST-02 compliance.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to asset inventory requirements by providing built-in visibility into the database instances, infrastructure resources, and users it manages. This visibility supports tracking and accountability for the subset of technology assets that DSM governs. Organization-wide TAASD inventory across all asset categories requires organizational processes and additional tooling beyond DSM itself.

DSM tracks the association between deployed databases and the infrastructure policies under which they were provisioned. Administrators can review databases and their configuration details through the Databases tab in the Infrastructure Policies view of the DSM Administrator UI, which displays each policy alongside the databases bound to it. Because infrastructure policies define the compute, storage, and networking resources allocated to databases, including allowed VM classes, this view gives administrators a structured picture of how platform resources are being consumed. The About the DSM UI Views section confirms the Infrastructure Policies view lists all policies available in the environment and the databases associated with each.

DSM administrators can define and configure data service policies for the data services DSM manages, supporting compliance with organizational standards across tenants. Each policy can be tailored to specific requirements and assigned to one or

more organizations to enforce consistent configurations. For tenant-facing self-service, the DSM Consumption Operator creates infrastructure policies as cluster-scoped resources in the consumption cluster and requires an `allowedInfrastructurePolicies` list that defines which policies a tenant cluster may use, giving administrators a clear inventory of the policies in scope per cluster. Tenant users create and consume databases under a Supervisor namespace through the VCF Automation Cloud Consumption Interface (CCI), and the DSM portal exposes a Consumption Operator endpoint that provides access to deployment artifacts.

For database-level visibility, the Database Health view in the DSM UI collects metric data for each database instance and cross-references alerts with resolution paths. DSM deploys a Telegraf agent on the Provider Appliance and a local Telegraf agent on each workload cluster to gather VM-level metrics such as CPU, memory, and disk usage, plus engine-specific metrics. DSM can forward metrics to an external Metrics target server, supporting integration with external monitoring or inventory aggregation systems.

For auditors, DSM's inventory-relevant information is accessible through the Administrator UI and is available to personnel with the Admin role. The Databases tab, Infrastructure Policies view, Database Health view, and Consumption Operator policy inventory collectively provide the granularity needed to account for DSM-managed database assets and the policies governing them. The documented DSM user roles (vSphere administrator, VCF Automation organization administrator, VCF Automation project user) clarify which personnel have visibility into which inventory views.

DSM provides resource tracking and visibility within its own management scope. DSM does not perform organization-wide asset discovery and does not inventory physical infrastructure, non-database applications, or data assets outside its management domain. A TAASD inventory program spanning all asset categories requires a CMDB or dedicated asset management solution that can aggregate DSM resource data alongside information from other platform components.

Not applicable for this control: VCF Protection and Recovery, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control A3.a (point 2)

Asset Management: Dependencies on supporting infrastructure (e.g. power, cooling etc) are recognised and recorded.

SCF Controls: AST-01.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control A3.a (point 3)

Asset Management: You have prioritised your assets according to their importance to the operation of network and information systems supporting your essential function(s).

SCF Controls: BCD-02

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several capabilities that support the identification and documentation of critical technology assets, applications, services, and data within a virtualized infrastructure.

VMware vCenter maintains a real-time inventory of all managed objects, including hosts, VMs, clusters, datastores, and networks, and supports linking multiple vCenter instances for centralized inventory management. The vCenter inventory tracks multiple instances of ClusterComputeResource, ComputeResource, Datacenter, Datastore, DistributedVirtualSwitch, and Folder objects, providing a structured view of all infrastructure components. VCF Operations can export lists of resources, such as powered-off virtual machines, to CSV files for offline documentation and review.

VCF Operations includes a Business Applications feature that allows administrators to group related infrastructure objects and assign business criticality classifications. Each Business Application can be tagged with a criticality level of Critical, Medium, or Low, with Medium as the default. The Object Summary card within VCF Operations displays details including the application's source, application tag, environment, and business criticality rating. This classification capability allows infrastructure teams to maintain a structured view of which applications and their underlying resources are most important to the organization.

VCF Operations Service Discovery automatically detects running services across the environment. Service Discovery displays a list of all supported services that can be discovered and those currently discovered on VMs once configured. It also discovers performance metrics for individual service objects and service type objects, maintaining a catalog of known services and their relationships to underlying infrastructure. This automated discovery reduces manual effort in maintaining an accurate asset inventory.

VCF Operations also provides alert definitions with configurable Impact and Criticality metadata. The Impact setting can be configured to values such as Risk to indicate potential problems, while the Criticality setting can be set to values like Immediate for proper alert prioritization. Alert notifications can be filtered by impact category and criticality level, helping teams classify infrastructure resources by their importance and focus attention on the most important infrastructure components. VCF Operations Insights data tracks resource capacity and can notify project owners of changes affecting their assets.

VCF Automation provides complementary asset identification capabilities through its resource discovery and tagging system. The discovery process automatically identifies machines, storage volumes, networks, load balancers, and security groups for each cloud account region that has been added. Once discovered, these resources can be organized using tags that facilitate search and identification. Tags placed on cloud zones, network profiles, storage profiles, and individual infrastructure resources function as capability tags that define desired capabilities and support governance by expressing capabilities and constraints. Using logical, human-readable tags for storage, network, and infrastructure items is recommended to facilitate search and identification functions.

VCF Automation organizes infrastructure through projects, which link users, catalog items, and IaaS resources to the locations where items are deployed. The Overview tab displays infrastructure and consumption metrics, providing a consolidated view of resource usage. Resource details views support filtering based on attributes such as project membership, enabling administrators to locate and review specific subsets of the infrastructure.

Blueprints in VCF Automation allow users to model complex IT services by visually designing infrastructure components such as VMs, networks, storage, and software components. Resource objects in blueprints represent the infrastructure components and services that are provisioned and managed, providing an architectural record of how assets support business functions.

Together, these inventory, discovery, classification, tagging, and visualization capabilities give operations teams the tools to identify, classify, and document the technology assets that support essential business functions. However, VCF provides the technical tooling for asset identification and classification rather than the organizational processes needed to define which assets are critical to the business mission. Establishing criticality criteria, maintaining asset documentation, and conducting periodic reviews of critical asset designations require organizational processes that operate alongside the platform's capabilities.

VMware vDefend (Contributes)

VMware vDefend contributes to identifying and documenting critical technology assets through the Security Services Platform (SSP) and its Security Intelligence feature, which provide asset inventory, classification, and visualization capabilities oriented toward network security segmentation planning.

Security Services Platform maintains a Platform Inventory of infrastructure assets, collecting status information for each asset including identification of assets that are timed out or out of sync. The inventory view provides filtering by Name and Status to locate specific infrastructure assets and identify their operational state. Tags assigned to each infrastructure asset are displayed for verification of tag assignments.

Security Intelligence gathers infrastructure services and servers from CSV files and discovers additional services and servers based on traffic flows analyzed from ESX hosts. During CSV import, Security Intelligence parses and validates the content format and inventory asset data. Security Intelligence also maps discovered unique assets during segmentation analysis, including workloads, groups, IP addresses, distributed virtual port groups (DVPGs), segments, tiers, infrastructure services, and infrastructure servers.

Security Services Platform identifies and publishes application assets, classifying them as either critical or regular applications. This criticality classification supports the identification of mission-critical technology assets within the environment. The inventory hierarchy spans regions, zones, environments, applications, and tiers, with each level displaying the total number of assets within its scope.

Security Intelligence organizes discovered and imported assets into structured Asset Collections: groups, infrastructure assets, environments (such as Production, Non-Prod, DMZ, PCI, and Development), applications, and application tiers. The Environment Asset Collection maps security zones to the operational contexts that support business functions. Application Asset Collections group workloads that provide enterprise functionalities, linking infrastructure resources to the business services they support. The Infrastructure Asset Collection node covers core networking services that enterprise workloads depend on, including LDAP, DNS, NTP, and DHCP. An Unknown Asset Collection surfaces compute entities that are not in the NSX inventory but are present in the data center and communicating to NSX entities, supporting discovery of assets that should be formally inventoried.

Security Intelligence Workload Classification can be set to "Infrastructure Service" to indicate that a compute entity provides infrastructure services such as DNS, DHCP, LDAP, and Syslog. Inferred infrastructure classifications for compute entities can be reviewed, accepted, or modified through the Monitor & Plan > Security Explorer interface.

These capabilities contribute to the control but do not fully satisfy it. vDefend's asset identification is scoped to network security segmentation planning rather than the enterprise-wide technology asset catalog this control requires. Identifying all critical technology assets, applications, services, and data across an organization requires broader inventory and configuration management capabilities within VCF, such as VCF Operations business application views, VMware vCenter inventory exports, and VCF Automation project tagging, which provide the enterprise-wide asset catalog that vDefend's security-focused inventory complements.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) organizes its protection model around identifying which assets are critical enough to warrant disaster recovery protection. Protection groups are an explicit declaration of critical assets, organizing virtual machines into logical units based on their replication and recovery requirements. Placing a workload in a protection group is a deliberate act of classifying it as essential to business operations.

Inventory mappings document how each protected-site asset (resource pools, folders, networks, datastores) corresponds to recovery-site resources, creating a structured record of the infrastructure that supports critical workloads. Site-wide inventory mappings apply defaults across all protected VMs, while per-VM customizations document specific recovery configurations for workloads with unique requirements.

The Protection and Recovery Configuration Import/Export Tool exports a complete record of the DR asset inventory, including site names, inventory mappings, placeholder datastores, advanced settings, array managers with SRA information, protection groups, and recovery plans. This export provides a structured, portable document of which assets are protected and how they are configured for recovery. The export is produced in XML format, enabling automated processing and retention as a configuration record.

PNR generates and exports reports documenting each run of a recovery plan, each test of a recovery plan, and each test cleanup operation. These reports provide an auditable record of which recovery plans executed and which protected workloads were involved.

PNR tracks site metrics including paired sites, pair names, vCenter addresses, site connectivity status, and counts of protection groups, recovery plans, protected virtual machines, and array managers. VCF Operations collects configuration, component health, and usage information from protection and recovery servers and site pairs, providing consolidated visibility into the DR infrastructure as a class of managed assets.

Not applicable for this control: VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control A3.a (point 4)

Asset Management: You have assigned responsibility for managing all assets, including physical assets, relevant to the operation of network and information systems supporting your essential function(s).

SCF Controls: AST-01.2, AST-03

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control A3.a (point 5)

Asset Management: Assets relevant to network and information systems supporting your essential function(s) are managed with cyber security in mind throughout their lifecycle, from creation through to eventual decommissioning or disposal.

SCF Controls: SEA-07.1

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides integrated lifecycle management capabilities that address the full span of technology assets, applications, and services from initial deployment through ongoing maintenance to decommissioning.

At the platform level, VCF lifecycle management simplifies and automates the process of applying updates and patches to the software components within the VCF stack. It manages different versions of software components across the infrastructure, tracking compatibility and stability as components are updated. Administrators can plan updates, schedule maintenance windows, and apply changes with minimal disruption to running services. This centralized approach covers the core VCF infrastructure components and coordinates updates across the stack to maintain interoperability between dependent products. VCF building-block services have independent lifecycles, so updates to one service do not require coordinated changes across the entire environment, supporting practical lifecycle management without forcing broad impact assessments for routine updates.

VCF Operations provides a dedicated lifecycle management interface, accessible through Fleet Management and then Lifecycle, where administrators can upgrade individual VCF management components. Starting with VCF 9, lifecycle management for all core components is performed through the VCF Operations UI. The upgrade planner allows administrators to select target versions for each VCF core component, download upgrade bundles, and run pre-upgrade prechecks that validate component connectivity, version compatibility, and environment readiness before any changes are applied. VCF Operations coordinates the actual upgrade process across vCenter, NSX, ESX, and vSAN, running version-specific prechecks against components that have available upgrade bundles. VCF Operations also provides lifecycle management actions for monitoring agents and application services through the Infrastructure Operations Configurations page, where administrators can activate, deactivate, and manage Telegraf agents and discovered application services.

For the hypervisor layer, vSphere Lifecycle Manager (vLCM) manages the lifecycle of ESX hosts at the cluster level using a desired-state image model. Administrators define a single software specification for each cluster that includes the ESX base image, firmware add-ons, vendor add-ons, and third-party solution components. vLCM checks host compliance against this specification and remediates hosts that have drifted from the approved image. This includes installing firmware on new hosts, applying software updates, performing version upgrades, and decommissioning hosts when they reach end of life. vLCM consumes software updates from its depot, providing a structured mechanism for tracking available updates and applying them systematically across host clusters. vLCM can also manage the lifecycle of standalone ESX hosts that are part of a vCenter inventory, extending this coverage beyond cluster-managed hosts. In environments using vSphere Distributed Services Engine, vLCM extends lifecycle management to the software and firmware running on DPU (Data Processing Unit) devices within those servers. Hardware Support Manager (HSM) plugins extend this model to vendor-specific firmware and driver management, so that hardware components are kept at validated versions alongside software. vSphere Configuration Profiles provide a complementary desired-state mechanism for host configuration settings, with drift detection and remediation. VCF Operations monitors vSphere Configuration Profiles drift status through a collection cycle that runs every 8 hours, giving administrators visibility into configuration consistency across clusters.

For Kubernetes workloads, VMware Kubernetes Service (VKS) provides self-service lifecycle management of VKS clusters. Updating a Supervisor triggers rolling updates of the VKS clusters deployed on it, including Kubernetes software versions, VM configurations, and supporting infrastructure such as vSphere Namespaces and custom resources. Kubernetes version updates follow the upstream sequential update policy, meaning minor versions cannot be skipped. After all Supervisor control plane VMs are updated, worker nodes are updated in a rolling fashion. VKS supports running different Kubernetes versions in

separate clusters, allowing staged rollouts and version-specific testing. The VCF CLI provides a cluster upgrade command for upgrading workload clusters to a specified Kubernetes release version. VKS cluster lifecycle is managed through three layers of controllers: Virtual Machine Service, Cluster API, and Cloud Provider Plugin, supporting the full lifecycle from cluster creation through upgrade and decommissioning. VM Service manages the lifecycle of virtual machines within a vSphere Namespace, covering both stand-alone VMs and VMs that comprise VKS clusters. The vSphere Automation SDKs for Java and Python provide programmatic interfaces for automating the creation and lifecycle management of vSphere Namespaces, enabling scripted and auditable namespace lifecycle transitions. VM classes in vSphere Supervisor set guardrails for policy and governance of VMs by anticipating development needs and accounting for resource availability and constraints.

At the application and workload level, Kubernetes Deployments manage application lifecycle through declarative configuration that specifies container images, replicas, and runtime parameters. Rolling updates, rollback capabilities, and revision history allow platform operators to move applications through update and retirement phases in a controlled manner, with Pods carrying updated specifications created while old Pods are terminated to maintain application availability. The Kubernetes Container Lifecycle API enables the management system to take actions in response to container lifecycle events, allowing workload owners to hook into start, stop, and termination events for coordinated transitions. Kubernetes Finalizers provide a mechanism for controlling lifecycle cleanup of resources owned by deleted objects, preventing premature deletion before dependent resources have been properly retired. For stateful and third-party services, Kubernetes operators implement automation logic that responds to custom resource lifecycle events, handling snapshot creation, StatefulSet and Volume management, backup scheduling, and version upgrades for the services they manage. Supervisor Services that include an operator provide API and graphical interfaces that DevOps engineers can use to create and manage service instances within a vSphere Namespace throughout each service's lifecycle. Harbor, available as a standard package on VKS clusters, supports artifact lifecycle management by providing a centralized repository for storing, versioning, and managing container images. Image retention policies and versioning in Harbor support tracking the lifecycle of deployed software components and restricting which image versions remain in active use.

For consumer-facing workload management, VCF Automation provides a self-service catalog through which consumers deploy IT resources and independently manage workloads. Catalog items include blueprints, VM images, storage, networks, and other infrastructure resources scoped to projects and available for self-service deployment. Consumers can request and deploy infrastructure on a self-service basis and perform day-2 actions such as updates and patches independently. The Tenant Portal resource management interface allows filtering deployed resources by project and other attributes, and executing day-2 actions specific to resource type and state, covering the operational lifecycle of deployed workloads. The IaaS Services Console and Local Consumption Interface provide snapshot management for VMs, with options for memory capture and guest file system quiescence, supporting point-in-time restore capabilities as part of workload lifecycle management. Lifecycle and day-2 actions for custom resources in a VCF Automation deployment must be shared with all projects to maintain continued management when deployments are moved between projects.

VCF also exposes lifecycle management through its APIs. The vCenter Lifecycle Management API provides discovery operations for listing VMware products that can be associated with vCenter, managing product associations, and creating interoperability reports. It supports operations to retrieve the product catalog, associate and update products, and download reports generated by interoperability and pre-check operations, allowing administrators to verify compatibility before applying changes. The vCenter patching API provides its own pre-check operation that validates upgrade readiness before applying updates.

For application lifecycle extension, VCF Automation integrates with VCF Operations Orchestrator Client to extend the lifecycles of applications through workflows. This integration enables custom automation around deployment, maintenance, and retirement processes, using hosted workflows to manage application lifecycle events.

VMware Private AI Services (PAIS) supports the management of AI technology asset lifecycles through the Model Gallery and its integration with VCF Automation. The Model Gallery is a dedicated repository where AI application developers and MLOps engineers upload models for automated CI/CD-based deployment of model runtimes. Models can be distributed for continuous delivery across organizations or promoted between platforms and environments to support staged deployment workflows. The Model Gallery stores model metadata in the Open Container Initiative (OCI) format to describe the contents

and dependencies of ML models, enabling identification of platforms that can run a target model and helping reduce redundant copies while maintaining model integrity within a controlled environment. Before publishing a model, evaluators can examine inference requests for malicious behavior and perform hands-on functional tests to assess suitability for the intended business use case.

VCF Automation extends lifecycle management to AI applications and services through a self-service catalog. Private AI Services catalog items include AI Workstation, VMware Data Services Manager (DSM) Database, Triton Inferencing Server, and AI Kubernetes Cluster, created in the VCF Automation catalog for deployment by users in selected namespaces. Catalog provisioning supports retrieval-augmented generation (RAG) clusters on VMware Kubernetes Service (VKS) with a vector database in a single request, and the storage policy and VM class for DSM databases supporting RAG workloads are selected to suit the target workload. The Model Runtime component enables MLOps engineers to run models as model endpoints for use in Agent Builder and for indexing knowledge bases in Data Indexing and Retrieval, creating a path from model storage through active service delivery. Data Indexing and Retrieval also implements an MCP server that exports a set of search tools for each knowledge base. For disconnected deployments, the artifact mirroring tool (AMT) distributed with the pais CLI plug-in mirrors components into the air-gapped environment, and the VCF Consumption CLI 'vcf context create' command establishes an authenticated namespace context against VCF Automation using endpoint, CA certificate, API token, and context type parameters.

Private AI Services includes observability mechanisms to support monitoring of active AI assets. A Prometheus server is deployed in the Private AI Services namespace with its own metrics database backed by a Persistent Volume, with storage size inferred from the metrics retention property in the PAISConfiguration custom resource. The storage class and metrics retention period are configurable to control how long metrics are stored. LLM traces from agents and knowledge base indexing can be forwarded to an OpenTelemetry Collector for analysis. DevOps engineers can visualize health and performance metrics for Private AI Services components running in a VCF Automation namespace using an observability platform such as Grafana, and MLOps engineers and application developers can perform monitoring and diagnostics of models used in agents to track health, quality, and behavior of AI applications. For organizations using VCF Operations, a Telegraf deployment in the vmware-system-monitoring namespace uses a telegraf-user-config ConfigMap to manage user-configured monitoring endpoints for Private AI Services controller metrics.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to technology lifecycle management by providing built-in tooling for managing the versions, update schedules, and operational states of the database services it provisions. Lifecycle management capabilities are accessible through the DSM UI, which gives administrators and users the ability to create, update, and deprovision data services. In DSM, supported engines include PostgreSQL, MySQL, MinIO, and Microsoft SQL Server.

For the DSM platform components themselves, the DSM UI provides version and upgrade management capabilities that give administrators visibility into current data service versions and options for upgrading or deactivating them. Database management capabilities accessible through DSM include operating system and database engine upgrades. The DSM controller manages component dependencies through status monitoring and automated remediation, helping keep platform components in a consistent operational state.

DSM provides a maintenance policy mechanism to control when automated software updates are applied to the DSM plug-in. Administrators can configure the maintenance policy through either the DSM UI or the vSphere Client. The policy settings include a start date, a start time, and a duration that limits how long the update window may run, allowing organizations to schedule updates during low-impact periods. The maintenance_policy setting is accessible under the plug-in software update section.

For individual database instances, DSM supports a separate maintenance window configuration and a maintenance policy that administrators can set at database creation and adjust throughout the database's operational lifetime. The default maintenance window is six hours, beginning each Saturday at 23:59, and it is configurable via the maintenance-window setting. DSM adds a Monthly Occurrences setting that refines the maintenance schedule from a standard weekly cadence to specific weeks within a month, allowing selection of a particular day and one or more occurrences of that day. This granular

scheduling is available for MySQL, SQL Server, and other supported engines, and is also accessible to tenants through the VCF Automation interface.

Infrastructure governance is supported through the Data Services Manager Consumption Operator, which automates database deployments based on predefined infrastructure and backup policies. The Consumption Operator applies infrastructure policy and backup location bindings to namespaces matching a configured selector, helping align deployed services with approved infrastructure configurations across their operational lifetime.

A vSphere administrator plans, administers, and secures resources for databases by creating and managing infrastructure policies in DSM. DSM deploys Telegraf agents on the provider appliance and on each database workload cluster to collect VM-level and engine-specific metrics, supporting operational awareness across the service lifecycle.

Technology lifecycle management at the organizational level requires processes beyond what DSM directly provides. DSM does not maintain a centralized inventory of all technology assets across the broader environment, nor does it manage end-of-support or end-of-life calendars for the infrastructure it depends on. Organizations must establish their own processes for tracking asset lifecycles, consulting vendor roadmaps, and making upgrade or retirement decisions within a formal change management framework. DSM's maintenance and version management capabilities are most effective when integrated into those broader organizational lifecycle processes.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer has built-in mechanisms for managing the lifecycle of its own technology components. The Avi Controller is the central management plane responsible for deploying, configuring, and decommissioning Service Engine VMs. In vCenter and NSX environments, the Controller automatically manages the Service Engine lifecycle, provisioning new Service Engine VMs when a Service Engine VM or its ESX host fails.

The Avi Controller REST API supports application lifecycle automation, providing programmatic visibility into all configured virtual services and enabling create, update, and delete operations across the application delivery estate. Infrastructure-as-code integrations build on this API: Avi Ansible modules allow operators to define, create, and manage Virtual Services, Pools, and Health Monitors consistently across deployments. Avi automation integrates with DevOps workflows and infrastructure-as-code practices to streamline operations and reduce manual errors.

VCF introduces a dedicated Avi Load Balancer integration for VCF. The VCF Automation Provider Management portal supports resource governance and capacity planning to help prevent organizations from over-consuming shared Avi Load Balancer resources. Organization and project administrators can define blueprints that act as reusable designs for deploying Layer 4 and Layer 7 virtual services; blueprints can be scoped to a single project or shared across projects within an organization. Service Engine Groups can be assigned to projects, enabling a self-service model for application teams while retaining administrative control over capacity allocation.

Avi also manages the lifecycle of associated security artifacts. The Avi License Hub manages the Platform CA certificate lifecycle and automatically initiates certificate refresh processes. The Controller license ledger tracks consumed and available licensing values and displays consumption metrics for Service Engines.

The control asks whether the organization manages the lifecycles of technology assets, applications, and services broadly. Avi contributes the mechanisms for lifecycle management of the application delivery layer, but the organizational governance process of tracking all technology assets across the environment, defining end-of-life criteria, and executing planned decommissioning activities extends beyond what any single tool provides.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control A4

Principle A4 Supply Chain: The organisation understands and manages security risks to network and information systems supporting the operation of essential functions that arise as a result of dependencies on suppliers. This includes ensuring that appropriate measures are employed where third party services are used.

SCF Controls: RSK-09, TPM-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control A4.a

Supply Chain: You understand and effectively manage the risks associated with suppliers to the security of network and information systems supporting the operation of your essential function(s).

SCF Controls: RSK-09

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control A4.b

Secure Software Development and Support: You actively maximise the use of secure and supported software, whether developed internally or sourced externally, within network and information systems supporting the operation of your essential function(s).

SCF Controls: TDA-06

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control B1

Principle B1 Service Protection Policies, Processes and Procedures: The organisation defines, implements, communicates and enforces appropriate policies, processes and procedures that direct its overall approach to securing systems and data that support operation of essential functions.

SCF Controls: GOV-02

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control B1.a

Policy, Process and Procedure Development: You have developed and continue to improve a set of cyber security and resilience policies, processes and procedures that manage and mitigate the risk of adverse impact to network and information systems supporting your essential function(s).

SCF Controls: GOV-03

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control B1.b

Policy, Process and Procedure Implementation: You have successfully implemented your security policies, processes and procedures and can demonstrate the security benefits achieved.

SCF Controls: GOV-02

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control B2

Principle B2 Identity and Access Control: The organisation understands, documents and manages access to network and information systems supporting the operation of essential functions. Users (or automated functions) that can access data or systems are appropriately verified, authenticated and authorised.

SCF Controls: IAC-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides a layered identity and access management architecture spanning centralized identity services, role-based access control, group-based access policies, identity provider federation, and programmatic access management through APIs.

VCF SSO is the centralized authentication service. VCF SSO issues security tokens that grant authenticated users access to VMware vCenter, NSX Manager, VCF Operations, and other platform components without requiring separate credentials for each service. VCF Operations supports importing users and groups from VCF SSO for consistent identity management across the stack. VMware Identity Manager provides a platform for managing users and groups, managing resources and user authentication, and configuring access policies and resource entitlements. vCenter also supports built-in identity source authentication using local domain credentials. The built-in identity provider can also be configured to use Active Directory as an identity source through LDAP/S, OpenLDAP/S, or Integrated Windows Authentication (IWA), depending on the directory environment.

VCF supports federation with enterprise identity providers. vCenter can be federated to providers such as Microsoft Entra ID, ADFS, and Okta, which enables multifactor authentication and automatic user synchronization with the organization's directory. PingFederate is also supported as a federated identity provider; for these integrations, vCenter uses System for Cross-domain Identity Management (SCIM) to automate the exchange of user and group identity information between the external identity domain and vCenter. VMware Identity Broker allows principals to authenticate to vCenter through an external identity provider. NSX Manager can be configured to authenticate users from identity management providers and can be integrated with Workspace ONE Access for identity management services. The Supervisor component supports registration of OIDC-compliant external identity providers for authentication to VMware Kubernetes Service (VKS) clusters; supported providers include Okta, Workspace ONE Access, and Dex, configured by supplying the Supervisor callback URL to the identity provider.

Role-based access control is enforced across all VCF components. In vCenter, permissions associate a user or group with a role on a specific inventory object, and predefined roles cover common administrative functions. Custom roles can be created with only the minimum required privileges for a given workflow. Managing identity provider configuration in vCenter requires the VcidentityProviders Manage privilege. VCF Operations supports group-based access control, allowing administrators to configure groups and assign roles that control access to dashboards, reports, policies, alerts, and administration functions, as well as granular role-based controls for platform operations including approvals, audits, certificates, and content libraries.

VCF Automation extends access management through organization-level and project-level controls. The VCF Automation Access Control service supports identity operations for managing groups and users, including editing user names, passwords, and role assignments. The organization portal enforces role-based access control, requiring either Organization Administrator or Organization Auditor roles to manage policy templates. Organization administrators can distribute infrastructure and configure group-level access through the organization management functionality. Project access is governed by predefined roles. Users and groups can be disabled at the organization level to revoke access without deleting accounts. The System Administrator role has the right to manage and view Access Control Lists, and the accessControls API allows administrators to view and manage ACL entries for defined entities.

For Kubernetes workloads within the VCF consumption layer, VKS supports two authentication methods: VCF SSO and OIDC-compliant external identity providers. The OIDC path is implemented through Pinniped and supports providers including Okta, Workspace ONE Access, Dex, GitLab, and Google OAuth. Configuring an external provider requires setting up an OpenID

Connect ID Token with a Groups claim type filter to enable group-based access control tied to the organization's directory. Custom ClusterClass configurations allow clusters to authenticate developers using existing corporate identity systems. VKS supports namespace permission roles: Owner (full control including deletion), Can Edit (provisioning and operating workloads), and Can View (read-only access). These roles map to Kubernetes ClusterRoles through RoleBindings, and RoleBinding objects can reference VCF SSO users and groups directly to integrate SSO identities with Kubernetes role-based access control. A user with the Namespaces.Edit privilege on a user-created Namespace folder can perform CRUD operations on Kubernetes API resources in the Supervisor. Namespace Self-Service permissions control which users can self-provision namespaces through kubectl.

Kubernetes RBAC is the primary authorization mechanism within VKS, using Roles, ClusterRoles, RoleBindings, and ClusterRoleBindings to bind permissions to users, groups, or service accounts. Kubernetes Attribute-Based Access Control (ABAC) is also available, defining access rights through policies that combine user, namespace, resource, and access mode attributes. Authorization webhooks can interpret field and label selectors to enforce fine-grained access control based on resource attributes such as node names and labels.

Service accounts provide namespaced workload identity within VKS clusters. For Windows containers, the Group Managed Service Account (gMSA) Webhook allows containers to run as Active Directory identities. VKS service accounts can be annotated with IAM role ARNs to enable pod identity and role assumption for cloud resource access through OIDC federation, replacing long-lived static credentials with short-lived, least-privileged credentials on demand. IAM role trust policies can be scoped to specific service accounts and namespaces to enforce least privilege.

Several supplementary services within the VKS layer extend the IAM surface. Harbor Registry, available as a standard package on VKS clusters, enforces role-based access control to manage access to container image artifacts. The Secret Store Supervisor Service enforces RBAC for administrators, DevOps engineers, and application tenants managing sensitive data. Argo CD supports both OIDC configuration for external identity providers and local account configuration with global RBAC policies that define role-based access through policy rules and group mappings. The Istio service mesh package includes a pluggable policy layer supporting access controls, rate limits, and quotas at the service-to-service level.

Programmatic access management is available through several APIs. The Identity API authenticates and manages the authorization provider. The Identity Service and Infrastructure as a Service APIs are used to acquire access tokens for REST API authentication. Principal Identity users authenticate using client certificates for service-to-service communications between VCF components.

NSX integrates with LDAP and external identity management services for administrative access to networking configuration. NSX Manager enforces role-based access control with roles such as auditor and network administrator assignable to LDAP users. vDefend, a separate product that extends NSX with security capabilities, offers an Identity Firewall that integrates with Active Directory for identity-based firewall rules.

VMware Private AI Services (PAIS) provides OIDC-based authentication and group-based authorization for AI workloads, the primary IAM mechanisms controlling access to model endpoints, the model runtime, Agent Builder, and Data Indexing and Retrieval capabilities. PAIS authentication is configured with an issuer URL, a client ID (pais-authentication-id), and the openid, groups, and offline_access scopes. The OIDC provider must support the .well-known/openid-configuration discovery endpoint. Authorization restricts access to user accounts that are members of named groups listed in the authorizedGroups setting (such as group-for-pais-access-01 or group-for-pais-access-02). A groups claim is included in the Access Token and a corresponding groups scope is created in the OIDC configuration, while the oidc-groups-claim setting selects which claim name carries group membership when the OIDC provider uses a non-default name. The oidc-extra-audiences setting accepts additional OAuth 2.0 client identifiers that PAIS will accept when validating Access Tokens, supporting integration with downstream clients that present their own audience. Activating PAIS in an organization namespace requires coordination with the OIDC provider administrator and an organization administrator account in VCF Automation.

Identity provider integration for PAIS deployments is configured at the Supervisor level under Workload Management > Supervisors > Configure > Identity Providers. When a PAIS region is created for a Supervisor, an identity provider entry is

automatically created in VMware vCenter for that Supervisor, linking the Supervisor namespace to the configured OIDC source.

The Model Gallery, the curated repository for ML models in PAIS, restricts access to model artifacts and the training data used to tune them through Harbor project access controls. These controls scope which users and service accounts can read, push, or manage sensitive model data, adding an IAM enforcement layer to the model supply chain. A Harbor registry is recommended for PAIS deployments, and OCI-compliant registries from other vendors are also supported.

PAIS Knowledge Bases extend IAM to ingested data sources. Confluence data sources authenticate with a user name and password or a personal access token, while Microsoft SharePoint On-Premises data sources authenticate with a user name and password. Personal access tokens for Knowledge Bases are generated from user account settings and used for programmatic access to linked data sources.

PAIS integrates with Grafana for metrics visualization using the same OIDC provider, extending the IAM model to the observability layer so that operators authenticate through the configured identity provider before accessing PAIS dashboards.

VMware vDefend (Contributes)

VMware vDefend contributes to identity and access management by providing identity-aware network enforcement through Identity Firewall, which integrates with Active Directory to apply firewall policy based on authenticated user identity rather than IP address alone. Identity Firewall supports assigning Active Directory users and groups as source criteria in both distributed firewall rules and gateway firewall rules, applying to tier-0 and tier-1 gateways. This allows organizations to enforce network access policy by user or group membership rather than relying solely on IP-based controls.

Within its management plane, the Security Services Platform implements role-based access control with five defined roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. These roles govern access to security policy management, analytics, incident response, and diagnostic functions across the platform. Network Detection and Response enforces the same five-role RBAC model for triage operations such as viewing detections and campaigns, and for configuration operations including SIEM integration management. For authentication, the Security Services Platform supports Active Directory and OpenLDAP as external identity sources, with one identity source configurable at a time. The License Hub integrates with external identity providers to store and manage user and group information for access delegation.

Centralized IAM for organizational users, including VCF SSO, MFA, and directory lifecycle management, is handled by VCF and falls outside vDefend's scope.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) incorporates multiple identification and access management mechanisms that support organization-wide IAM controls within the data services layer.

DSM implements role-based access control with two defined roles: the DSM Admin role, which can create, monitor, and manage all data services in the environment, and the DSM User role, which is restricted to managing and monitoring data services within the namespaces to which the user has been granted access. These roles are assigned at user creation time and govern what each user can see and do within the DSM interface. The Permissions view in the DSM dashboard provides administrators with a centralized location for creating, monitoring, and managing all configured users.

DSM supports two identity sources, which can be used independently or together. Local users are created directly within DSM, with credentials validated by matching email address and password. LDAPS users are sourced from a configured LDAP identity provider, allowing organizations to extend their existing directory service into DSM. When LDAPS is configured, administrators can import users from the directory provider and assign them DSM Admin or DSM User roles. DSM also supports group-based access control: Directory Service Groups from the LDAP provider can be assigned roles directly, so group membership in the external directory determines access level in DSM without requiring per-user assignments.

At the database level, DSM extends authentication controls beyond the platform management layer. MySQL database instances support LDAPS authentication using Active Directory. PostgreSQL and other database instances support host-based authentication (HBA) rule configuration, which determines which clients are permitted to authenticate to a given

database instance. SQL Server instances support Windows Authentication through Active Directory integration, enabling Kerberos-based authentication so that clients such as SQL Server Management Studio running on domain-joined machines can authenticate via single sign-on. SQL Server also uses contained database users, where identity information resides within the database itself rather than at the server level. Administrators can configure SQL Server instances with either a SQL User or Windows Principal as the primary administrator identity, with Windows Principal available for Active Directory-integrated clusters. An internal `dsm_mgmt` management login restricts users from accessing or modifying system-level objects, keeping administrative operations within an isolated context.

Namespace isolation adds a further access boundary. DSM namespaces enforce role-based access control that allows multiple users to work jointly on data services within a namespace while remaining isolated from data services in other namespaces. This supports least-privilege access within multi-tenant deployments.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides a dedicated administrative identity and access management plane through the Avi Controller, supporting multiple authentication methods and fine-grained authorization controls that allow organizations to implement IAM policies across both the management plane and the application delivery layer.

For administrative access, the Avi Controller supports local user accounts, LDAP and LDAPS directory integration, SAML-based federated authentication (including integration with Workspace ONE Access for catalog-based application access), basic authentication, and OAuth/OIDC for API access. Auth Mapping Profiles allow organizations to map external directory groups to specific roles and tenants, so that group membership in an external identity provider directly controls what a user can access within Avi.

Authorization is handled through role-based access control (RBAC) with object-level granularity. Avi's extended granular RBAC uses markers, which are labels assigned to objects, to enable fine-grained authorization based on object ownership and classification. Permission categories cover Operations (including alerts, actions, and traffic capture) and Administration (including controller, tenant, user, role, and system configuration management). This allows restrictions so that a user's permissions apply only to the specific resources matching the markers assigned to their role. RBAC covers object categories including Virtual Services, Application Profiles, SSL/TLS Certificates, Certificate Management Profiles, Cloud definitions, TCP/UDP Profiles, Persistence Profiles, Health Monitors, Analytics Profiles, IP Address Groups, String Groups, SSL/TLS Profiles, PKI Profiles, and Authentication Profiles, with distinct read and write access levels configured per object type.

For multi-tenant deployments, Auth Mapping Profiles support tenant isolation with configurable user group to role mappings, allowing organizations to enforce separation between teams or business units operating within the same Avi Controller.

The Avi License Hub supports role-based access control through an external identity provider, with three predefined roles: Enterprise Admin (full access for all operations, including upgrades and authentication configuration), Auditor (view-only access for tracking activity without making changes), and Support Bundle Collector (restricted to collecting system logs and diagnostics). Management interface access is further controlled through restrictions on allowed ciphers and HMACs for management sessions.

For deployments involving the Avi Kubernetes Operator (AKO), Kubernetes RBAC policies can be applied to AKO Custom Resource Definitions (CRDs) to enforce stricter access control over routing configuration for specific user groups. The Avi Controller also implements RBAC at the Kubernetes and OpenShift cluster level by assigning tenants and roles to user accounts.

At the application layer, Avi can enforce client authentication using OAuth, SAML, JWT token validation, and mutual TLS with client certificates, extending access control to the traffic flowing through virtual services rather than only to the management interface.

Organizations are responsible for defining roles, mapping directory groups to permissions, establishing naming conventions for markers, and maintaining user lifecycle processes. Avi provides the technical mechanisms; the governance and operational processes for identity management must be organized by the teams managing the deployment.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control B2.a

Identity Verification, Authentication and Authorisation: You robustly verify, authenticate and authorise access to network and information systems supporting your essential function(s).

SCF Controls: IAC-02, IAC-03

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides centralized authentication, authorization, and auditing through VCF SSO, which acts as the identity broker for all VCF management components. All user and service authentication flows through VCF SSO, providing a single point of control for identity management across VMware vCenter, VMware ESX, NSX, VCF Operations, and VCF Automation. VCF SSO is configured via the VCF Operations console and provides a unified authentication source for VCF components.

VCF supports multiple authentication mechanisms for organizational users. VCF SSO issues SAML tokens for authenticated sessions and supports multiple authentication context methods, including PasswordProtectedTransport (password over HTTPS) and holder-of-key tokens that embed security artifacts for delegation scenarios. vCenter supports built-in identity source authentication using local domain credentials and basic authentication through the OAuth 2.0 Password grant type when federated to an external identity provider. VCF SSO also supports the use of SSPI (Security Support Provider Interface) for client authentication.

Identity federation with enterprise identity providers (via SAML or OIDC) enables organizations to extend their existing AAA infrastructure to VCF. Federating vCenter to an enterprise identity provider supports multifactor authentication and automatic registration and termination of users across services. vCenter has documented federation configurations for specific providers including Okta and PingFederate. VCF SSO also supports the System for Cross-domain Identity Management (SCIM) protocol for automating the exchange of user identity information between identity domains and external identity providers.

Organizations using Microsoft Active Directory can use user identities contained in a Windows Server domain controller or Active Directory service across their virtual infrastructure. VCF Automation allows each organization to define its own identity provider that it shares with other applications; users authenticate to the identity provider to obtain a token that they then use to log in to the organization. Every organization in VCF Automation has its own identity source for user import. The Supervisor component supports registration of external OIDC identity providers for authentication using Pinniped, which inspects upstream identity tokens from the external provider to determine user identity and group membership before passing that information to the Kubernetes API server. Supervisor can be configured with any OIDC-compliant provider, including Okta, Workspace ONE Access, and Dex, to authenticate users connecting to VMware Kubernetes Service (VKS) clusters. Custom ClusterClass configurations for VKS clusters can be used to authenticate developers using existing corporate identity systems. The Kubernetes API server also supports integration with organizational authentication infrastructure such as LDAP or Kerberos through authentication plugins, enabling Supervisor to participate in existing centralized identity management. An Identity API is available to programmatically authenticate and manage the authorization provider, supporting automated identity lifecycle management.

Authorization is enforced through role-based access control across all VCF components. vCenter maps authorization levels to groups and roles, providing consistent security controls regardless of operational context. VCF verifies what objects principals have access to as part of its authorization model. NSX has a set of built-in roles including Enterprise Admin, Auditor, Cloud Admin, Cloud Operator, Network Admin, Network Operator, Project Admin, Security Admin, and others. Local guest user accounts in NSX have the Auditor role by default, and only a user with the Enterprise Admin role can create new local guest user accounts. VCF Automation provides Organization Administrator, Organization Auditor (read-only), and Organization Owner roles, along with the ability to create custom roles scoped to an organization. Organization Administrators can view the rights associated with roles and create roles local to their organization. For Kubernetes workloads, vSphere Supervisor supports Namespace Owner, Edit, and View permission roles that allow consumers of vSphere Namespaces to provision VKS clusters and vSphere Pods using kubectl. Kubernetes RBAC evaluates Roles, ClusterRoles, RoleBindings, and ClusterRoleBindings against the username, UID, group membership, and extra fields supplied by authenticator modules to determine whether a request is permitted. Users authenticated through external OIDC providers are referenced in

ClusterRoleBindings using the `oidc:user@example.com` naming convention; users authenticated through VCF SSO use the `sso:<username>@<domain>` convention. The `AuthorizeWithSelectors` feature gate passes field and label selector information to authorization webhooks, supporting more granular per-resource authorization decisions. User impersonation is governed by Kubernetes RBAC: the "impersonate" verb on user, group, and ServiceAccount resources under authentication.k8s.io allows designated administrators to act on behalf of other principals in a traceable manner. Kubernetes also distinguishes human user accounts, whose identities are managed externally by the identity provider, from ServiceAccounts, which are namespace-scoped API objects used by automated workloads and processes; separating their lifecycle management supports differentiated audit strategies for each category. IAM role trust policies for VKS clusters can be scoped to specific service accounts and namespaces to enforce least privilege.

VCF provides role-based visibility into policy enforcements. The Organization Administrator and Organization Auditor roles can view policy enforcements within their organizations. VCF's logging infrastructure captures authentication and authorization events across management components. The Kubernetes API server records API server activity with structured per-event metadata. Audit annotations include `authorization.k8s.io/decision` and `authorization.k8s.io/reason`, which record each authorization decision and its human-readable justification in the audit log, providing per-request traceability of who performed what action and how the authorization decision was reached. An audit event is logged for each impersonation request, enabling tracking of how impersonation is used over time. Audit rules can be configured to alert on specific events, such as concurrent reading of multiple Secrets by a single user. Authentication context, including username and group memberships, can be retrieved and logged using `kubectl auth whoami` for verification purposes. Administrators can use `kubectl auth can-i` with user impersonation to determine what actions other users are permitted to perform.

Service-to-service authentication uses certificate-based Principal Identity users rather than password credentials. Principal identity user certificates must be SHA256-based and use RSA/DSA message algorithm with 2048 bits or above key size. Each VCF component registers with VCF SSO as a solution user. VCF Operations integrates with VCF SSO for centralized user and group authentication and management, and also supports LDAP authentication sources for additional monitoring and management access.

Additional Consumption-layer services extend the AAA model to workload infrastructure. Harbor Registry, available as a standard package on VKS clusters, enforces role-based access control for container image artifacts and artifact security policies. The Secret Store Supervisor Service enforces RBAC across administrators, DevOps engineers, and application tenants for access to secrets and credentials. Argo CD, deployable as a Supervisor Service, supports OIDC authentication with PKCE via the `enablePKCEAuthentication` field and defines access through global RBAC policies using policy rules and group mappings.

While VCF provides the technical mechanisms for authentication, authorization, and audit, centralizing these capabilities requires the organization to deploy and manage an external identity provider (such as Active Directory or an OIDC-compliant provider), define identity governance policies, and establish processes for user lifecycle management including provisioning, periodic access reviews, and de-provisioning. Role assignment procedures and access review processes are organizational responsibilities that fall outside VCF's direct control.

VMware Private AI Services (PAIS) integrates with an external OIDC identity provider to authenticate organizational users accessing AI infrastructure on VCF. The `PAISConfiguration` custom resource is configured with an OIDC authentication block specifying the issuer URL, the client ID (`'pais-authentication-id'`), and the scopes `'openid'`, `'groups'`, and `'offline_access'`. When a region is created for a supervisor in PAIS, an identity provider is automatically created in VMware vCenter for that supervisor, establishing a consistent authentication entry point for AI workloads. Activating PAIS in an organization namespace requires coordination with the OIDC provider administrator, who supplies the issuer URL and client ID.

Authorization for PAIS is enforced through OIDC group-based access control. The `'authorizedGroups'` setting in the `PAISConfiguration` restricts service access to user accounts that belong to designated OIDC groups (for example, `'group-for-pais-access-01'` or `'group-for-pais-access-02'`). The `'oidc-groups-claim'` setting names the claim used to identify group membership in the Access Token, and `'oidc-extra-audiences'` accepts additional OAuth 2.0 client IDs that PAIS will recognize when validating tokens. Grafana, used for PAIS metrics visualization, extends the same model through the `'grafana-oidc-role-`

mapping` configuration: users in a designated PAIS access group are assigned the Admin role automatically, while remaining authenticated users receive the Viewer role.

Harbor Registry imposes its own credential boundaries for AI artifact access. PAIS integrates with Harbor registries as a model storage backend, requiring authentication and certificate-based trust for model retrieval. Processes that push artifacts to Harbor authenticate using the `oras login` command with username and password credentials. Knowledge Base integrations support per-source authentication: Confluence connections accept a user name and password or a personal access token, and SharePoint On-Premises connections use user name and password authentication. These mechanisms restrict access to organizational AI artifacts and reference data to authorized accounts.

VMware vDefend (Contributes)

VMware vDefend contributes to this control through two mechanisms: management plane authentication for its Security Services Platform (SSP) and Identity Firewall (IDFW) for network policy enforcement.

SSP provides two built-in local user accounts configured during deployment: an admin account with the Enterprise Admin role, which has full privileges to deploy, manage, upgrade, and configure authentication and authorization settings, and an audit account with the Auditor role, which provides read-only visibility into system activity and API access for auditing without the ability to make configuration changes. The SSP License Hub implements role-based access control with three defined roles: Enterprise Admin, Auditor, and Support Bundle Collector. Roles can be assigned to individual users or groups defined in an external identity provider, allowing organizations to integrate Active Directory or LDAP group membership into access control for the platform.

SSP supports directory-backed authentication through Active Directory over LDAP and OpenLDAP in addition to local accounts. The platform uses Authelia, an open-source authentication and authorization server, to provide two-factor authentication and single sign-on capabilities for management access, allowing organizations to require multiple authentication factors for access to vDefend's security management functions.

Identity Firewall processes user identity at the source workload to enforce DFW and gateway firewall rules based on Active Directory user and group membership. This allows AD users and groups to be used as source criteria in firewall rules, enabling network access controls based on authenticated user identity rather than IP address. Security administrators are directed to distinguish between two primary administrative personas when managing vDefend access, maintaining security boundaries between different projects and the broader organization.

Centralized AAA for organizational users across the broader VCF environment, including single sign-on and multi-factor authentication for all users, is provided by VMware vCenter and VCF SSO and is outside vDefend's scope.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) addresses the authentication component of this control through a two-tier identity model. DSM supports both local user accounts and LDAPS-integrated directory service accounts, and administrators can configure one or both identity sources simultaneously. Local users are authenticated by matching their email address and validating their password directly within DSM. LDAPS users are authenticated by matching the email domain name against the registered LDAPS server and validating credentials against the directory service. DSM can be configured to use an LDAP server for both authentication and authorization of platform-level users.

Authentication for the managed databases is handled through database-native mechanisms that DSM exposes and configures. PostgreSQL databases use host-based authentication (HBA), with rules managed through DSM. The HBA configuration applies ordered matching rules where the first entry matching the connection type, client address, requested database, and user name is applied. The default final entry uses SCRAM-SHA-256, providing strong password-based authentication; an optional LDAP entry can also be included. MySQL databases support LDAPS integration using a simple authentication plug-in, with a unique LDAPS user entry per user and support for Active Directory authentication. PostgreSQL and MySQL databases also support LDAPS user accounts linked to organizational directory services, with LDAPS user creation managed through the DSM interface.

DSM adds SQL Server as a supported database engine. SQL Server clusters support two administrator identity types: SQL User credentials and Windows Principal accounts for clusters integrated with Active Directory. DSM's Active Directory integration supports Kerberos-based authentication for domain-joined SQL Server clients, allowing tools such as SQL Server Management Studio running on a Windows machine to authenticate using domain credentials. DSM maps the dbo user, the database object owner, to administrator-controlled identities for SQL Server database access. SQL Server clusters can also use contained database users, where each user authenticates directly against the database rather than a server-level login, keeping identity information self-contained within the database.

Authorization is handled through a role-based model. DSM provides two platform-level roles, DSM Admin and DSM User, which determine the capabilities available to each user within the DSM management interface and API. Custom user roles can be configured for directory service group members, providing scoped monitoring and management access. The Permissions view in DSM supports the creation, monitoring, and management of configured users, giving administrators visibility into who has access. Role assignments also affect behavior in database operations; DSM automatically establishes trust between primary and secondary PostgreSQL instances for Admin-role users, while User-role accounts require manual trust establishment.

DSM produces audit records covering both user-initiated and system-initiated actions. Audit events are generated for actions performed through the DSM UI and API, and each audit log entry includes a Source field identifying the initiating entity: either a user's email address or "System" when the action was initiated by DSM itself. Gateway Audit Logs provide visibility into gateway-level events, and the System Audit Events view is the designated location in the DSM UI for tracking nondatabase-related operations and tasks. For SQL Server clusters, DSM provides configurable server auditing with preset audits for login tracking and log retention; the Login Auditing option can automatically create a simple audit for login events.

In self-service consumption deployments, the DSM Consumption Operator authenticates with the DSM infrastructure using a dedicated authentication secret (dsm-auth-creds), providing a defined authentication path for Kubernetes-native database provisioning.

DSM's authentication, authorization, and audit capabilities are scoped to the DSM platform and its managed databases. Centralized AAA for the broader organizational user population, including account lifecycle management, privileged access governance, and enterprise-wide log aggregation, requires organizational identity governance programs and security tooling outside DSM's scope.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) maintains its own administrative identity plane with mechanisms covering all three AAA elements: authentication, authorization, and audit. User accounts fall into two categories: local users and remote users. Remote users are authenticated through external AAA servers, with support for LDAP, TACACS+, and SAML-based authentication profiles. The product documentation recommends federated authentication as the preferred approach, delegating the authentication process to an organization's central identity provider rather than managing credentials locally within Avi.

For authorization, the Avi Controller evaluates authorization mapping rules on every user login, updating the user record with tenant and role pairs. Auth Mapping Profiles can map multiple user groups to different roles with tenant isolation, supporting both simple single-role assignments and multi-tenant configurations where a single user requires access across multiple administrative boundaries. The admin user is authorized and responsible for the highest-level configuration operations, including user creation and authorization and tenant management. The admin account is maintained as a locally authenticated account even in a system configured for remote authentication, providing a break-glass path for Controller access.

The Avi Controller License Hub provides dedicated role-based accounts for administration and auditing. The Admin account holds the enterprise_admin role with full access to deploy and manage security services, perform upgrades, and configure authentication and authorization. The Audit account holds the auditor role with full access to APIs and services for system auditing. LDAP can be configured as an identity provider for License Hub authentication, and the Admin user can reset the Audit user's password.

Avi also supports OAuth and OpenID Connect (OIDC) for client authentication at the application proxy layer. When configured, the Controller acts as a resource server and retrieves identity information from the OIDC UserInfo endpoint or from ID token claims, enabling per-user identity context to be associated with proxied application traffic. DataScript can check if a user ID is in an approved group list and redirect unauthenticated users to a login page, providing identity-based access control at the virtual service layer.

In the Avi for VCF Organization-Managed Mode, the organization administrator must be authenticated to edit Service Engine Groups and manage their own infrastructure configurations, reinforcing role-based access enforcement at the VCF integration layer.

The control asks whether the organization centrally manages AAA across its environment. Avi provides the mechanisms for its own administrative plane and supports integration with a central identity provider, but the organization must configure that integration, maintain the identity provider, and establish processes for reviewing audit log output.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control B2.b

Device Management: You fully know and have trust in the devices that are used to access your networks, information systems and data that support your essential function(s).

SCF Controls: IAC-04

Aggregate Coverage: Meets

VCF (Meets)

VCF provides multiple mechanisms for uniquely identifying and authenticating devices, services, and infrastructure components before establishing connections, using cryptographically-based bidirectional authentication.

VCF SSO is the centralized authentication, authorization, and auditing backbone across the platform. VCF SSO supports both SAML and OIDC authentication protocols, which incorporate replay resistance through nonces, timestamps, and token expiration. Organizations can integrate external identity providers such as Microsoft Entra ID or Ping Identity through these protocols, enabling centralized identity management for both users and service accounts. VCF Operations, VCF Log Management, and other platform components integrate with VCF SSO, providing a single point of AAA policy enforcement across the environment. VMware Kubernetes Service (VKS) clusters running on vSphere Supervisor support both VCF SSO and OIDC-compliant external identity providers for cluster authentication. Supervisor uses Pinnipd to broker OAuth 2.0-based user authentication and group membership resolution with external providers, and cluster access is distributed via kubeconfig files that carry the federated identity configuration. The Kubernetes JWT authenticator verifies that tokens presented to the API server have been signed by the configured issuer and resolves the public signing key from the issuer's OIDC discovery endpoint; multiple JWT issuers can be configured to support multiple identity providers simultaneously.

VMware ESX hosts authenticate to VMware vCenter using cryptographic credentials during the host addition process. Each ESX host has a unique machine SSL certificate issued by a Certificate Authority, and the CommonName in the certificate must match the host's FQDN or IP address used to add it to the vCenter system. vCenter validates this certificate before accepting the host into the managed inventory, and the root certificate of the CA must be present in the trusted root store of both vCenter and connected ESX hosts. This mutual TLS authentication is bidirectional: the host verifies it is communicating with a legitimate vCenter, and vCenter verifies the host's identity through its certificate.

For machine-to-machine communication, NSX supports Principal Identity certificates as the preferred approach for authenticating automated clients and service integrations. Any NSX Manager client can create and use a Principal Identity certificate, providing certificate-based mutual authentication that is inherently bidirectional and cryptographically-based. NSX requires authentication prior to establishing any management connection for administrative access. For network-layer device authentication, NSX BGP neighbor communication can be configured with password-based authentication to verify the identity of routing peers before establishing sessions.

VCF enforces TLS as the transport security protocol for inter-component communication. Components such as Telegraf are configured with a minimum TLS version that provides bidirectional authentication through the TLS handshake, cryptographic key exchange, and built-in replay protection. vCenter supports holder-of-key security token authentication through the LoginByToken method, which binds the authentication token to a specific cryptographic key held by the client, providing proof of possession that is resistant to token replay. Valid session identifiers in vSphere verify the identity of principals and establish trust with API endpoints.

Within the Consumption layer of the VCF platform, VKS clusters on vSphere Supervisor implement bidirectional cryptographic authentication between all Kubernetes cluster components. Each kubelet presents an X.509 client certificate to the Kubernetes API server during connection establishment, and the API server presents its own certificate in return, forming a mutual TLS handshake that is cryptographically based and replay resistant. Operators can restrict the cipher suites accepted for API server connections using the kube-apiserver --tls-cipher-suites parameter, set a minimum protocol version using --tls-min-version, and apply equivalent constraints at the node level via the KubeletConfiguration tlsCipherSuites and tlsMinVersion fields. The Kubernetes Scheduler exposes an equivalent --tls-cipher-suites parameter for its own API surface. VKS clusters include TLS certificates supporting cryptographic authentication among all cluster components, and the guidance

recommends configuring short certificate lifetimes and automating rotation to reduce the exposure window for any compromised credential. For ingress, the Contour ingress controller available as a standard VKS package supports a configurable `tls.minimum-protocol-version` parameter. For service-to-service authentication within VKS workload clusters, Istio is available as a standard package and enforces mutual TLS between services using X.509 certificates issued by Istio's built-in certificate authority; the minimum TLS protocol version for the mesh is configurable via `meshConfig.meshMTLS.minProtocolVersion`, which defaults to TLS 1.2 and supports TLS 1.3. Antrea, the default CNI for Supervisor, supports configurable TLS cipher suites for its own control-plane communication. The Supervisor secret injection agent automatically configures mutual TLS for communication with the vault-agent-injector service using auto-generated certificates. For environments subject to strict cryptographic requirements, VKS ClusterClass variables support enabling FIPS mode via the `fips.enabled` setting, which restricts the cluster to FIPS-validated cryptographic modules for all component communication. Harbor, available as a Supervisor service, presents a TLS certificate to clients before any image pull or push operation, providing cryptographic authentication for the container registry endpoint.

Network devices discovered and managed through VCF Operations are authenticated using credentials appropriate to their connection type. VCF Operations supports SSH, SNMP v2, SNMPv3, and API-based access credential types for device discovery and ongoing management. SNMPv3 includes authentication and privacy parameters that provide cryptographic verification of device identity. VCF Operations also supports detection and remediation of default manufacturer passwords on network devices, helping to ensure that devices are uniquely authenticated rather than relying on shared default credentials.

For storage devices, VCF supports mutual CHAP authentication, which provides bidirectional cryptographic verification between initiators and storage targets before establishing a connection. The vSAN iSCSI target service supports both CHAP and Mutual CHAP authentication, and the vSphere API provides the `UpdateInternetScsiAuthenticationProperties` method for configuring iSCSI authentication parameters.

The cryptographic foundation underpinning these authentication mechanisms uses FIPS 140-3 validated modules. NSX is configured to use FIPS 140-3 validated cryptographic modules by default, with validation performed through the NIST Cryptographic Module Validation Program. VCF Automation uses the BouncyCastle FIPS 2.0.0 cryptographic module, which is compliant with FIPS 140-3. This validated cryptographic foundation supports the integrity of all certificate-based and token-based authentication operations across the platform. The vCenter appliance uses VMware's Boring Crypto Module version 6.0 and the OpenSSL FIPS Object Module version 3.0, both FIPS-validated, supporting algorithms including AES, ECDSA, HMAC, RSA, and SHA variants for cryptographic operations. Starting in vSphere 9.0, all TLS profiles are FIPS compliant, and the COMPATIBLE profile supports modern TLS cipher suites and elliptic curves. For VKS clusters, FIPS mode can be enabled via the `fips.enabled` ClusterClass variable, which restricts the cluster to FIPS-validated cryptographic modules for all component communication.

VCF Automation also provides a device authorization OAuth endpoint that implements the OAuth 2.0 Device Authorization Grant flow. This endpoint accepts a client identifier and returns a device code, user code, verification URI, expiration time, and polling interval, enabling devices with limited input capability to authenticate through a secure, time-bounded authorization process.

VMware vDefend (Contributes)

VMware vDefend contributes to device authentication through its NDR Sensor onboarding process and ongoing sensor-to-platform communication. NDR Sensors connect to Security Services Platform using Mutual TLS (mTLS), providing bidirectional, cryptographically-based authentication before establishing the management connection. During initial registration, Security Services Platform generates a unique registration token that is valid for 30 minutes; the sensor presents this time-limited token as part of the mTLS-secured registration sequence, providing replay resistance for the onboarding step. Security Services Platform and NDR Sensor components implement FIPS 140-2 and FIPS 140-3 validated cryptographic modules for the underlying cryptographic operations, including the VMware BouncyCastle Module (Certificate #4943) and the VMware OpenSSL FIPS provider Object Module (Certificate #4861).

Beyond this sensor authentication, vDefend does not provide centralized AAA for general network devices. vDefend enforces policy on traffic flows based on identity, application, and network context, but it does not issue device certificates or manage a

device identity registry for arbitrary network endpoints. That capability falls outside vDefend's scope and would be addressed by network infrastructure and PKI controls at the platform level.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides cryptographic, replay-resistant authentication for its own inter-site components. When two sites are paired for recovery operations, PNR validates the identity of each peer through certificate-based authentication and supports importing certificate-authority-signed server certificates through the PNR Appliance Management Interface. Site pairing, site reconnection, and site pair break operations all require credential authentication, and the PNR Appliance Management Interface itself requires authentication as the admin user for service configuration, network configuration, hostname changes, and disconnection from the PNR Global Console.

For inter-site service authentication, PNR servers acquire a holder-of-key SAML token from VCF SSO using token-based authentication, then send cryptographically signed requests carrying that token to remote services. The remote service validates the token to establish the identity of the calling service before the connection proceeds, supplying bidirectional, replay-resistant authentication between PNR components without transmitting passwords across site boundaries. The VMware vCenter appliance handles authentication between the PNR server and vCenter at the VCF SSO level, and in an Enhanced Linked Mode environment the remote site reuses the same service account to authenticate to local services.

PNR also implements an OAuth 2.0 flow for remote site authentication, with a configurable authorization request lifetime through the `oauth2.authRequestLifetime` setting (default 60 seconds). The Cyber Recovery Connector authenticates with an OAuth app secret that Broadcom rotates every three months. Management communications are carried over TLS, with the minimum protocol version configurable through the `envoy-proxy-config.json` file. The PNR user interface maintains logs that record certificate validation errors and connection failures during authentication attempts, supporting the audit dimension of AAA for PNR's own management traffic.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer contributes to device identification and authentication at the application delivery layer through configurable SSL/TLS profiles, FIPS 140-3 mode cryptographic enforcement, Hardware Security Module (HSM) integration for hardware-rooted key protection, and support for federated client authentication protocols including SAML, OAuth, and OpenID Connect (OIDC).

Avi's SSL/TLS Profile mechanism, configured under **Templates > Security > SSL/TLS Profile**, defines accepted protocol versions and cipher suites for each virtual service. Administrators can restrict accepted options to those meeting organizational policy for strong, replay-resistant authentication. In 9.1, the SSL Profile includes post-quantum cryptography options for TLS 1.3, providing a path to quantum-resistant authentication at the application delivery boundary. The same profile mechanism applies to the Controller's own management-plane connections, giving administrators a consistent control point for the cryptographic posture of both the data plane and the management interface.

When FIPS mode is enabled on the Avi Controller, all cryptographic operations are restricted to FIPS 140-3 approved algorithms. The Avi Controller uses an OpenSSL FIPS Object Module validated at FIPS 140-3 Security Level 1 (CMVP Certificate #4985). FIPS mode is enabled at the Controller cluster level and scopes cipher suite choices for all Service Engine connections, satisfying the cryptographically-based and replay-resistant dimension of the control for traffic processed at the Avi layer.

For hardware-backed device authentication, Avi Service Engines support integration with Hardware Security Modules, including Thales Luna HSM, through HSM Groups configured under **Templates > Security > HSM Groups**. The Avi Controller performs mutual authentication with HSM devices using client certificate registration and verification, providing hardware-rooted key storage for SSL certificates and supporting the bidirectional authentication requirement.

At the application delivery layer, Avi supports client authentication through SAML 2.0 (with identity providers such as Okta and PingFederate), OAuth 2.0, and OIDC, configured through SSO Policies referencing authentication profiles. These mechanisms allow Avi virtual services to enforce identity verification before forwarding connections, supporting the

Authenticate and Authorize dimensions of the control for workloads behind Avi. LDAP-based federated authentication is also available for environments using directory-integrated identity.

Avi's audit logging infrastructure records authentication failures for SSH and TLS sessions, logging and persisting those records for auditing purposes, covering the Audit dimension of the AAA requirement for authentication events that pass through Avi.

The central device identity infrastructure, including the PKI, certificate authority, and device enrollment and management functions, is provided by VCF rather than by Avi itself. Avi validates certificates at the application proxy boundary but does not operate the device identity registry or provide the central AAA framework for the broader infrastructure. Organizations must ensure that the PKI and device identity management components in VCF are configured to issue and manage certificates for devices connecting through Avi virtual services.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control B2.c

Privileged User Management: You closely manage privileged user access to network and information systems supporting your essential function(s).

SCF Controls: IAC-16

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides layered role-based access control (RBAC) across its component products, giving organizations granular mechanisms to restrict and control privileged access rights. These technical controls form a strong foundation for a privileged account management program, though full PAM implementation requires additional organizational processes and tooling beyond what VCF provides natively.

VMware vCenter implements fine-grained privilege-based access control where individual privileges can be grouped into roles and mapped to users or groups on specific inventory objects. Administrators can create custom roles with granular privilege assignment and configure permission propagation across the vSphere object hierarchy. For example, a custom role can allow a user to encrypt virtual machines but not decrypt them by selectively granting Cryptographic Operations privileges. Only a System Administrator can modify the rights in a predefined role. These privilege requirements apply uniformly regardless of how a client application accesses server content, whether through the vSphere Client, CLI, or SDK. The vSphere Web Services API Permission object enforces this model programmatically, enabling automated governance of role assignments. The Administrator role is required for full vCenter interface access, and the platform guidance recommends restricting this role to only those users who require access to all objects and actions in the environment. At the appliance management layer, access to the vCenter Appliance Management Interface and the vCenter appliance shell is restricted to root or a user with super administrator role, where root is the default super administrator user. Bash shell access for non-root users holding the super administrator role can be enabled by running ``shell.set --enabled true`` from the appliance shell.

Authentication is centralized through VCF SSO, which provides token-based authentication across VCF components. VCF SSO supports identity federation with external identity providers through SAML 2.0 and OIDC protocols, enabling integration with enterprise authentication systems and multi-factor authentication. When using an external identity provider, users first obtain a JSON Web Token (JWT) from the provider, which is then exchanged for a SAML token. VCF SSO integrates with a VCF Identity Broker to manage authentication for VCF Instance components. Solution users (service accounts used for component-to-component communication) authenticate using certificates rather than passwords, and VCF SSO supports multiple authentication methods including username token, X.509 certificate, and holder-of-key token authentication. This centralized authentication model removes the need for direct access to VMware ESX hosts for routine administrative tasks.

VCF Operations enforces its own RBAC model where users can only perform the actions that their assigned permissions allow. A vCenter user must hold either the vCenter Admin role or a specific VCF Operations privilege such as PowerUser, assigned at the root level in vCenter, to log in to VCF Operations. Administrators in vCenter receive mapped roles in VCF Operations during registration, but these accounts only receive a specific role on the root folder if it is explicitly assigned. The administrators role should be reserved for users who need access to objects and actions across the entire environment.

VCF Automation extends access control through entitlements and access control lists (ACLs). Organization users can use only those rights from their roles that are published to their organizations, restricting lateral privilege expansion. System administrators with the Manage General ACL right can create, modify, and remove specific ACLs through the accessControls API. Entity-type access can be granted to specific users and organizations, and system administrators must create entitlements using user criteria to manage access to projects and catalog items in the Service Catalog. VCF Automation project access is governed by pre-defined roles that scope what operations each user can perform within a project.

NSX provides RBAC through user role assignments that can be configured for local user accounts and users authenticated from identity management providers such as Active Directory over LDAP. NSX VPC user role assignments are managed from the User Management page. NSX Manager also supports local authentication where users authenticate using the PAM stack on the Unified Appliance, and local user passwords are secured using default Linux/PAM libraries with hashed and salted

storage. The admin user can manage account creation, deletion, and deactivation through the CLI or UI. vSAN similarly supports RBAC and permissions management for authentication and authorization.

VCF Operations uses a CloudAdmin role model that restricts access to platform-level operations. It supports ADMIN role accounts authenticated with username and password, and its System Administrator rights include granular controls over approvals, audits, certificates, and other administrative functions. VCF Operations provides a password management interface accessible through the Security menu, where administrators assigned the Administrator role can rotate account passwords and remediate service account passwords for integrated components. VCF Operations maintains a root user account and a super user (vcf) account that require ongoing password management. The VCF Operations API exposes a credentials endpoint at /v1/credentials that can be queried to retrieve vCenter root credentials, and if VCF Operations is not operational, these credentials can be recovered from the file-based backup. Default password complexity rules enforced through the Linux PAM module require at least 12 characters with mixed case, digits, special characters, and at least five different characters.

The VCF consumption layer, which encompasses VMware Kubernetes Service (VKS), vSphere Supervisor, and vSphere Namespaces, extends privileged access management across both the platform management plane and the Kubernetes workload layer. At the vSphere Namespace level, permissions are assigned to VCF SSO users and groups through three roles: Can View (read-only), Can Edit (provisioning and operating workloads), and Owner (full control including namespace deletion). The Owner role is available only with VCF SSO authentication. A VCF SSO user granted the Edit permission on a vSphere Namespace is automatically assigned the cluster-admin role for any VKS cluster deployed in that namespace, meaning namespace-level permission decisions directly determine cluster-level administrative rights. The VCF CLI enforces these role boundaries and returns a Forbidden error when a user lacks sufficient permissions on the vSphere Namespace for Supervisor or VKS cluster access. Administrative operations such as activating Supervisor Services or deleting a service registration require the Manage Supervisor Services privilege on the VMware vCenter system. Access assignments can be managed programmatically through the vSphere Automation REST API, and authentication for Kubernetes contexts can use either VCF SSO or external OpenID Connect providers.

Within VKS clusters, Kubernetes RBAC controls API server authorization through Role, ClusterRole, RoleBinding, and ClusterRoleBinding objects. RBAC rules specify fine-grained permissions by defining apiGroups, resources, and verbs (get, list, watch, create, update, patch, delete), and Role objects can further restrict access to specific named resources using the resourceNames field. ServiceAccounts can be bound to Roles or ClusterRoles via RoleBindings, enabling workloads to receive only the minimum permissions required to function. Granting cluster-admin to all ServiceAccounts cluster-wide is strongly discouraged because it allows any application full cluster access and grants any user with read access to Secrets the ability to create privileged pods; per-namespace permission management is the recommended approach. Cluster operators should restrict permissions that allow users or ServiceAccounts to escalate privileges through workload creation, and should carefully control authorization for CustomResourceDefinitions that govern ServiceAccount usage, ConfigMap mounting, or volume mounting. Kubernetes guidance recommends creating least-privilege access even for administrators, with broader access such as cluster-admin reserved for break-glass scenarios. For VKS clusters using a versioned ClusterClass, IAM role trust policies can be scoped to specific service accounts and namespaces to enforce least privilege at the identity layer. Dynamic Resource Allocation APIs should be controlled via RBAC to restrict access based on user persona.

Pod-level privilege control is available through Pod Security Admission (PSA) profiles enforced per namespace. The Privileged PSA level provides unrestricted permissions and allows known privilege escalations, making it appropriate only for trusted system workloads in controlled namespaces; the Baseline and Restricted profiles apply progressively tighter constraints. Security contexts within pod and container specifications allow configuration of runAsUser, Linux capabilities, and seccomp profiles to restrict the runtime permissions of individual containers. Kubernetes AppArmor profiles can further restrict per-program access privileges on Linux nodes. When requirePasswordOnSudo is configured on a VKS cluster, administrative sudo operations require explicit password entry. Namespaces that host privileged workloads should establish and enforce appropriate access controls to maintain least-privilege principles. The vmware-system-restricted Pod Security Policy, applied through RoleBindings, restricts which workloads service accounts within a namespace can run.

The consumption layer includes additional access control mechanisms for specific service types. The Secret Store Supervisor Service enforces RBAC across administrator, DevOps engineer, and application tenant roles for managing and distributing

sensitive data within VKS clusters, and Kubernetes recommends configuring least-privilege access to Secret objects through RBAC policies. Argo CD, which can be deployed as a Supervisor Service for GitOps-based workload management, supports local account authentication with global RBAC policies that define role-based access through policy rules and group mappings. For Windows workloads on VKS, Group Managed Service Accounts (GMSA) provide automatic password management, simplified service principal name management, and the ability to delegate management to other administrators; a service account must be bound to a cluster role via RoleBinding to authorize pods to use a specific GMSA credential specification. Access to Supervisor control plane nodes via SSH requires root user credentials through vCenter, which organizations should track and manage as a privileged access path reserved for troubleshooting operations.

To build a complete privileged account management program around VCF, organizations need to layer additional processes and tools on top of these platform capabilities. VCF does not natively provide session recording for privileged access, just-in-time privilege elevation, or automated access reviews. Organizations should implement policies governing who receives privileged roles, periodic recertification of privileged accounts, monitoring of privileged session activity, and integration with a dedicated PAM solution for credential vaulting and checkout workflows where required.

VMware Private AI Services (PAIS) provides AI-workload-specific mechanisms to restrict and control privileged access to its services, model artifacts, and AI resources. These operate on top of the foundational identity and access management that VCF supplies through VCF SSO and the VCF Automation role framework.

Access to Private AI Services is gated through OIDC group-based authorization. Administrators specify allowed groups in the authorizedGroups field of the PAISConfiguration custom resource when activating Private AI Services in an organization namespace through kubectl, or through the oidc-authorized-groups setting when activating through the VCF Automation UI. Only user accounts that are members of the specified groups, such as group-for-pais-access-01 or group-for-pais-access-02, can access the service. The OIDC configuration includes a groups claim in the access token and a groups scope, so group membership is enforced as part of the authenticated session.

The Grafana observability interface for Private AI Services applies role differentiation through OIDC group membership. Administrators configure the grafana-oidc-role-mapping property to assign the Admin role to users that match a specified group attribute and the Viewer role to all other authenticated users. This separates operators who can modify dashboards from those who can only view metrics.

Access to AI catalog items in VCF Automation is scoped by project-based permissions. PAIS catalog items are shared only with selected project members, and DevOps engineers must receive explicit permissions from organization administrators before they can request GPU-accelerated VMware Kubernetes Service (VKS) clusters, deep learning VMs, or other AI resources. The Private AI Services Quickstart setup itself requires organization administrator credentials to access the VCF Automation organization UI, and VI administrators need vCenter privileges to deploy deep learning VM templates on a vSphere cluster. Programmatic access to VCF Automation uses provider administrator and tenant administrator access tokens obtained from the Provider Management UI, with API tokens that must be saved locally for subsequent calls.

The PAIS Model Gallery uses Harbor project access controls to restrict which users can read or write the ML models and training data stored in the registry. Harbor project membership and role assignments determine who can read or write model artifacts, and Harbor registry read-write permissions on a project are required to store models. PAIS model endpoints support authentication through the harbor-pull-secret-readonly mechanism to control access to container images stored in private registries, and the oras login command authenticates to a private Harbor registry using user name and password credentials for resource push and pull operations.

PAIS Knowledge Bases extend privileged access controls to the retrieval data sources that ground model responses. Confluence data sources use either a user name and password or a personal access token configured under the Confluence administrator's settings, Google Drive folders that act as data sources must be shared with the PAIS service account using view-only permissions, and personal access tokens generated from user account settings are used for programmatic access to Knowledge Bases and data sources. Remote MCP servers integrated with Private AI Services can optionally use static authentication tokens to control access to specialized data and capabilities.

VMware vDefend (Contributes)

VMware vDefend implements role-based access control across its management plane through the Security Services Platform (SSP). SSP defines five built-in roles with differentiated permissions: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. Permission levels range from Full Access (Create, Read, Update, and Delete) to Read-only or no access, depending on the role and operation. The Enterprise Admin role grants full authority over deployment, configuration, authentication and authorization settings, and backup operations. Modifying role assignments requires Admin privileges, and editing remote user or group role assignments requires LDAP to be configured as an authentication provider.

The two predefined local accounts, admin and audit, map to the Enterprise Admin and Auditor roles respectively, limiting each account to its designated functional scope. LDAP user account passwords are managed remotely by administrators, keeping credential management under organizational control.

Beyond its management plane, vDefend's Distributed Firewall (DFW) supports an Identity Firewall (IDFW) feature that enforces network access controls based on Active Directory user identity. Administrators create security groups in Active Directory and configure DFW rules that allow or deny user access to application servers based on group membership, applying role-based access controls at the network layer.

vDefend's Malware Prevention Service applies additional access restrictions to its service VMs: SSH access is disabled by default on the Malware Prevention Service virtual machine and must be explicitly activated by a vCenter administrator when needed for troubleshooting, then deactivated after use. The Malware Prevention Service VM ships with a default root password that must be changed on first login.

vDefend's contribution to this control is scoped to its own management interfaces and network-layer access enforcement. Controlling privileged access across the broader IT environment, identity lifecycle governance, and access controls for systems outside vDefend's domain require organizational processes and tooling beyond what vDefend provides.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides role-based access control that restricts privileged access to database platform resources. The platform defines two built-in roles: DSM Admin and DSM User. The DSM Admin role is a super user role with full access to all data services in the environment, while the DSM User role restricts users to viewing and managing only the objects they own. This separation means that standard database consumers cannot affect or view resources belonging to other users or managed by administrators. The DSM console enforces this separation by restricting the views and actions available to each user based on their assigned role.

Privileged access within DSM is further scoped through namespaces. DSM User role assignments can be restricted to one or more specific namespaces, limiting access to only those assigned workspaces. This namespace-level scoping provides a granular mechanism for controlling who can access which database workloads. Namespace RBAC is enforced at the platform level, preventing users within a shared namespace from accessing resources in other namespaces.

Role and user management is performed through the vSphere Client Permissions interface under the DSM Configure tab, and through the DSM administrator UI Permissions view, where administrators can create, monitor, and manage configured users. DSM supports both local users and LDAPS-authenticated directory service groups, enabling organizations to align DSM role assignments with their existing enterprise identity management systems. Directory Service Groups can be assigned either the DSM Admin or DSM User role. When local and LDAPS users share the same username, login precedence must be considered to avoid authentication conflicts.

At the platform infrastructure level, DSM uses a dedicated VMware vCenter service account rather than persisting administrator credentials. During initial setup, the deploying user must provide local vCenter administrator credentials. DSM uses those credentials to create a dedicated vCenter service account and then discards the original credentials after successful registration. Ongoing operations use only the service account, which is configured with the minimum permissions required for service account creation, plug-in registration, and resource management. The service account credentials for the target vCenter can be verified and updated in Settings > System Settings under Target vCenter.

For SQL Server databases, DSM applies additional engine-level privileged access controls. DSM deactivates the default sa account and uses a reserved internal account, `dsm_mgmt`, with sysadmin privileges for management operations. The cluster administrator login is granted restricted read-only privileges and specific ALTER privileges for server management and auditing rather than full system privileges. When Windows Authentication is configured for SQL Server, DSM requires a Privileged Account configured in Active Directory to automate management of service principal names (SPNs) and DNS records.

Because DSM relies on vCenter for underlying infrastructure privilege management, achieving full coverage of this control requires organizational processes that are outside DSM's scope: maintaining an inventory of privileged accounts, conducting periodic access reviews, and managing approval workflows for new privileged account requests. DSM provides the technical enforcement mechanisms for restricting privileged platform access; the organization is responsible for the operational privileged access management procedures required to fully satisfy this control.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides a native role-based access control (RBAC) system on the Avi Controller that restricts and controls privileged access to application delivery resources. The RBAC model assigns each user a role that governs their access level, with three permission states available per resource: write, read, or no access. The No Access privilege level is a distinct state that blocks users from accessing, reading, or listing resources entirely. Administrators can create custom roles through the Controller UI that grant precisely scoped access to specific system areas, with each resource configured independently. This supports least-privilege configurations tailored to distinct operational roles such as application operators, application admins, and system administrators.

For environments requiring finer-grained control, Avi's Extended Granular RBAC applies and enforces label-based permissions on cloud objects. The `restrict_cloud_read_access` field in controller properties governs whether label-based access scoping applies to cloud object reads. Roles can be configured with `write_access` type and the `resource_permission_pool` setting to restrict role privileges to specific pool sub-resources such as `subresource_pool_enabled`, providing field-level access scoping within a resource type. Auth Mapping rules can be updated to deny privileges to specific users, blocking them from obtaining any roles or tenants upon login. Multi-tenant deployments can scope access by tenant: user groups can be mapped to a limited set of tenants with read-only privileges, while separate groups hold application owner privileges within those same tenants, enabling separation of duties between groups managing different applications or environments within a shared Avi deployment.

Avi supports TACACS+ server integration for centralized authentication and role assignment. Authorization attributes from a TACACS+ server map Avi users to roles and tenants, allowing organizations to govern privileged access through their existing network access control or identity infrastructure. The Avi Controller also supports LDAP authentication with the Administrator Bind configuration for user authentication and group membership validation. LDAP user account passwords are managed remotely and set by an administrator, not locally.

Administrators can create custom user account security profiles with organization-specific thresholds for password history, login failure, session limits, and credential timeout policies. The Controller implements Super User Accounts as a separate user account security mechanism. The admin account is maintained as a locally authenticated account even in systems configured for remote authentication. The `avidebuguser` account has sudo privileges on the Avi Controller for Linux CLI access, and access to this account should be restricted to authorized personnel. Using role-based access control, the ability to export certificates and private keys must be restricted to the fewest administrators possible.

Avi Cloud Console enforces access control through two access levels: Full Access (User Administrator or Product Administrator role) and Read-Only (Site Access role), with differentiated permissions for license visibility, management, and administration operations.

When Avi is deployed in a VMware vCenter environment, the Cloud Connector uses a dedicated vCenter account configured with a minimal set of permissions. Two vCenter roles are required: one with global privileges and another with folder-level privileges. The Avi-Folder-Role scopes the account's permissions to the specific folders containing Service Engine VMs in the vCenter inventory. In VCF deployments with a vSphere Supervisor, the Avi Controller cloud configuration supports either a

vCenter administrator account or a dedicated account with lesser, precisely defined permissions. The Cloud Connector role requires specific vCenter privileges covering Virtual Machine Guest Operations, Host Local Operations, and other provisioning capabilities, following the principle of least privilege for service account access to the underlying platform.

Several permissions classified under Operations and Administration are not supported for per-application label-based RBAC, including L4POLICYSET, WAFPOLICYPSMGROUP, PINGACCESSAGENT, NETWORKSERVICE, and NATPOLICY, among others. These permissions remain under global administration scope and cannot be delegated to application-scoped roles.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control B2.d

Identity and Access Management (IdAM): You closely manage and maintain identity and access control for users, devices and systems accessing network and information systems supporting your essential function(s).

SCF Controls: IAC-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides a layered identity and access management architecture spanning centralized identity services, role-based access control, group-based access policies, identity provider federation, and programmatic access management through APIs.

VCF SSO is the centralized authentication service. VCF SSO issues security tokens that grant authenticated users access to VMware vCenter, NSX Manager, VCF Operations, and other platform components without requiring separate credentials for each service. VCF Operations supports importing users and groups from VCF SSO for consistent identity management across the stack. VMware Identity Manager provides a platform for managing users and groups, managing resources and user authentication, and configuring access policies and resource entitlements. vCenter also supports built-in identity source authentication using local domain credentials. The built-in identity provider can also be configured to use Active Directory as an identity source through LDAP/S, OpenLDAP/S, or Integrated Windows Authentication (IWA), depending on the directory environment.

VCF supports federation with enterprise identity providers. vCenter can be federated to providers such as Microsoft Entra ID, ADFS, and Okta, which enables multifactor authentication and automatic user synchronization with the organization's directory. PingFederate is also supported as a federated identity provider; for these integrations, vCenter uses System for Cross-domain Identity Management (SCIM) to automate the exchange of user and group identity information between the external identity domain and vCenter. VMware Identity Broker allows principals to authenticate to vCenter through an external identity provider. NSX Manager can be configured to authenticate users from identity management providers and can be integrated with Workspace ONE Access for identity management services. The Supervisor component supports registration of OIDC-compliant external identity providers for authentication to VMware Kubernetes Service (VKS) clusters; supported providers include Okta, Workspace ONE Access, and Dex, configured by supplying the Supervisor callback URL to the identity provider.

Role-based access control is enforced across all VCF components. In vCenter, permissions associate a user or group with a role on a specific inventory object, and predefined roles cover common administrative functions. Custom roles can be created with only the minimum required privileges for a given workflow. Managing identity provider configuration in vCenter requires the VcidentityProviders Manage privilege. VCF Operations supports group-based access control, allowing administrators to configure groups and assign roles that control access to dashboards, reports, policies, alerts, and administration functions, as well as granular role-based controls for platform operations including approvals, audits, certificates, and content libraries.

VCF Automation extends access management through organization-level and project-level controls. The VCF Automation Access Control service supports identity operations for managing groups and users, including editing user names, passwords, and role assignments. The organization portal enforces role-based access control, requiring either Organization Administrator or Organization Auditor roles to manage policy templates. Organization administrators can distribute infrastructure and configure group-level access through the organization management functionality. Project access is governed by predefined roles. Users and groups can be disabled at the organization level to revoke access without deleting accounts. The System Administrator role has the right to manage and view Access Control Lists, and the accessControls API allows administrators to view and manage ACL entries for defined entities.

For Kubernetes workloads within the VCF consumption layer, VKS supports two authentication methods: VCF SSO and OIDC-compliant external identity providers. The OIDC path is implemented through Pinniped and supports providers including Okta, Workspace ONE Access, Dex, GitLab, and Google OAuth. Configuring an external provider requires setting up an OpenID

Connect ID Token with a Groups claim type filter to enable group-based access control tied to the organization's directory. Custom ClusterClass configurations allow clusters to authenticate developers using existing corporate identity systems. VKS supports namespace permission roles: Owner (full control including deletion), Can Edit (provisioning and operating workloads), and Can View (read-only access). These roles map to Kubernetes ClusterRoles through RoleBindings, and RoleBinding objects can reference VCF SSO users and groups directly to integrate SSO identities with Kubernetes role-based access control. A user with the Namespaces.Edit privilege on a user-created Namespace folder can perform CRUD operations on Kubernetes API resources in the Supervisor. Namespace Self-Service permissions control which users can self-provision namespaces through kubectl.

Kubernetes RBAC is the primary authorization mechanism within VKS, using Roles, ClusterRoles, RoleBindings, and ClusterRoleBindings to bind permissions to users, groups, or service accounts. Kubernetes Attribute-Based Access Control (ABAC) is also available, defining access rights through policies that combine user, namespace, resource, and access mode attributes. Authorization webhooks can interpret field and label selectors to enforce fine-grained access control based on resource attributes such as node names and labels.

Service accounts provide namespaced workload identity within VKS clusters. For Windows containers, the Group Managed Service Account (gMSA) Webhook allows containers to run as Active Directory identities. VKS service accounts can be annotated with IAM role ARNs to enable pod identity and role assumption for cloud resource access through OIDC federation, replacing long-lived static credentials with short-lived, least-privileged credentials on demand. IAM role trust policies can be scoped to specific service accounts and namespaces to enforce least privilege.

Several supplementary services within the VKS layer extend the IAM surface. Harbor Registry, available as a standard package on VKS clusters, enforces role-based access control to manage access to container image artifacts. The Secret Store Supervisor Service enforces RBAC for administrators, DevOps engineers, and application tenants managing sensitive data. Argo CD supports both OIDC configuration for external identity providers and local account configuration with global RBAC policies that define role-based access through policy rules and group mappings. The Istio service mesh package includes a pluggable policy layer supporting access controls, rate limits, and quotas at the service-to-service level.

Programmatic access management is available through several APIs. The Identity API authenticates and manages the authorization provider. The Identity Service and Infrastructure as a Service APIs are used to acquire access tokens for REST API authentication. Principal Identity users authenticate using client certificates for service-to-service communications between VCF components.

NSX integrates with LDAP and external identity management services for administrative access to networking configuration. NSX Manager enforces role-based access control with roles such as auditor and network administrator assignable to LDAP users. vDefend, a separate product that extends NSX with security capabilities, offers an Identity Firewall that integrates with Active Directory for identity-based firewall rules.

VMware Private AI Services (PAIS) provides OIDC-based authentication and group-based authorization for AI workloads, the primary IAM mechanisms controlling access to model endpoints, the model runtime, Agent Builder, and Data Indexing and Retrieval capabilities. PAIS authentication is configured with an issuer URL, a client ID (pais-authentication-id), and the openid, groups, and offline_access scopes. The OIDC provider must support the .well-known/openid-configuration discovery endpoint. Authorization restricts access to user accounts that are members of named groups listed in the authorizedGroups setting (such as group-for-pais-access-01 or group-for-pais-access-02). A groups claim is included in the Access Token and a corresponding groups scope is created in the OIDC configuration, while the oidc-groups-claim setting selects which claim name carries group membership when the OIDC provider uses a non-default name. The oidc-extra-audiences setting accepts additional OAuth 2.0 client identifiers that PAIS will accept when validating Access Tokens, supporting integration with downstream clients that present their own audience. Activating PAIS in an organization namespace requires coordination with the OIDC provider administrator and an organization administrator account in VCF Automation.

Identity provider integration for PAIS deployments is configured at the Supervisor level under Workload Management > Supervisors > Configure > Identity Providers. When a PAIS region is created for a Supervisor, an identity provider entry is

automatically created in VMware vCenter for that Supervisor, linking the Supervisor namespace to the configured OIDC source.

The Model Gallery, the curated repository for ML models in PAIS, restricts access to model artifacts and the training data used to tune them through Harbor project access controls. These controls scope which users and service accounts can read, push, or manage sensitive model data, adding an IAM enforcement layer to the model supply chain. A Harbor registry is recommended for PAIS deployments, and OCI-compliant registries from other vendors are also supported.

PAIS Knowledge Bases extend IAM to ingested data sources. Confluence data sources authenticate with a user name and password or a personal access token, while Microsoft SharePoint On-Premises data sources authenticate with a user name and password. Personal access tokens for Knowledge Bases are generated from user account settings and used for programmatic access to linked data sources.

PAIS integrates with Grafana for metrics visualization using the same OIDC provider, extending the IAM model to the observability layer so that operators authenticate through the configured identity provider before accessing PAIS dashboards.

VMware vDefend (Contributes)

VMware vDefend contributes to identity and access management by providing identity-aware network enforcement through Identity Firewall, which integrates with Active Directory to apply firewall policy based on authenticated user identity rather than IP address alone. Identity Firewall supports assigning Active Directory users and groups as source criteria in both distributed firewall rules and gateway firewall rules, applying to tier-0 and tier-1 gateways. This allows organizations to enforce network access policy by user or group membership rather than relying solely on IP-based controls.

Within its management plane, the Security Services Platform implements role-based access control with five defined roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. These roles govern access to security policy management, analytics, incident response, and diagnostic functions across the platform. Network Detection and Response enforces the same five-role RBAC model for triage operations such as viewing detections and campaigns, and for configuration operations including SIEM integration management. For authentication, the Security Services Platform supports Active Directory and OpenLDAP as external identity sources, with one identity source configurable at a time. The License Hub integrates with external identity providers to store and manage user and group information for access delegation.

Centralized IAM for organizational users, including VCF SSO, MFA, and directory lifecycle management, is handled by VCF and falls outside vDefend's scope.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) incorporates multiple identification and access management mechanisms that support organization-wide IAM controls within the data services layer.

DSM implements role-based access control with two defined roles: the DSM Admin role, which can create, monitor, and manage all data services in the environment, and the DSM User role, which is restricted to managing and monitoring data services within the namespaces to which the user has been granted access. These roles are assigned at user creation time and govern what each user can see and do within the DSM interface. The Permissions view in the DSM dashboard provides administrators with a centralized location for creating, monitoring, and managing all configured users.

DSM supports two identity sources, which can be used independently or together. Local users are created directly within DSM, with credentials validated by matching email address and password. LDAPS users are sourced from a configured LDAP identity provider, allowing organizations to extend their existing directory service into DSM. When LDAPS is configured, administrators can import users from the directory provider and assign them DSM Admin or DSM User roles. DSM also supports group-based access control: Directory Service Groups from the LDAP provider can be assigned roles directly, so group membership in the external directory determines access level in DSM without requiring per-user assignments.

At the database level, DSM extends authentication controls beyond the platform management layer. MySQL database instances support LDAPS authentication using Active Directory. PostgreSQL and other database instances support host-based authentication (HBA) rule configuration, which determines which clients are permitted to authenticate to a given

database instance. SQL Server instances support Windows Authentication through Active Directory integration, enabling Kerberos-based authentication so that clients such as SQL Server Management Studio running on domain-joined machines can authenticate via single sign-on. SQL Server also uses contained database users, where identity information resides within the database itself rather than at the server level. Administrators can configure SQL Server instances with either a SQL User or Windows Principal as the primary administrator identity, with Windows Principal available for Active Directory-integrated clusters. An internal `dsm_mgmt` management login restricts users from accessing or modifying system-level objects, keeping administrative operations within an isolated context.

Namespace isolation adds a further access boundary. DSM namespaces enforce role-based access control that allows multiple users to work jointly on data services within a namespace while remaining isolated from data services in other namespaces. This supports least-privilege access within multi-tenant deployments.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides a dedicated administrative identity and access management plane through the Avi Controller, supporting multiple authentication methods and fine-grained authorization controls that allow organizations to implement IAM policies across both the management plane and the application delivery layer.

For administrative access, the Avi Controller supports local user accounts, LDAP and LDAPS directory integration, SAML-based federated authentication (including integration with Workspace ONE Access for catalog-based application access), basic authentication, and OAuth/OIDC for API access. Auth Mapping Profiles allow organizations to map external directory groups to specific roles and tenants, so that group membership in an external identity provider directly controls what a user can access within Avi.

Authorization is handled through role-based access control (RBAC) with object-level granularity. Avi's extended granular RBAC uses markers, which are labels assigned to objects, to enable fine-grained authorization based on object ownership and classification. Permission categories cover Operations (including alerts, actions, and traffic capture) and Administration (including controller, tenant, user, role, and system configuration management). This allows restrictions so that a user's permissions apply only to the specific resources matching the markers assigned to their role. RBAC covers object categories including Virtual Services, Application Profiles, SSL/TLS Certificates, Certificate Management Profiles, Cloud definitions, TCP/UDP Profiles, Persistence Profiles, Health Monitors, Analytics Profiles, IP Address Groups, String Groups, SSL/TLS Profiles, PKI Profiles, and Authentication Profiles, with distinct read and write access levels configured per object type.

For multi-tenant deployments, Auth Mapping Profiles support tenant isolation with configurable user group to role mappings, allowing organizations to enforce separation between teams or business units operating within the same Avi Controller.

The Avi License Hub supports role-based access control through an external identity provider, with three predefined roles: Enterprise Admin (full access for all operations, including upgrades and authentication configuration), Auditor (view-only access for tracking activity without making changes), and Support Bundle Collector (restricted to collecting system logs and diagnostics). Management interface access is further controlled through restrictions on allowed ciphers and HMACs for management sessions.

For deployments involving the Avi Kubernetes Operator (AKO), Kubernetes RBAC policies can be applied to AKO Custom Resource Definitions (CRDs) to enforce stricter access control over routing configuration for specific user groups. The Avi Controller also implements RBAC at the Kubernetes and OpenShift cluster level by assigning tenants and roles to user accounts.

At the application layer, Avi can enforce client authentication using OAuth, SAML, JWT token validation, and mutual TLS with client certificates, extending access control to the traffic flowing through virtual services rather than only to the management interface.

Organizations are responsible for defining roles, mapping directory groups to permissions, establishing naming conventions for markers, and maintaining user lifecycle processes. Avi provides the technical mechanisms; the governance and operational processes for identity management must be organized by the teams managing the deployment.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control B3

Principle B3 Data Security: Data stored or transmitted electronically is protected from actions such as unauthorised access, modification, or deletion that may cause an adverse impact on essential functions. Such protection extends to the means by which authorised users, devices and systems access critical data necessary for the operation of essential functions. It also covers information that would assist a threat actor, such as design details of network and information systems.

SCF Controls: DCH-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides multiple layers of data protection controls spanning encryption, storage resilience, backup and recovery, disaster recovery, centralized monitoring, and access management.

For data at rest, vSAN encryption protects data on storage devices so that if a device is physically removed from the cluster, the data remains unreadable. At the virtual machine level, VM encryption protects NVRAM, swap (VSWP), and snapshot (VMSN) files, providing per-VM granularity independent of the underlying storage encryption. For data in transit, vSAN data-in-transit encryption protects data as it moves between hosts and file service inter-host connections within a vSAN cluster, with forward secrecy enforced. TLS protects data in transit between other VCF components. Both vSAN and VM encryption integrate with external Key Management Server (KMS) infrastructure for key lifecycle management, requiring a trust relationship established through certificate and key file exchange. VCF components use FIPS-validated cryptographic modules: NSX cryptographic modules are validated to FIPS 140-3 standards, vSphere uses FIPS-validated cryptographic modules matching the FIPS 140-2 standard, and VCF Automation runs in FIPS-compliant mode by default using FIPS 140-3 validated modules.

vSAN implements erasure coding through RAID-5 storage policies, which split data into blocks with parity information to protect against component failures. vSAN includes failure indication and data rebuild mechanisms that detect storage failures and automatically reconstruct unavailable data. Virtual machines on vSAN datastores can be assigned storage policies that define specific data protection and performance characteristics, giving administrators granular control over how data is protected at the workload level.

VCF supports backup methods for its management components at multiple levels. VMware vCenter file-based daily backups are configured through the vCenter Management Interface for each vCenter instance. vCenter file-based backup supports optional password-based encryption of backup files, and backup files are stored off-appliance on servers accessible via FTP, FTPS, HTTP, HTTPS, SFTP, NFS, or SMB. When vSphere Native Key Provider is configured, vCenter backups contain the Key Derivation Key and must be stored in a secure, access-controlled location. VCF Operations backups support both file-based and image-based methods. NSX Manager backup is configured automatically during the bring-up process. For vSphere Supervisor environments, control plane backup and restore can be performed from the Workload Management UI, and Supervisor control plane backup can also be included as an option in vCenter file-based backup schedules. vSAN Data Protection uses native snapshots stored locally on vSAN Express Storage Architecture (ESA) clusters to help recover virtual machines from operational failure or ransomware attacks.

For Kubernetes workloads, VMware Kubernetes Service (VKS) provides dedicated data protection capabilities built into the VCF platform. VKS cluster node VMs are backed up through Supervisor state backup using the vCenter backup feature available in the vCenter Management Interface, so Supervisor state is covered by the same vCenter backup workflow used for the management plane. When data protection is activated for a VKS cluster, VKS cluster management installs the data protection extension, selected plugins, and Velero on the cluster; activation requires an Organization Administrator or Project Administrator role. Backup and restore operations are managed through the VCF Automation Tenant Portal under Manage & Govern > VCF Services > Kubernetes Management > Clusters > Data Protection. Two backup methods are available: vSphere Plugin Snapshot performs block-level backup writing directly to object storage and is faster for workloads with large numbers of small files, while File System Backup operates at the file system level and supports incremental backups. The vSphere

Plugin Snapshot method performs full backups on each run since it does not support changed block tracking, so organizations that require incremental backups should use the File System Backup method. Both methods support stateless and stateful workloads. Backup scope is configurable to the entire cluster, selected namespaces, or specific resources identified by label, and VKS cluster backups include file system backups in the restore by default. Velero 1.17 supports scheduled backups, allowing organizations to configure automated backup cadences. Backup repositories support deduplication, compression, and encryption of backup data. The Velero Plugin for vSphere backs up and restores both stateless and stateful applications running on vSphere Pods in the Supervisor. VKS Backup and Restore Hooks enable execution of pre- and post-operation scripts for granular control over the data protection lifecycle, supporting application consistency and custom automation during recovery. Cross-cluster restore is available through the Restore from another cluster option in the Data Protection tab of the VCF Automation Tenant Portal. Data protection account credentials are scoped to users with Organization Administrator or Project Administrator roles, restricting who can configure backup target locations; VCF Automation enables platform teams to create target locations pointing to self-provisioned storage environments, supporting both cloud-hosted accounts and on-premises endpoints. VCF Automation also supports snapshotting VM groups, where each member VM receives a distinct snapshot, and restoring a VM group snapshot restores each member of the group.

Kubernetes cluster state is stored in etcd, and two backup methods are available for the etcd datastore: the built-in snapshot method and volume snapshot. The `etcdctl snapshot save` command creates a backup by specifying the endpoint, CA certificate, client certificate, and client key, providing authenticated access to the backup operation. Snapshots can be restored from a snapshot file or from a remaining data directory. During `kubeadm` upgrades, backup folders for etcd state and cluster manifests are written automatically to `/etc/kubernetes/tmp` with timestamped names, providing a recovery point in case of upgrade failure. Storage policy-based data management is available through Kubernetes StorageClass objects that reference vSphere storage policies via Storage Policy Based Management (SPBM); those policies may include encryption settings, allowing organizations to apply consistent encryption-at-rest requirements to persistent volumes through standard Kubernetes StorageClass configuration. CSI-based data protection for VKS requires a validated configuration between VKS and the underlying storage infrastructure.

VKS clusters on the Supervisor also support the Kubernetes VolumeSnapshot API, which provides `VolumeSnapshotContent` and `VolumeSnapshot` resources as a native point-in-time snapshot mechanism for persistent volumes. Volume snapshots can be provisioned dynamically from a `PersistentVolumeClaim` using a `VolumeSnapshotClass` that specifies storage provider parameters and the deletion policy for snapshot content. Restoring from a snapshot is performed by creating a new `PersistentVolumeClaim` with the target `VolumeSnapshot` as its `dataSource`, referenced via the `snapshot.storage.k8s.io` API group. Kubernetes `PersistentVolumes` have a configurable reclaim policy; setting the policy to `Retain` preserves volume data in a `Released` state after the associated `PersistentVolumeClaim` is deleted, allowing administrators to recover or migrate the data before the underlying storage is reclaimed.

Kubernetes Secrets provide a mechanism for storing sensitive configuration data separately from application code, reducing the risk of accidental exposure in container workloads. Applications consuming Secrets from environment variables or mounted volumes should avoid logging secret values in the clear or transmitting them to untrusted parties. Using short-lived Secrets helps limit the impact of accidental or intentional exposure. Kubernetes and applications can take additional precautions with Secrets, such as avoiding writing sensitive data to non-volatile storage.

vSphere APIs for Data Protection provide an integration point for third-party backup software to perform nondisruptive full, differential, and incremental image backups using VMFS snapshot capabilities, without requiring virtual machines to be powered off or placing backup processing overhead on VMware ESX hosts. For virtual machines running supported Microsoft Windows operating systems, these APIs integrate with Microsoft Volume Shadow Copy Services (VSS) to maintain application consistency during backup operations.

VMware Live Site Recovery extends data protection with orchestrated disaster recovery across sites. Replication can be configured with recovery point objectives as low as 60 seconds, with options for network compression, multiple point-in-time recovery, and automatic replication of new disks. vSphere Replication provides configurable RPO settings for VM-level replication to local or remote datastores. Application-level high availability and disaster recovery mechanisms combine real-

time availability with sitewide disaster recovery, with data replication to secondary sites providing recovery options in case of catastrophic failure.

VCF Operations Data and Site Resiliency Monitoring provides centralized visibility into data protection metrics across private clouds, enabling administrators to track the status of data protection controls from a single view. This monitoring layer helps organizations verify that their data protection configurations remain in place and functioning as expected.

For Kubernetes workloads on VKS clusters, volume health status is reported through `volumehealth.storage.kubernetes.io/messages` annotations on `PersistentVolumeClaims`, giving administrators granular visibility into whether individual persistent volumes are accessible.

Management of data protection settings is restricted through role-based access controls. VCF Operations uses privilege-based access controls that restrict visibility based on user roles, limiting which accounts can view sensitive operational data. For VKS clusters, managing data protection requires assignment of an Organization Administrator or Project Administrator role. VCF documentation includes storage security best practices covering securing access to storage devices, implementing storage encryption, and protecting virtual machine data as part of an overall data protection posture.

Selecting which of these data protection mechanisms apply to specific datasets, defining protection policies and recovery objectives, and configuring the relevant features to match those decisions remain organizational responsibilities. VCF supplies the technical mechanisms; organizations define what to protect, to what recovery point, and with which retention and access controls.

VMware Private AI Services (PAIS) contributes to data protection by applying access controls, authenticated connectivity, and credential management to AI workloads, model repositories, knowledge bases, and associated data assets that the platform handles.

The Model Gallery uses Harbor project access capabilities to restrict access to the sensitive data used to train and tune models. PAIS integrates with Harbor registries as a model storage backend, requiring authentication and certificate-based trust for model retrieval. PAIS is also compatible with OCI-compliant registries from other vendors, so organizations using an alternate backend can apply equivalent registry-level access controls.

Access to PAIS itself is gated by OIDC group-based authorization. Only user accounts that are members of the groups specified in the `authorizedGroups` configuration can access the service, and the OIDC group claim name is configurable to match the identity provider in use. PAIS uses a CA trust bundle for secure communication with external services and databases, and supports CA trust bundle management for secure connections with external registries and content management systems by uploading or referencing certificate files. VCF Automation Provider Management requires trusted certificate import for vCenter validation before integration with PAIS, restricting integration paths to validated endpoints.

For retrieval-augmented generation, PAIS Knowledge Bases link to external data sources through stored credentials, scoping indexed-data retrieval to defined service identities, and Data Indexing and Retrieval handles automatic collection and indexing of updates from those linked sources over time. Personal access tokens generated from user account settings provide programmatic access to Knowledge Bases and data sources. SharePoint data sources for PAIS Knowledge Bases require user name and password authentication, with support limited to SharePoint On-Premises deployments.

PAIS observability also flows through authenticated paths: the Grafana integration uses OIDC provider authentication for metrics visualization, and LLM traces can be sent to an OpenTelemetry Collector for monitoring.

PAIS DSM database resource allocation is controlled through an infrastructure policy that defines the quality and quantity of resources the database can consume from vSphere clusters, with associated storage policies and VM classes. A default storage policy can be selected to define storage placement for the database in PAIS, and storage policy and VM class selections should be chosen to suit RAG workloads when the database supports RAG use cases.

Organizations connecting external data sources or registries to PAIS should examine the capabilities and parameters of those integrations and approve only those suitable for use, since unreviewed connectors can affect what data models access or expose.

VMware vDefend (Contributes)

VMware vDefend (vDefend) contributes to data protection controls by providing network-level security mechanisms that protect data in transit and restrict unauthorized network access to systems where data is stored or processed.

The vDefend distributed firewall (DFW) enforces microsegmentation policies at the vNIC level, restricting which workloads can communicate with data stores, databases, and application tiers. By segmenting the data center network into isolated security zones, vDefend limits the blast radius of a compromise and restricts lateral movement toward systems that hold sensitive data. Administrators define granular firewall rules based on workload identity, security tags, and application-level attributes, limiting access to data repositories to authorized services. Identity Firewall extends policy enforcement to user identity, allowing administrators to define access controls based on which authenticated user initiated the connection rather than solely the source workload, strengthening data access controls in environments with user-based authorization requirements. Security policies are defined, propagated, and enforced across Bare Metal servers through the Security Services Platform (SSP), extending microsegmentation protections beyond virtualized workloads to physical infrastructure connected to the environment.

The SSP includes Security Intelligence, which identifies risky application protocols that transport data in clear text, including HTTP, Telnet, FTP, TFTP, LDAP, POP3, and IMAP. This visibility allows administrators to detect and remediate unencrypted data flows that could expose sensitive information in transit. Security Intelligence administrators can monitor traffic leakage between environments, establish exceptions, and implement lockdown protection rules to control inter-environment flows. Security Intelligence also enables administrators to generate policy recommendations and deploy them in monitor-before-enforcement mode, allowing observation of traffic patterns before applying restrictive rules. The SSP summary panel displays the number of services that are fully protected, partially protected, or not protected, giving administrators a dashboard view of segmentation coverage gaps across the environment.

IDS/IPS profiles attach to Distributed Firewall and Gateway Firewall rules to inspect east-west and north-south network traffic for signatures and behaviors associated with data theft, command-and-control communication, and exploitation of vulnerabilities in data-handling services. In vDefend, IDS/IPS signature rules support storing TLS/SSL certificates on disk for forensic analysis and threat investigation, providing durable artifacts for post-incident review of potential data exfiltration events.

Malware Prevention profiles attach to DFW and Gateway Firewall rules and can be configured to send files to the cloud for detailed analysis or to process files locally without cloud connectivity, accommodating environments with data-residency or air-gap requirements. Malware Prevention collects file analysis data including file hash submissions and assigns an Analyst UUID to each submission to track its analysis lifecycle. The Malware Prevention dashboard displays trends of malicious, suspicious, and suppressed file events across the data center, and file verdict filtering allows operators to focus on specific verdict categories such as malicious-only views.

Network Detection and Response (NDR) anonymizes sensitive customer information when sharing telemetry data to cloud services, providing a built-in data privacy mechanism for environments that enable cloud-assisted threat detection.

These network security controls complement the data-at-rest encryption, backup, replication, and access management capabilities provided by other VCF components. vDefend does not perform data encryption, classification, backup, or recovery itself, but it protects the network paths and access patterns through which data is stored, replicated, and retrieved.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides replication-based data protection for virtual machine workloads across sites. Protection groups allow administrators to organize virtual machines and datastores under consistent snapshot and replication policies at scale, covering both local recovery via vSAN snapshots and cross-site recovery via vSphere Replication or array-based replication. Protection group membership can be modified after creation, and virtual machines can be automatically enrolled for protection using storage tag selection on designated datastores, reducing manual overhead in maintaining protection coverage across a growing environment.

PNR introduces an immutability mode for protection groups that, when enabled, prevents the data protection group from being modified or deleted. This mechanism allows administrators to safeguard protection configurations against inadvertent or unauthorized changes. PNR Health monitoring provides consolidated visibility into data protection service health, operation issues for local and replication snapshots, storage utilization, and protection group membership changes, giving administrators a current view of protection posture across the environment.

Site Recovery Manager (SRM) integrates with vSphere Replication to provide orchestrated failover with configurable recovery point objectives, giving organizations control over acceptable data loss thresholds for protected workloads. PNR supports additional site topologies, including shared recovery site configurations where protected site resources are mapped to isolated datacenters, networks, folders, and datastores on the recovery site. Inventory mappings allow administrators to define resource configurations once and apply them consistently across protection groups.

vSAN Snapshots and Replication is a native, integrated snapshot-based backup capability for virtual machines running on vSAN datastores, managed through the vSphere Client. It provides VM restore and clone operations from existing snapshots, supporting both rapid recovery from operational failures and ransomware recovery scenarios. Test failover operations allow administrators to validate that recovery configurations are functional before an actual recovery event occurs.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides several mechanisms that support data protection for managed database instances, covering PostgreSQL, MySQL, and SQL Server databases.

The most direct contribution is DSM's automated backup framework, which administrators can enable on a per-database basis or through data service policies. When configured, DSM performs scheduled full and incremental backups of database content and stores them in S3-compatible object storage at a configurable backup location. Backup retention is configurable (backup-retention-period), and DSM retains backups of deleted databases until the configured retention period expires, supporting recovery from accidental deletion. For point-in-time recovery, DSM restores a backup to a newly created database VM with a user-specified name and datastore location, and can target the most recent timestamp or a specific point in time. DSM archives binary logs in backup storage as part of its backup protection mechanism. Administrators can also initiate manual on-demand backups of primary PostgreSQL databases to safeguard data before high-impact operations or as immediate protection after major changes. For PostgreSQL multi-site deployments, DSM performs a full backup automatically during a promotion event before resuming the regular schedule.

Data service policies give administrators control over backup behavior across all databases governed by a policy. Policies can require that databases have automated backups enabled, allow users to opt in, or disallow automated backups entirely. The allowed-backup-locations setting in the data service policy restricts users to selecting from approved backup locations, reducing the risk of backup misconfiguration. Policies can be enforced across multiple tenants and across different namespaces and namespace labels, supporting consistent data protection posture in multi-tenant deployments. A Compliance tab on data service policies displays compliance reports and allows administrators to expand each policy violation to view the noncompliant database, data service, and namespace, giving administrators visibility into where data protection requirements are not being met. In 9.1, data service policies extend to SQL Server databases in addition to MySQL and PostgreSQL.

DSM implements role-based access control that separates administrative and user-level database access. DSM Admins can create, monitor, and manage all data services in the environment; DSM Users can only manage and monitor the data services they own. This access model limits who can modify backup configurations and policy settings. Infrastructure policies govern which storage resources are available for database VMs, including CPU, memory, storage policies, IP pool, and VM classes, giving administrators control over the storage environment in which data resides.

Control plane recovery requires that a Provider Backup Repo has been configured at installation time. If the Provider VM fails, the restore-provider command restores it to the latest timestamp. In the VCF Automation context, tenants can perform point-in-time restores directly through the VCF Automation UI, broadening restore access to self-service scenarios.

One limitation applies: if an incremental backup in the backup chain is deleted, DSM cannot restore the full data; a successful restore from an incremental chain requires the last full backup and all following incremental backups. Organizations must protect the integrity of the backup chain through access controls on the backup storage.

DSM provides configurable backup, recovery, and policy enforcement mechanisms for managed database instances. The broader data protection program requires organizational decisions about backup schedules, retention periods, backup storage security, and off-site management that DSM does not prescribe on its own.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several application-layer mechanisms that support the implementation of data protection controls within a VCF deployment.

At the transport layer, Avi performs TLS termination with configurable SSL/TLS profiles for connections between clients and virtual services. The SSL/TLS protocol at the Avi proxy secures data in transit by reducing the risk of unauthorized parties reading or modifying information transferred between end users and application workloads. SSL/TLS profiles are configurable through the Avi Controller UI under Templates > Security > SSL/TLS Profile. Management interface access is further restricted through configuration of allowed ciphers and HMACs for management sessions.

Avi integrates with Hardware Security Modules (HSMs), including the Thales Luna (formerly SafeNet Luna) HSM, for cryptographic key storage and management. This allows organizations to store the private keys used in TLS termination and other cryptographic operations within a dedicated hardware key store rather than in software. The Avi Controller also stores sensitive configuration data encrypted in a local database, and backup files can be protected with a passphrase that encrypts the keys included in the backup. Backup and restore operations verify that the FIPS mode of the backup configuration matches the target controller environment.

Avi's Web Application Firewall (WAF) applies both positive and negative security models to inspect and filter HTTP/HTTPS application traffic. WAF policies support ModSecurity rules for application protection and a Positive Security model that learns application behavior to define allowed request patterns. The Application Rules service, available through the Avi Cloud Console, provides WAF rules specifically designed to address known application vulnerabilities including CVE-tracked issues, with automatic updates to keep rules current. WAF configuration is accessible through the Controller UI under Templates > Security > WAF Policy.

Avi DataScript provides a programmable layer for enforcing additional data protection behaviors at the proxy boundary. DataScripts are Lua-based scripted rules that allow inspection and manipulation of client HTTP requests and server HTTP responses, supporting content switching, redirection, header manipulation, and logging. DataScript can be used to enforce cipher suite policies by denying clients connecting with unsupported ciphers. DataScript also supports blocklist-based access control by checking client IP addresses against named IP groups and terminating connections from blocked sources while logging the violation. XML-based DataScript use cases can extract client identifiers from request payloads and compare them against configured string groups to restrict access to authorized clients.

Access to Avi configuration objects is restricted through granular role-based access control (RBAC). Avi supports extended granular RBAC using label-based markers to restrict user permissions to specific resources based on key-value pair matching. The RBAC model differentiates Read and Write access across objects such as SSL/TLS Profiles, PKI Profiles, Authentication Profiles, IP Address Groups, and Health Monitors, allowing organizations to scope access to data protection-relevant configuration to authorized roles only. Roles can also be scoped to tenants through label group associations.

These mechanisms address data protection at the application delivery layer. Broader organizational data protection controls, including data classification policies, data handling procedures, and data-at-rest protection beyond the Avi proxy boundary, require organizational governance and platform-level capabilities that Avi does not provide as an application delivery controller.

Control B3.a

Understanding Data: You have a good understanding of data important to the operation of network and information systems supporting your essential function(s), where it is stored, where it travels and how unavailability or unauthorised access, uncontrolled release, modification or deletion would adversely impact the essential function(s). This also applies to third parties storing or accessing data important to the operation of your essential function(s).

SCF Controls: AST-04, DCH-02, DCH-06.2, DCH-14.3, DCH-19

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several capabilities that contribute to maintaining network architecture diagrams and data flow documentation, though the organizational process of creating, maintaining, reviewing, and governing formal diagram artifacts remains a customer responsibility.

VCF Operations for Networks includes an end-to-end interactive network map that displays a detailed model of both physical and virtual devices in the environment, including physical switches, physical firewalls, routers, load balancers, transport nodes, and NSX virtual entities. The Network Map Summary presents a view of the data center that includes these entities along with an alert chart showing alert status across the inventory. Users can scope the view to focus on specific portions of the network. Because the map updates based on data collected from configured sources, it reflects the discovered state of the monitored infrastructure rather than a static diagram, providing a foundation for understanding the current network architecture and validating formal network diagrams.

NSX network connectivity workflows include a built-in topology visualization that correlates user configuration inputs with the resulting network topology, helping administrators understand the architecture before committing changes and reducing the risk of misconfiguration by providing a view of the entire setup. The NSX Manager Network Topology feature allows users to view network connectivity by zooming in to see details about logical entities and their logical paths, along with the services configured on those entities. The NSX Main Dashboard displays the topology of a selected object and how it connects to elements in the network, with a view of related alerts. The vSphere Client provides topology views of compute, storage, and network relationships, displaying logical and physical components such as segments, transport zones, and resource dependencies. The vSphere Distributed Switch topology diagram specifically shows information about the physical adapter connecting virtual adapters to the external network, with filters that default to displaying up to 32 port groups, 32 hosts, and 1,024 virtual machines.

The vSphere Network Inventory Dashboard provides a dedicated topology view of the vSphere network inventory, including information related to vSphere environments, vCenter instances, data centers, distributed vSwitches, distributed port groups, virtual machines, and associated properties and metrics. The Network Configuration Dashboard displays key configuration information including bar charts focused on critical security settings for vSphere distributed switches, providing visibility into the security-relevant configuration state of the network infrastructure.

For data flow analysis, VCF Operations for Networks collects flow data defined by 5-tuple values: source IP address, source port, destination IP address, destination port, and protocol. At the virtual switch level, vSphere Distributed Switches also support NetFlow export, configured with an Observation Domain ID that identifies the switch within the flow collection infrastructure, so flow data can be sent to external collectors for analysis alongside data collected by VCF Operations for Networks. The Access Flow Insight page in Network Operations allows analysis of all flows available in the environment, where each dot in the graph represents multiple flows and users can drill into individual flow details. The Custom Analysis section within Flow Insight provides two-dimensional visualization of flow data on user-selected dimensions to identify outliers in network traffic patterns. Flow metrics display traffic flow data collected from flow-enabled data sources, aggregated to show metrics such as total bytes and traffic rate. Flow analytics can also be run to understand bandwidth and packet rates.

VCF Operations for Networks supports flow-based application discovery, accessible by navigating to Infrastructure Operations, then Analyze, and selecting the Flows tab. This allows administrators to discover applications by analyzing traffic patterns and network flows in the environment, with the ability to modify the scope, naming preference, and duration of the discovery process. The application topology map displays traffic flows between application tiers, internet endpoints, shared services, and other applications, showing how data moves between workload groups. The map shows tier overviews, lists of members (including VMs, Kubernetes services, and physical IPs), flows between tiers, and the physical IPs and shared services that applications depend on.

VCF Operations for Networks also provides a Security Planning capability that analyzes flows and displays traffic flow patterns and micro-segmentation views. This feature supports security assessment by making it possible to see how traffic moves through the environment, which is directly relevant to documenting sensitive or regulated data flows and assessing the security posture of the network architecture. The platform also provides planning and recommendations for implementing micro-segmentation security, and the micro-segmentation flow analysis interface allows filtering by protection status to view allowed and blocked flows.

VCF Operations for Networks includes a PCI Compliance page that presents a network flow diagram showing data flow paths, firewall placements, connections, and other details associated with the network. This built-in visualization is oriented toward compliance assessment and can supplement organizational network architecture documentation.

For multi-site environments, VCF Operations for Networks supports flow visualization for SDDC-to-SDDC communication through VMware Transit Connect via the VMware Managed Transit Gateway (VTGW), providing visibility into cross-data-center network flows. The Streaming Databus supports cross-data center network flow analysis by grouping query results by source data center, destination data center, and flow type.

Firewall rules can be exported to CSV files using the `run_fw_rule_export` CLI command, producing files that can be transferred via secure copy for integration into formal documentation. VCF also documents its own internal network ports and protocols at `ports.broadcom.com`, which provides reference material for documenting the platform's own communication paths.

While VCF provides tools for network topology visualization, flow analysis, application discovery, and security-oriented network views, the control requires a formal organizational process for maintaining network architecture diagrams and data flow diagrams that are kept current and contain sufficient detail for security assessment. VCF's capabilities provide the underlying data and visualization tools that inform these diagrams, but the creation, review, approval, and maintenance lifecycle of the formal documentation is an organizational responsibility.

VMware vDefend (Contributes)

VMware vDefend contributes to generating logical maps of data-sharing relationships through Security Intelligence's visualization and analysis capabilities, though the full scope of this control also requires organizational processes, formal agreements, and documentation outside vDefend's scope.

Security Intelligence, hosted within the Security Services Platform, performs segmentation analysis that maps discovered unique assets including workloads, groups, IP addresses, DVPs, segments, tier-0 and tier-1 gateways, infrastructure services, and infrastructure servers. IP addresses are resolved to VMs, and tier-0 and tier-1 information is mapped to corresponding segments, providing a structured view of how workloads and network constructs relate within the NSX environment. Security Intelligence also maintains an inferred infrastructure Classifications table, with each classification in a Not Reviewed state until accepted or modified by an administrator, supporting the development of a reviewed inventory of compute entities.

The Security Explorer Computes View supports assigning labels to compute entity nodes for organizational and filtering purposes, and label and entity information can be exported to CSV for external documentation. The Applications View enables drill-down into application tiers to view the specific VMs and IP addresses within each tier, providing visibility into how workloads communicate across application boundaries. Together, these capabilities support understanding which workloads share data and across what network paths, which is a building block for generating logical maps of data-sharing relationships.

The Distributed Firewall (DFW) rule base functions as a network-layer access control defining which workloads are permitted to communicate with each other. The Identity Firewall feature extends this model by enforcing policies based on user identity. Active Directory users and groups can be used as source criteria in Distributed Firewall and Gateway Firewall rules, enabling access control anchored to user group membership rather than workload IP address alone. Identity Firewall rules can be applied to tier-0 or tier-1 gateways using Active Directory group membership as a source criterion for access control decisions.

Role-based access control within the Security Services Platform restricts who can view and manage these visualizations and flow data. Five roles are defined with differentiated permissions: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector.

Generating formal Interconnection Security Agreements, mapping data-sharing relationships with external parties beyond the network boundary, and maintaining a registry of all parties with whom sensitive data is shared are organizational governance activities outside vDefend's scope.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) contributes to network architecture and data flow documentation through its network mapping capabilities, which record the topology between protected and recovery sites and provide programmatic access to that information for inclusion in formal diagrams.

PNR supports site-wide network mappings that define how networks on the protected site correspond to networks on the recovery site. These mappings can specify a different network to use during recovery plan tests, capturing the separate set of data flows that apply during DR exercises. For stretched storage environments, network mappings can be configured manually to override automatic mapping behavior between sites.

The Protection and Recovery Plug-In for the VCF Operations orchestrator provides API workflows that enumerate these mappings programmatically. The Get Network Mappings workflow lists all networks on a local site with existing mappings. The Get Network Mapping Pairs workflow retrieves the full set of mapping pairs for a specified site. The Get Test Network Mapping Pairs workflow lists test network mappings between corresponding objects across the remote site, and can query both protected and recovery sites when both are registered as local, providing a complete picture of the site-to-site network topology. An Add Test Network Mapping to Recovery Plan workflow maps a remote network to a test network within a specific recovery plan. IP customization workflows allow per-mapping customization of IP mapping rules and can remove customization rules from existing mappings.

The Plug-In also supports inventory mapping workflows that span folder mappings, network mappings, resource pool mappings, and test network mappings, providing a unified interface for enumerating all inter-site relationships.

Organizations should incorporate PNR's network mapping data and Plug-In workflow outputs into their formal network architecture diagrams to document DR topology, test network configurations, and the data flows that traverse the replication paths between sites.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides application-layer geographic visibility that supports the data flow documentation this control requires. Its Global Server Load Balancing (GSLB) feature maintains an explicit record of where application services are deployed geographically. Geographic information for geolocated services is loaded into the GSLB leader Controller either in bulk or on a location-by-location basis, then converted to geo-DB format and distributed to all DNS Service Engines in the group. GSLB service members can be configured with geolocation data drawn from three sources: the geo-DB, user-configured values, or values inherited from the site. This configuration is a machine-readable registry of which application endpoints are active at which geographic locations. Operators configure geolocation-based load balancing through a Geo Profile, created in the Avi UI at Infrastructure > GSLB > Geo Profile, where a previously created geo-DB file object is selected as the Geo-DB Entries source.

At the application traffic level, Avi maintains geo-DB files that map IP addresses to region, city, latitude, and longitude data. The GSLB geo-DB supports multiple files as input, with a priority mechanism that determines which data takes precedence

when multiple sources define a location for the same IP address. Custom geo-DB files can be uploaded to the Avi Controller and consumed by Service Engines for geolocation-based decisions. The Avi Service Engine Geo-DB implementation includes a System-LocationDB-File object stored at `/var/lib/avi/geo_db/admin` containing region, city, latitude, and longitude data for IPv4 addresses. Avi Service Engines report geolocation information for client IP addresses, including latitude, longitude, and geographic location names at the country, region, and city level, and this data appears in traffic logs and troubleshooting checklists.

The DataScript API function `avi.utils.get_geo_from_ip` retrieves geolocation data for a queried IP address, returning autonomous system (AS) number, country code, country name, continent name, continent code, latitude, longitude, region, and city. The DNS DataScript location API similarly returns a table containing validity status, longitude, latitude, location name, and client location tag. These APIs let operators build custom data flow reporting that identifies the geographic origin of application traffic programmatically.

Geolocation-based policies in WAF, the HTTP Policy Set, and Network Security Policy can reference geo-DB data to apply rules based on client geographic origin. Avi WAF Policy allows selection of a Geo Location Mapping Database from a drop-down menu. The HTTP Policy Set supports Geo-DB selection for use in the geolocation algorithm. Together, these capabilities let operators document which geographic regions application services serve and apply enforcement policies based on that geography.

Organizations should use GSLB site configuration and Avi's traffic analytics as inputs to a broader data flow inventory. The full inventory must extend to the compute, storage, and network layers of VCF that Avi's application delivery scope does not cover.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control B3.b

Data in Transit: You have protected the transit of data important to the operation of network and information systems supporting your essential function(s). This includes the transfer of data to third parties.

SCF Controls: CRY-03

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides cryptographic protection for data in transit across management, compute, storage, and inter-site networks. The architecture applies encryption at multiple layers using validated cryptographic modules and current TLS protocol versions.

VCF management and monitoring communications use TLS as the transport protocol. VCF Operations for Networks supports modern TLS protocol versions, with the ability to restrict cryptographic module usage to FIPS-validated modules by enabling FIPS mode for external connections. Telegraf, the metrics collection agent, is configured to require a modern minimum TLS version for its communication channels. When using the databus for on-premises environments, HTTPS is the recommended transport to protect data during transmission and to verify subscriber authenticity. The TLS implementation includes customizable PKI options ranging from fully automated certificate management within VCF to integration with enterprise PKI infrastructure such as Microsoft Active Directory Certificate Services. VCF Operations provides centralized certificate lifecycle management across VCF components, supporting auto-renewal for VMCA, MSCA, and OpenSSL CA, handling automated renewal, monitoring, and replacement. Machine SSL certificates can be renewed through the API for a specified period up to 730 days. Starting in vSphere 9.0, all vSphere TLS profiles are FIPS compliant, and the COMPATIBLE profile supports modern TLS cipher suites and elliptic curves. The vCenter appliance uses VMware's Boring Crypto Module version 6.0, which provides FIPS-validated cryptographic operations including AES, ECDSA, HMAC, RSA, and SHA-2 variants.

NSX, which provides networking services within VCF, uses FIPS 140-3 validated cryptographic modules by default. These modules are validated through the NIST Cryptographic Module Validation Program. NSX Manager uses FIPS 140 approved algorithms for authentication to its cryptographic module. For site-to-site connectivity, the NSX L2 VPN FIPS compliance suite uses FIPS-approved encryption with Perfect Forward Secrecy enabled and standardized Diffie-Hellman key exchange, providing transmission confidentiality for tunneled traffic. VCF Operations for Networks supports modern ECDSA and RSA signature algorithms for data source connections.

VCF Automation uses the BouncyCastle FIPS 2.0.0 cryptographic module, which is compliant with FIPS 140-3 (Certificate #4743). VCF Operations for Networks uses the BC-FJA (Bouncy Castle FIPS Java API) version 2.0.0 with FIPS 140-2 Certificate #37009. These validated modules underpin the cryptographic operations used for securing communications across the automation and operations components.

At the storage layer, vSAN provides data-in-transit (DIT) encryption that protects data as it moves between hosts within the cluster. DIT encryption is a cluster-wide setting that, when enabled, encrypts all data and metadata traffic across hosts. Forward secrecy is enforced for vSAN data-in-transit encryption, meaning that compromise of a long-term key does not expose previously encrypted traffic. DIT encryption operates independently of data-at-rest encryption and does not require external key management servers. The behavior differs by storage architecture: in vSAN Original Storage Architecture (OSA), data-at-rest encryption occurs at the target host's Local Object Manager layer, so data traverses the network before encryption, making DIT encryption strongly recommended. In vSAN Express Storage Architecture (ESA) in HCI mode, data is encrypted at the VM host before network transmission, making DIT encryption optional based on compliance requirements.

VM Encryption provides confidentiality protection across all datastore types including vSAN, iSCSI, NFS, and Fibre Channel. VM encryption is implemented on the ESX host rather than on the storage array, so it protects data both at rest and in transit to the storage backend. Disk encryption uses AES-256 as the disk encryption key.

Encrypted vSphere vMotion protects VM data during live migrations. For encrypted VMs, vMotion always uses encryption and cannot be disabled. For unencrypted VMs, encrypted vMotion offers three settings: Disabled, Opportunistic (default, uses

encryption when supported), and Required. AES-NI significantly improves encryption performance for these operations. Cross-vCenter vMotion supports encryption when source and destination use shared key providers; vCenter Crypto Manager provides an `importProvider` method to import a vSphere Native Key Provider configuration between sites. vSphere Fault Tolerance log traffic, which synchronizes VM state between primary and secondary instances, can also be encrypted to protect this synchronization data in transit.

Storage protocol support varies by type. vSAN File Service supports NFS4 Kerberos authentication with security options `krb5`, `krb5i`, and `krb5p`, where `krb5p` provides authentication plus encryption of data in transit. iSCSI uses CHAP for session authentication but does not encrypt data natively, so VM Encryption or in-guest encryption is needed for confidentiality on iSCSI networks. Fibre Channel Gen 7 supports end-to-end encryption with secure Host Bus Adapters.

HCX Network Extension services support transport encryption for data between site pairs, and this encryption is enabled by default. VCF Operations HCX tunnel encryption similarly uses transport encryption by default to protect Network Extension data and migration traffic between sites. This default-on approach reduces the risk of data being transmitted in cleartext during workload migrations or network extensions.

High-quality entropy generation on ESX hosts supports the proper functioning of security-related operations such as generating encryption keys for secure network communication. This foundational capability helps maintain the strength of cryptographic keys used across all transmission encryption functions in the platform.

VMware Kubernetes Service (VKS), which runs on vSphere Supervisor, applies TLS encryption across all control-plane communication paths. The Kubernetes API server enforces encrypted transmission within the control plane and between the control plane and its clients by default, so all API server interactions travel over TLS. Cipher suites are configurable at each component layer: the `kube-apiserver` `--tls-cipher-suites` parameter accepts a comma-separated list of permitted cipher suites; the `kube-scheduler` exposes the same `'tls-cipher-suites'` parameter to keep its API endpoint aligned; and the `kubelet` exposes `'tlsCipherSuites'` and `'tlsMinVersion'` settings in `'KubeletConfiguration'` to scope the permitted cipher algorithms and minimum protocol version at the node level. Antrea, the CNI plugin included with Supervisor, supports configurable TLS cipher suites for its own secure communication channels through the `'tlsCipherSuites'` setting, and the vSphere Cloud Provider Interface (CPI) exposes the same capability through a configurable cipher suite list.

For environments with strict cryptographic requirements, VKS supports FIPS mode through the `ClusterClass` variable `'fips.enabled'`, which controls which encryption algorithms are permitted at the node level. Tanzu Kubernetes Release references carrying the `'-fips.1'` suffix indicate that FIPS cryptographic modules are active for that node pool. The Istio service mesh package, available as a standard package on VKS clusters, ships with FIPS compliance and supports mutual TLS (mTLS) between pods within the mesh; the `'meshMTLS.minProtocolVersion'` setting controls the minimum acceptable protocol version for all inter-service traffic. Ingress-layer encryption for workloads is handled by the Contour package, which exposes `'tls.minimum-protocol-version'` and `'tls.maximum-protocol-version'` settings so operators can define a bounded range of acceptable protocol versions for inbound HTTPS traffic. The Supervisor secret injection agent automatically configures mutual TLS for its communication with the vault agent injector service using auto-generated certificates. Harbor, available as a Supervisor Service, accepts custom TLS certificates through its `'tlsCertificate.tls.crt'` and `'tlsCertificate.tls.key'` configuration fields, supporting encrypted access to the container registry for image distribution.

Defining the encryption policy for customer workload traffic, selecting cipher and FIPS configurations for environments with stricter requirements, and validating that data transmitted from customer applications and containerized workloads meets confidentiality standards are organizational data-policy decisions.

VMware Private AI Services (PAIS) provisions VKS clusters using a FIPS-enabled Kubernetes build for cryptographic compliance across both control plane and worker node communications. The VKS cluster topology version is `v1.33.1--vmware.1-fips-vkr.2` with FIPS compliance enabled, running on an Ubuntu 24.04 OS image, covering the cryptographic modules that protect data in transit within the cluster fabric.

PAIS, activated through the `PAISConfiguration` custom resource on the Supervisor, requires HTTPS for all external integrations. The `spec.clientTls.caBundleRefs` section of the `PAISConfiguration` YAML references CA trust bundles supplied as `ConfigMap` resources. Operators must configure HTTPS trust bundles for the OIDC provider, the Harbor container registry,

content management systems hosting Knowledge Base data sources, MCP servers providing tools to models, and the pgvector database. Separate trust bundles are recommended per application, with periodic updates required before certificate expiration.

The PAIS Supervisor endpoint uses HTTPS on port 6443 with certificate-based authentication. The PAIS ingress endpoint is protected by a self-signed certificate stored in the `pais-ingress-default` Kubernetes Secret. Administrators retrieve the CA certificate using `kubectl get secrets/pais-ingress-default -o yaml` and distribute it to clients that connect to the service, including Grafana when configured to scrape the PAIS Prometheus endpoint. CA trust bundles for external entity connections are managed through ConfigMaps and updated as certificate content changes.

VCF Automation Provider Management for PAIS uses a base64-encoded certificate (`TM_CERT_BASE64`) obtained by running `openssl s_client` against the VCF Automation FQDN on port 443, enabling authenticated HTTPS communication between AI catalog tooling and the PAIS environment. MCP server integrations require the MCP server's issuer certificate to be added as a CA trust bundle before connecting over HTTPS using either Streamable HTTP or Server-Sent Events transport.

Telemetry sent from PAIS to the OpenTelemetry Collector is authenticated using a Kubernetes Secret containing Authorization Bearer tokens and custom authorization headers. LLM trace transport to the collector uses HTTP/protobuf or gRPC, both protecting trace traffic in transit.

One configuration detail that auditors should verify: PAIS Prometheus TLS client authentication and certificate validation are turned off by default (the `tls-client-authentication` setting on the Prometheus endpoint). Organizations should review this setting and enable mutual TLS where their policy requires it. The underlying network transport encryption between VMs and workload domains is provided by VCF and is documented in VCF Coverage.

VMware vDefend (Contributes)

VMware vDefend contributes to transmission confidentiality through inspection, visibility, and enforcement mechanisms at the network layer, while the underlying cryptographic protection of data in transit is the responsibility of endpoint applications and infrastructure components.

TLS Inspection uses a transparent TLS proxy to intercept and analyze encrypted traffic flows traversing the environment. This allows security policy to be applied to traffic that would otherwise be opaque and supports detection of threats embedded within encrypted sessions. TLS Inspection can be deployed to provide visibility into encrypted connections while preserving end-to-end encryption for flows not subject to a decryption policy, and supports both inbound and outbound inspection profiles.

Security Intelligence, integrated within the Security Services Platform (SSP), surfaces workloads communicating over application protocols that transport data without encryption. The Security Segmentation Report identifies communication chains containing at-risk unprotected members and quantifies the number of unprotected data flows hitting default-allow rules across observed traffic. Administrators can use this reporting to identify and prioritize remediation of encryption coverage gaps, including restricting or blocking cleartext protocols.

The Security Services Platform and its component services use FIPS 140-2 and FIPS 140-3 validated cryptographic modules for their own communications. Network Detection and Response (NDR) Sensors connect to the SSP using mutual TLS authentication (mTLS), with a dedicated certificate for each sensor signed by an intermediate certificate authority on the SSP. The SSP can be configured to forward log messages to a syslog server over TLS, and Malware Prevention Service remote logging likewise uses TLS to transmit log data to a remote log server. NDR also supports SSL verification for event logs sent over HTTPS. When NDR shares data to the cloud, it anonymizes sensitive customer information before transmission.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides cryptographic protection for data transmitted during disaster recovery operations, covering management communications and replication data flows.

All communications between the PNR server and VMware vCenter (vCenter) instances take place over TLS connections. PNR requires an SSL/TLS certificate, with x509v3 Extended Key Usage indicating TLS Web Server Authentication, as the endpoint

certificate for all TLS connections to the PNR server. PNR defaults to the current TLS version for all communication endpoints and supports administrative configuration of the minimum acceptable protocol version. Administrators configure the minimum TLS protocol version by editing the `tls_minimum_protocol_version` parameter in the `envoy-proxy-config.json` file; when changing the minimum version, the update must be applied consistently across all occurrences in the system. PNR uses TLS certificates and private keys to protect network communication and authenticate with other servers.

For replication data, vSphere Replication encrypts replication traffic in transit for both new and existing replications. Network encryption is mandatory when using vSphere Replication 9.0.3 and later and is enabled by default. PNR also supports configuring network encryption of replication traffic as an option for replication scenarios where mandatory encryption does not apply automatically. PNR supports protection and recovery of encrypted virtual machines through both array-based and vSphere Replication protection groups, allowing VM disk encryption to persist through the replication process. Recovery of encrypted virtual machines requires that the protected and recovery sites share a common Key Management Server (KMS), or that the KMS clusters at both sites use common encryption keys, to maintain key availability after failover.

Defining the encryption policy for environments with stricter requirements and validating that workload traffic running on protected virtual machines meets confidentiality standards are organizational data-policy decisions.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) applies TLS-based encryption across multiple communication paths, covering database client connections, management interfaces, service-to-service communication, and data migration traffic. Starting with DSM, the platform enforces FIPS 140-3 compliant cryptographic standards and validates certificates during upload, rejecting unsupported algorithms such as Ed25519.

For database client connections, DSM enforces a minimum TLS protocol version across all supported database engines. PostgreSQL instances enforce a configurable minimum TLS protocol version via the `'ssl_min_protocol_version'` setting and support certificate-based authentication with CA verification. PostgreSQL replication connections support SSL/TLS encryption with a configurable `'sslmode'` parameter to secure data in transit between source and target databases, and DSM validates SSL trust before establishing replication. MySQL locks TLS protocol enforcement at the platform level so users cannot weaken it. MySQL has `'require_secure_transport'` set to ON by default, which requires all client connections to use encrypted transport. MySQL supports FIPS mode via the `'ssl_fips_mode'` setting. DSM adds SQL Server as a supported database engine; SQL Server clusters use TLS to encrypt client connections, require a minimum TLS version for DSM operator management, and expose the `'network.tlsProtocols'` engine setting to configure the set of allowed TLS versions.

For management and service-to-service communication, the DSM Provider exposes an HTTPS endpoint. The Consumption Operator requires a TLS certificate for secure communication with the DSM provider. In network-isolated deployments, Consumption Operator image transfers to a private registry support optional TLS certificate authentication. Metrics forwarding from DSM to VCF Operations supports mutual TLS (mTLS) authentication, requiring a client certificate and private key. DSM SMTP settings include an Auto TLS option that establishes a secure connection to the SMTP server.

DSM provides certificate management capabilities to support the TLS infrastructure. Custom certificates are validated for FIPS 140-3 compliance at upload time; accepted key types are ECDSA P-256, ECDSA P-384, and RSA with a minimum key size of 2048 bits, and Ed25519 keys are rejected as non-compliant. Trusted root certificates added through the DSM UI must comply with FIPS requirements.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides native, configurable cryptographic mechanisms to protect the confidentiality of data in transit at both the application data plane and the Controller management plane.

Each virtual service in Avi is associated with an SSL/TLS Profile, which defines the accepted protocol versions, cipher suites, and their priority order. SSL/TLS Profiles are managed at Templates > Security > SSL/TLS Profile in the Controller UI. Predefined profile templates are available, including a System-Standard template, and administrators can create custom profiles to enforce the cipher suites and protocol versions appropriate for their environment. Elliptic Curve (EC) cryptography is available for virtual services and supports Perfect Forward Secrecy with less computational overhead than RSA-based key

exchange. TLS persistence state exchanged between Service Engines when a client reconnects is carried in encrypted form. At the L4 proxy level, the Default-TLS protocol parser can be associated with a virtual service to inspect TLS handshake data using DataScript, supporting selective offload and re-encryption scenarios.

In Kubernetes environments, the Avi Kubernetes Operator (AKO) supports a PKIProfile custom resource definition that enables certificate-based authentication and encryption for backend service communication. The System-Standard SSL Profile can be applied through the RouteBackendExtension CRD to enable SSL/TLS re-encryption for traffic to backend servers, providing modern cipher suites for Kubernetes ingress and routing scenarios. In VCF environments, the Avi load balancer uses secrets to handle encrypted HTTPS traffic, configured through the VCF IaaS Service Console.

When FIPS mode is enabled on the Avi Controller cluster, all cryptographic operations across the Controller and Service Engines are restricted to FIPS 140-3 approved algorithms. Avi uses the OpenSSL FIPS Provider version 3.1.2 in this mode, which has been validated at FIPS 140-3 Security Level 1 and awarded Certificate #4985 by CMVP. Enabling FIPS mode is a cluster-level configuration that applies uniformly to all cryptographic material handled by the platform. FIPS mode does not support SSL Client Hello events in Avi DataScript, and post-quantum cryptographic capabilities are not available in FIPS mode.

The Avi Controller and Service Engines use SSH for secure management communication. The SE_SECURE_CHANNEL designation classifies traffic between the Controller and Service Engines to maintain a dedicated secure communication channel. Avi also integrates with Let's Encrypt via the ACME protocol to automate certificate issuance and renewal for virtual services, and with hardware security modules such as the Thales Luna HSM for external key management. Remote server file transfer supports Secure Copy Protocol (SCP) and Secure File Transfer Protocol (SFTP). For deployments requiring hardware acceleration, Avi Service Engine integrates with Intel QuickAssist Technology to offload bulk cryptographic operations following SSL/TLS handshake completion.

Avi DataScript exposes cryptographic functions for application-layer use cases. The `avi.crypto.encrypt()` function encrypts data using a caller-provided key, optional initialization vector, and algorithm parameter. The HTTP Cookie Encryption Gateway uses these functions to encrypt cookie values in HTTP responses, protecting session state carried between client and server. The `avi.utils.rand_bytes` function generates cryptographically secure random bytes for token and nonce generation.

Defining which application traffic requires encryption and configuring the virtual service profiles to apply protection at the appropriate boundary are organizational data-policy decisions.

Control B3.c

Stored Data: You have protected stored soft and hard copy data important to the operation of network and information systems supporting your essential function(s).

SCF Controls: CRY-05

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides multiple cryptographic mechanisms for protecting data at rest across its infrastructure stack, primarily through vSAN data-at-rest encryption and vSphere Virtual Machine Encryption.

vSAN data-at-rest encryption is the primary mechanism for protecting stored data within VCF. When enabled on a vSAN cluster, vSAN encrypts everything in the vSAN datastore, including all files, virtual machines, and their corresponding data. This protection extends to scenarios where a physical storage device is removed from the cluster, as the encrypted data remains unreadable without the proper keys. vSAN supports both Original Storage Architecture (OSA) and Express Storage Architecture (ESA) deployments, with encryption behavior varying by architecture. For OSA, data-at-rest encryption occurs at the Local Object Manager (LSOM) layer on the target host, and each disk has a different randomly generated Data Encryption Key. For ESA in hyperconverged infrastructure mode, data is encrypted at the VM host before network transmission, and all disks in the cluster use the same DEK to encrypt object data. In OSA, encryption occurs after other data processing operations such as deduplication and compression, preserving storage efficiency. vSAN encryption is the recommended approach for securing data on vSAN datastores because it is designed to be compatible with vSAN deduplication and compression, whereas virtual machine encryption causes these storage efficiency features to become less effective.

vSphere Virtual Machine Encryption provides an alternative or complementary data-at-rest encryption layer that works across all datastore types, including vSAN, iSCSI, NFS, and Fibre Channel. VM Encryption occurs before data reaches the storage layer, protecting virtual machine files and disks regardless of the underlying storage technology. This can be applied on a per-VM basis and operates independently of the underlying storage layer, making it applicable to environments where granular, VM-level encryption control is required. Most virtual machine files, in particular guest data not stored in the VMDK file, are encrypted. When combined with storage-level encryption, administrators should evaluate the performance impact of multiple encryption layers on latency and throughput, as well as the potential loss of storage efficiency features like deduplication and compression.

For organizations consuming VCF through the VCF Automation layer, VCF Encryption Management extends these VM and disk encryption capabilities to the namespace level. This service allows organization administrators to use encryption keys from their own third-party key providers to encrypt VMs and disks within a VCF Automation namespace, and also supports encrypting VMs with a Virtual Trusted Platform Module (vTPM). Provider administrators must register a default standard key provider in VMware vCenter before organization administrators can configure namespace-level encryption; the vSphere Native Key Provider cannot be used in this role, and key providers must be listed in the VMware Compatibility Guide for Key Management Servers. Organization administrators configure encryption by setting up a key provider and creating a namespace encryption class. Configuration of key providers requires either the Encryption Management Admin role or a custom role that grants the right to configure key providers.

Both encryption mechanisms require a key management infrastructure. VCF supports integration with KMIP 1.1-compatible external Key Management Servers (KMS) or the built-in vSphere Native Key Provider (NKP). VCF establishes a cryptographic domain of trust between key providers, VMware vCenter, and VMware ESX hosts. When using a Standard Key Provider, the KMS sends keys to vCenter upon request, which are used as the Key Encryption Key (KEK) and are AES-256 keys. Standard Key Providers support key wrapping, creating a three-tier key hierarchy: Data Encryption Keys (DEK) encrypt object data, Key Encryption Keys (KEK) protect the DEK, and a wrapping key stored in the KMS protects the KEK. This approach reduces the number of keys stored in external KMS systems while maintaining cryptographic separation. When using an external KMS, the recommendation is to deploy highly available KMS clusters to distribute the keys that encrypt the vSAN datastore, avoiding a single point of failure in the encryption key chain. The vSphere Native Key Provider offers a simpler deployment model for

environments that do not require an external KMS. Native Key Provider equips each participating host with decryption keys so hosts can operate independently of network-accessible key servers.

vSAN supports key rotation for both Key Encryption Keys (KEK) and Data Encryption Keys (DEK), with the capability to re-encrypt all data on the storage using new keys. vSAN encryption supports configurable rekey intervals that can be set to default or custom values. Key wrapping supports automatic key rotation with configurable intervals. This allows organizations to meet key lifecycle management requirements without disrupting operations. Encryption can also be enforced through vSAN storage policies, where the data-at-rest encryption option can be specified as a policy attribute, allowing administrators to define which datastores require encryption when provisioning virtual machines.

VCF supports virtual Trusted Platform Module (vTPM) 2.0 for virtual machines, enabling in-guest encryption capabilities such as Windows BitLocker and Linux disk encryption. Virtual machines can include various forms of encryption: VMs using a vTPM device, VMs with disks encrypted, and VMs with encryption enabled without disks encrypted. These guest-level encryption features work independently of or in combination with VMware's infrastructure-level encryption, supporting defense-in-depth strategies.

ESX hosts store their configuration data in encrypted form. When the host has a physical TPM 2.0 enabled, the configuration encryption key is stored in the TPM. Core dumps on an ESX host that has encryption mode enabled are always encrypted. ESX also supports key persistence as a cache for encryption keys in environments where a KMS may be unavailable. With key persistence enabled, ESX hosts can persist the encryption keys in the Trusted Platform Module (TPM) across reboots, allowing encryption operations to continue when the key server is unavailable. Each ESX host obtains the encryption keys initially and retains them in its key cache; if the ESX host has a TPM, the encryption keys are persisted in the TPM across reboots. Key persistence requires that the ESX host has a TPM, and can be enabled using the `esxcli system security keypersistence enable` command.

Memory Tiering encryption protects tiered memory without requiring external key management. VCF generates random 256-bit AES-XTS keys at the kernel level during VM power-on, unique to each VM instance. During vMotion, tiered memory pages are decrypted and transmitted over the encrypted vMotion channel, with new keys generated at the destination.

For access control over cryptographic operations, VCF provides the No Cryptography Administrator role, which supports all Administrator privileges except for the Cryptographic Operations privileges. This allows standard VM and infrastructure management while restricting unauthorized encryption changes. The No Cryptography Administrator role can be cloned to create custom roles with only specific Cryptographic Operations privileges, providing fine-grained control over encryption-related tasks.

The cryptographic modules used across VCF components are validated against industry-standard best practices. NSX is configured to use FIPS 140-3 validated cryptographic modules by default, with validation performed through the NIST Cryptographic Module Validation Program (CMVP). VCF Automation uses the BouncyCastle FIPS 2.0.0 cryptographic module compliant with FIPS 140-3 (Certificate #4743). VCF Operations for Networks uses BC-FJA (Bouncy Castle FIPS Java API) version 2.0.0 as a validated cryptographic module. The vCenter appliance uses VMware's Boring Crypto Module version 6.0, which provides FIPS-validated cryptographic algorithms including AES, ECDSA, HMAC, RSA, and SHA2 variants, as well as VMware OpenSSL FIPS Object Module versions 3.0 and 2.0.20-vmw, which collectively support AES, CKG, DRBG, DSA, ECDSA, HMAC, KAS-SSC, RSA, SHS, Triple-DES, SHA-3, and additional key derivation functions. ESX hosts use FIPS 140-2 validated cryptographic modules that implement security functions as a combination of hardware, software, and firmware. vSAN encryption uses AES-NI CPU offloading for efficient processing.

For workloads deployed through VMware Kubernetes Service (VKS) on vSphere Supervisor, the Kubernetes control plane supports encryption at rest for API objects stored in etcd. The kube-apiserver implements this through the EncryptionConfiguration API, specified via the `--encryption-provider-config` argument. When configured, Secrets, ConfigMaps, and other designated resource types are encrypted on write to etcd. The kube-apiserver supports an external KMS provider as well as local encryption keys; when using local keys, the aescbc provider encrypts data using Base64-encoded secret keys specified in the EncryptionConfiguration resource. Using an external KMS is the recommended approach for production environments, as it allows keys to be managed and rotated independently of the cluster configuration.

Encryption at rest for the Kubernetes control plane is not enabled by default; the default identity provider stores data in plaintext, and administrators must explicitly configure EncryptionConfiguration to activate it. After enabling EncryptionConfiguration, existing objects remain unencrypted until they are read and re-written. The Kubernetes etcd encryption mechanism does not extend to data stored in filesystems mounted into containers; for container workload data on persistent volumes, encryption depends on the underlying storage layer. vSAN File Service volumes used with vSphere Supervisor are mounted without encryption by default, so workloads relying on shared file volumes must address encryption at the storage layer or within the application. Kubernetes Secrets encrypted at rest are also protected from disclosure if an attacker gains access to etcd backup data.

Classifying which data requires encryption, selecting between vSAN encryption, VM encryption, or both for specific workload categories, choosing the Key Provider model, and operating the key lifecycle (rotation, revocation, archive, destruction) are organizational data-policy decisions.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) preserves and integrates with the data-at-rest encryption capabilities of the underlying VCF platform, so that encrypted virtual machines remain protected through replication and recovery operations. The encryption mechanisms themselves, including VM Encryption, vSphere Native Key Provider, external key management servers, and storage policies, are VCF platform capabilities; PNR's role is to maintain encryption continuity through the disaster recovery lifecycle.

vSphere Replication within PNR supports replication of encrypted virtual machines when vSphere Native Key Provider (NKP) or a common external Key Management Server (KMS) is configured at both sites. When NKP is used, it must be configured manually on both the local and remote sites, and the NKP ID assigned to the encrypted VM on the local site must match the NKP ID on the remote site. NKP enables encryption without requiring a separately deployed external KMS; vSphere Enterprise+ licensing is required for NKP. Replica disks must be located on datastores accessible through at least one host in a VMware vCenter cluster. A VM Storage Policy with VM Encryption enabled must be applied to target disks to enforce encryption continuity during replication configuration. Replication configuration using seed disks together with a vSAN target datastore and a VM Encryption Policy storage policy is not a supported combination.

Not all PNR replication methods support encrypted virtual machines. vSAN Snapshots and Replication, an alternative replication method within PNR, does not support replication of encrypted VMs. Organizations that require encrypted VM replication should configure protection groups using vSphere Replication rather than vSAN Snapshots and Replication.

vSphere Replication also supports optional network encryption of replication traffic, which can be enabled during replication configuration to protect data in transit between source and target sites.

Not applicable for this control: VMware vDefend, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control B3.d

Mobile Data: You have protected data important to the operation of network and information systems supporting your essential function(s) on mobile devices (e.g. smartphones, tablets and laptops).

SCF Controls: END-01, MDM-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control B3.e

Media / Equipment Sanitisation: Before reuse and / or disposal you appropriately sanitise devices, equipment and removable media holding data important to the operation of network and information systems supporting your essential function(s).

SCF Controls: DCH-09

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several technical capabilities that support media sanitization workflows for virtualized infrastructure, though the full control requires organizational procedures for physical media handling, verification, and documentation.

Encryption-based cryptographic erasure

VCF supports encryption of virtual machine disk (VMDK) files, where data in an encrypted VMDK is never written in cleartext to storage or transmitted in cleartext over the network. For storage environments using vSAN data-at-rest encryption or VM Encryption, cryptographic erasure is available as a sanitization method: destroying the encryption keys associated with the storage renders the encrypted data unrecoverable without requiring block-level overwriting. This approach is recognized by industry-standard best practices as an acceptable sanitization technique for encrypted media. Administrators configure VM encryption through VMware vCenter and the key management infrastructure, which supports both KMIP-compatible external Key Management Servers and vSphere Native Key Provider.

The vSphere Web Services API provides `removeKey` and `removeKeys` methods for programmatic removal of cryptographic keys by ID, each with an optional `force` parameter. The `force` option is intended for cases where a key has been compromised or expired, removing it from use across the environment. These API methods support automated key destruction workflows as part of a cryptographic erasure process. On VMware ESX hosts, calling `removeKey` without the `force` option deletes the key from the host's key cache and renders any encrypted virtual machine using that key unusable, because ESX hosts do not track which keys are in use.

The No Cryptography Administrator role separates cryptographic privileges from routine administrative operations. This role includes all Administrator privileges except Cryptographic Operations, and it can be cloned to create custom roles with only specific cryptographic privileges. This separation helps restrict who can modify encryption settings or remove keys during media lifecycle activities.

vSAN disk sanitization features

vSAN includes a disk wipe capability for securely wiping storage devices. Before wiping ineligible disks, administrators must check the partition table and verify the data stored on those disks. When encryption is enabled on an existing vSAN cluster, the "Erase disks before use" option wipes existing data from storage devices as they are brought into encrypted disk groups. Devices added to a vSAN disk group that contain residual data or partition information must be cleaned before they can be claimed, providing a built-in sanitization step during device onboarding. vSAN also supports re-encrypting all data using new keys through a rolling disk reformat, which generates a new Key Encryption Key and new Data Encryption Keys.

ESX host configuration protection

ESX stores its configuration data in encrypted form on boot devices. When a Trusted Platform Module (TPM) 2.0 is available, encryption keys can be persisted in the TPM across reboots using the `esxcli system settings encryption set` command with the `--mode=TPM` parameter. This means host decommissioning can include clearing the TPM to render the stored configuration unrecoverable.

Orphaned disk identification and reclamation

VCF Operations provides capabilities for identifying orphaned virtual disks, defined as VMDKs on datastores that are not connected to any registered virtual machines and have not been modified during a defined period. Administrators can

configure a reporting threshold that sets the minimum number of days before unattached VMDKs are flagged as orphaned. The Reclaim Resources feature allows execution of resource reclamation processes, and administrators should verify the accuracy of reported orphaned disks before performing reclamation. A Reclaimable Orphaned Disks metric displays potential savings from removing orphaned VMDKs across all datastores. Identifying and removing orphaned disks that may contain residual sensitive data is a relevant step in the media sanitization lifecycle.

Datastore removal and virtual disk controls

When a VMFS datastore is destroyed via the RemoveDatastore API, the partitions that compose the VMFS volume are removed and the datastore becomes unavailable to all ESX systems after a rescan. Datastore resignaturing is irreversible because it overwrites the original VMFS UUID. These operations provide mechanisms for decommissioning storage volumes as part of a media reuse or disposal workflow. The delete operation for a VMFS datastore permanently deletes all files associated with virtual machines on the datastore. Before initiating deletion, Storage DRS and Storage I/O Control should be disabled for the datastore to prevent automated storage management processes from interfering with the deletion workflow.

VCF also provides the `isolation.tools.diskWiper.disable` setting, which controls whether guest operating systems can issue virtual disk wiper operations. In hardened environments, this setting is typically configured to restrict disk wiper access, giving administrators centralized control over disk sanitization activities rather than allowing individual virtual machines to initiate wipe operations.

Protecting sensitive data in operational files

Backup files for VCF Operations, VMware vCenter, and NSX are encrypted using AES-256-CBC encryption with SHA256 message digest. After file-based restore operations, administrators are directed to securely delete decrypted backup files and control access to them during the restore process.

Core dumps on vCenter systems are not encrypted and can contain memory contents that include credentials, encryption keys, or other sensitive data. Administrators should consider disabling core dumps on vCenter systems to restrict sensitive information from persisting in diagnostic files. Managing the lifecycle of these operational files is part of a complete media sanitization program.

VCF does not include dedicated media sanitization workflow tools, inventory tracking for media disposal, or chain-of-custody documentation capabilities. These organizational processes, along with physical media destruction procedures and verification of sanitization effectiveness, must be addressed through enterprise asset management and data governance programs outside of VCF.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control B4

Principle B4 System Security: Network and information systems and technology critical for the operation of essential functions are protected from cyber attack. An organisational understanding of risk to essential functions informs the use of robust and reliable protective security measures to effectively limit opportunities for threat actors to compromise networks and systems.

SCF Controls: CFG-01, CFG-02

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides secure baseline configurations for all major platform components, consistent with industry-accepted hardening standards. The VCF Security Baseline is a purpose-built document that builds on VCF security fundamentals to address frequently requested compliance standards, regulations, and frameworks. It is designed and validated to tailor security configurations without affecting VCF's ability to meet its design objectives. Organizations can use the VCF Security Baseline to evaluate both default and non-default configurations and to secure their environments in a compliance context.

VCF Operations includes a consolidated out-of-the-box benchmark called the VCF 9 Security Baseline, which provides a ready-to-use compliance profile for evaluating the security posture of a VCF environment. This benchmark enables automated assessment of configurations against the documented baseline, helping maintain a consistent configuration across VCF components. ISO Security Standards compliance benchmarks are also available from the VCF Operations repository as a native pack, giving organizations the ability to measure their environment against internationally recognized hardening standards. Broadcom also provides DISA Security Technical Implementation Guides (STIGs) for VCF components, including vSphere 7.0 and vSphere 8.0 STIGs, which provide detailed instructions for securing and configuring systems to meet specific security requirements.

Individual VCF components have their own security configuration guides that document hardening recommendations. The vSphere Security Configuration Guide provides best practices for securing VMware vCenter, including securing the installation, configuring access and authentication, defining roles and permissions, and enabling auditing and logging. VMware ESX host hardening covers authentication and authorization settings, disabling unnecessary services, enabling security features such as Secure Boot and Trusted Platform Module (TPM), and implementing network security measures. The vSphere Security Configuration Guide documents specific STIG-aligned values for the Security.PasswordQualityControlPwquality setting on ESX hosts, including parameters such as minlen=15, maxrepeat=3, maxclassrepeat=4, difok=4, and enforce_for_root. The NSX Security Configuration Guide provides recommendations for securing NSX components, including NSX nodes, NSX Controllers, and NSX Edge nodes, by configuring strong authentication, implementing role-based access control, and securing administrative access.

VCF Operations also provides a Configure Host Security Config Data workflow that allows selective enforcement of host security hardening rules. Beyond security settings, vSphere Lifecycle Manager maintains a desired-state cluster image that defines the ESX base build, vendor add-ons, and firmware for every host in a cluster, so the software baseline stays consistent across hosts, and VCF Operations runs scheduled drift detection that flags configuration deviations from the desired state for remediation. Administrators can configure individual configuration elements under Enforce Options, enabling granular control over which baseline settings are applied and enforced across the environment. This supports reducing organizational and business risk by maintaining configuration consistency. vSphere Host Profiles provide an additional mechanism for automated and centrally managed host configuration baseline enforcement, capturing a reference host's configuration and applying it consistently across ESX hosts, covering memory, storage, networking, and other configuration aspects.

For containerized workloads, VMware Kubernetes Service (VKS) includes preconfigured security policy templates. The Baseline security template provides a set of constraints that restrict known privilege escalations while maintaining compatibility with common containerized workloads.

DISA STIGs for Supervisor and VKrs are available to guide hardening of the Supervisor control plane and individual VKS cluster releases, providing baseline security guidance at the same standard as the DISA STIGs applied to VCF infrastructure components. The VKS cluster management interface provides out-of-the-box security policy templates that mirror industry-standard Pod Security Standards profiles, including both Baseline and Restricted configurations. Custom VKS Cluster Management Security Policy templates are also available to fine-tune individual security context parameters and support governance controls tailored to specific organizational requirements.

Pod Security Admission (PSA), enabled in VKr 1.25 and later, enforces pod security standards at the namespace level. Three policy profiles are defined: Privileged (unrestricted, for system-level workloads), Baseline (helps prevent known privilege escalations while allowing the default minimally specified pod configuration), and Restricted (heavily restricted, following pod hardening best practices). Three enforcement modes are available: enforce, warn, and audit. The `podSecurityStandard` field in the ClusterClass API encodes the intended security posture in cluster definitions, accepting these modes with specific policy versions and namespace exemptions so that baseline security configurations are applied consistently across VKS deployments. System namespaces including `kube-system`, `tkg-system`, and `vmware-system-cloudprovider` are excluded from pod security enforcement. The PSA admission controller can also be statically configured with default enforce, audit, and warn levels for unlabeled namespaces, so namespaces created without explicit labels still receive a defined security baseline. To support gradual policy adoption, audit and warn modes can be set to a stricter level such as restricted while enforce remains at baseline, giving administrators visibility into policy violations before full enforcement is applied. VCF Automation IaaS Resource Policies provide an additional enforcement point at the management layer, supporting requirements that Kubernetes clusters operate at a minimum baseline pod security level.

Kubernetes-native kernel security mechanisms provide workload-level baseline hardening options. `seccomp` restricts the Linux kernel system call surface available inside containers using BPF-based profiles, and the `RuntimeDefault` `seccomp` profile provides a strong set of security defaults while preserving workload functionality. `AppArmor` and `SELinux` provide further kernel-level restrictions through default configurations that offer foundational protections. Kubernetes default RBAC role bindings should be reviewed as part of establishing a security baseline, as defaults may grant broader access than a hardened configuration requires. Isolating each workload in its own Kubernetes namespace allows tailored security policies to be applied per workload and restricts access to namespace-scoped resources such as `ConfigMaps` and `Secrets`.

Harbor Registry, available as a standard package for VKS clusters, supports a controlled baseline for container artifacts entering the environment. Harbor provides vulnerability scanning, content trust, and policy-based replication, along with role-based access control and artifact security policies, supporting controlled management of the container image supply chain. For stand-alone virtual machines deployed in vSphere Supervisor environments, Content Libraries can distribute VM images created with current patches and required security settings that follow corporate security policies.

VMware Private AI Services (PAIS) provides PAIS-specific declarative configuration mechanisms that organizations can use to define and apply baseline settings across the AI infrastructure stack on VCF.

The primary mechanism is the `PAISConfiguration` custom resource. Private AI Services settings are declared in a YAML file compliant with the `PAISConfiguration` schema and applied with `kubectl`, giving administrators a single resource that captures observability, identity, and trust configuration for an organization namespace. Observability includes the `spec.observability.prometheusRuntime` section for Prometheus metrics collection with a configurable storage class and metrics retention period, and an `llmTraces` section for routing large language model traces to an OpenTelemetry Collector. The `PAISConfiguration` custom resource can be patched with `kubectl patch` and verified with `kubectl get paisconfiguration`, supporting baseline change control and drift detection at the AI service layer.

Certificate trust is handled through the `spec.clientTls.caBundleRefs` section, which references `ConfigMaps` containing CA trust bundles. Private AI Services requires HTTPS trust bundles for the OIDC provider, the Harbor registry, content management systems hosting knowledge database data, and MCP servers that provide tools to models. Trust bundles can be organized per application, with periodic updates required before certificate expiration. Access scope is restricted through the `authorizedGroups` setting, which limits Private AI Services access to specified OIDC groups.

Harbor registry distribution carries baseline controls for model and image artifacts. Replication rules support configurable filters, target namespace, and trigger mode, including a manual trigger mode, so administrators can align artifact replication with organizational policy for connected and disconnected sites. The Model Gallery uses Harbor project access capabilities to restrict access to sensitive training and tuning data. Air-gapped deployments capture the self-hosted registry URL and registry login credentials as part of the activation flow.

Workload resource baselines are defined through `SupervisorNamespaceClassConfig`, which specifies per-zone CPU limits, CPU reservations, memory limits, and memory reservations for resource allocation across zones. GPU-capable VM classes can carry GPU reservations and be confined to a single zone or supervisor namespace, supporting isolation of GPU consumption to a specific tenant. A default storage policy selection in the Private AI Services quickstart defines storage placement and resources for the service database.

Deep Learning VM (DL VM) baselines are captured through VCF Automation self-service catalog items that parameterize VM class, data disk size, user password, and optional SSH public key authentication for remote access. The DL VM OVF property config-json accepts a base64-encoded configuration file that controls DCGM Exporter metrics visibility through `export_dcgm_to_public` and JupyterLab authentication through `enable_jupyter_auth`, giving operators a consistent surface to define DL VM hardening parameters.

Credentials supplied during Private AI Services activation, including the private container registry password and proxy password, are stored as secrets in VCF Automation rather than as plaintext configuration values, supporting credential hygiene as part of the deployment baseline.

VMware vDefend (Contributes)

VMware vDefend contributes to secure baseline configurations within its network security domain by providing structured configuration management capabilities, predefined security profiles and strategies, and configuration integrity controls that align with industry-accepted hardening practices.

vDefend supports draft configuration management with configuration locking to prevent multiple users from simultaneously opening and editing a manual draft, helping maintain configuration integrity and reducing the risk of conflicting changes to firewall policy. Role-Based Access Control (RBAC) in vDefend governs who can create or modify firewall policies, providing control over which administrators can alter the security baseline.

In vDefend, five system-defined VPC Security Strategies are available for establishing security baselines across Virtual Private Clouds (VPCs): VPC Isolation, VPC Isolation with Essential Services, VPC External Connectivity, VPC Secure Connection, and NONE. These strategies are consumed through Security Profiles in VCF Automation, which are predefined configuration templates that define the default security posture for VPCs. VPC Security Strategies provide a declarative, consistent way to apply DFW security baselines across multiple VPCs within a project, and Project Admins are guided to select a pre-defined high-level security posture that enforces Secure by Default principles rather than manually configuring individual firewall rules. Security profiles can be applied to one or more VPCs simultaneously and updated as requirements evolve.

vDefend provides predefined TLS Decryption Action Profiles with four settings: Balanced (default), High Fidelity, High Security, and Custom. These profiles are vendor-defined baseline configurations for TLS inspection behavior, giving organizations a documented starting point aligned with different security postures. TLS Inspection policies also support an Advanced Configuration option to lock policies, preventing multiple users from making concurrent changes to TLS inspection policy baseline settings.

Security Services Platform validates configuration changes before implementation through a deployment wizard that conducts thorough validations to confirm configurations are correct and compatible. The platform enforces initial security policies that cannot be modified through the user interface after they have been published, providing an immutability mechanism for foundational policy baseline elements. Security Services Platform supports backup and restore of configuration data, and certificate consistency between backup and restored environments should be verified to maintain NDR sensor integrity.

Security Services Platform's Bare Metal Security feature extends vDefend policy enforcement to physical servers, applying L3/4 security policies to bare metal infrastructure using the same policy model and management plane as virtualized

workloads. Two default DFW rules are created when Bare Metal servers are onboarded to Security Services Platform, providing an immediate baseline posture for physical infrastructure. Security policies are defined, propagated, and enforced across Bare Metal servers with consistent application and monitoring.

vDefend's configuration management capabilities operate within the network security layer. The broader secure baseline configuration program for VCF, including the VCF Security Baseline document, component hardening guides, DISA STIGs, and compliance scanning through VCF Operations, is managed at the platform level. vDefend contributes by maintaining its own secure defaults and configuration controls within the network security domain.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides configurable security baseline mechanisms for its replication and recovery infrastructure. The PNR appliance includes a security reference section that identifies configuration files containing settings that affect environment security, and PNR documentation establishes that secure operation depends on proper configuration and maintenance of the PNR server. The security reference also documents network port requirements, providing the technical specifications needed to develop and maintain secure baseline configurations for disaster recovery infrastructure.

PNR includes a Configuration Import/Export Tool that captures the complete set of protection and recovery configuration settings, including server version, build number, local and remote site names, inventory mappings, placeholder datastores, advanced settings, and array managers. The tool supports both UI-based and scripted exports and can transfer configuration data without requiring credential entry when using the bundled generated script. This gives organizations a mechanism to document, back up, and restore known-good baseline configurations for their disaster recovery infrastructure. The underlying system configuration is stored in the va-configurator.xml file and is accessible through Advanced Settings on the Site Pair tab in the management interface, providing a defined location for baseline review and modification.

The PNR appliance management interface allows administrators to configure appliance security settings after deployment. The Advanced Settings system provides privileged users with the ability to adjust default values governing protection and recovery features. When modifying the minimum protocol version for TLS, PNR requires that the change be applied consistently across all configuration occurrences in the system, supporting systematic baseline management for transport security settings.

For cyber recovery deployments, PNR documentation recommends using standard VCF topology with separate workload and management domains to achieve better isolation and align with security best practices at the recovery site.

Full compliance with this control requires an organizational baseline configuration management program, documentation practices, version control, and hardening tooling extending beyond what PNR provides directly.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to secure baseline configuration management through its infrastructure policy framework, data service policy enforcement, and built-in secure defaults for authentication and certificate management.

Infrastructure policies in DSM define the compute, storage, and networking resources for each database deployment, including the list of allowed VM classes and compatible storage policies. These policies are configured by DSM administrators and act as standardized, repeatable deployment baselines that database users must follow. When administrators configure infrastructure policies, they constrain the quality and quantity of resources that users can consume from vSphere clusters, establishing guardrails that support consistent deployments across the environment. Database cluster creation applies both infrastructure policies and storage policies that enforce isolation and resource constraints, reducing the risk of misconfiguration by individual users.

Data service policies extend this baseline enforcement across multi-tenant deployments. DSM administrators can define and configure data service policies for various database services and enforce them across different tenants to maintain a consistent security and compliance posture. Data service policies constrain which infrastructure options can be applied to database instances. When DSM is integrated with VCF Automation, data service policies can be applied consistently across organizational units.

DSM also ships with predefined secure defaults for database authentication. PostgreSQL databases on DSM use scram-sha-256 as the default password-based authentication method, as configured in the default `pg_hba.conf` entries stored at `/pgsql/data/pg_hba.conf`. Custom `pg_hba.conf` entries support scram-sha-256, reject, and cert authentication methods. TLS is enforced by default for database client connections, with an administrator-controlled option to relax enforcement via the `postgrescluster-allow-non-ssl-system-users` setting in the advanced-system-config ConfigMap within the `dsm-system` namespace.

Certificate management is integrated into the database creation workflow and validates certificate chains for connections to external systems, including VMware vCenter. DSM introduces a stricter default certificate validation mode, the "latest" mode, that enforces cryptographic and KeyUsage validations for all DSM endpoints, including the Provider VM and data service clusters. Certificates uploaded to DSM are validated against FIPS 140-3 cryptographic standards, and uploads containing unsupported algorithms or parameters are rejected. Custom trusted root certificates must comply with FIPS requirements. DSM also verifies the SHA256 thumbprint of vCenter during initial configuration to confirm the management connection targets the expected endpoint. Custom certificate support allows organizations to replace the default DSM certificate with organization-issued certificates for both the Provider VM and database clusters. For self-service deployments using the DSM Consumption Operator, signature verification confirms package integrity before installation.

DSM validates certificate chains using configured root CA certificates stored in ConfigMaps and supports private container registry configuration with CA certificate validation for air-gapped environments.

Addressing this control fully requires organizational processes beyond what DSM provides directly. DSM does not include tooling to document baseline configurations in a compliance-ready format, map configurations to specific industry hardening standards, or audit deviations from defined baselines over time. Organizations should supplement DSM's policy and defaults framework with configuration management documentation, change tracking processes, and integration with compliance scanning tools to satisfy the full requirements of this control.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several built-in mechanisms that support the development and application of secure baseline configurations for the application delivery layer.

The SSL/TLS Profile system gives administrators a documented starting point for cryptographic configuration. Profile Templates define accepted SSL and TLS versions and ciphers in prioritized order, and can be associated with virtual services or the Controller itself. The Standard SSL/TLS Profile is suitable for typical deployments, while the System-Standard profile provides modern cipher suites for backend server re-encryption in Kubernetes environments managed through the Avi Kubernetes Operator (AKO). Avi includes a curated list of cipher suites considered reasonably strong for SSL/TLS configuration, and the documentation notes the trade-offs between security, compatibility, and computational expense when selecting profiles. The Service Engine disables unsafe legacy renegotiation by default, providing a built-in protocol hardening baseline that reduces the risk of protocol downgrade attacks.

The System-Secure-HTTP application profile is a pre-configured baseline for securing HTTP virtual services. It enforces HTTPS, protects cookies, manages client IP handling, and controls protocol behavior, giving administrators a hardened starting point for web application delivery. Administrators can supplement these defaults with more granular settings through policies or DataScripts.

For deployments requiring validated cryptographic modules, Avi Load Balancer implements FIPS 140-3 compliance, providing a cryptographic baseline aligned with the U.S. and Canadian government standard for cryptographic modules.

The Avi Web Application Firewall (WAF) Positive Security model supports application-layer baseline configuration through rules that define allowed application behavior. Each rule supports Enable/Disable control, mode selection between Detection and Enforcement, and configurable Paranoia levels, allowing organizations to tune an application security baseline to their risk posture. The Positive Security Rule Updates feature can be enabled to activate additional configuration options for application security policies. The Cloud Console Application Rules service extends this with rules specifically designed to address known application vulnerabilities, including those with CVEs, and updates them automatically.

For Kubernetes deployments, AKO uses Custom Resource Definitions (CRDs) to enable syntactical validation of configuration objects at creation time, which helps prevent invalid configurations from being deployed. The AKO L4 CRD Rule supports SSL profiles and PKI profiles for securing pool connections, allowing Kubernetes-native expression of Avi's cryptographic baseline settings.

Certificate lifecycle management supports maintaining cryptographic baselines over time. Certificate Management Profiles support automated certificate renewal workflows, and the Trust Protection Platform integration can automatically handle certificate and chain certificate renewals by learning the mapping of virtual service names to their certificates.

The organizational process of developing, documenting, and maintaining baseline configurations across all in-scope technology assets, including selecting appropriate profile settings, applying them consistently, and updating them as software versions and security guidance evolve, remains outside what Avi performs on the organization's behalf.

Control B4.a

Secure by Design: You design security into network and information systems that support the operation of your essential function(s). You minimise their attack surface and ensure that the operation of your essential function(s) should not be impacted by the exploitation of any single vulnerability.

SCF Controls: GOV-15, GOV-15.1, GOV-15.2, SEA-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control B4.b

Secure Configuration: You securely configure network and information systems that support the operation of your essential function(s).

SCF Controls: CFG-02

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides secure baseline configurations for all major platform components, consistent with industry-accepted hardening standards. The VCF Security Baseline is a purpose-built document that builds on VCF security fundamentals to address frequently requested compliance standards, regulations, and frameworks. It is designed and validated to tailor security configurations without affecting VCF's ability to meet its design objectives. Organizations can use the VCF Security Baseline to evaluate both default and non-default configurations and to secure their environments in a compliance context.

VCF Operations includes a consolidated out-of-the-box benchmark called the VCF 9 Security Baseline, which provides a ready-to-use compliance profile for evaluating the security posture of a VCF environment. This benchmark enables automated assessment of configurations against the documented baseline, helping maintain a consistent configuration across VCF components. ISO Security Standards compliance benchmarks are also available from the VCF Operations repository as a native pack, giving organizations the ability to measure their environment against internationally recognized hardening standards. Broadcom also provides DISA Security Technical Implementation Guides (STIGs) for VCF components, including vSphere 7.0 and vSphere 8.0 STIGs, which provide detailed instructions for securing and configuring systems to meet specific security requirements.

Individual VCF components have their own security configuration guides that document hardening recommendations. The vSphere Security Configuration Guide provides best practices for securing VMware vCenter, including securing the installation, configuring access and authentication, defining roles and permissions, and enabling auditing and logging. VMware ESX host hardening covers authentication and authorization settings, disabling unnecessary services, enabling security features such as Secure Boot and Trusted Platform Module (TPM), and implementing network security measures. The vSphere Security Configuration Guide documents specific STIG-aligned values for the Security.PasswordQualityControlPwquality setting on ESX hosts, including parameters such as minlen=15, maxrepeat=3, maxclassrepeat=4, difok=4, and enforce_for_root. The NSX Security Configuration Guide provides recommendations for securing NSX components, including NSX nodes, NSX Controllers, and NSX Edge nodes, by configuring strong authentication, implementing role-based access control, and securing administrative access.

VCF Operations also provides a Configure Host Security Config Data workflow that allows selective enforcement of host security hardening rules. Beyond security settings, vSphere Lifecycle Manager maintains a desired-state cluster image that defines the ESX base build, vendor add-ons, and firmware for every host in a cluster, so the software baseline stays consistent across hosts, and VCF Operations runs scheduled drift detection that flags configuration deviations from the desired state for remediation. Administrators can configure individual configuration elements under Enforce Options, enabling granular control over which baseline settings are applied and enforced across the environment. This supports reducing organizational and business risk by maintaining configuration consistency. vSphere Host Profiles provide an additional mechanism for automated and centrally managed host configuration baseline enforcement, capturing a reference host's configuration and applying it consistently across ESX hosts, covering memory, storage, networking, and other configuration aspects.

For containerized workloads, VMware Kubernetes Service (VKS) includes preconfigured security policy templates. The Baseline security template provides a set of constraints that restrict known privilege escalations while maintaining compatibility with common containerized workloads.

DISA STIGs for Supervisor and VKRs are available to guide hardening of the Supervisor control plane and individual VKS cluster releases, providing baseline security guidance at the same standard as the DISA STIGs applied to VCF infrastructure components. The VKS cluster management interface provides out-of-the-box security policy templates that mirror industry-standard Pod Security Standards profiles, including both Baseline and Restricted configurations. Custom VKS Cluster

Management Security Policy templates are also available to fine-tune individual security context parameters and support governance controls tailored to specific organizational requirements.

Pod Security Admission (PSA), enabled in VKr 1.25 and later, enforces pod security standards at the namespace level. Three policy profiles are defined: Privileged (unrestricted, for system-level workloads), Baseline (helps prevent known privilege escalations while allowing the default minimally specified pod configuration), and Restricted (heavily restricted, following pod hardening best practices). Three enforcement modes are available: enforce, warn, and audit. The `podSecurityStandard` field in the ClusterClass API encodes the intended security posture in cluster definitions, accepting these modes with specific policy versions and namespace exemptions so that baseline security configurations are applied consistently across VKS deployments. System namespaces including `kube-system`, `tkg-system`, and `vmware-system-cloudprovider` are excluded from pod security enforcement. The PSA admission controller can also be statically configured with default enforce, audit, and warn levels for unlabeled namespaces, so namespaces created without explicit labels still receive a defined security baseline. To support gradual policy adoption, audit and warn modes can be set to a stricter level such as restricted while enforce remains at baseline, giving administrators visibility into policy violations before full enforcement is applied. VCF Automation IaaS Resource Policies provide an additional enforcement point at the management layer, supporting requirements that Kubernetes clusters operate at a minimum baseline pod security level.

Kubernetes-native kernel security mechanisms provide workload-level baseline hardening options. `seccomp` restricts the Linux kernel system call surface available inside containers using BPF-based profiles, and the `RuntimeDefault` `seccomp` profile provides a strong set of security defaults while preserving workload functionality. AppArmor and SELinux provide further kernel-level restrictions through default configurations that offer foundational protections. Kubernetes default RBAC role bindings should be reviewed as part of establishing a security baseline, as defaults may grant broader access than a hardened configuration requires. Isolating each workload in its own Kubernetes namespace allows tailored security policies to be applied per workload and restricts access to namespace-scoped resources such as ConfigMaps and Secrets.

Harbor Registry, available as a standard package for VKS clusters, supports a controlled baseline for container artifacts entering the environment. Harbor provides vulnerability scanning, content trust, and policy-based replication, along with role-based access control and artifact security policies, supporting controlled management of the container image supply chain. For stand-alone virtual machines deployed in vSphere Supervisor environments, Content Libraries can distribute VM images created with current patches and required security settings that follow corporate security policies.

VMware Private AI Services (PAIS) provides PAIS-specific declarative configuration mechanisms that organizations can use to define and apply baseline settings across the AI infrastructure stack on VCF.

The primary mechanism is the `PAISConfiguration` custom resource. Private AI Services settings are declared in a YAML file compliant with the `PAISConfiguration` schema and applied with `kubectl`, giving administrators a single resource that captures observability, identity, and trust configuration for an organization namespace. Observability includes the `spec.observability.prometheusRuntime` section for Prometheus metrics collection with a configurable storage class and metrics retention period, and an `llmTraces` section for routing large language model traces to an OpenTelemetry Collector. The `PAISConfiguration` custom resource can be patched with `kubectl patch` and verified with `kubectl get paisconfiguration`, supporting baseline change control and drift detection at the AI service layer.

Certificate trust is handled through the `spec.clientTls.caBundleRefs` section, which references ConfigMaps containing CA trust bundles. Private AI Services requires HTTPS trust bundles for the OIDC provider, the Harbor registry, content management systems hosting knowledge database data, and MCP servers that provide tools to models. Trust bundles can be organized per application, with periodic updates required before certificate expiration. Access scope is restricted through the `authorizedGroups` setting, which limits Private AI Services access to specified OIDC groups.

Harbor registry distribution carries baseline controls for model and image artifacts. Replication rules support configurable filters, target namespace, and trigger mode, including a manual trigger mode, so administrators can align artifact replication with organizational policy for connected and disconnected sites. The Model Gallery uses Harbor project access capabilities to restrict access to sensitive training and tuning data. Air-gapped deployments capture the self-hosted registry URL and registry login credentials as part of the activation flow.

Workload resource baselines are defined through `SupervisorNamespaceClassConfig`, which specifies per-zone CPU limits, CPU reservations, memory limits, and memory reservations for resource allocation across zones. GPU-capable VM classes can carry GPU reservations and be confined to a single zone or supervisor namespace, supporting isolation of GPU consumption to a specific tenant. A default storage policy selection in the Private AI Services quickstart defines storage placement and resources for the service database.

Deep Learning VM (DL VM) baselines are captured through VCF Automation self-service catalog items that parameterize VM class, data disk size, user password, and optional SSH public key authentication for remote access. The DL VM OVF property `config-json` accepts a base64-encoded configuration file that controls DCGM Exporter metrics visibility through `export_dcgml_to_public` and JupyterLab authentication through `enable_jupyter_auth`, giving operators a consistent surface to define DL VM hardening parameters.

Credentials supplied during Private AI Services activation, including the private container registry password and proxy password, are stored as secrets in VCF Automation rather than as plaintext configuration values, supporting credential hygiene as part of the deployment baseline.

VMware vDefend (Contributes)

VMware vDefend contributes to secure baseline configurations within its network security domain by providing structured configuration management capabilities, predefined security profiles and strategies, and configuration integrity controls that align with industry-accepted hardening practices.

vDefend supports draft configuration management with configuration locking to prevent multiple users from simultaneously opening and editing a manual draft, helping maintain configuration integrity and reducing the risk of conflicting changes to firewall policy. Role-Based Access Control (RBAC) in vDefend governs who can create or modify firewall policies, providing control over which administrators can alter the security baseline.

In vDefend, five system-defined VPC Security Strategies are available for establishing security baselines across Virtual Private Clouds (VPCs): VPC Isolation, VPC Isolation with Essential Services, VPC External Connectivity, VPC Secure Connection, and NONE. These strategies are consumed through Security Profiles in VCF Automation, which are predefined configuration templates that define the default security posture for VPCs. VPC Security Strategies provide a declarative, consistent way to apply DFW security baselines across multiple VPCs within a project, and Project Admins are guided to select a pre-defined high-level security posture that enforces Secure by Default principles rather than manually configuring individual firewall rules. Security profiles can be applied to one or more VPCs simultaneously and updated as requirements evolve.

vDefend provides predefined TLS Decryption Action Profiles with four settings: Balanced (default), High Fidelity, High Security, and Custom. These profiles are vendor-defined baseline configurations for TLS inspection behavior, giving organizations a documented starting point aligned with different security postures. TLS Inspection policies also support an Advanced Configuration option to lock policies, preventing multiple users from making concurrent changes to TLS inspection policy baseline settings.

Security Services Platform validates configuration changes before implementation through a deployment wizard that conducts thorough validations to confirm configurations are correct and compatible. The platform enforces initial security policies that cannot be modified through the user interface after they have been published, providing an immutability mechanism for foundational policy baseline elements. Security Services Platform supports backup and restore of configuration data, and certificate consistency between backup and restored environments should be verified to maintain NDR sensor integrity.

Security Services Platform's Bare Metal Security feature extends vDefend policy enforcement to physical servers, applying L3/4 security policies to bare metal infrastructure using the same policy model and management plane as virtualized workloads. Two default DFW rules are created when Bare Metal servers are onboarded to Security Services Platform, providing an immediate baseline posture for physical infrastructure. Security policies are defined, propagated, and enforced across Bare Metal servers with consistent application and monitoring.

vDefend's configuration management capabilities operate within the network security layer. The broader secure baseline configuration program for VCF, including the VCF Security Baseline document, component hardening guides, DISA STIGs,

and compliance scanning through VCF Operations, is managed at the platform level. vDefend contributes by maintaining its own secure defaults and configuration controls within the network security domain.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides configurable security baseline mechanisms for its replication and recovery infrastructure. The PNR appliance includes a security reference section that identifies configuration files containing settings that affect environment security, and PNR documentation establishes that secure operation depends on proper configuration and maintenance of the PNR server. The security reference also documents network port requirements, providing the technical specifications needed to develop and maintain secure baseline configurations for disaster recovery infrastructure.

PNR includes a Configuration Import/Export Tool that captures the complete set of protection and recovery configuration settings, including server version, build number, local and remote site names, inventory mappings, placeholder datastores, advanced settings, and array managers. The tool supports both UI-based and scripted exports and can transfer configuration data without requiring credential entry when using the bundled generated script. This gives organizations a mechanism to document, back up, and restore known-good baseline configurations for their disaster recovery infrastructure. The underlying system configuration is stored in the `va-configurator.xml` file and is accessible through Advanced Settings on the Site Pair tab in the management interface, providing a defined location for baseline review and modification.

The PNR appliance management interface allows administrators to configure appliance security settings after deployment. The Advanced Settings system provides privileged users with the ability to adjust default values governing protection and recovery features. When modifying the minimum protocol version for TLS, PNR requires that the change be applied consistently across all configuration occurrences in the system, supporting systematic baseline management for transport security settings.

For cyber recovery deployments, PNR documentation recommends using standard VCF topology with separate workload and management domains to achieve better isolation and align with security best practices at the recovery site.

Full compliance with this control requires an organizational baseline configuration management program, documentation practices, version control, and hardening tooling extending beyond what PNR provides directly.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to secure baseline configuration management through its infrastructure policy framework, data service policy enforcement, and built-in secure defaults for authentication and certificate management.

Infrastructure policies in DSM define the compute, storage, and networking resources for each database deployment, including the list of allowed VM classes and compatible storage policies. These policies are configured by DSM administrators and act as standardized, repeatable deployment baselines that database users must follow. When administrators configure infrastructure policies, they constrain the quality and quantity of resources that users can consume from vSphere clusters, establishing guardrails that support consistent deployments across the environment. Database cluster creation applies both infrastructure policies and storage policies that enforce isolation and resource constraints, reducing the risk of misconfiguration by individual users.

Data service policies extend this baseline enforcement across multi-tenant deployments. DSM administrators can define and configure data service policies for various database services and enforce them across different tenants to maintain a consistent security and compliance posture. Data service policies constrain which infrastructure options can be applied to database instances. When DSM is integrated with VCF Automation, data service policies can be applied consistently across organizational units.

DSM also ships with predefined secure defaults for database authentication. PostgreSQL databases on DSM use `scram-sha-256` as the default password-based authentication method, as configured in the default `pg_hba.conf` entries stored at `/pgsql/data/pg_hba.conf`. Custom `pg_hba.conf` entries support `scram-sha-256`, `reject`, and `cert` authentication methods. TLS is enforced by default for database client connections, with an administrator-controlled option to relax enforcement via the `postgrescluster-allow-non-ssl-system-users` setting in the advanced-system-config ConfigMap within the `dsm-system` namespace.

Certificate management is integrated into the database creation workflow and validates certificate chains for connections to external systems, including VMware vCenter. DSM introduces a stricter default certificate validation mode, the "latest" mode, that enforces cryptographic and KeyUsage validations for all DSM endpoints, including the Provider VM and data service clusters. Certificates uploaded to DSM are validated against FIPS 140-3 cryptographic standards, and uploads containing unsupported algorithms or parameters are rejected. Custom trusted root certificates must comply with FIPS requirements. DSM also verifies the SHA256 thumbprint of vCenter during initial configuration to confirm the management connection targets the expected endpoint. Custom certificate support allows organizations to replace the default DSM certificate with organization-issued certificates for both the Provider VM and database clusters. For self-service deployments using the DSM Consumption Operator, signature verification confirms package integrity before installation.

DSM validates certificate chains using configured root CA certificates stored in ConfigMaps and supports private container registry configuration with CA certificate validation for air-gapped environments.

Addressing this control fully requires organizational processes beyond what DSM provides directly. DSM does not include tooling to document baseline configurations in a compliance-ready format, map configurations to specific industry hardening standards, or audit deviations from defined baselines over time. Organizations should supplement DSM's policy and defaults framework with configuration management documentation, change tracking processes, and integration with compliance scanning tools to satisfy the full requirements of this control.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several built-in mechanisms that support the development and application of secure baseline configurations for the application delivery layer.

The SSL/TLS Profile system gives administrators a documented starting point for cryptographic configuration. Profile Templates define accepted SSL and TLS versions and ciphers in prioritized order, and can be associated with virtual services or the Controller itself. The Standard SSL/TLS Profile is suitable for typical deployments, while the System-Standard profile provides modern cipher suites for backend server re-encryption in Kubernetes environments managed through the Avi Kubernetes Operator (AKO). Avi includes a curated list of cipher suites considered reasonably strong for SSL/TLS configuration, and the documentation notes the trade-offs between security, compatibility, and computational expense when selecting profiles. The Service Engine disables unsafe legacy renegotiation by default, providing a built-in protocol hardening baseline that reduces the risk of protocol downgrade attacks.

The System-Secure-HTTP application profile is a pre-configured baseline for securing HTTP virtual services. It enforces HTTPS, protects cookies, manages client IP handling, and controls protocol behavior, giving administrators a hardened starting point for web application delivery. Administrators can supplement these defaults with more granular settings through policies or DataScripts.

For deployments requiring validated cryptographic modules, Avi Load Balancer implements FIPS 140-3 compliance, providing a cryptographic baseline aligned with the U.S. and Canadian government standard for cryptographic modules.

The Avi Web Application Firewall (WAF) Positive Security model supports application-layer baseline configuration through rules that define allowed application behavior. Each rule supports Enable/Disable control, mode selection between Detection and Enforcement, and configurable Paranoia levels, allowing organizations to tune an application security baseline to their risk posture. The Positive Security Rule Updates feature can be enabled to activate additional configuration options for application security policies. The Cloud Console Application Rules service extends this with rules specifically designed to address known application vulnerabilities, including those with CVEs, and updates them automatically.

For Kubernetes deployments, AKO uses Custom Resource Definitions (CRDs) to enable syntactical validation of configuration objects at creation time, which helps prevent invalid configurations from being deployed. The AKO L4 CRD Rule supports SSL profiles and PKI profiles for securing pool connections, allowing Kubernetes-native expression of Avi's cryptographic baseline settings.

Certificate lifecycle management supports maintaining cryptographic baselines over time. Certificate Management Profiles support automated certificate renewal workflows, and the Trust Protection Platform integration can automatically handle certificate and chain certificate renewals by learning the mapping of virtual service names to their certificates.

The organizational process of developing, documenting, and maintaining baseline configurations across all in-scope technology assets, including selecting appropriate profile settings, applying them consistently, and updating them as software versions and security guidance evolve, remains outside what Avi performs on the organization's behalf.

Control B4.c

Secure Management: You manage your organisation's network and information systems that support the operation of your essential function(s) to enable and maintain security.

SCF Controls: CFG-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides a layered configuration management capability spanning infrastructure state definition, drift detection, policy enforcement, and workload-level configuration automation.

VCF Operations includes a Configuration Templates feature that allows administrators to define a desired state as a set of configurations and then monitor the environment against those definitions. Configuration templates are created and managed through the Fleet Management > Configuration Drifts interface in VCF Operations, or through the Infrastructure Operations > Configurations > Policy Definition interface. VCF Operations supports managing global configuration templates across multiple vCenter instances, with the ability to assign templates to policies, activate them, and enforce them across the fleet.

The Configuration Drifts feature provides a proactive method to monitor configuration changes across vCenter instances and vSphere clusters, comparing the current vCenter value against the configuration template value for each instance. When a deviation from assigned template values occurs, a configuration drift notification alerts administrators. The Configuration Drift dashboard allows viewing and comparing drifts, and the Detect Drift function can be run across all configuration templates to display results in a consolidated drifts table. Drift detection can also be scheduled, enabling continuous detection of configuration deviations from the desired state without manual intervention.

Source control integration extends the configuration management program with version control, change tracking, and auditability. VCF Operations can synchronize configuration templates to and from a supported source control repository, enabling versioning, auditing, and controlled management of templates. This integration facilitates accurate configuration updates, supports change control with reviews, and enables continuous integration and continuous development workflows for automated testing and validation of configuration changes.

VCF Operations provides policy management capabilities through the Infrastructure Operations Configurations module, including the ability to add, edit, and remove policies. The Configure Host Security Config Data workflow allows selective enforcement of host security hardening rules by configuring enforcement options for individual configuration elements. VCF Operations also supports export of configuration content, including configuration files, policies, compliance scorecards, and global settings, enabling backup and portability of configuration baselines. The config polling interval can be adjusted to control how frequently configuration data is collected from data sources, allowing administrators to tune the monitoring cadence to their operational requirements.

vSphere Lifecycle Manager (vLCM) provides image-based lifecycle management for ESX hosts, maintaining consistency by defining and enforcing approved host images across the fleet. vLCM manages all hosts in a cluster collectively with a single image, and clusters are assigned a base image and optional vendor add-on to define the desired state. When hosts deviate from the defined image, the cluster reports a non-compliant status, and remediation installs the approved image across all hosts in the cluster. vSphere Lifecycle Manager images are created in the vSphere Client and then imported into VCF using VCF Operations.

vSphere Host Profiles provide a complementary mechanism that captures the configuration of a validated reference host, including memory, storage, networking, and advanced settings, stores it as a managed object, and enforces it against other hosts to detect and remediate configuration deviations. vSphere Configuration Profiles extend this to the cluster level through JSON configuration documents that can be downloaded, edited offline, and imported, with built-in alarm support to notify administrators of configuration drift via email or SNMP traps.

At the Kubernetes consumption layer, VMware Kubernetes Service (VKS) extends configuration management with a Kubernetes-native declarative model in which every cluster component, workload, and security policy is expressed as a YAML

manifest. Kubernetes recommends that object configuration be stored in a source control system such as Git to enable change review processes and audit trails. VKS cluster security configurations are immutable and persistent by design, moving away from manual node-level configuration. ClusterClass configuration variables expose granular control over cluster infrastructure across releases, and the VKS Add-on Management feature provides a declarative API for add-on installation and configuration across a fleet of workload clusters through AddonConfig resources. The Cluster API, which underlies VKS cluster creation and management, provides declarative, Kubernetes-style APIs for the full cluster lifecycle including creation, configuration, and ongoing management. StatefulSet controllers use ControllerRevision objects to track historical configuration changes, supporting rollback and version tracing. Kubernetes Operators extend the declarative model to custom resources by interacting with the API server to reconcile the actual state of complex stateful applications and services against a declared desired state, enabling management of domain-specific workloads beyond native Kubernetes primitives. Kubernetes ConfigMaps separate application configuration from container images by storing configuration data as key-value pairs; they can be updated at runtime to propagate changes to running pods without requiring a pod restart. The KubeletConfiguration API type, managed through kubeadm, centralizes kubelet configuration across cluster nodes.

The Argo CD Supervisor Service implements a GitOps model for the consumption layer: all infrastructure and application configurations are expressed declaratively in a Git repository, and Argo CD can automatically apply changes from the repository to the target environment. Argo CD also manages VKS cluster lifecycle, with applications defined in Git referencing cluster lifecycle management manifests that target a specific namespace and Kubernetes API server endpoint, extending configuration-as-code governance from workloads to the clusters themselves. Argo CD continuously monitors the live application state against the desired state in Git, tracks per-resource sync status and health state, and reports deviations as OutOfSync. It provides both a CLI and a web-based UI for defining applications and visualizing cluster configuration drift, paralleling the drift-detection capability at the VCF Operations layer. Kustomize, available as a Kubernetes-native configuration management tool, transforms base resource manifests through declarative patching, field customization, and resource composition, enabling environment-specific variation without modifying source manifests. VKS Cluster Management Policies use the open-source OPA Gatekeeper as the policy engine for Security, Registry, Mutation, and Custom policy types; custom Security Policy templates allow organizations to fine-tune security context parameters and governance controls to their specific requirements. Security Technical Implementation Guides (STIGs) for Supervisor and VMware Kubernetes Release (VKr) deployments are available through Tanzu STIG Hardening, providing a structured configuration baseline for organizations building a configuration management program across the full VCF stack.

VCF Automation extends configuration management to workloads through integration with Ansible Open Source, Ansible Automation Platform, and Puppet Enterprise. Ansible integration is configured through Infrastructure > Connections > Integrations > Add Integration > Ansible Tower, and allows automated configuration management of VM-based applications deployed on the platform. Puppet Enterprise integration requires establishing a connection between the external Puppet system and the VCF Automation instance and is available on all projects by default. VCF Automation policies apply to both current and new deployments, and the Provisioning Service API allows programmatic integration and centralization of configuration properties.

VMware Private AI Services (PAIS), formerly Private AI Services, provides structured, configurable mechanisms that organizations can apply as part of a configuration management program for AI infrastructure on VCF.

The PAISConfiguration Custom Resource Definition (CRD) is the central PAIS configuration artifact. Administrators define PAIS settings in a YAML file compliant with the PAISConfiguration CRD, with sections for storage policy, CA trust bundles, PostgreSQL database connection, OIDC provider integration, and ingress service type. Configuration is managed using kubectl to update or patch the PAISConfiguration custom resource. Client TLS configuration references CA bundles for OIDC provider and Harbor authentication, with trust bundles supplied through ConfigMap resources referenced in the spec.clientTls.caBundleRefs section. The documentation recommends organizing CA trust bundles per application and monitoring them for certificate expiration so renewals are applied before associated certificates expire. When a CA certificate is selected and added from the namespace, PAIS is updated with a new ConfigMap resource.

Harbor Registry integration provides configuration control points for AI model distribution and lifecycle management. PAIS deployment uses Harbor replication rules with configurable filters, target namespaces, and trigger mode controls, including

manual trigger mode for explicit replication runs. Disconnected (air-gapped) environments use a Bastion and Admin host pattern for PAIS setup, with replication configured to a destination registry aligned to organizational requirements.

The VCF Automation Provider Management surface manages region configuration and quotas for PAIS deployments. Provider administrators configure regions by selecting an NSX Manager instance integrated with the vCenter instances for the region, then assign region quota based on the zones selected for one or more supervisors. Regions are associated with supervisor clusters for PAIS deployment. VCF Automation aggregates zones with the same name across multiple supervisors in a region, combining their CPU, memory, and reserved VM class resources and presenting them as a single unit at the region level.

VCF Automation provides catalog items for provisioning AI workloads, including Deep Learning VMs and GPU-accelerated VMware Kubernetes Service (VKS) clusters, through a self-service catalog organizations configure to their deployment standards. The PAIS Quickstart generates blueprints that can be customized for deployment on VCF Automation. Passwords entered in the PAIS Quickstart, including the private container registry password and proxy password, are saved as secrets in VCF Automation rather than embedded in catalog item definitions. PAIS Data Services Manager (DSM) database resource allocation is controlled through an infrastructure policy that defines the quality and quantity of resources the database can consume from vSphere clusters, with associated storage policies and VM classes.

PAIS observability is configured through the same PAISConfiguration custom resource. Prometheus runtime metrics collection is activated by uncommenting the `spec.observability.prometheusRuntime` section and supplying a storage class and configurable metrics retention period; LLM traces can be exported to an OpenTelemetry Collector through the same configuration path. VI administrators can visualize PAIS controller pod operation metrics in VCF Operations, with Telegraf user configuration stored in a `telegraf-user-config` ConfigMap in the `vmware-system-monitoring` namespace. The VCF Consumption CLI provides a command-line interface for cluster management capabilities through a plugin installation command, giving administrators a scriptable surface for repeatable PAIS workload operations.

VMware vDefend (Contributes)

VMware vDefend provides configuration management mechanisms for its network security policy infrastructure, contributing to an organization's broader configuration management program.

The vDefend distributed firewall (DFW) supports a draft configuration management workflow that separates policy authoring from activation. Administrators prepare and review firewall policy changes in draft form before publishing them to the enforcement plane. Draft configurations can be saved as a new configuration or as an update to an existing one, and can be locked with an optional comment requirement to enforce change control discipline. Auto drafts and manual drafts can be cloned and saved, with the option to edit the name and lock the configuration with a required comment. Export options include the published configuration, an auto-saved draft, or a manually saved draft. The Publish function commits a draft and makes it active; the Revert function returns the environment to the previous published configuration. Auto-drafts and saved manual drafts can be loaded and published at any time, giving administrators the ability to restore a prior policy state after a change.

In federated deployments, a Global Manager provides centralized configuration management across distributed Local Manager sites. IDS/IPS signatures, profiles, Distributed Firewall and Gateway Firewall policies, oversubscription settings, and syslog settings can all be managed centrally from the Global Manager and applied across all Local Managers. This enables consistent security policy baselines across geographically distributed environments.

The vDefend also supports full rollback capability, which deletes newly added policies and reverts the security configuration to its prior state in reverse order. This applies to broader policy migration and transition scenarios, beyond the draft-level Revert function.

Security Services Platform (SSP) extends configuration management to vDefend's detection and prevention services. The SSP deployment wizard conducts validations before implementing configuration changes to confirm that configurations are correct and compatible. The SSP Configuration Database is the storage layer for system settings and configurations. SSP also extracts all IDS policies, rules, and security profiles to support multiple remediations, clean up stale policies, and suggest policies that do not conflict with each other. IDS/IPS remediation policies can be verified by navigating to Security > IDS/IPS & Malware

Prevention > Emergency Threat Rules. Security policies defined within SSP are propagated and enforced across Bare Metal servers as well, extending policy management scope beyond virtual workloads.

Administrators can use flow inactivity data and Security Intelligence recommendations to identify and remove unused or outdated DFW policies and rules, supporting configuration lifecycle hygiene. Security Intelligence's segmentation posture assessment stores data in a Configuration Management Database (CMDB) within the Security Services Platform, maintaining application context and workload attributes. Segmentation planning supports importing workload context from flat files containing IP addresses, subnets, virtual machines, logical segments, and organizational roles, allowing administrators to establish a baseline for policy configuration decisions.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides several configuration management mechanisms specific to disaster recovery operations.

The Configuration Import/Export Tool allows administrators to export and import PNR configuration data, including inventory mappings, recovery plans, protection groups, and related objects, into XML files. This capability supports configuration versioning and backup by capturing the complete disaster recovery configuration state: server version, build number, local and remote site names, inventory mappings, placeholder datastores, advanced settings, and array manager information with Storage Replication Adapter details. The tool provides schema support for programmatic configuration management and offers multiple export and import modes. Administrators can use a properties file (`srm_configuration.properties`) to simplify or automate the import process, invoke the `import-export.jar` utility interactively using the `--importInteractive` flag with parameters for the XML file path, delay, and retry count, or use a script-based method that exports configuration data without requiring credential entry. Exports can be integrated directly into recovery plans as callout steps, so configuration data is captured automatically during recovery operations.

The Protection and Recovery Appliance Management Interface allows administrators to configure network settings on the appliance after initial deployment. PNR upgrade procedures preserve advanced settings and configurations from the prior release, maintaining configuration continuity across version changes. Advanced settings can also be modified through the Site Pair > Configure > Advanced Settings interface in the product UI.

The DR IP Customizer tool provides structured management of network configuration for protected virtual machines. It generates CSV files describing the IP properties of protected VMs grouped by site and recovery plan, which administrators can modify with recovery-site-specific values and reapply. This structured approach supports repeatable and auditable network configuration changes during recovery operations.

Storage Replication Adapter (SRA) configuration management is supported through the Appliance Management Interface, which provides a Download Configuration Archive function for retrieving and importing SRA configurations. PNR also rescans storage arrays every 24 hours by default to detect configuration changes.

In deployments that integrate with VCF Automation, Provider Administrators install PNR in desired regions, pair regions together, and manage organizational access to PNR capabilities through the VCF Automation Provider Management UI. The VCF Operations Orchestrator Plugin for Protection and Recovery requires administrator login to access and execute workflows for managing site mappings and network configurations.

Access to PNR configuration changes is governed by role-based access control. Granular permissions restrict who can modify advanced settings, manage array managers, and create, modify, or execute protection groups and recovery plans, supporting separation of duties for configuration change management.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) supports configuration management by providing structured mechanisms for defining, applying, and monitoring the configuration of database infrastructure components. Administrators interact with DSM through two primary interfaces: the Provider UI for system-wide settings and the vSphere Client for infrastructure configuration. The Settings view in the Provider interface is the central location for managing system-wide settings, including LDAPS integration, SMTP configuration, and directory service settings. The Administrator Dashboard displays at-a-glance metrics covering the

number of configured users, their assigned roles, and the types and counts of provisioned database services, giving administrators a current view of deployment state.

Infrastructure configuration in DSM is governed by infrastructure policies. These policies define which VM classes are available for database VMs, which storage policies apply, and which vSphere clusters and namespaces are used during provisioning. Infrastructure policy configuration requires that placements, storage policies, VM classes, and IP ranges be correctly configured for valid policy status. Policies that are actively in use by a database cannot have their existing settings modified, though new compute resources with corresponding parameters can be added; unused policies can be changed at any time. VM classes are configurable resource profiles that specify vCPU cores and memory allocation, and can be defined to match organizational capacity standards. Infrastructure policies also establish guardrails that restrict the quantity and quality of resources DSM users can consume from vSphere clusters. Configuration tasks performed during initial deployment include configuring IP pools, defining VM classes, assigning user permissions, creating infrastructure policies, and selecting storage policies.

Database-level configuration is managed through the database instance settings. DSM allows configuration of database instances using either custom or default configuration profiles, with configuration properties varying by database type (PostgreSQL, MySQL, MinIO, or SQL Server). DSM automates provisioning, backups, and security patch application for managed database instances. After initial provisioning, database VM resource configuration can be adjusted at runtime. Optional database configuration parameters for PostgreSQL and MySQL databases can be added or removed after database creation. Maintenance windows can be configured to control when software updates and database option changes are applied, providing a mechanism for scheduled, controlled configuration changes.

DSM provides a Maintenance Policy editor, accessible from the Version & Upgrade section under the DSM System tab, for configuring automatic software updates of the DSM plug-in within defined maintenance windows. The DSM controller manages component and feature dependencies through status monitoring and automated remediation.

When integrated with VCF Automation, DSM supports data service policies that define and enforce configurations for each tenant or organization. These policies can be enforced across different namespaces and namespace labels to maintain a uniform configuration posture. The Consumption Operator automates database deployments based on predefined infrastructure and backup policies, reducing the scope for manual configuration drift.

DSM provides visibility into configuration activity through the Operations tab, which displays the progress of database configuration changes, resource changes, and disk extension tasks. A support bundle can be created and downloaded to collect diagnostic information for troubleshooting system configuration failures. DSM system configuration is also managed through a `dsmsystemconfig` Custom Resource within the gateway, which can be inspected via SSH access to the appliance VM to review directory service status and configuration details.

DSM's contribution to a configuration management program is at the platform level: it provides technical mechanisms for defining baseline configurations through policies and VM classes, enforcing them during provisioning, and tracking changes through operational visibility. The broader configuration management program, including change control processes, configuration baseline documentation and approval, configuration audits against external standards, and periodic review cycles, must be established and maintained by the organization.

VMware Avi Load Balancer (Contributes)

Avi Load Balancer provides several mechanisms that support the implementation of configuration management controls across the application delivery layer.

The Controller maintains a centralized Configuration Database that stores all configuration information including tenants, virtual services, pools, policies, and accounts. This is the single source of truth for all system settings. When an administrator makes a change through the web interface, CLI, or REST API, that change is automatically propagated to all Controller cluster members, so any node can assume leadership with a complete and current configuration.

The Controller CLI provides direct access to the full configuration surface. The `configure systemconfiguration` command allows administrators to modify system-wide parameters including DNS, NTP, portal settings, and cryptographic algorithm

configuration, with changes synchronized to Service Engines. The ``configure`` command covers a broad range of objects including virtual services, pools, health monitors, authentication profiles, application profiles, and policy sets, and supports creation, modification, and deletion of those objects. The REST API exposes comparable capabilities programmatically, including the ``PUT api/systemconfiguration`` endpoint for system-wide settings and the ``/api/cloud`` endpoint for cloud configuration resources.

Configuration management in Avi can be automated through the Ansible ``aviconfig`` role, which allows configurations to be expressed as structured dictionaries and applied in a repeatable manner, reducing the need for multiple individual task definitions. The Controller supports on-demand configuration backup and restore, enabling disaster recovery and configuration migration across Controller instances.

In the 9.1 VCF integration, Avi distinguishes between two operational modes: Provider-Managed Mode, where the provider administrator manages Service Engine Group settings including scale-out, CPU, and memory configurations; and Organization-Managed Mode, where the organization administrator manages their own Service Engine Group configurations and infrastructure settings. This separation clarifies ownership and scope of configuration responsibilities within a shared VCF deployment. After upgrading Avi components, a drift check should be performed against VCF Operations, vCenter, and NSX Manager to verify configuration consistency across the stack.

For Kubernetes environments, the Avi Kubernetes Operator (AKO) configuration is customized through the AddonConfig resource, a Supervisor namespace-scoped resource that supports modification of parameters such as logging level and shard virtual service size.

The Config Events overlay in the Service Engine Analytics view allows operators to correlate configuration changes with observed traffic behavior, supporting investigation of the impact of individual changes. Avi Load Balancer events provide the building blocks for configuration automation workflows.

Organizations should define change control procedures, assign ownership of configuration baselines, and determine which changes require approval before these mechanisms can function within a formal configuration management program. Avi provides the technical instruments; the program structure requires organizational governance.

Control B4.d

Vulnerability Management: You manage known vulnerabilities in network and information systems to prevent adverse impact on your essential function(s).

SCF Controls: VPM-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides integrated vulnerability and patch management capabilities across its infrastructure stack, addressing both the implementation and monitoring aspects of this control.

VCF includes built-in lifecycle management that automates the process of applying updates and patches to software components within the stack. Patch releases provide time-sensitive fixes to security and critical issues and can be applied selectively to individual components without requiring synchronized updates across all VCF components. VCF Operations includes a patch planner that identifies available updates for VCF core components, downloads binaries from online depots (or stages them for offline environments), and orchestrates installation across the stack. Pre-update validation runs health checks and compatibility verification before applying changes. VCF Operations automatically backs up components during the patch process to provide a recovery point in case of failure. For vCenter appliance patching, an LVM snapshot is automatically created before the patching process begins; if patching fails, the orchestrator offers the option to roll back to that snapshot or continue after addressing the underlying issue. Lifecycle management also provides tools for planning updates so that administrators can schedule maintenance windows and coordinate changes with minimal disruption to services.

vSphere Lifecycle Manager (vLCM) manages the desired-state configuration for ESX hosts, including firmware and drivers through Hardware Support Manager (HSM) plugins provided by OEM vendors. vLCM images consist of a base image, vendor add-ons, components, and firmware add-ons that can be independently retrieved and applied to hosts. vLCM scans hosts against the desired image specification, flags deviations, and remediates non-compliant hosts. vSphere Lifecycle Manager also supports Live Patch for applicable updates, enabling patches to be applied to ESX hosts without requiring them to enter maintenance mode. It works with three types of software depots (online, offline, and UMDS) to provide flexibility in how patches are sourced and distributed. Update Manager supports dynamic baselines that automatically adjust their patch data based on specified criteria each time new patches are downloaded, allowing administrators to define patching policies that stay current without manual intervention. The Update Manager PowerCLI module provides cmdlets for downloading software patches, creating and modifying baselines, and scanning and remediating virtual machines and hosts, enabling automation of patching workflows.

For the VMware Kubernetes Service (VKS) and vSphere Supervisor layer, Security Technical Implementation Guides (STIGs) are available for Supervisor and VMware Kubernetes Release (VKr) components through Tanzu STIG Hardening, providing a structured security configuration baseline against which VKS deployments can be assessed and remediated. VKr components and Standard Packages are updated using the VCF CLI ``vcf package installed update`` command, which upgrades a package installation to a newer version and applies new configuration values, giving administrators a structured mechanism for applying package-level updates to components running in the Supervisor environment. VCF building-block services have independent lifecycles, enabling components to be updated individually without affecting the broader environment. The Node Problem Detector can be deployed within VKS clusters to monitor node health and report infrastructure-level problems through configurable detection rules, supporting the monitoring dimension of vulnerability management at the workload tier.

For container workloads running on VKS, Harbor is available as a deployable Standard Package with built-in vulnerability scanning using the Trivy database, which can be configured to use a custom or mirrored repository for air-gapped deployments. Harbor also provides content trust features that support image signing and policy-based replication, giving operations teams mechanisms to detect and restrict deployment of images containing known vulnerabilities. Harbor packages are updated using the ``vcf package installed update harbor`` command. Kubernetes guidance recommends that container images be regularly scanned during creation and in deployment, with known vulnerable software patched before workloads reach the runtime environment. Kubernetes security vulnerabilities are tracked and announced through the Kubernetes

Security Response Committee, which maintains an official list of known CVEs and publishes security-related announcements to the kubernetes-announce mailing list. For CI/CD pipelines running on VCF, Harness CI/CD is available as a Supervisor Service with integrated Security Testing Orchestration (STO) that incorporates the Wiz CLI to automate vulnerability management throughout the pipeline, performing infrastructure-as-code (IaC) and secret detection scans and container image scans against artifacts stored in JFrog Artifactory. Vulnerability scan findings from Wiz are reported to the Harness security dashboard, and Harness STO automatically deduplicates findings and displays them on the vulnerabilities tab of each pipeline execution for review.

VCF Diagnostics automatically detects known issues and critical vulnerabilities within the VCF software stack, providing detailed descriptions, root cause insights, and actionable remediation steps. The Security Operations dashboard in VCF Operations provides a consolidated view of security posture, helping administrators identify areas requiring attention. VCF Operations compliance management continuously monitors infrastructure for policy violations, highlights risk areas, and provides actionable remediation recommendations. When VCF Operations detects non-compliance with a policy, it can generate alerts or notifications, and depending on the severity of the non-compliance, automated remediation actions can be configured to bring the object back into compliance.

Configuration drift monitoring provides an additional layer of ongoing assurance. VCF Operations provides unified configuration management that supports scheduled drift detection for vCenter and cluster objects. It detects deviations from assigned configuration template values, displays drift results across all configuration templates, and allows administrators to compare changes against desired values. This helps identify unauthorized or unintended changes to the infrastructure that could introduce vulnerabilities.

Patching operations are governed by role-based access controls. Editing remediation settings in vSphere Lifecycle Manager requires specific privileges (`VcIntegrity.lifecycleSettings.Read` and `VcIntegrity.lifecycleSettings.Write`), and image remediation operations require a separate set of API privileges.

Broadcom publishes security advisories (VMSAs) for VCF vulnerabilities and releases patches to address them.

VMware vDefend (Contributes)

VMware vDefend contributes to vulnerability management through network-layer detection, virtual patching, and security posture monitoring capabilities that complement traditional patch management workflows.

vDefend Distributed IDS/IPS provides signature-based detection of vulnerability exploitation attempts across east-west traffic within the data center. When a new vulnerability is disclosed, administrators can deploy custom IDS/IPS signatures to detect and block exploitation attempts before official patches are available, a practice commonly referred to as virtual patching. In 9.1, IDS/IPS event monitoring displays Common Vulnerability Scoring System (CVSS) scores and CVE reference information for vulnerabilities targeted by exploits, giving security teams direct visibility into which specific vulnerabilities are being actively targeted in their environment. The IDS/IPS dashboard provides monitoring and analysis of intrusion events, and Security Services Platform collects metrics to monitor IDS/IPS readiness and performance across the environment. Malicious IP reputation feeds, managed centrally through the Global Manager, automatically update threat intelligence so that known attacker infrastructure is blocked without manual intervention.

The Threat Event Monitoring dashboard in Security Services Platform displays the top IPs on which an intrusion was attempted and the top VMs based on Vulnerability Severity criteria. The Threat Event Monitoring tab on the Security Overview dashboard surfaces key insights about the current state of various security issues in the data center, helping security teams understand network activity and prioritize focus areas.

Security Intelligence, a feature within Security Services Platform, provides posture assessment and segmentation monitoring capabilities. Administrators can monitor traffic leakage between environments, establish exceptions, and implement lockdown protection rules to control inter-environment traffic. The Security Posture dashboard presents information that can be used to plan and implement additional security policies. The Security Explorer provides a visual representation of workloads, their traffic flows, and connection status, which helps identify workloads that may be exposed to unpatched vulnerabilities. Security Services Platform also generates Security Segmentation Reports and Blast Radius Reports that break down at-risk workloads, communication chains, and traffic flows, providing the visibility needed to plan subsequent protection stages. The Security

Operator role in Security Services Platform is designated to monitor security systems and respond to security incidents, supporting the operational dimension of vulnerability management monitoring.

vDefend Advanced Threat Prevention extends detection capabilities to include behavioral analysis and sandboxing, identifying malware and exploit attempts that signature-based detection might miss. The Security Overview dashboard in Security Services Platform displays file inspection statistics organized by different ranges of threat score, giving security teams a quantitative view of file-based threats detected in their environment. This provides an additional layer of protection for systems awaiting patches.

These capabilities address the detection and monitoring dimensions of vulnerability management. Patch deployment and software lifecycle management are handled by other VCF components such as VCF Operations and vSphere Lifecycle Manager.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides patch management and monitoring capabilities that support an organization's vulnerability management program as it applies to the database services DSM manages.

For patch management, DSM exposes a Maintenance Policy that administrators configure in the vSphere Client. The Maintenance Policy controls when and for how long the platform applies automatic minor software updates to DSM appliances. Configurable settings include the start date (maintenance-policy-start-date), start time in hours and minutes (maintenance-policy-start-time), and duration of the update window (maintenance-policy-duration). The default maintenance window starts each Saturday at 23:59 with a six-hour duration, and administrators should always set a future date and time when configuring the policy. Upgrade operations during the maintenance window may include CVE fixes, bug fixes, and performance improvements. Per-database maintenance windows follow the same structure and can be adjusted during database creation or subsequent operations.

DSM requires that at least one complete chain of software updates for appliances be attempted, irrespective of the configured maintenance window duration. Patch cycles cannot be indefinitely deferred through policy configuration alone. Within the configured maintenance duration, plug-in software updates attempt up to three times with a 10-minute interval between attempts. The maintenance policy can be edited during the 10-minute interval between attempts, which cancels the next scheduled attempt and applies the newly configured policy. Administrators can view available upgrades and the upgrade history through the Version & Upgrade interface, accessible from the vSphere Client under the VMware vCenter Configure tab. The vSphere Administrator role is explicitly responsible for managing DSM VM updates and creating and managing infrastructure policies, which supports assigning patch management responsibilities to designated personnel. Both a vSphere administrator and a DSM user in the admin role can manage plug-in and database template software updates.

The DSM controller manages feature dependencies through status monitoring and automated remediation. When an upgrade requires resolution of VKS release dependencies, the controller automatically resumes the provisioning process after those dependencies are resolved, helping maintain patch state consistency during VCF environment upgrades.

DSM also provides monitoring capabilities that help identify conditions requiring remediation. The Global Alerts page, accessible in both the plug-in UI and the standalone UI, displays non-catastrophic alerts and system status. The Administrator UI Dashboard surfaces the same Global Alerts view for environment-wide visibility. DSM generates alerts for authentication failures, backup and restore corruptions, and certificate errors. The monitoring framework supports metrics-based and status-condition-based alerts covering conditions such as database engine degradation, non-operational status, and backup failure. Administrators and database users can configure alert thresholds for CPU Health, Data Disk Health, System Disk Health, and Max Connections, each with separate warning and critical thresholds. DSM supports webhook-based alerting for database monitoring events triggered by threshold violations. DSM also provides mitigation suggestions alongside database alerts to help administrators resolve issues without disrupting database services. SQL Server administrators can define maintenance windows for operating system patching of SQL Server instances.

For diagnostics, DSM generates system support bundles containing system logs and diagnostic information, with a configurable retention duration before the system automatically deletes them. The Monitoring tab in the DSM UI displays monitoring data for individual database instances, including an Alerts pane and an Operations view for tracking operations

targeted on database VMs. DSM can also be monitored using VCF Operations for troubleshooting and status visibility, with VCF Operations providing a view of PostgreSQL and MySQL cluster health within the DSM environment.

The overall vulnerability management program, including scanning, prioritization, remediation timelines, and organizational governance, is an organizational responsibility outside DSM's scope. DSM contributes by providing the update scheduling mechanisms and monitoring visibility needed to act on vulnerability management decisions within the scope of the database services it manages.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides a structured patch management lifecycle for both the Controller and Service Engine groups, supporting the application delivery layer's contribution to an organizational vulnerability management program. The CLI patch command offers distinct patching modes (Controller Patch, SE Group Patch, Disruptive Patch, and System Patch), giving administrators flexibility to apply patches to specific components or across the entire system without requiring a full upgrade cycle. The documentation recommends applying patches only to the Service Engine groups that require them, based on Service Engine group segmentation. Patch images are uploaded to the Controller and verified for inclusion in the image bundle before any upgrade operation proceeds.

Rollback capability is available for patch releases via CLI. The ``rollbackpatch controller`` command reverts the Controller to the previous patch version, while ``rollbackpatch system`` rolls back the Controller and all Service Engine groups simultaneously. Rollback transitions the system to the version without the specific patch and does not roll back to the previous major version. The Avi for VCF documentation recommends planning a remediation strategy before re-attempting an upgrade following a rollback. On restore operations, the Controller checks for patches applied as part of the restore to maintain version consistency.

For application-layer vulnerability management, Avi Load Balancer supports virtual patching through two complementary mechanisms. The Web Application Firewall (WAF) integrates with Dynamic Application Security Testing (DAST) scanners; the Avi SDK integrates with OWASP ZAP Attack Proxy and Qualys Web App Scanning, allowing scan results to be imported and used to identify application vulnerabilities and apply WAF-based protections while permanent code fixes are developed and deployed. The Live Security Threat Intelligence service, available through the Cloud Console, extends virtual patching coverage with an Application Rules service providing rules designed to block attacks on known application vulnerabilities, including many with associated CVEs. These rules cover over 5,000 applications including WordPress, Drupal, and Apache, and are automatically updated through continuous Application Rules Database synchronization, keeping WAF protections current.

An Application Security Report provides a downloadable PDF documenting security findings and pre-check results, supporting vulnerability management reporting and documentation. The alert automation infrastructure supports ControlScripts that alert actions can invoke to automatically add offending client IP addresses to a blocklist attached to a network security policy, enabling automated response to detected threats.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control B5

Principle B5 Resilient Networks and Systems: The organisation builds resilience against cyber attack and system failure into the design, implementation, operation and management of systems that support the operation of your essential function(s).

SCF Controls: SEA-01.3

Aggregate Coverage: Contributes

VCF (Contributes)

The Consumption layer of VCF, delivered through VMware Kubernetes Service (VKS) and vSphere Supervisor, provides several technical mechanisms that contribute to resistance against both unintentional configuration errors and intentional security circumvention. Designing and implementing security, compliance, and resilience as organizational disciplines remains outside the platform's direct scope; the mechanisms described here support that work rather than substitute for it.

Admission control

The Kubernetes admission controller chain in Supervisor intercepts API server requests before they are persisted or executed. ValidatingAdmissionPolicy resources enforce declarative rules over incoming API objects; when FailurePolicy is set to Fail, policy evaluation failures or compilation errors cause the resource to be rejected outright rather than silently accepted. ValidatingAdmissionPolicy is the preferred mechanism for preventing specific kinds of changes to resources, including protecting platform namespaces from modification by tenant workloads. Admission control catches constraint violations at submission time rather than at runtime, directly resisting unintentional misconfigurations.

Pod Security Admission

The Pod Security Admission (PSA) controller supports three security profiles (Privileged, Baseline, and Restricted) applied per namespace in three enforcement modes: enforce, audit, and warn. In enforce mode, pods that violate the selected profile are rejected at submission. In audit mode, violations are recorded in the audit log without blocking the pod. In warn mode, operators receive a warning without blocking. The recommended practice for production namespaces is to apply the Baseline profile in enforce mode while applying Restricted in warn and audit modes. ClusterClass variables allow cluster-wide Pod Security Standard defaults to be set consistently across VKS cluster provisioning. VKS Cluster Management Security Policies use the resource hierarchy for scalable governance, with constraints applied at the organization or project level automatically inherited by all child resources; custom security policy templates allow fine-tuning of individual security context parameters to support flexible governance controls tailored to specific organizational requirements.

RBAC and privilege scope

Supervisor namespaces use Kubernetes RBAC, with Roles, ClusterRoles, RoleBindings, and ClusterRoleBindings controlling what each principal can do within a namespace or cluster. Secure RBAC design requires cluster administrators to understand privilege escalation paths, such as the ability to create pods with elevated security contexts or to escalate through controller service accounts, in order to reduce the risk of excessive access leading to security incidents. The Secret Store Supervisor Service reinforces this by enforcing separate RBAC policies for administrators, DevOps engineers, and application tenants managing sensitive data. VKS Cluster Management Policy Insights provide health alerts to infrastructure-level failures that prevent policy enforcement, such as an unhealthy policy operator or a failed Gatekeeper installation, so that gaps in coverage are visible rather than silent.

Container image security

Harbor Registry, available as a Supervisor Service, provides vulnerability scanning, content trust (image signing and verification), and policy-based replication. Artifact access is controlled through RBAC policies. These capabilities reduce the risk that a workload deploys a vulnerable or tampered container image, addressing both inadvertent use of unscanned images and intentional supply chain attacks. Software distribution to cluster components should use encrypted transport with a verifiable chain of trust to support supply chain integrity for cluster components and their dependencies.

Immutable infrastructure and audit integrity

Immutable infrastructure patterns, where running containers are replaced rather than modified in place, make it easier to identify and mitigate security risks by preventing or detecting unauthorized changes to workload state. The combination of immutability and version control in infrastructure-as-code creates a durable audit log of every authorized change to a system. For high-assurance environments, cryptographic protections can be applied to audit logs to support tamper detection and confidentiality. CSI Volume Snapshots provide a resilient safety net for VKS clusters, keeping mission-critical data recoverable if the primary storage infrastructure fails.

Hardening guidance and cluster resilience

DISA Security Technical Implementation Guides (STIGs) are available for Supervisor and VMware Kubernetes Release (VKr) components, providing hardening configuration baselines that address misconfiguration risks and known attack patterns. VM classes in vSphere Supervisor help set guardrails for VM policy and governance by anticipating development needs and accounting for resource availability and constraints. Kubernetes provides a framework for running distributed systems resiliently, handling scaling and failover for applications; if any built-in controller fails, another part of the control plane takes over. At the node level, MachineHealthCheck in VKS evaluates worker node conditions against user-defined criteria and triggers automated remediation when nodes are identified as unhealthy, reducing dependence on manual intervention when infrastructure faults occur. Kubernetes liveness probes extend self-healing behavior to the application layer, detecting broken application states and automatically restarting containers that fail health checks. For batch workloads, the podFailurePolicy field in Kubernetes Job specifications supports granular failure handling based on container exit codes and Pod conditions, allowing operators to distinguish non-retriable failures from transient faults and avoid unnecessary retries. Production workloads and their dependencies, including CoreDNS, should be configured for resilience through ReplicaSets, rolling deployment updates with rollback capability, and application replication where higher availability is needed to mitigate involuntary disruptions.

What additional processes are needed

The Consumption layer's technical controls address configuration enforcement, workload integrity, cluster resilience, and supply chain security, but the control requires that security, compliance, and resilience be designed and implemented across the organization. Meeting this requirement fully involves threat modeling during development to identify trust boundaries and risks, organizational security policies governing cluster configuration standards, and processes that translate STIG hardening guidance into consistently deployed configurations. These governance and development lifecycle activities fall outside the platform's direct scope.

VMware Private AI Services (PAIS) includes AI-infrastructure-specific mechanisms that contribute to resistance against both unintentional software errors and intentional attacks on the AI supply chain.

The Model Gallery validation workflow provides a structured gate against error and attack at the model onboarding step. Before uploading an ML model to the Model Gallery, MLOps engineers validate the model against the organization's security, privacy, and technical requirements (p.193). As part of this workflow, model files are validated for integrity by checking hash codes, scanned for malware, scanned for serialization attacks, and tested for correct inference behavior using Triton Inference Server inside the deep learning VM sandbox (p.193). Beyond static validation, the workflow recommends examining inference requests for malicious behavior and performing hands-on functional tests before deployment (p.193). To keep validated models inside a controlled boundary, the Model Gallery is used to reduce redundant copies and maintain model integrity within the organization (p.192), and models distributed within an organization should be those validated on a deep learning VM rather than models retrieved directly from the Internet, which could contain malicious code or be tuned for malicious behavior (p.192).

PAIS integrates with Harbor registries as the model storage backend and requires authentication and certificate-based trust for model retrieval (p.195). A Harbor registry should be set up for PAIS deployment, and OCI-compliant registries from other vendors are also supported (p.35). These controls reduce unauthorized access to and modification of the AI artifact supply chain.

Component communication is protected through a CA trust bundle. PAIS uses a CA trust bundle for secure communication with external services and databases (p.90), giving administrators a single configuration point for trust between PAIS components, identity providers, registries, and downstream services.

Operational observability is provided through integration with Prometheus, Grafana, and VCF Operations. Metrics collection for observability is activated by uncommenting the `spec.observability.prometheusRuntime` section of the `PAISConfiguration` custom resource (p.90). Observability is configured as part of PAIS activation in VCF Automation and must be verified as active in the PAIS instance namespace (p.100). PAIS integrates with Grafana for metrics visualization using OIDC provider authentication (p.100), and MLOps engineers can visualize PAIS metrics in Grafana dashboards once observability is activated (p.100). PAIS controller pod metrics are integrated into observability platforms through Telegraf configuration in the Supervisor instance (p.102), and VI administrators can visualize PAIS controller pod operation metrics in VCF Operations (p.100). MLOps engineers and application developers can also perform monitoring and diagnostics of models used in agents through observability platforms such as Grafana to track the health, quality, and behavior of AI applications (p.191).

Broader platform resilience capabilities, including infrastructure redundancy, backup, disaster recovery, network-level isolation, and microsegmentation, are provided by the underlying VCF platform and are addressed in VCF Coverage of this assessment.

VMware vDefend (Contributes)

VMware vDefend is designed to provide resilience within the network security domain by containing the blast radius of attacks through Distributed Firewall microsegmentation, resisting intentional threats through IDS/IPS and malware prevention, and identifying anomalies through Security Intelligence capabilities in the Security Services Platform.

The Distributed Firewall includes Secure by Default VPC posture profiles that allow Project Admins to select pre-defined high-level security posture settings, reducing error-prone manual rule configuration and providing resistance to unintentional misconfiguration. Privileged labels offer a tamper-proof mechanism that anchors firewall rules to immutable labels, preventing VMs from being removed from security groups through unauthorized changes. The Security Services Platform enforces initial segmentation policies that cannot be modified through the user interface after publication, providing a hardened baseline that resists tampering once the security posture is established.

In 9.1, vDefend policies can be propagated and enforced across Bare Metal servers in addition to virtual workloads, extending network security controls to physical infrastructure. Security Services Platform has high availability enabled by default and supports deployment on vSAN stretched configurations for resilience against host failures within a single site, and its backup and restore functionality allows restoration of a platform instance when the current instance is in a non-recoverable state. Backup and restore operations require the platform to be in a healthy state.

The Security Services Platform generates Security Intelligence policy recommendations that can be reviewed, modified, and published to enforce network security policies. Security Intelligence administrators should monitor traffic leakage between environments, establish exceptions, and implement lockdown protection rules to control inter-environment traffic. The Intelligent Assist feature performs automated policy creation based on user role and permissions and provides Response and Remediation capabilities that help address threats detected by IDS/IPS, with remediation policies verifiable through the Security Services Platform interface.

NSX Federation Security maintains vDefend security posture during disaster recovery and workload migration by providing continuity of security policy enforcement across data centers.

vDefend's resilience capabilities are scoped to the network security layer; broader system resilience, redundancy architecture, and organizational continuity planning remain outside its direct scope.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) incorporates several technical mechanisms that contribute to security, compliance, and resilience across the database-as-a-service layer, addressing both resistance to unintentional errors and defense against circumvention by design.

Resistance to Unintentional Errors

DSM infrastructure policies function as guardrails that restrict the quality and quantity of resources that users can request from underlying vSphere clusters. These policies are defined by administrators and applied to all user-provisioned databases, reducing the risk of misconfiguration through constrained self-service rather than open-ended provisioning. Administrators should rely on predefined infrastructure policies and their associated standards when creating databases, so database owners are not required to make low-level infrastructure decisions that could introduce error.

When a data service policy is created or modified, DSM requires review of policy violations before the change is applied, giving administrators the opportunity to assess consequences before committing the modification. This pre-flight violation display is available in both the DSM native UI and the VCF Automation UI. DSM also provides a Compliance tab for each data service policy that displays a compliance report listing policy violations, noncompliant databases, data services, and namespaces; each violation can be expanded to identify the specific noncompliant object. DSM monitors infrastructure policy compliance continuously and generates specific compliance alerts, including `INFRASTRUCTURE_POLICY_CLUSTER_COMPLIANT` and `INVALID_SUPERVISOR_INFRASTRUCTURE_POLICY_STATUS`, to surface configuration drift on managed clusters. The system requires that High Availability be active on VMware vCenter (vCenter) clusters as a prerequisite for infrastructure policy compliance, embedding resilience as an operational requirement. When critical alarms are active for vCenter hosts, DSM guidance directs administrators to avoid create, upgrade, and scale operations to reduce the risk of failures during degraded conditions.

Resistance to Intentional Attack or Circumvention

Data service policies can be enforced consistently across different tenants, so security and compliance posture is not subject to override by individual database owners. Policies can be configured for MySQL, PostgreSQL, and SQL Server databases. Administrators define the allowed set of infrastructure policies as cluster-scoped resources in the consumption cluster, restricting which resources tenant users can access. DSM generates alerts for authentication failures and certificate errors, supporting detection of access anomalies. Secure network configuration using VDS port groups is a documented prerequisite for reliable and secure DSM operation.

Data service policies can also require that all databases under the policy have automated backups configured, enforced through the Require Automated Backups setting. This makes backup continuity a compliance requirement rather than a discretionary choice for individual database owners. DSM Consumption Operator deployment includes Signature Verification validation to confirm package integrity before installation, providing a check against tampered or unauthorized software components.

Availability and Continuity

Resiliency of the DSM Provider Appliance is provided through vSphere High Availability, so the management plane recovers from host failures without manual intervention. Databases can be deployed in multiple topologies to provide resiliency: the Cross vSphere Cluster HA topology for PostgreSQL and MySQL deploys replicas across multiple vSphere clusters, providing the highest availability for environments that require resilience across failure domains. For PostgreSQL databases specifically, automatic failover promotes a replica to primary when the primary node fails. Multi-site deployment is supported for PostgreSQL, enabling disaster recovery through instance promotion and demotion, with switchover and failback workflows that reverse primary and secondary roles. Secondary PostgreSQL instances support read-only connections during normal operation and can be promoted to primary during a failover event.

DSM addresses technical resilience at the database services layer but does not provide the organization-wide program required by SEA-01.3. Threat modeling, security architecture reviews, and organizational governance over software development and operational processes fall outside DSM's scope and require organizational practices and tooling beyond the database services layer.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer contributes to this control through application-layer mechanisms that address both dimensions of the requirement: resistance to intentional attack at the application delivery boundary and protection against unintentional errors in the data and management planes.

At the application layer, Avi's Web Application Firewall operates in both negative and positive security modes. The WAF Positive Security model uses Positive Security groups that define explicitly allowed application behavior, restricting requests that fall outside the learned or configured baseline. Avi WAF Policies attach a Positive Security group to apply learned traffic data and define hit and miss enforcement actions. The WAF Core Rule Set provides signature-based detection of common attack patterns, and Application Rules deliver targeted protection against known application vulnerabilities, including many tied to specific CVEs, with automatic updates delivered through the Avi Cloud Console Application Rules service. Core Rule Set exceptions can be scoped per application to avoid false positives. Network Security Policy evaluates incoming client connections based on network-level parameters and determines whether a connection should be accepted, discarded, or rate-limited, providing a complementary layer of connection-level traffic filtering. The System-Secure-HTTP application profile enforces HTTPS, protects cookies, manages client IP tracking, and controls protocol behavior on L7 virtual services. TLS termination at the Service Engine layer protects connections between clients and the application, restricting interception or modification of data in transit.

For resilience against unintentional errors and component failures, Avi's Service Engine high availability architecture is designed so that a scaled-out virtual service experiences no more than performance degradation if a single Service Engine in the group fails, making scaled-out Service Engine groups preferable to legacy active/standby configurations for this reason. The Avi Controller is deployed as a three-node cluster to provide management plane high availability and resilience; single-node deployments must use the Backup and Restore feature for disaster recovery. Controller cluster deployments can span Availability Zones to handle failure scenarios across networks. Avi Availability Zones can be configured to spread Service Engines across clusters and vCenter instances, providing fault domain separation for the data plane and reducing the impact of shared-fault conditions such as power failures affecting multiple ESX hosts simultaneously. Avi Global Server Load Balancing (GSLB) provides resilience when loss of a data center or network connection occurs, routing application traffic across geographically distributed sites. For Kubernetes-based deployments, the Avi Multi-Cluster Kubernetes Operator (AMKO) federation architecture designates a leader cluster and multiple member clusters, enabling disaster recovery coordination for containerized workloads across clusters.

Avi's contribution is scoped to the application delivery and WAF boundary. Organization-wide security, compliance, and resilience design practices that span the full technology stack require additional governance, tooling, and processes beyond Avi's application delivery scope.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control B5.a

Resilience Preparation: You are prepared to restore the operation of your essential function(s) following adverse impact to network and information systems.

SCF Controls: BCD-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides a broad set of infrastructure-level capabilities that support business continuity and disaster recovery planning. While VCF does not itself constitute a Business Continuity Management System, it supplies the technical mechanisms that underpin resilient deployments and contingency operations.

vSAN stretched clusters allow organizations to extend a single vSAN datastore across two geographically separated sites with an independent witness host. When configured with site mirroring, a stretched cluster can tolerate the complete loss of one site while maintaining data availability. vSphere HA, when enabled on a stretched cluster, automatically restarts virtual machines on the surviving site during a site failure. To support this, vSphere HA admission control should be configured to reserve 50% of the cluster's aggregate CPU and memory resources for failover, and site-specific isolation response addresses should be defined so that vSphere HA can validate host isolation even when network connectivity between sites is lost. The admission control setting for host failures the cluster tolerates should also be updated after cluster expansion to reflect the correct host count per availability zone. When stretching a workload domain cluster, the default management vSphere cluster must already be stretched. vSphere HA uses network heartbeats to validate the state of VMware ESX hosts, and can also use heartbeat datastores mounted to more than one host (excluding vSAN datastores) for cluster membership monitoring.

vSphere HA also operates at the individual cluster level independent of stretched clusters. The HA configuration remediation mode can be set to quarantine mode, maintenance mode, or mixed mode to handle host failures in a controlled manner, helping maintain workload availability during hardware events. vSphere Fault Tolerance provides a higher tier of availability for individual virtual machines by maintaining a secondary VM in continuous lockstep with the primary, enabling instantaneous failover with no data loss if the primary host fails.

vSAN Data Protection provides snapshot-based protection through the vSAN Snapshot Service. Protection groups support configurable snapshot scheduling with adjustable intervals and retention policies that define retention duration and time units. This allows organizations to define data protection policies aligned with their recovery point objectives. The Snapshot Service API also supports operations such as restoring deleted virtual machines from snapshots and creating linked clones from snapshots.

vSphere Replication provides asynchronous replication of virtual machines with a configurable Recovery Point Objective (RPO), allowing organizations to replicate workloads to a secondary site and define acceptable data loss windows as part of their contingency planning.

VCF requires all management components, including VCF Operations, VMware vCenter, NSX, and VCF Automation, to be configured with a regular backup schedule and retention policy. VCF Operations configures NSX Manager backups during the initial deployment, with a recommended backup frequency of hourly and 7-day retention. Backup jobs for VCF Operations and all vCenter instances should start within the same 5-minute window to capture a consistent state. The VMware Infrastructure Health adapter within VCF Operations monitors backup job retention for management components, including NSX Manager. Changed Block Tracking (CBT) tracks modified disk sectors on virtual machines to support incremental backups, reducing backup windows and storage requirements for VM-level backup operations. vCenter itself also supports a High Availability configuration with Active and Passive nodes whose configuration files are continuously replicated, providing management-plane resilience independent of the backup schedule.

VMware HCX provides workload mobility capabilities for migrating and replicating VMs between sites. HCX supports multiple migration types through its Mobility Agent service, including vMotion, Cold Migration, Bulk Migration, and Replication Assisted vMotion (RAV), each addressing different scenarios from large-scale parallel migrations to zero-downtime live migrations.

HCX also includes appliance-level backup and restore capabilities for the HCX Manager, including certificate backup and restore, supporting planned migrations and recovery scenarios as part of broader BC/DR operations.

VCF Operations monitors infrastructure health and surfaces alerts when conditions threaten availability, giving operations teams early warning of potential failures. The Platform Health Alerts page provides a centralized view of alerts across data sources and infrastructure nodes. VCF Automation provides alerts through the associated VCF Operations application for capacity, performance, and availability monitoring. VCF Operations also includes infrastructure planning and what-if analysis capabilities that help organizations forecast capacity requirements and plan for contingency scenarios. Committed scenarios reserve capacity by setting aside resources for new, upcoming, or planned workloads, helping stakeholders understand capacity requirements across the environment. Integration with IT Service Management and Configuration Management Database platforms is supported through VCF Automation, enabling organizations to tie their infrastructure management into broader service continuity workflows.

Lifecycle management tools allow administrators to plan updates and schedule maintenance windows to make changes with minimal disruption to services, supporting the operational continuity aspect of business continuity planning.

While VCF provides these technical capabilities, a complete BCMS requires organizational elements that fall outside the platform: documented continuity of operations plans, recovery time and recovery point objectives defined by business stakeholders, regular testing and exercise of recovery procedures, communication plans, and management oversight of the continuity program. VCF supplies the infrastructure resilience and recovery mechanisms that such plans depend on, but the planning, governance, and procedural components must be established and maintained by the organization.

VMware vDefend (Contributes)

VMware vDefend contributes to business continuity by providing security-layer continuity mechanisms that remain active during disaster recovery events and workload migrations. NSX Federation Security maintains security posture across data centers during disaster recovery and workload migration, preserving distributed firewall and gateway firewall policies so that enforcement continues through failover.

The Security Services Platform, which provides the underlying infrastructure for vDefend's threat detection and inspection services, supports vSphere High Availability configurations. When a VMware ESX host becomes unhealthy, vSphere HA migrates the affected Security Services Platform virtual machines to healthy hosts in the cluster, restoring threat detection capacity without manual intervention. VMware recommends enabling vSphere HA for host-level failure recovery and configuring a storage policy with RAID for datastore-level failure tolerance in Security Services Platform deployments.

Security Services Platform can also be deployed on a vSAN stretched cluster configuration, which replicates storage across two physically distinct sites connected by a high-bandwidth or low-latency inter-site link. This configuration requires a minimum of two sites with their own hosts and a witness host to handle potential conflicts arising from network partitions, supporting site-level failure scenarios.

When vSphere HA restarts workload VMs on a new recovery host after a failover, the vDefend distributed firewall automatically reinspects all traffic from those VMs on the receiving host, because the Flow Table contents cannot be moved between hosts during host recovery. Security policy enforcement resumes on the new host without manual reconfiguration.

The broader BCMS framework, including Continuity of Operations Plan and BC/DR playbooks, impact analyses, and organizational governance processes, is outside vDefend's scope and must be established through dedicated business continuity management programs.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides the technical execution layer for contingency planning in virtualized infrastructure. Recovery plans define the sequence, priority, and configuration for failover operations, acting as executable BC/DR playbooks. Protection groups organize virtual machines into logical units aligned with application tiers or business functions, establishing the scope of each contingency plan.

Recovery plans support non-disruptive testing before use in planned migration or disaster recovery, allowing organizations to validate their contingency procedures without affecting production workloads. Recovery plan configuration differs between emergency scenarios at the protected site and planned migration of services from one site to another, with PNR supporting both modes. A forced recovery function is available during disaster recovery plan execution for scenarios requiring immediate failover.

vSphere Replication provides host-based replication with configurable Recovery Point Objectives (RPO), allowing organizations to set per-workload data loss tolerances. vSphere Replication supports up to 200 point-in-time recovery instances per virtual machine using the Latest Instances option, enabling recovery to specific earlier states. This capability is relevant to contingency scenarios involving data corruption or ransomware events. When the source site is accessible at the time of recovery, vSphere Replication can synchronize recent changes from the source site to the target site before completing the operation, reducing data loss.

In 9.1, PNR extends to multi-tenant disaster recovery through integration with VCF Automation. The product implements role-based access control with Organization Administrator, Project Administrator, and Project Advanced User roles, each with defined authorization levels for disaster recovery operations. Role assignments must be configured on both the primary and secondary PNR sites to maintain consistent access control across the DR environment. A multi-region deployment topology places separate management domains in each region to contain disaster impact to one region, while enabling service recovery in an alternate management domain when VCF Automation and VCF Operations are affected. The VCF Operations Orchestrator Plug-In for PNR provides Configuration, Inventory Mappings, Protection Groups, and Storage predefined workflow categories for workflow-driven recovery operations.

Cyber recovery deployments support a standard VCF topology where the workload domain is isolated from the management domain, providing separation between management and user workloads in clean-room recovery scenarios.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides application-layer resilience mechanisms at both the control plane and the data plane that organizations can incorporate into business continuity plans for application delivery services.

At the control plane, the Avi Controller is deployed as a cluster with continuous configuration replication across all nodes, providing management-plane redundancy so that a single Controller node failure does not interrupt application delivery operations. Avi supports deployment of the Controller cluster across two availability zones, with vSphere HA recommended to support recovery of any node that fails in the secondary zone. For single-node deployments, enabling vSphere HA on the Controller VM is recommended for node recovery following a host failure. The Avi Controller provides configuration backup and restore capability that supports disaster recovery and configuration migration across Controller instances; organizations should capture and retain Controller backups as part of their continuity documentation.

Availability Zone awareness in Avi allows multiple availability zones to be configured, each defining a subset of vCenter instances, hosts, and datastores that share a fault domain. Configuring availability zones during Service Engine Group setup distributes data-plane capacity across isolated failure domains, supporting continuity designs where application delivery capacity remains available if one fault domain becomes unavailable.

At the data plane, Avi's Elastic High Availability mode provides fast recovery for individual virtual services following Service Engine failure. In vSphere DRS-enabled clusters, virtual service recovery occurs before vSphere HA brings up a replacement Service Engine when virtual service slots are available in other Service Engines, giving the application delivery layer its own recovery path distinct from the infrastructure restart cycle. If vSphere HA does not recover the failed Service Engine within a configured timeout period, the Avi Controller resumes recovery independently. Service Engine VMs should be deployed on vSphere clusters configured with both HA and DRS in fully automated mode; when Avi is deployed with VMware Kubernetes Service (VKS) on VCF, DRS and HA are required on every vSphere cluster used with Avi.

For Kubernetes environments, the Avi Multi-Cluster Kubernetes Operator (AMKO) provides federation architecture that supports disaster recovery across Kubernetes clusters. AMKO designates a leader cluster and multiple member clusters, coordinating application delivery failover as part of a multi-cluster DR strategy.

Avi ControlScripts, used in conjunction with the alert framework, can perform automated failover actions such as adding or removing routes based on VIP attachment and detachment events, allowing organizations to define automated remediation workflows that respond to system events without manual administrator intervention.

In 9.1 deployments using VCF Automation, Avi's Central Licensing maintains a global capacity pool that removes the requirement for duplicate licenses in DR scenarios, supporting license continuity across failover sites.

Organizations should document these mechanisms, including the Elastic HA configuration, Controller cluster topology and backup schedule, availability zone placement, and AMKO federation design, in their Business Continuity and Disaster Recovery playbooks. The technical recovery capabilities are built into the product; the planning artifacts, testing procedures, and escalation workflows are organizational responsibilities that extend beyond what Avi provides.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control B5.b

Design for Resilience: You design network and information systems supporting your essential function(s) to be resilient to cyber security incidents. Systems are appropriately segregated and resource limitations are mitigated.

SCF Controls: SEA-01, SEA-01.3

Aggregate Coverage: Contributes

VCF (Contributes)

The Consumption layer of VCF, delivered through VMware Kubernetes Service (VKS) and vSphere Supervisor, provides several technical mechanisms that contribute to resistance against both unintentional configuration errors and intentional security circumvention. Designing and implementing security, compliance, and resilience as organizational disciplines remains outside the platform's direct scope; the mechanisms described here support that work rather than substitute for it.

Admission control

The Kubernetes admission controller chain in Supervisor intercepts API server requests before they are persisted or executed. ValidatingAdmissionPolicy resources enforce declarative rules over incoming API objects; when FailurePolicy is set to Fail, policy evaluation failures or compilation errors cause the resource to be rejected outright rather than silently accepted. ValidatingAdmissionPolicy is the preferred mechanism for preventing specific kinds of changes to resources, including protecting platform namespaces from modification by tenant workloads. Admission control catches constraint violations at submission time rather than at runtime, directly resisting unintentional misconfigurations.

Pod Security Admission

The Pod Security Admission (PSA) controller supports three security profiles (Privileged, Baseline, and Restricted) applied per namespace in three enforcement modes: enforce, audit, and warn. In enforce mode, pods that violate the selected profile are rejected at submission. In audit mode, violations are recorded in the audit log without blocking the pod. In warn mode, operators receive a warning without blocking. The recommended practice for production namespaces is to apply the Baseline profile in enforce mode while applying Restricted in warn and audit modes. ClusterClass variables allow cluster-wide Pod Security Standard defaults to be set consistently across VKS cluster provisioning. VKS Cluster Management Security Policies use the resource hierarchy for scalable governance, with constraints applied at the organization or project level automatically inherited by all child resources; custom security policy templates allow fine-tuning of individual security context parameters to support flexible governance controls tailored to specific organizational requirements.

RBAC and privilege scope

Supervisor namespaces use Kubernetes RBAC, with Roles, ClusterRoles, RoleBindings, and ClusterRoleBindings controlling what each principal can do within a namespace or cluster. Secure RBAC design requires cluster administrators to understand privilege escalation paths, such as the ability to create pods with elevated security contexts or to escalate through controller service accounts, in order to reduce the risk of excessive access leading to security incidents. The Secret Store Supervisor Service reinforces this by enforcing separate RBAC policies for administrators, DevOps engineers, and application tenants managing sensitive data. VKS Cluster Management Policy Insights provide health alerts to infrastructure-level failures that prevent policy enforcement, such as an unhealthy policy operator or a failed Gatekeeper installation, so that gaps in coverage are visible rather than silent.

Container image security

Harbor Registry, available as a Supervisor Service, provides vulnerability scanning, content trust (image signing and verification), and policy-based replication. Artifact access is controlled through RBAC policies. These capabilities reduce the risk that a workload deploys a vulnerable or tampered container image, addressing both inadvertent use of unscanned images and intentional supply chain attacks. Software distribution to cluster components should use encrypted transport with a verifiable chain of trust to support supply chain integrity for cluster components and their dependencies.

Immutable infrastructure and audit integrity

Immutable infrastructure patterns, where running containers are replaced rather than modified in place, make it easier to identify and mitigate security risks by preventing or detecting unauthorized changes to workload state. The combination of immutability and version control in infrastructure-as-code creates a durable audit log of every authorized change to a system. For high-assurance environments, cryptographic protections can be applied to audit logs to support tamper detection and confidentiality. CSI Volume Snapshots provide a resilient safety net for VKS clusters, keeping mission-critical data recoverable if the primary storage infrastructure fails.

Hardening guidance and cluster resilience

DISA Security Technical Implementation Guides (STIGs) are available for Supervisor and VMware Kubernetes Release (VKr) components, providing hardening configuration baselines that address misconfiguration risks and known attack patterns. VM classes in vSphere Supervisor help set guardrails for VM policy and governance by anticipating development needs and accounting for resource availability and constraints. Kubernetes provides a framework for running distributed systems resiliently, handling scaling and failover for applications; if any built-in controller fails, another part of the control plane takes over. At the node level, MachineHealthCheck in VKS evaluates worker node conditions against user-defined criteria and triggers automated remediation when nodes are identified as unhealthy, reducing dependence on manual intervention when infrastructure faults occur. Kubernetes liveness probes extend self-healing behavior to the application layer, detecting broken application states and automatically restarting containers that fail health checks. For batch workloads, the podFailurePolicy field in Kubernetes Job specifications supports granular failure handling based on container exit codes and Pod conditions, allowing operators to distinguish non-retriable failures from transient faults and avoid unnecessary retries. Production workloads and their dependencies, including CoreDNS, should be configured for resilience through ReplicaSets, rolling deployment updates with rollback capability, and application replication where higher availability is needed to mitigate involuntary disruptions.

What additional processes are needed

The Consumption layer's technical controls address configuration enforcement, workload integrity, cluster resilience, and supply chain security, but the control requires that security, compliance, and resilience be designed and implemented across the organization. Meeting this requirement fully involves threat modeling during development to identify trust boundaries and risks, organizational security policies governing cluster configuration standards, and processes that translate STIG hardening guidance into consistently deployed configurations. These governance and development lifecycle activities fall outside the platform's direct scope.

VMware Private AI Services (PAIS) includes AI-infrastructure-specific mechanisms that contribute to resistance against both unintentional software errors and intentional attacks on the AI supply chain.

The Model Gallery validation workflow provides a structured gate against error and attack at the model onboarding step. Before uploading an ML model to the Model Gallery, MLOps engineers validate the model against the organization's security, privacy, and technical requirements (p.193). As part of this workflow, model files are validated for integrity by checking hash codes, scanned for malware, scanned for serialization attacks, and tested for correct inference behavior using Triton Inference Server inside the deep learning VM sandbox (p.193). Beyond static validation, the workflow recommends examining inference requests for malicious behavior and performing hands-on functional tests before deployment (p.193). To keep validated models inside a controlled boundary, the Model Gallery is used to reduce redundant copies and maintain model integrity within the organization (p.192), and models distributed within an organization should be those validated on a deep learning VM rather than models retrieved directly from the Internet, which could contain malicious code or be tuned for malicious behavior (p.192).

PAIS integrates with Harbor registries as the model storage backend and requires authentication and certificate-based trust for model retrieval (p.195). A Harbor registry should be set up for PAIS deployment, and OCI-compliant registries from other vendors are also supported (p.35). These controls reduce unauthorized access to and modification of the AI artifact supply chain.

Component communication is protected through a CA trust bundle. PAIS uses a CA trust bundle for secure communication with external services and databases (p.90), giving administrators a single configuration point for trust between PAIS components, identity providers, registries, and downstream services.

Operational observability is provided through integration with Prometheus, Grafana, and VCF Operations. Metrics collection for observability is activated by uncommenting the `spec.observability.prometheusRuntime` section of the `PAISConfiguration` custom resource (p.90). Observability is configured as part of PAIS activation in VCF Automation and must be verified as active in the PAIS instance namespace (p.100). PAIS integrates with Grafana for metrics visualization using OIDC provider authentication (p.100), and MLOps engineers can visualize PAIS metrics in Grafana dashboards once observability is activated (p.100). PAIS controller pod metrics are integrated into observability platforms through Telegraf configuration in the Supervisor instance (p.102), and VI administrators can visualize PAIS controller pod operation metrics in VCF Operations (p.100). MLOps engineers and application developers can also perform monitoring and diagnostics of models used in agents through observability platforms such as Grafana to track the health, quality, and behavior of AI applications (p.191).

Broader platform resilience capabilities, including infrastructure redundancy, backup, disaster recovery, network-level isolation, and microsegmentation, are provided by the underlying VCF platform and are addressed in VCF Coverage of this assessment.

VMware vDefend (Contributes)

VMware vDefend is designed to provide resilience within the network security domain by containing the blast radius of attacks through Distributed Firewall microsegmentation, resisting intentional threats through IDS/IPS and malware prevention, and identifying anomalies through Security Intelligence capabilities in the Security Services Platform.

The Distributed Firewall includes Secure by Default VPC posture profiles that allow Project Admins to select pre-defined high-level security posture settings, reducing error-prone manual rule configuration and providing resistance to unintentional misconfiguration. Privileged labels offer a tamper-proof mechanism that anchors firewall rules to immutable labels, preventing VMs from being removed from security groups through unauthorized changes. The Security Services Platform enforces initial segmentation policies that cannot be modified through the user interface after publication, providing a hardened baseline that resists tampering once the security posture is established.

In 9.1, vDefend policies can be propagated and enforced across Bare Metal servers in addition to virtual workloads, extending network security controls to physical infrastructure. Security Services Platform has high availability enabled by default and supports deployment on vSAN stretched configurations for resilience against host failures within a single site, and its backup and restore functionality allows restoration of a platform instance when the current instance is in a non-recoverable state. Backup and restore operations require the platform to be in a healthy state.

The Security Services Platform generates Security Intelligence policy recommendations that can be reviewed, modified, and published to enforce network security policies. Security Intelligence administrators should monitor traffic leakage between environments, establish exceptions, and implement lockdown protection rules to control inter-environment traffic. The Intelligent Assist feature performs automated policy creation based on user role and permissions and provides Response and Remediation capabilities that help address threats detected by IDS/IPS, with remediation policies verifiable through the Security Services Platform interface.

NSX Federation Security maintains vDefend security posture during disaster recovery and workload migration by providing continuity of security policy enforcement across data centers.

vDefend's resilience capabilities are scoped to the network security layer; broader system resilience, redundancy architecture, and organizational continuity planning remain outside its direct scope.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) incorporates several technical mechanisms that contribute to security, compliance, and resilience across the database-as-a-service layer, addressing both resistance to unintentional errors and defense against circumvention by design.

Resistance to Unintentional Errors

DSM infrastructure policies function as guardrails that restrict the quality and quantity of resources that users can request from underlying vSphere clusters. These policies are defined by administrators and applied to all user-provisioned databases, reducing the risk of misconfiguration through constrained self-service rather than open-ended provisioning. Administrators should rely on predefined infrastructure policies and their associated standards when creating databases, so database owners are not required to make low-level infrastructure decisions that could introduce error.

When a data service policy is created or modified, DSM requires review of policy violations before the change is applied, giving administrators the opportunity to assess consequences before committing the modification. This pre-flight violation display is available in both the DSM native UI and the VCF Automation UI. DSM also provides a Compliance tab for each data service policy that displays a compliance report listing policy violations, noncompliant databases, data services, and namespaces; each violation can be expanded to identify the specific noncompliant object. DSM monitors infrastructure policy compliance continuously and generates specific compliance alerts, including `INFRASTRUCTURE_POLICY_CLUSTER_COMPLIANT` and `INVALID_SUPERVISOR_INFRASTRUCTURE_POLICY_STATUS`, to surface configuration drift on managed clusters. The system requires that High Availability be active on VMware vCenter (vCenter) clusters as a prerequisite for infrastructure policy compliance, embedding resilience as an operational requirement. When critical alarms are active for vCenter hosts, DSM guidance directs administrators to avoid create, upgrade, and scale operations to reduce the risk of failures during degraded conditions.

Resistance to Intentional Attack or Circumvention

Data service policies can be enforced consistently across different tenants, so security and compliance posture is not subject to override by individual database owners. Policies can be configured for MySQL, PostgreSQL, and SQL Server databases. Administrators define the allowed set of infrastructure policies as cluster-scoped resources in the consumption cluster, restricting which resources tenant users can access. DSM generates alerts for authentication failures and certificate errors, supporting detection of access anomalies. Secure network configuration using VDS port groups is a documented prerequisite for reliable and secure DSM operation.

Data service policies can also require that all databases under the policy have automated backups configured, enforced through the Require Automated Backups setting. This makes backup continuity a compliance requirement rather than a discretionary choice for individual database owners. DSM Consumption Operator deployment includes Signature Verification validation to confirm package integrity before installation, providing a check against tampered or unauthorized software components.

Availability and Continuity

Resiliency of the DSM Provider Appliance is provided through vSphere High Availability, so the management plane recovers from host failures without manual intervention. Databases can be deployed in multiple topologies to provide resiliency: the Cross vSphere Cluster HA topology for PostgreSQL and MySQL deploys replicas across multiple vSphere clusters, providing the highest availability for environments that require resilience across failure domains. For PostgreSQL databases specifically, automatic failover promotes a replica to primary when the primary node fails. Multi-site deployment is supported for PostgreSQL, enabling disaster recovery through instance promotion and demotion, with switchover and failback workflows that reverse primary and secondary roles. Secondary PostgreSQL instances support read-only connections during normal operation and can be promoted to primary during a failover event.

DSM addresses technical resilience at the database services layer but does not provide the organization-wide program required by SEA-01.3. Threat modeling, security architecture reviews, and organizational governance over software development and operational processes fall outside DSM's scope and require organizational practices and tooling beyond the database services layer.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer contributes to this control through application-layer mechanisms that address both dimensions of the requirement: resistance to intentional attack at the application delivery boundary and protection against unintentional errors in the data and management planes.

At the application layer, Avi's Web Application Firewall operates in both negative and positive security modes. The WAF Positive Security model uses Positive Security groups that define explicitly allowed application behavior, restricting requests that fall outside the learned or configured baseline. Avi WAF Policies attach a Positive Security group to apply learned traffic data and define hit and miss enforcement actions. The WAF Core Rule Set provides signature-based detection of common attack patterns, and Application Rules deliver targeted protection against known application vulnerabilities, including many tied to specific CVEs, with automatic updates delivered through the Avi Cloud Console Application Rules service. Core Rule Set exceptions can be scoped per application to avoid false positives. Network Security Policy evaluates incoming client connections based on network-level parameters and determines whether a connection should be accepted, discarded, or rate-limited, providing a complementary layer of connection-level traffic filtering. The System-Secure-HTTP application profile enforces HTTPS, protects cookies, manages client IP tracking, and controls protocol behavior on L7 virtual services. TLS termination at the Service Engine layer protects connections between clients and the application, restricting interception or modification of data in transit.

For resilience against unintentional errors and component failures, Avi's Service Engine high availability architecture is designed so that a scaled-out virtual service experiences no more than performance degradation if a single Service Engine in the group fails, making scaled-out Service Engine groups preferable to legacy active/standby configurations for this reason. The Avi Controller is deployed as a three-node cluster to provide management plane high availability and resilience; single-node deployments must use the Backup and Restore feature for disaster recovery. Controller cluster deployments can span Availability Zones to handle failure scenarios across networks. Avi Availability Zones can be configured to spread Service Engines across clusters and vCenter instances, providing fault domain separation for the data plane and reducing the impact of shared-fault conditions such as power failures affecting multiple ESX hosts simultaneously. Avi Global Server Load Balancing (GSLB) provides resilience when loss of a data center or network connection occurs, routing application traffic across geographically distributed sites. For Kubernetes-based deployments, the Avi Multi-Cluster Kubernetes Operator (AMKO) federation architecture designates a leader cluster and multiple member clusters, enabling disaster recovery coordination for containerized workloads across clusters.

Avi's contribution is scoped to the application delivery and WAF boundary. Organization-wide security, compliance, and resilience design practices that span the full technology stack require additional governance, tooling, and processes beyond Avi's application delivery scope.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control B5.c

Backups: You hold accessible and secured current backups of data and information needed to recover operation of your essential function(s) following an adverse impact to network and information systems.

SCF Controls: BCD-11

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides built-in backup capabilities across its management components, workload layers, and storage subsystems, supporting organizations in meeting their Recovery Time Objectives (RTOs) and Recovery Point Objectives (RPOs).

Management component backups

VCF supports backup of all core management components. VMware vCenter supports both file-based and image-based backup methods, with file-based daily backups configured through the vCenter Management Interface of each vCenter instance. vCenter file-based backup and restore supports FTP, FTPS, HTTP, HTTPS, SFTP, NFS, or SMB as the backup server protocol. vCenter file-based backup optionally encrypts backup files using an encryption password that must be provided during restore; because vCenter backups contain the Key Derivation Key used for vSphere encryption, backup files should be stored on a secured backup server with appropriate access controls. VCF Operations similarly supports file-based and image-based backup methods. NSX Manager uses file-based backup, which VCF Operations configures automatically during the initial bring-up process. File-based backup jobs for VCF Operations and vCenter must be configured separately after deployment.

Scheduled backups should be implemented to prepare for critical failure scenarios, upgrade events, or certificate updates of management components. To capture a consistent state across related components, VCF requires creating a series of coordinated backup jobs that run simultaneously across component nodes. Simultaneous backups of component nodes help ensure that the backed-up state is logically consistent, reducing the need for integrity remediation during a restore. On-demand manual backups can be taken after a successful recovery operation or after a scheduled backup failure. VCF Operations backup is also configured to take a backup on state change, providing an additional layer of protection when configuration changes occur.

The backup file server stores backups from all NSX Manager or Global Manager nodes, and NSX includes a script to automatically delete old backups to manage storage consumption. NSX Global Manager backups should be periodically cleaned up to avoid excessive storage consumption on the backup file server. VCF Operations for Networks can store backups on local storage, retaining up to five backup files, or upload them to SSH or FTP servers. An initial on-demand backup should be performed after configuring VCF Operations to verify that backups complete successfully before relying on scheduled jobs. Sufficient storage capacity must be provisioned to accommodate backup data across all components.

Backup integrity and restore procedures

Backup integrity verification in VCF centers on version compatibility. When restoring a vCenter instance from a file-based backup, administrators must have a valid backup that matches the exact version of the vCenter appliance being restored to. VCF Operations must be available before restoring vCenter, and vCenter must be available before restoring VCF Operations, establishing a defined dependency order for restore operations. These dependencies require careful sequencing during recovery to restore the management plane to a consistent state.

Workload-level data protection

For workload-level data protection, VCF provides several mechanisms. Changed Block Tracking (CBT) tracks modified disk blocks on virtual machines, enabling incremental backups that reduce backup windows and storage requirements. VMware vSphere Storage APIs for Data Protection (VADP) provide a standardized interface for third-party backup solutions to integrate with VCF. vSphere Supervisor supports backup of VM Service VMs through backup partner solutions based on VADP, and if a VADP-based backup solution is deployed on the default management cluster, the solution must be properly

started and operational before starting up or shutting down VCF. Quiesced snapshots are appropriate for automated or periodic backups of VM Service virtual machines, as they capture a consistent state before the backup operation proceeds. VCF Automation supports snapshotting a VM group to create an object that references distinct snapshots for each member VM; restoring a VM group snapshot restores each member of the group.

vSphere Supervisor control plane backup and restore can be performed using vCenter file-based backup and restore from the Workload Management UI. For applications that provide their own backup capabilities, VCF documentation recommends using application-specific backup methods rather than relying on filesystem backup alone.

vSAN data protection and snapshots

vSAN Data Protection allows snapshots to be managed through protection groups with configurable snapshot retention policies and scheduling intervals. The native Snapshot Service is supported by vSAN Express Storage Architecture (ESA) but not by vSAN Original Storage Architecture (OSA). Native snapshots in vSAN ESA are much faster than traditional vSphere snapshots because a base VMDK and its snapshots are contained in one vSAN object rather than being separate objects, allowing more frequent backups and faster recovery. In vSAN OSA, snapshots are separate vSAN objects. The vSAN Distributed File System Snapshot can be used by third-party backup vendors to copy changed files incrementally to a different physical location. The vSAN Snapshot Service API provides programmatic access for operations including creating linked clones from snapshots and restoring deleted virtual machines.

VMware Kubernetes Service backup

VMware Kubernetes Service (VKS) and the Supervisor layer extend VCF's backup capabilities to containerized workloads, cluster state, and persistent volume data. VKS Supervisor backup and restore for cluster node VMs is activated through the vCenter backup feature available in the vCenter Management Interface, integrating Kubernetes cluster state backup with the same management-plane backup infrastructure used for other VCF components.

For workload-level backup of VKS clusters, the platform supports three complementary methods: vSphere Plugin Snapshot (CSI Snapshot), File System Backup (FSB), and the Velero Plugin for vSphere. The vSphere Plugin Snapshot method produces crash-consistent, block-level backups of persistent volumes through the Container Storage Interface (CSI) layer and supports snapshot direct access and network traffic offload; it is faster and less resource-intensive than filesystem backup for complex filesystems with large numbers of small files, making it well-suited for production databases and high-IOPS applications. The File System Backup method operates at the filesystem level, supports NFS volumes and incremental backups where unchanged files are not re-transferred between runs, and offers backup repository features including deduplication, compression, and encryption; it is appropriate for legacy volumes with non-CSI storage. The Velero Plugin for vSphere can back up and restore both stateless and stateful applications running on vSphere Pods in the Supervisor. Platform teams can use both FSB and CSI Volume Snapshots within a single protection strategy to maximize data durability across workload types. VKS cluster backup supports opt-in and opt-out approaches for FSB volume backup, giving operators control over which volumes are included in filesystem-level operations. Third-party backup software can also integrate with VKS clusters using the standard Kubernetes CSI snapshot API: tools create a VolumeSnapshot object from the target PVC, materialize a temporary PVC from the snapshot, and use a Data Mover pod to transfer data to the backup destination. Kubernetes implements Persistent Volume Claim as Snapshot Source Protection, which blocks deletion of in-use API objects while a snapshot is in progress, reducing the risk of partial or inconsistent backup data. Kubernetes also supports provisioning a new PersistentVolumeClaim directly from a VolumeSnapshot by specifying the snapshot as the dataSource, enabling volume-level point-in-time recovery without requiring a full application restore workflow.

VKS cluster management provides a Create backup wizard that allows users to create backups immediately or schedule backups of specified data resources in a cluster. Backup scheduling supports immediate execution, recurring schedule formats with targeted start times, or custom cron expressions; automated backup scheduling can also be configured using the Velero CLI with the `velero schedule create` command, specifying the interval or cron expression for recurring backup operations. For on-demand backups outside a scheduled window, the `velero backup create` command backs up Kubernetes resources and persistent volume data for stateful workloads, with support for per-namespace targeting and volume snapshot inclusion. VKS cluster backups can retain a maximum of 720 backups per backup schedule; when high-frequency schedules are required, the

retention period should be reduced to remain within this limit. Backup schedules can be edited, paused, or deleted through the management interface. File system backups are included in the restore by default, and snapshot data can be moved to a separate backup storage location. Before defining a backup, a target location and credential must be created; if a data protection credential is deleted, scheduled backups relying on that credential will fail on their next execution, creating a detectable gap in backup execution history that administrators should monitor. Creating a backup schedule requires the Organization Administrator or Project Administrator role.

VKS cluster backup and restore operations are managed through the VCF Automation Tenant Portal under Manage & Govern > VCF Services > Kubernetes Management > Clusters > Data Protection. The portal provides restore operations on specific backups, and a dedicated cross-cluster restore capability in the Data Protection tab enables restoring backups from a source cluster to a different target cluster. VKS cluster management supports backup and restore of an entire cluster, selected namespaces from the backup, or specific resources identified by a label. The CloneFromSnapshot CRD includes a status.phase field that tracks restore progress through multiple phases, providing operational visibility during restore operations.

For Kubernetes cluster state, etcd is the backing store for all Kubernetes objects, and clusters using etcd should have a backup plan. etcd backup can be performed using the built-in etcdctl snapshot save command by specifying the endpoint, CA certificate, and client credentials, or by taking a volume snapshot of the etcd storage volume when the underlying storage supports it. etcd snapshots can be restored from a previous snapshot file or from the remaining data directory, and cross-patch-version restores are supported. During kubeadm upgrades, automatic backup folders are written to /etc/kubernetes/tmp containing etcd data and manifests as a recovery point.

Backup automation through APIs

VCF exposes backup automation through its APIs, including the RecoveryBackupJobBackupRequest data structure for specifying backup location, protocol, authorization, and database scope, as well as the RecoveryBackupSchedulesUpdateSpec for programmatically managing backup schedules.

Disaster recovery planning

For disaster recovery planning, VCF supports application disaster recovery with data replication to a secondary site. Organizations should plan and test disaster recovery strategies regularly to meet their RTO and RPO targets. VCF Operations provides integration with VCF Protection and Recovery for periodic test runs to validate that existing recovery plans work with the underlying infrastructure and configured RPO limits. Application disaster recovery may result in some data loss during failover depending on the configured RPO.

VCF directly provides the mechanisms for creating recurring backups, managing retention, and supporting RTO/RPO requirements through multiple backup and snapshot methods. However, organizations must establish backup policies, define RTO/RPO targets, schedule regular restore testing, and maintain backup infrastructure such as external storage and third-party backup solutions to fully satisfy this control.

VMware vDefend (Contributes)

VMware vDefend's Security Services Platform (SSP) provides backup and restore capabilities for the vDefend control plane, covering firewall rules, microsegmentation policies, IDS/IPS configurations, Bare Metal server information, tokens, and all associated security data managed by the platform. These backups protect against data loss from hardware or software malfunctions, data corruption, malware incidents, or unintentional deletion.

SSP supports recurring backup schedules configurable through the Backup Schedule interface, with frequency options ranging from 6 hours to 720 hours (30 days), as well as weekly scheduling by selecting the day and time. Recurring backups can be activated or deactivated by toggling the Recurring setting. Best practice guidance recommends scheduling backups during periods of low platform usage to minimize operational impact. A backup should also be performed before executing scale-out operations on the SSP cluster, to preserve the current configuration state before significant topology changes. Backup data is encrypted with a passphrase and transmitted to an SFTP server. Adequate storage must be verified on the backup server before activating recurring backups, and the platform must be in a healthy state for backup operations to proceed. Backup is also blocked if NSX is not onboarded to SSP.

SSP maintains a Backup History section that displays the status of each backup operation, showing "Completed" when the operation succeeds. When backup or restore operations enter a failed state, pod logs provide detailed error messages, including database query failures and volume attachment errors, to support troubleshooting. Restoration supports deploying the backed-up configuration onto the same SSP instance or a new instance, enabling recovery when the current instance is in a non-recoverable state. Restoration requires that the same NSX instance that was onboarded at the time of backup be used, and that the platform be deployed on the same vSAN datastore and build version as the initial installation. Certificate consistency between backup and restored environments must be maintained to avoid disruptions to NDR Sensor connectivity.

These capabilities address the backup component of this control for vDefend's own configuration and policy data. vDefend does not back up general workload data or application-level information; those responsibilities fall to the broader VCF platform's replication, snapshot, and backup mechanisms, including vSAN Data Protection, Protection and Recovery (PNR), and integration with third-party backup providers. vDefend's contribution is limited to protecting the security policy and configuration data that defines the network security posture of the environment.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides replication, snapshot, and recovery testing capabilities that support recovery point and recovery time objectives for protected workloads.

vSphere Replication delivers host-based continuous replication with RPO configurable from 1 minute to 24 hours, set via a slider during replication configuration. PNR uses the configured RPO to determine the most recent available state to which virtual machines are recovered during disaster recovery. vSAN snapshots and replication is a native, integrated snapshot-based backup solution for VMs running on vSAN datastores, managed through the vSphere Client, and supports RPO as low as 1 minute. Snapshot retention schedules support hourly, daily, weekly, and monthly snapshots with a maximum retention duration of three years. Predefined retention templates are available for quick configuration of RPO and snapshot retention parameters. Array-based replication supports configuring replication schedule, frequency, and RPO through VM storage policies, depending on the storage array's implementation.

PNR replication classes are preconfigured with an RPO that defines the acceptable amount of data loss after a disaster. In deployments using VCF Automation integration, replication classes can be assigned at the organization level.

Cyber Recovery, the cloud-based recovery component within PNR, uses incremental snapshots that transfer only modified or new data to cloud backup. This design enables detection of ransomware encryption by comparing entropy rates between normal snapshots and snapshots containing suspect data. Ransomware recovery plans in Cyber Recovery support predefined retention templates for configuring snapshot RPO and retention parameters.

PNR's own configuration is protected through backup settings that specify a datastore path, enable or disable the backup scheduler, set a retention period, and schedule backup frequency and time. PNR REST APIs can be configured to export and upload configuration data to a datastore on a daily basis. PNR also maintains internal database backups for audit and recovery purposes, covering the replication manager database (srmdb), recovery manager database (vrmsdb), and snapshot service database (snapservice).

Recovery plan testing is the integrity verification mechanism for protected data. During disaster recovery execution, PNR first attempts storage synchronization; if that succeeds, it uses the synchronized storage state to recover virtual machines to their most recent available state per the configured RPO. RPO violation dashboards in VCF Operations report violation counts for incoming and outgoing replications, enabling monitoring of whether replication is meeting defined targets.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides a built-in backup framework for managed PostgreSQL, MySQL, and SQL Server databases, giving administrators and database owners the tools to establish recurring backup schedules aligned with organizational recovery objectives.

Backup configuration is available at database creation and can be modified at any time through the database settings interface. Administrators activate automated backups using the Enable Automated Backups toggle (also exposed as Enable Backups in MySQL flows), specify a backup location pointing to S3-compatible object storage, and define a retention period.

PostgreSQL databases support both full and incremental backups, and SQL Server databases support full and differential backup schedules. SQL Server adds a Log Backup Frequency setting in Advanced Settings with a maximum value of 30 minutes that is directly related to the Recovery Point Objective for that database. Backup schedules are expressed as cron expressions and can be customized per database or applied at the policy level.

Data Service Policies provide centralized backup governance for databases deployed within a namespace. A policy can include named backup jobs specifying backup type and schedule, and the policy backup requirement setting offers three options: Require Automated Backups (databases must have automated backups), Allow Automated Backups (users can choose to activate or deactivate automated backups), and Disallow. Allowed backup locations are defined in the policy via the `allowedBackupLocations` parameter, restricting where backups can be stored. When multiple policies apply, DSM aggregates the backup schedules into a single effective backup policy per database. High Availability clusters require automated backups to be enabled in order to provision databases, helping ensure that recoverable copies exist for replicated topologies.

DSM also supports on-demand backups for primary PostgreSQL databases, independent of the configured automated schedule, which is useful for capturing a point-in-time snapshot before a significant change. Backup storage is managed centrally through the Settings pane Storage Settings tab, which displays Database Backup Storage buckets and allows administrators to add or edit object storage targets. Provider-level control plane backups are stored in a designated Provider Backup Repo bucket configured during Provider VM setup, and recovery of the Provider VM from backup uses the `restore-provider` command with a `pgbackrest.conf` path to restore the appliance to the latest timestamp.

DSM retains automated backups of deleted databases until the configured retention period expires. When a database with configured backups is deleted, the system automatically creates an archive containing all collected backups that remains available in the Archives tab for the remainder of the retention period, allowing recovery of inadvertently deleted databases. Administrators can also manually delete retained backups of deleted databases when they are no longer needed.

Point-in-time recovery is supported from configured backup storage, restoring a backup at a specified date and time to a newly created database VM with a user-specified name and datastore location. The restore function is also accessible through the VCF Automation UI for tenant users. If any incremental backup in a chain is deleted, DSM cannot restore data to points in time that depended on that backup, and a restore from an incremental chain requires the last full backup plus all following incremental backups. Maintaining a balanced schedule of full and incremental backups reduces the risk of a gap in the recovery chain.

DSM provides operational validation of the backup target through the backup storage repository alert, which checks connection and operational status, bucket name, certificate expiration date, credentials, and sufficient available space in the repository. This helps surface configuration drift or storage failures that would otherwise compromise recoverability.

Satisfying this control fully requires that the organization define RTOs and RPOs for each database workload, configure backup policies accordingly, and periodically test restoration to verify that backup data is valid and recovery objectives are achievable. DSM provides the technical backup infrastructure and operational checks on the backup target; RTO and RPO definition and end-to-end backup integrity testing are organizational responsibilities.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) includes a built-in backup and restore capability for the Avi Controller configuration database. The configuration database defines all clouds, virtual services, users, tenants, and related entities. Protecting it is the primary mechanism for recovering the Avi control plane after a Controller failure.

Backup operations can be created on-demand or on a recurring schedule via the Controller web UI, CLI (using the `export` command), or REST API (using the `/api/scheduler/` endpoint). The scheduler supports configurable frequency units, including hourly, daily, and weekly intervals, with the run mode set to periodic. For single-node Controller deployments, enabling periodic external configuration backups is mandatory; the product documentation states that external backups are required to handle recovery from a complete VM or disk failure.

Avi supports multiple backup storage targets. Local backups are stored directly on the Controller with a configurable retention count, configured via the "Enable Local Backups (On Controller)" setting. Remote backups are transferred over Secure Copy

Protocol (SCP) or Secure File Transfer Protocol (SFTP) to an off-Controller server, configured via the "Enable Remote Server Backup" setting. In 9.1, configuration backups can also be stored in Amazon S3 buckets as an additional remote storage target. When deployed as part of VCF, Avi backups are stored by default on the same server used for VCF Operations appliance backups; the recommended best practice is to configure an external SFTP server as the backup destination. VCF Operations can be used to configure the external backup server and storage path for Avi backups. Product guidance also recommends storing backups with clear labeling that includes version and date information.

Before a restore proceeds, Avi performs a set of pre-restore checks to validate the backup image. In 9.1, these checks include verification of backup configuration version compatibility, presence of all file objects from the configuration on the Controller, FIPS mode consistency between the backup and the current Controller environment, Service Engine attachment verification, system configuration validation, and patch verification. All checks must pass before the restore operation is allowed to proceed.

Restore operations can be performed via the CLI (import command with the `keep_uid` option to restore configuration to an empty Controller), the web UI, or the REST API restore endpoint. The API method accepts a configuration file and a passphrase parameter to decrypt an encrypted backup; the passphrase must match the one used when creating the backup. Restore operations generate system reports tracking operation state, start time, end time, duration, and total checks completed. The Controller metrics database can also be exported and imported separately to prevent loss of metrics data during version rollbacks. If all three nodes of a Controller cluster are permanently unavailable, recovery must be performed using a backup and restore procedure.

For multi-site deployments, Avi GSLB (Global Server Load Balancing) supports an Active disaster recovery deployment mode, enabling traffic redirection to a healthy site when a primary site fails. Avi GSLB adaptive replication mode also protects against configuration errors propagating across data centers by preventing faulty configuration objects from being replicated to follower sites.

The Avi backup and restore capability covers the Controller configuration plane. Application data, workload VM images, and the broader RTO/RPO framework depend on organizational process decisions and on the underlying VCF platform for VM-level data protection (see VCF Coverage).

Control B6

Principle B6 Staff Awareness and Training: Staff have appropriate awareness, knowledge and skills to carry out their organisational roles effectively in relation to the security of network and information systems supporting the operation of your essential function(s).

SCF Controls: SAT-02

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control B6.a

Cyber Security Culture: You develop and maintain a positive cyber security culture and a shared sense of responsibility.

SCF Controls: SAT-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control B6.b

Cyber Security Training: The people who support the operation of network and information systems supporting your essential function(s) are appropriately trained in cyber security.

SCF Controls: SAT-03

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control C1

Principle C1 Security Monitoring: The organisation monitors the security status of network and information systems supporting the operation of essential function(s) in order to detect security events indicative of a security incident.

SCF Controls: MON-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides enterprise-wide monitoring through integrated tools that span infrastructure health, performance metrics, compliance assessment, log analysis, and alerting.

VCF Operations continuously monitors the operational state of all VCF components to detect conditions that may affect availability or compliance. It collects metrics across compute, storage, and networking resources, and correlates them over time to identify trends that may lead to potential failures. VCF Health, a component of VCF Operations, continuously monitors the operational state of VCF components to verify they are functioning as expected, giving platform operators a single view of operational status. Platform operators can configure alerts, perform log analysis, run infrastructure diagnostics, and review VCF health from a unified interface.

VCF Operations provides continuous compliance management by monitoring infrastructure against industry-standard benchmarks and custom policies. Administrators can create custom compliance benchmarks that monitor selected alert definitions and policies, tailoring the monitoring posture to organizational requirements. The platform assesses objects based on selected compliance policies and activates alert definitions associated with the current scorecard, providing ongoing visibility into compliance status. Compliance-related alerts are triggered on objects and displayed through a dedicated compliance alert subtype.

The alerting subsystem in VCF Operations supports the full lifecycle of alert management. Administrators can configure and manage alert definitions to monitor infrastructure events and conditions, including performance metrics, log events, and custom conditions configured through the Management Pack Builder. The Platform Health Alerts page provides a centralized view of all alerts related to overall system health, including alerts from data sources and infrastructure nodes. Health alerts are generated for conditions that affect the health of the environment and require immediate attention. Administrators can create policies to govern how alert definitions are evaluated, including which objects to monitor and what thresholds to apply, and can apply consistent practices to optimize alert behavior across monitored objects.

VCF Operations supports flexible grouping and scheduling to align monitoring with operational realities. Custom groups can be configured with automatic membership criteria to support monitoring strategies and achieve a high level of automation. Maintenance schedules can be assigned to objects undergoing planned downtime to keep monitoring data accurate and avoid false alerts when an object is offline for scheduled maintenance.

VCF Log Management provides centralized log collection and analysis. It ingests logs from VMware vCenter, VMware ESX hosts, NSX, vSAN, VCF Automation, VCF Operations, VCF Identity Broker, VCF Operations for Networks, and VCF Operations HCX. VCF Operations and VCF Log Management must be integrated to implement the centralized log collection architecture. The platform provides dashboards and analytics for troubleshooting and security investigation. Log-based alert definitions allow administrators to trigger notifications when specific log patterns appear across monitored systems. Log forwarding to external SIEM or syslog targets is configurable, with support for TLS encryption to protect log data in transit. The vCenter syslog forwarding API supports TCP, UDP, TLS, and RELP protocols. NSX Manager syslog supports TLS and requires port 6514 for encrypted log transmission.

At the vSphere layer, the alarm infrastructure integrates with events and performance counters to provide real-time alerting. The MetricAlarmExpression data object allows administrators to set alarms on specific performance metrics with configurable monitoring intervals and aggregation functions for processing data points. The vSphere Client provides direct visibility into tasks and events for change tracking and troubleshooting. VCF ships with preconfigured vSphere alarms that are active by

default and monitor specific components including the Identity Management Service, Message Bus Configuration Service, ESX Agent Manager, VMware Service Control Agent, vSphere HA host status, and host connection and power state. The vCenter Management Interface provides appliance-level health visibility through an Overall Health badge that reflects one of five states (Good, Warning, Alert, Critical, or Unknown) across all vCenter components, and notifies administrators of available security patches through Critical or Alert badge indicators when automatic patch checks are enabled.

When VCF Automation is integrated with VCF Operations, the Insights dashboard and Alerts tab provide real-time capacity awareness and alert information for VCF Automation objects, giving IT teams visibility into resource usage across both provisioned workloads and the underlying infrastructure. The VCF Automation Monitor tab surfaces deployment health information sourced from VCF Operations, and deployment cards display Last Request Status information that tracks the most recent operation on each deployment (Create, Update, or Delete) and its outcome (Successful, In Progress, or Failed). The Management Pack Builder allows administrators to set up event definitions for integrated systems, monitoring specific conditions or thresholds and configuring alerts for proactive management. Management Packs extend monitoring to network devices, including sensor monitoring for devices such as switches and routers. Adapters can be installed on VCF Operations nodes to extend monitoring to additional systems and data sources beyond the core VCF components.

The VMware Kubernetes Service (VKS) layer of VCF extends enterprise monitoring to container workloads and Kubernetes infrastructure. VKS clusters support MachineHealthCheck objects for both control plane nodes and worker node deployments; administrators manage these through the VCF CLI `vcf cluster machinehealthcheck` command, which supports configuration of unhealthy-condition definitions, maximum unhealthy thresholds (expressed as an absolute number or a percentage), and label selectors to target specific machines. The VCF CLI `vcf cluster machinehealthcheck node get` and `vcf cluster machinehealthcheck control-plane get` commands retrieve node and control plane health status on demand. VKS cluster health conditions, including the Ready and ControlPlaneReady status indicators, reflect the operational state of each cluster and are accessible via `kubectl` and the VCF CLI. The VCF Automation Provider Management UI includes a Services overview interface that exposes VKS cluster management functions and the health status of all cluster elements, giving platform operators a centralized view of the VKS tier. The Kubernetes API server within VKS clusters exposes diagnostic and health check endpoints (`/healthz`, `/livez`, `/readyz`, `/statusz`, and `/metrics`) that external monitoring systems can scrape to track API server availability and readiness; the `kube-apiserver` also emits the `kubernetes_healthchecks_total` counter and `kubernetes_healthcheck` gauge metric, which report structured health check status for components including `etcd` and `autoregister-completion`. Access to these monitoring endpoints is governed by the built-in Kubernetes system:monitoring RBAC group, which grants read access to liveness, readiness, and metrics endpoints while restricting broader cluster access. The Kubernetes Watch API allows monitoring tools to track changes to any API object as a live stream, supporting event-driven monitoring without continuous polling. The Node Problem Detector monitors node health and surfaces node-level problems as Kubernetes events and node conditions that external monitoring systems can consume via the event stream.

For workload-level monitoring within VKS clusters, Prometheus Operator is available as a standard package and defines custom resource definitions to deploy and manage Prometheus and Alertmanager StatefulSets, enabling high-availability alerting configurations. The Prometheus Alertmanager custom resource definition configures alert grouping, inhibition, and routing to external notification systems. The Istio service mesh, also available as a standard package on VKS clusters, provides service-level monitoring alongside its traffic management capabilities. The Dynatrace Operator can be deployed on VKS clusters to automate the deployment, scaling, and maintenance of the Dynatrace monitoring stack. Historical analysis, dashboarding, and alerting on cluster-level metrics require a dedicated monitoring solution configured to scrape the VKS metrics endpoints and subscribe to the Kubernetes event stream. The `vcf cluster support-bundler create` command gathers diagnostic information from Supervisor and VKS clusters when troubleshooting is needed.

At the network layer, NSX provides monitored indicators including node uptime status, deployment status, management and controller connections, tunnel status, PNIC status, and uptime duration. NSX time series APIs allow viewing data such as VPN statistics, including metadata about the number of tunnels configured and how many are up or down at a given time.

VCF Operations also supports self-monitoring through the VCF Operations adapter, which collects internal metrics such as activity success counts. This allows administrators to verify that the monitoring platform itself is functioning correctly. The VCF

Operations policy engine monitors conditions and generates events to react to changing states in the orchestrator server or connected technologies. The Adapter Instance monitoring interval is configurable, with intervals as granular as five minutes.

VMware Private AI Services (PAIS) includes a built-in observability stack that supplies monitoring data for AI infrastructure and AI workloads. PAIS Controller metrics are exposed at a Prometheus metrics endpoint on the `pais-controller-manager` service, allowing collection by monitoring systems and visualization in observability platforms such as Grafana. Observability is activated by updating the `PAISConfiguration` custom resource with optional sections for Prometheus metrics collection and LLM trace forwarding. The Prometheus runtime can be configured with a specified storage class policy and a configurable metrics retention period, giving administrators control over how long monitoring data is stored. A Prometheus server pod must be in a ready and running state for observability to function.

LLM trace data from PAIS can be forwarded to an OpenTelemetry Collector endpoint over `http/protobuf` or `gRPC`, providing distributed tracing for AI model inference activity. The `observability.llmTraces` configuration governs trace forwarding and works alongside the Prometheus metrics pipeline to produce two signals: metrics for health and performance, and traces for inference-level behavior. PAIS Controller metrics include the Model Endpoint Controller and PAIS Configuration Controller, giving monitoring platforms component-level visibility into PAIS operations.

In 9.1, PAIS adds direct integration with VCF Operations. The `controller-pod-metrics-streaming` setting activates streaming of PAIS controller pod metrics from the Supervisor cluster to VCF Operations, allowing administrators to view PAIS metrics alongside other VCF infrastructure metrics. A Telegraf deployment in the `vmware-system-monitoring` namespace uses a `telegraf-user-config` ConfigMap to manage user-configured monitoring endpoints for PAIS. The VCF Consumption CLI connects to the Supervisor endpoint and enables VI administrators to stream metrics from the PAIS controller pod. DevOps engineers can visualize health and performance metrics for PAIS components running in a VCF Automation namespace using Grafana, and MLOps engineers and application developers can monitor the health, quality, and behavior of AI applications and the models used in agents through the same observability platforms.

PAIS supplies the technical monitoring mechanisms this control requires. Enterprise-wide orchestration of monitoring controls, including alert threshold definition, escalation procedures, and integration with a centralized monitoring or log management platform, remain organizational responsibilities.

VMware vDefend (Contributes)

VMware vDefend (vDefend) supports network security monitoring through multiple integrated capabilities that contribute to enterprise-wide monitoring frameworks.

Security Intelligence, hosted on the Security Services Platform (SSP), provides continuous visibility into network traffic flows across protected workloads. It monitors flows between application pairs, updates the Policy Protection Status for each application to indicate that flows are being monitored, and continuously detects new flows between environment pairs, alerting administrators to unauthorized or unexpected traffic. The Monitor & Plan Overview page presents a consolidated view of pending actions, data collection activity status, network security posture, flow trends, and a summary of suspicious traffic. The Security Intelligence Recommendations monitoring capability checks for changes in the scope of monitored entities every hour when the Monitoring toggle is enabled, allowing administrators to keep policy recommendations current as environments evolve. Segmentation Monitoring provides dedicated views of application and infrastructure flows with configurable time ranges spanning from the last hour to the last month, and displays flows related to detected infrastructure servers in a specified time interval.

The Network Detection and Response (NDR) Sensor checks the status of activated detection features every 15 minutes and updates its configuration accordingly, supporting sustained threat detection coverage. NDR Sensor health status monitoring tracks whether key components, including network traffic capture, file analysis, and data transmission, are operating properly. The NDR Sensor also sends alerts notifying administrators of conditions such as services being down, high CPU, memory, or disk usage, packet drops, or missed heartbeats. NDR provides role-based access control covering triage operations such as viewing detections and campaigns, as well as SIEM configuration management.

The Security Services Platform monitors its own health, with Yellow or Red health status indicators displayed when issues occur in subcomponents. SSP monitoring tracks the status of the flow clustering job that runs every hour and reports

suspicious traffic detector execution status after each run, with values such as SUCCESS, NOT_ENOUGH_BASELINE, and FAILURE.

The Security dashboard provides a consolidated view for monitoring and configuring security features across network workloads. In federated deployments, the Global Manager provides centralized event management and monitoring for malicious IP blocking activity across all Local Managers.

vDefend generates Unified Security Logs that VCF Log Management can collect and analyze. These logs cover Distributed Firewall, Gateway Firewall, Identity Firewall, FQDN Analysis, TLS Inspection, Intrusion Detection/Prevention System (IDPS), and URL Filtering activity. Broader log aggregation and SIEM correlation for enterprise-wide monitoring remain the responsibility of the SIEM and logging infrastructure deployed alongside vDefend.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides monitoring capabilities specific to the disaster recovery domain and integrates with the broader VCF monitoring ecosystem through dedicated Protection and Recovery dashboards in VCF Operations. VCF Operations collects configuration, component health, and usage information from protection and recovery servers and site pairs, presenting this through an overview dashboard that displays all site pairs, configurations, health scores, and protection and recoverability status for sites and virtual machines. PNR provides default health alerts for protection groups, recovery plans, cloud file systems, recovery SDDCs, and protected sites through VCF Operations, and the dashboards surface alerts informing administrators about configurations and deployments that require attention. Separate dashboard views cover vSAN Snapshots and Replication monitoring, and an Inventory view provides health status, metrics, alerts, and network topology for all monitored objects.

Within its own domain, PNR provides event logging and configurable alarms for replication and recovery operations. Administrators can create alarms that trigger on specified event conditions, with support for email notifications, SNMP traps, or script execution in response. PNR monitors connections between sites by sending periodic ping requests, logs connection check events, and generates alarms when broken connections are detected. The alarm system generates warning-level alerts for expired snapshot schedules, replication errors such as missing VMs, and connectivity issues with protected and target sites. PNR also monitors resource consumption on the Protection and Recovery Server host and raises alarms when configurable resource thresholds are reached.

PNR includes a health monitoring service that checks each health finding every five minutes and records a timestamp at each check. Health findings are tracked with status history that can be reviewed over configurable time periods, defaulting to a 24-hour window. The Protection and Recovery Appliance supports syslog forwarding to a remote syslog server for log analysis and centralized monitoring, allowing appliance-level events to flow into existing log management infrastructure.

The Clean Room Orchestrator, part of PNR's Cyber Recovery capabilities, supports monitoring of clean room events, tasks, and alarms for recovery operations. Clean Room Orchestrator can forward events to VCF Operations, Microsoft Sentinel, or Splunk Cloud for centralized monitoring, supporting organizations that require DR event data to flow into enterprise SIEM and log management platforms as part of a broader monitoring strategy. The Clean Room Orchestrator integrates with endpoint detection and response tools, including CrowdStrike and Carbon Black sensor appliances, for threat detection within isolated recovery environments.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to enterprise-wide monitoring controls through a layered set of observability capabilities covering database health, infrastructure compliance, and event-driven alerting.

DSM provides a built-in monitoring framework that tracks database instance health across multiple dimensions. From the Monitoring tab in the DSM UI or the vSphere Client, administrators and authorized users can view real-time and historical metrics for database VMs, including CPU Health, Data Disk Health, System Disk Health, Max Connections, Active Connections, Write Throughput, Read Throughput, Thread Resource Utilization, Slow Queries per Second, InnoDB Buffer Usage, and InnoDB Reads and Writes. The Monitoring page defaults to the last three hours of aggregated metric data, with the time range

adjustable through the Time Range Last dropdown. This visibility supports detection of resource contention, performance degradation, and connectivity anomalies at the database layer.

DSM's alert framework provides configurable thresholds for warning and critical conditions on key health indicators. Administrators and users can set separate warning and critical thresholds for CPU Health, Data Disk Health, System Disk Health, and Max Connections parameters. When thresholds are exceeded, DSM generates typed alerts such as Database Engine Health, Custom Config Health, and Backup Storage Health alerts. DSM monitors database replication status and raises an alert when a secondary database is not replicating data from the primary. DSM also raises an alert when metrics are no longer being received from a cluster, supporting detection of monitoring gaps. Alerts can be activated or deactivated per data service through the "Enable Alerts for DB Alert" setting, providing granular control over which databases are subject to active alerting. For each alert, DSM provides mitigation suggestions to help administrators resolve issues without disrupting database services.

In addition to database-level alerts, DSM generates global infrastructure alerts that surface vCenter integration and infrastructure policy issues. These include `INFRASTRUCTURE_POLICY_VC_ALARMS`, raised when vCenter resource alarms are active; `INFRASTRUCTURE_POLICY_CLUSTER_COMPLIANT` and `INVALID_SUPERVISOR_INFRASTRUCTURE_POLICY_STATUS`, which reflect cluster compliance state; `VCENTER_CONNECTIVITY`, raised when vCenter connectivity fails and triggering troubleshooting steps that include verifying connectivity and checking authentication logs; and `LicensingNotUpdated` and `vCenterBinding` API status alerts that surface license and API integration conditions. A Global Alerts page in the DSM UI provides a centralized view of these alerts during and after installation and ongoing operation.

In 9.1, DSM integrates with VCF Operations to extend observability beyond the DSM UI. When configured, VCF Operations automatically discovers and monitors PostgreSQL and MySQL clusters in the Ready state and displays a Data Services View dashboard showing active alerts and inventory items. VCF Operations presents performance data across three levels: cluster-level for overall health, node-level for infrastructure resource use, and database-level for KPIs including Active Connections, Commits, Rollbacks, and Deadlocks. This integration requires configuring the connection between DSM and VCF Operations before use.

DSM also adds SQL Server as a supported database type, with dedicated monitoring through an integrated InfluxDB instance and Telegraf agents deployed across the provider appliance and SQL Server workload clusters. The monitoring framework supports metrics-based and status-condition-based alerts for SQL Server, covering database engine degradation, non-operational status, and automated or transaction log backup failure conditions.

DSM supports event notification to external systems through a webhook integration. Webhooks transmit alert notifications containing the triggered date, triggered time, triggered user email, task status, previous status, and task type. This allows DSM alerts to feed into centralized monitoring or incident management platforms maintained by the organization. DSM generates plug-in registration logs that administrators can review for vCenter connectivity errors, and DSM's troubleshooting guidance directs administrators to review active vCenter infrastructure alarms and resolve underlying issues identified through the alert system.

Enterprise-wide monitoring requires organizational decisions about monitoring architecture, log aggregation platforms, alerting policies, and operational response procedures that lie outside DSM's scope. DSM provides the data and integration points; the organization must determine how those signals are collected, correlated, and acted upon across the broader environment.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) contributes to enterprise-wide monitoring through application-delivery-layer mechanisms built into the Avi Controller and Service Engines.

The Avi Controller monitors Service Engine metrics and sends alarms and notifications to administrators when resource utilization data exceeds defined thresholds. Administrators configure custom thresholds on Service Engine groups through the Resource Events tab in the Avi UI. The Alert feature processes system events and metrics against user-defined rules and generates alerts that trigger configured actions, including sending an email, a syslog message, or an SNMP trap. Alert

notifications can be forwarded to remote syslog servers for integration with centralized log management and monitoring platforms.

ControlScripts extend this event-response capability: a ControlScript can alter Avi configuration or communicate to external systems, including through webhook integrations with external monitoring tools, in response to defined system events. This supports dynamic responses including resource scaling or automated notifications based on health scores from monitoring data.

The Avi Controller and Service Engines track health score changes and SSL certificate expiration events. Avi integrates with external monitoring tools such as Prometheus for metrics collection and analysis. User-Defined Metrics allow administrators to define and extract customized telemetry data for specific compliance or reporting needs through the API. Real-time metrics are available via API but deactivate by default after 30 minutes to conserve resources and must be reactivated when sustained real-time visibility is required.

At the data plane, Avi health monitors track the status of backend servers and Service Engines continuously. Service Engine health monitoring records detailed server operational status, including health monitor name, type, last transition timestamps, rise count, fall count, total checks, and total failed checks. Each health monitor can be assigned its own threshold and timeout period for server health validation. Monitors support HTTP, HTTPS, TCP, and UDP health-check protocols with configurable success and failure thresholds, send intervals, and receive timeouts.

In Kubernetes environments managed by the Avi Kubernetes Operator (AKO), the HealthMonitor custom resource definition (CRD) allows users to define custom health monitoring configurations for backend services with fine-grained control over health check parameters. The Avi Multi-Cluster Kubernetes Operator (AMKO) GlobalDeploymentPolicy supports health monitor references for consistent monitoring across multi-cluster deployments. Within VCF Automation, a HealthMonitor custom resource can create monitors for tracking backend pool member status using TCP, PING, and HTTP check types.

Control C1.a

Sources and Tools for Logging and Monitoring: The data sources and tools that you include in your logging and monitoring allow for timely identification of events which might adversely affect the security or resiliency of network and information system(s) supporting the operation of your essential function(s).

SCF Controls: MON-01.4, MON-01.8, MON-03

Aggregate Coverage: Meets

VCF (Meets)

VCF provides layered event logging, continuous monitoring, and alerting capabilities across all platform components, supporting ongoing review of security events and incident escalation.

VCF Operations delivers continuous monitoring through its event auditing capability, which provides visibility into platform interaction changes across the infrastructure and surfaces suspicious access events and policy violations. Audit events tracked by VCF Operations include user searches, logins, logouts, capability checks, and configuration modifications, with each interaction generating a corresponding audit record. A dedicated audit events view gives operators a consolidated perspective on authentication and security-related activity across the environment. The audit events framework captures interactions across vSphere, vSAN, and NSX resources, so security-relevant actions are registered for review.

Centralized log collection is handled by VCF Log Management, which collects log data from VMware vCenter, VMware ESX hosts, NSX, and other VCF components. Administrators can search and filter log events by timestamp, source, text, and structured fields. VCF Log Management includes content packs for VCF components that provide pre-built dashboards, alerts, and queries organized by use case, giving immediate visibility into authentication failures, privilege changes, configuration modifications, and other security-relevant events. A dedicated NSX content pack provides alerts for NSX environment monitoring. VCF Log Management can be configured to pull tasks, events, and alerts from vCenter instances and receive syslog feeds from ESX hosts. vCenter can also stream events directly to a remote syslog server by enabling the `vpxd.event.syslog.enabled` option in the vCenter Management Interface, providing a direct path to external SIEM or log management systems. ESX hosts support configurable syslog log levels and can forward syslog messages to a remote log server using `esxcli` commands. The `Syslog.global.auditRecord.remote` parameter specifically controls whether ESX audit records are forwarded to the remote syslog host defined by `Syslog.global.logHost`, allowing auditors to verify that security-relevant audit records reach the centralized log collection infrastructure. NSX components record security-related events in audit logs stored at `/var/log/audit/audit.log` and send audit logs directly to configured remote syslog servers. NSX also provides security compliance events documented in the NSX Event Catalog. VCF Operations integrates its own audit log with syslog and can forward user activity audit logs to an external syslog server to support security auditing requirements.

Within VMware Kubernetes Service (VKS) clusters and vSphere Supervisor, the Kubernetes API server produces structured audit records for all API interactions. Each audit event captures the audit level, a unique audit ID, the requesting user, the target resource and namespace, the source IP address, the operation performed, and the stage of request handling at the time the record was generated. An audit policy controls which verbs and resource types are recorded and at what level of detail, allowing administrators to scope coverage to security-relevant operations. The Kubernetes audit logger records actions taken by the API for later analysis. Audit records can be written to a local file by mounting a policy at `/etc/kubernetes/audit-policy.yaml` with logs written to `/var/log/kubernetes/audit/`, and node log agents can collect and forward them to a central log store as part of the observability pipeline. Kubernetes system component logs, including those from the API server, controller manager, and scheduler, record cluster events with configurable verbosity, providing coarse-grained error reporting up to fine-grained step-by-step traces. Application and system logs together give a chronological record of events inside workloads and security-related activities, and should be routed to an external SIEM or log management platform to make ongoing review feasible at scale. Pod Security Admission, when configured in audit mode for VKS clusters running VKr 1.25 and later, adds an audit annotation to the audit log entry for each security policy violation without blocking the workload, creating a reviewable trail of policy deviations. The Kubernetes seccomp facility supports the `SCMP_ACT_LOG` action, which allows syscalls to

execute while logging each to syslog or auditd; an audit.json seccomp profile can log all syscalls of a process for detailed syscall-level visibility. Audit rules can be written to alert on specific security-relevant events, such as concurrent reading of multiple Secrets by a single user.

For log forwarding from the VKS and consumption layer, administrators can apply the LogAgentConfiguration Custom Resource to a vSphere Namespace to stream workload logs to a remote syslog server. Syslog messages from vSphere Pods include metadata fields for namespace name, pod UID, pod name, container name, and ESX host name, providing the context needed to correlate pod events with platform-level audit records. VKS clusters support the Fluent Bit standard package, which can forward logs to Syslog, HTTP, Elasticsearch, Kafka, and Splunk endpoints, giving operators a direct path to route VKS log streams into external SIEM or log management systems alongside VCF platform logs. Fluent Bit on VKS clusters collects Kubernetes API Server audit logs in JSON format, Linux authentication logs, and container runtime interface logs through configurable parsers and filters. On vSphere Supervisor control plane nodes, Fluent Bit collects kube-apiserver audit output from /var/log/vmware/audit/kube-apiserver.log using the tag audit.apiserver.*, with local buffering at /var/log/vmware/fluentbit/flb_audit_apiserver before forwarding to configured destinations. VM Operator logs within VKS clusters record reconciliation events for VirtualMachineService resources and VM creation failures, extending operational event visibility to the workload layer.

For alerting and escalation, VCF Operations classifies alerts by impact into three categories: Health alerts indicate problems requiring immediate attention, Risk alerts indicate problems that must be addressed before they become health issues, and Efficiency alerts identify areas where resources can be reclaimed or optimized. The Platform Health Alerts page provides a centralized view of all health-related alerts across data sources and infrastructure nodes, and alerts can be filtered and sorted by severity on the dashboard. Alert definitions can be created against log events and metrics, and when an alert fires, it presents the triggering symptoms along with recommendations for resolution so operators can evaluate the event and take action. Custom alert definitions allow organizations to tailor monitoring to their specific escalation criteria. VCF Operations also activates alert definitions within compliance policies, assessing objects against selected compliance standards and triggering alerts when deviations are detected. Administrators can create custom compliance benchmarks that monitor selected alert definitions and policies, tailoring the alerting posture to organizational requirements.

VCF Operations supports multiple outbound notification methods for incident escalation: Standard Email, SNMP Trap, Webhook Notification, Slack, and ServiceNow Notification plug-ins all support notification rules. Notification rules can be configured with payload templates to route specific alert types to the appropriate teams or external incident management systems. Syslog forwarding from all VCF components enables integration with external SIEM platforms for organizations that centralize event review and incident escalation in those systems.

The Troubleshooting Incidents page provides a summary of all incidents, including status, entity counts for in-progress incidents, and counts of top root causes, giving operators a consolidated view for ongoing event review. Predefined dashboards are complemented with out-of-the-box customizable alerts and reports to assist with operational awareness.

VMware vDefend (Contributes)

VMware vDefend generates security event logs across its Distributed Firewall (DFW), Gateway Firewall (GFW), and IDS/IPS components. In 9.1, vDefend integrates with VCF Log Management, which collects Unified Security Logs covering DFW, GFW, Identity Firewall, FQDN Analysis, TLS Inspection, IDPS, and URL Filtering events in a consolidated stream suitable for forwarding to external SIEM platforms.

The Security Overview Dashboard's Threat Event Monitoring tab provides ongoing visibility into security issues across the data center, displaying statistics on Malicious IPs, Top Blocked IPs, Top VMs Accessing Malicious IPs, and Top Blocked Categories. Administrators can filter the view by All Traffic, Distributed Only, or Gateway Only events, and a trend graph shows intrusion events over time categorized by Intrusion Severity.

The dedicated IDS/IPS Security Dashboard supports event monitoring for both Distributed and Gateway deployments. Intrusion events can be filtered by Attack Target, Attack Type, and CVSS score threshold to focus review on the highest-priority activity. IDS/IPS events can also be exported directly to syslog by enabling the ids_events_to_syslog setting on ESX hosts, providing centralized log collection through existing syslog infrastructure independent of the NDR component; this

setting is disabled by default and must be explicitly enabled. In 9.1, vDefend IDS/IPS and Network Detection and Response (NDR) support date range filtering for event detail review through the Intelligent Assist triage interface, enabling temporal analysis of security events and intrusion attempts.

Security Intelligence, accessible through Security Explorer, provides a View Full Event History capability that surfaces all events associated with a given signature ID along with their intrusion severity, supporting focused review of specific threat patterns. File event statistics are available through the Threat Monitoring dashboard in Security Services Platform, with graphs filterable by configurable time period.

NDR collects and analyzes security event data for real-time monitoring and supports SIEM integration for centralized event management. The organizational processes of reviewing logs on an ongoing basis and escalating incidents in accordance with defined timelines and procedures must be established and managed outside vDefend through SIEM tooling and documented response procedures.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) generates structured audit events and alarm notifications across its disaster recovery components, providing the event sources and escalation mechanisms that support ongoing security event monitoring.

PNR supports event logging where each event type has a corresponding alarm that can trigger when the event occurs. Events carry three severity levels: Info for normal operational information, Warning for conditions requiring attention that do not affect system operation, and Error for failed operations. Event records include timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. Audit events for user actions include the event name, user identity, and source IP address. vSphere Replication maintains a dedicated audit log at `/opt/vmware/support/logs/hms/hms-audit.log` and records login events with timestamps, user identity, session keys, and locale information. Authorization error messages include timestamps and component information to support security event tracking.

PNR audits changes to protection configurations: it logs when consistency groups are added to protection groups as Info-level events and when protected consistency groups enter error or warning states as Error-level events. PNR monitors connections between sites by sending periodic ping requests and logging Site Status Events that reflect the connection state between protected and recovery sites. vSphere Replication generates typed audit events when virtual machines and hosts are configured or unconfigured for replication. The PNR health monitor service checks each health finding every five minutes and raises Warning-status alerts for expired snapshot schedules, replication errors such as missing VMs, and site connectivity issues.

Alarms can be configured to send email notifications, SNMP traps, or execute scripts when specified event conditions are met, allowing DR events to feed into established incident response and escalation procedures. PNR maintains an Alarms list that provides a searchable, severity-filterable history of notifications that required attention, supporting periodic review.

VCF Operations collects configuration, component health, and usage information from PNR servers and site pairs to populate Protection and Recovery dashboards. These dashboards display alerts about configurations requiring attention and health status for protection groups, recovery plans, cloud file systems, recovery SDDCs, and protected sites. The Inventory view provides object-level monitoring of health status, metrics, and alerts across all protected objects.

The Clean Room Orchestrator maintains a global collection of events, tasks, and alarms for ransomware recovery operations. Event forwarding from PNR to VCF Log Management (version 9.0 and above) is supported for centralized log collection and review.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) provides several capabilities that support ongoing event log review. The primary interface for reviewing non-database-related operations is the System Audit Events view, accessible through the System Audit section of the Provider interface. This view records and displays DSM management-plane operations in a structured format, including the Component field (which DSM component performed the operation), Event Type (the type of audited event or operation), Event Details (operation-specific details for the event), Event Time in UTC, Status, and Source. The Source field

records either a user identifier (Email ID) for user-initiated events or "System" for events initiated by DSM without user intervention. Administrators can review these events directly in the UI or export them in CSV or XLSX format using the ACTIONS drop-down menu in the System Audit Events view. Exports include all audit events visible to the reviewing user, regardless of how many events appear on a single page, enabling complete off-platform analysis and reporting.

In addition to the System Audit Events view, DSM provides Gateway Audit Logs accessible through the Audit Logs section. Gateway Audit Logs track user read and write operations to DSM data services and infrastructure objects performed in the DSM UI or the DSM Gateway Kubernetes interface. Gateway audit log files are stored on the Provider VM at `/var/log/tadm/provider/audit/` with filenames in the format `gateway-audit-timestamp.log`, and are retained for the last five days on the Provider VM. When a default S3 provider log repository is configured, DSM archives these files periodically to an S3 subpath named "gateway audit," supporting log retention for ongoing and retrospective review. The gateway audit logs contain standard Kubernetes audit events but do not record the content of secrets.

DSM generates a structured set of alerts to support proactive monitoring and help surface conditions that may require investigation. At the infrastructure level, DSM raises an `INFRASTRUCTURE_POLICY_VC_ALARMS` alert when one or more active infrastructure resource alarms are detected in VMware vCenter, and generates alerts for vCenterBinding API status and LicensingNotUpdated conditions. DSM also generates a `VCENTER_CONNECTIVITY` alert when vCenter connectivity fails; troubleshooting steps include verifying vCenter connectivity, checking vCenter authentication logs, and verifying that the service account is not locked. At the database level, DSM provides an Alerts pane in the Monitoring tab where administrators can monitor alerts triggered on databases, covering conditions such as CPU Health, Data Disk Health, System Disk Health, Max Connections, Custom Config Health, and Database Engine Health. Administrators can configure and edit alert threshold values and time limits for warning and critical severities on these conditions, allowing organizations to tune alerting sensitivity to their operational requirements. DSM supports webhook-based alerting for database monitoring events triggered by threshold violations, enabling integration with external notification systems.

Organizations that deploy the VCF Operations integration can extend monitoring visibility. When configured, VCF Operations automatically discovers and monitors PostgreSQL and MySQL clusters in the Ready state, displays active alerts and inventory items on the Data Services View dashboard, and surfaces performance data at three levels: cluster-level for overall health, node-level for infrastructure resource use, and database-level for database-specific metrics such as Active Connections, Commits, Rollbacks, and Deadlocks.

DSM provides the audit event records, alert generation, export capabilities, log archival, and optional VCF Operations integration needed to support a log review program. The review cadence, escalation thresholds, escalation workflows, and incident management procedures are organizational responsibilities that must be defined and operated separately. Integration with a SIEM or centralized log management platform is also an organizational decision.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer provides a multi-layer event logging and alerting infrastructure that gives organizations the data needed to support ongoing security event review and incident escalation.

Avi's Event Logs record detailed information about system activities, configuration changes, and operational events, including the identity of users who made configuration changes and the timestamps of those changes. The Config Audit Trail provides a filtered view of this event stream, isolating configuration changes and user activity events over a selectable time period to support both real-time review and retrospective audit. The Avi Controller and Service Engine track health score changes and SSL certificate expiration events, extending automated monitoring beyond configuration activity.

At the application layer, the WAF captures security events through App Log Analytics when a WAF Application Rule is triggered, recording information about the type of attack detected. WAF logging supports granular audit log parts, including matched XSS data with variable name and matched content (using the `ctl:auditLogParts=+E` configuration). Avi DataScript supports logging of security events such as blocklisted IP access attempts using the `log()` function, enabling custom event capture for virtual services. Avi Controller also logs denial-of-service attack events with event details including event identifier, attack count, threshold values, and alert level.

For external integration, Avi forwards events to SIEM platforms and monitoring systems through multiple channels. The Syslog-Audit-Persistence alert action template streams audit events to external syslog servers to support audit compliance requirements. Alert notifications can be delivered by email, SNMP trap, or custom API webhooks, notifying administrators of security events as they occur. Avi Controller and Service Engine log audit records for trusted channel initiation, termination, and failures to Events, Syslog, and Splunk. The Avi Application Security Report gives security teams a consolidated view of overall security posture, threat monitoring, and audit-ready records.

Administrators should be aware that debug logs and Event Logs are not forwarded through OS-level syslog configuration; Event Logs require the Avi-specific Syslog-Audit-Persistence mechanism to reach external syslog servers. Syslog notifications push alerts to syslog servers but do not automatically export virtual service logs; those must be pulled via API or scripted for delivery from the Controller to a remote log server.

Control C1.b

Securing Logs: You hold log data securely and grant appropriate user and system access only to accounts with a business need. Log data is held for a suitable retention period, after which it is deleted.

SCF Controls: MON-08, MON-10

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several technical mechanisms that help protect event logs from unauthorized access, modification, and deletion, though full satisfaction of this control requires organizational policies and additional tooling beyond the platform itself.

Remote syslog forwarding is the primary mechanism for protecting log integrity across the VCF stack. VMware ESX hosts can be configured to send syslog messages to a remote log server using the `esxcli system syslog config set` command, specifying the target server IP and port. The `Syslog.global.auditRecord.remote` parameter specifically controls whether ESX audit records are forwarded to the remote hosts defined by `Syslog.global.logHost`, providing a dedicated configuration knob for audit record remote transmission separate from general message forwarding. The NSX networking components send audit logs directly to the configured remote syslog server, separating them from the local syslog file and storing them in `/var/log/audit/audit.log` on the local host. NSX API audit logging is always enabled and cannot be disabled, providing a persistent record of all API-driven administrative actions. VCF Log Management can be configured to pull tasks, events, and alerts from VMware vCenter instances and receive syslog feeds from ESX hosts, acting as a centralized log aggregation point within the VCF environment. VCF Operations itself integrates its audit log with syslog and supports forwarding user activity audit logs to an external syslog server. VCF Operations HCX similarly supports configuring a remote syslog server so that logs generated on both the HCX manager and appliance virtual machines are forwarded off-host.

Log forwarding supports encrypted transport to protect log data in transit. NSX Manager syslog supports the TLS protocol and requires port 6514 to be open on both the NSX Manager and the remote log server for TLS-encrypted log transmission. The vCenter syslog forwarding API supports TCP, UDP, TLS, and RELP protocols, and Foundation Load Balancer syslog communication requires a certificate for secure log forwarding. vCenter event streaming to a remote syslog server is separately enabled through the `vpzd.event.syslog.enabled` option in the vCenter Management Interface, providing a dedicated control for event export independent of the syslog API.

By forwarding logs to remote collection infrastructure, VCF reduces the risk that a compromised host or component could modify or delete its own log records. The local copies remain on each component, but the remote copies provide an independent record that local administrators cannot alter.

Access controls on log data are handled through the role-based access model within each VCF component. Access to VCF Log Management is governed by role-based access controls, restricting who can view and manage log data. Within VCF Operations for Networks, only users with the Admin role can view audit logs and configure whether personally identifiable information is included in those logs. For Windows-based domain controllers in the environment, read-only security log access can be enabled, and membership in the Event Log Readers group governs which accounts have permission to read event logs. The NSX documentation notes that core files and audit logs may contain sensitive information such as passwords or encryption keys.

VCF Operations provides an Audit Events page accessible through the Security menu, where administrators can review audit records that capture interactions within the platform including searches, logins, logouts, capability checks, and configuration modifications. Audit logs across VCF Operations capture actions from the API, user interface, and CLI, including regular create, read, update, and delete operations as well as login and logout events. VCF Operations audit data can be filtered by user ID, user name, authentication source, session, client IP, category, and message, supporting targeted review of specific activities. VCF Operations for Networks audit logs similarly capture API, UI, and CLI actions. These audit records include structured metadata such as timestamps, thread identifiers, source IP addresses, log levels, and component class names.

NSX audit logs use a structured syslog format with an audit flag (audit="true") in the structured-data field to distinguish security-relevant events from operational messages. Dedicated log files separate audit records: nsx-audit.log contains all messages with the audit flag, while nsx-audit-write.log contains messages flagged as both audit and update operations. NSX audit log messages include metadata fields such as component identifier, log level, request ID, split ID, and subcomponent classification, and each API-associated audit log entry includes a request ID parameter (req-id) to identify a specific API call. NSX logs all auditable events to support compliance requirements.

The Consumption layer of VCF, comprising VMware Kubernetes Service (VKS), vSphere Supervisor, and vSphere namespaces, adds its own audit logging mechanisms that extend event log protection to the Kubernetes control plane. The Kubernetes API server generates a security-relevant, chronological audit log documenting all actions in the cluster, including activities from users, applications using the Kubernetes API, and the control plane itself. Each audit event in the audit.k8s.io API group carries structured fields including apiVersion, kind, level, auditID, and stage, along with an AuthenticationMetadata block that records impersonation constraints when constrained impersonation was used to authorize a request. Audit event delivery is configured through the kube-apiserver --audit-log-path and --audit-log-mode parameters; the delivery mode defaults to blocking, which writes each event synchronously before the API server returns a response, reducing the risk of event loss under load. An audit policy file, mounted at /etc/kubernetes/audit-policy.yaml, governs the scope of the audit stream by defining which event types are recorded at which detail level; if the audit logging flag is omitted from the policy, no events are logged. Audit event truncation is disabled by default and must be explicitly enabled, so audit records are written in their entirety unless an administrator opts into size-based truncation. Backends include local log files written to /var/log/kubernetes/audit/ and webhook endpoints for forwarding to external systems. Pod Security Standards (PSA) audit mode, when enabled on a VKS cluster, records security policy violations as audit annotations in the audit log stream, extending audit coverage to workload-level security events. Kubernetes seccomp profiles using the SCMP_ACT_LOG action allow individual syscalls of a process to be logged to syslog or auditd, providing fine-grained syscall-level audit recording for sensitive workloads.

Fluent Bit agents deployed by VCF in the vmware-system-logging namespace on VKS clusters collect and forward logs to external destinations, with access to that namespace restricted to cluster administrators. Fluent Bit processes Kubernetes API server audit logs separately from container logs and Linux daemon logs when forwarding to VCF Log Management, maintaining the distinction of audit records in the forwarded stream. On vSphere Supervisor control plane nodes, Fluent Bit collects kube-apiserver audit logs from /var/log/vmware/audit/kube-apiserver.log using the tag audit.apiserver.* and stores them in a local database at /var/log/vmware/fluentbit/flb_audit_apiserver before forwarding; on VKS worker cluster nodes, audit logs are collected in JSON format from /var/log/kubernetes/kube-apiserver.log with a 50 MB memory buffer limit. Fluent Bit also collects Linux authentication logs and container runtime interface logs from VKS cluster nodes, extending the set of log types forwarded to external destinations. The Supervisor can be configured to preserve the source IP addresses of authentication and Kubernetes API server requests for later inspection in audit logs, supporting attribution of actions to specific network origins. Supported forwarding targets include VCF Log Management, Syslog servers, Elasticsearch, Kafka, and Splunk. For workloads running in vSphere Namespaces as vSphere Pods, the LogAgentConfiguration custom resource can be applied to a namespace to stream syslog messages to a remote Syslog server; each forwarded message includes metadata fields for namespace name, pod UID, pod name, container name, and ESX host name. By routing audit records to an external log management system, the platform creates a copy of the audit trail outside the cluster, so that a compromise or administrative action affecting the cluster does not also destroy audit evidence.

To fully satisfy this control, organizations deploying VCF should implement log forwarding to a dedicated, hardened log management or SIEM platform where retention, integrity verification, and access controls can be managed independently of the VCF infrastructure. VCF does not provide immutable or tamper-evident log storage on its own; protection against log modification or deletion at the storage layer requires integration with a write-once-read-many (WORM) log repository or equivalent storage. For high-assurance environments, Kubernetes guidance recommends deploying cryptographic protections to produce tamper-evident and confidential logs. Organizations should also establish policies governing who may access log data, how long logs are retained, and how log integrity is validated over time.

VMware Private AI Services (PAIS) generates audit-relevant logs across its AI infrastructure components and exposes an observability subsystem with configurable retention and external forwarding that contributes to event log protection.

Deep Learning VMs record cloud-init script logs in `/var/log/dl.log` and GPU driver installation logs for the vGPU guest driver or NVIDIA data center GPU driver in `/var/log/gpu-install.log`. JupyterLab instances on Deep Learning VMs surface logs that can be examined to verify component installation and operation. Model endpoints support configurable log verbosity through the `VLLM_LOGGING_LEVEL` environment variable, letting operators control what the vLLM inference server records.

PAIS observability is activated by updating the `PAISConfiguration` custom resource. Operators set a Prometheus storage class policy through `observability.prometheusRuntime.storageClassName` and a retention period through `observability.prometheusRuntime.metricsRetention.period`, which define where collected metrics are stored and how long they are preserved. LLM traces can be forwarded to an external OpenTelemetry Collector over HTTP/protobuf or gRPC by uncommenting the `spec.observability.llmTraces` section of the `PAISConfiguration` custom resource, externalizing trace data away from the system where it was generated. PAIS Controller metrics are exposed at the Prometheus metrics endpoint on the `pais-controller-manager` service and can be streamed from the Supervisor cluster to VCF Operations for consolidated observability. PAIS integrates with Grafana for metrics visualization using OIDC provider authentication, restricting who can view the collected observability data.

Access to the underlying log files on Deep Learning VM filesystems and the persistent volumes backing Prometheus storage is governed by the Kubernetes RBAC and persistent volume access controls provided by VCF. Organizations should configure the Prometheus storage class and retention parameters to align with their log protection requirements and route LLM traces and observability data to a protected external platform such as Grafana, VCF Operations, or another OpenTelemetry-compatible backend.

VMware vDefend (Contributes)

VMware vDefend generates structured security event logs across its Distributed Firewall, Gateway Firewall, IDS/IPS, and Malware Prevention components, with several mechanisms that support protection of those logs from suppression or loss.

The Security Services Platform audit log is enabled by default and cannot be disabled through configuration. All access events to the Security Services Platform, including access to the License Hub, are recorded in these audit logs, preventing log suppression at the platform level.

The Distributed IDS/IPS can be configured to forward events directly to external syslog consumers via the `ids_events_to_syslog` setting; this forwarding is disabled by default and requires explicit configuration. When remote syslog is enabled on ESX hosts, IDS/IPS events are exported directly from those hosts to external receivers. vDefend components write log files to `/var/log`, with syslog messages conforming to RFC 5424 on vDefend appliances and RFC 3164 on ESX hosts. Gateway Firewall isolation rules log blocked traffic attempts to the `unifiedsyslog.log` file on Edge Nodes.

Malware Prevention produces structured event logs in JSON format that include standard attributes (date, log level, module) along with detailed file analysis metadata: file hashes (SHA256, SHA1, and MD5), file type, file size, inspection timestamp, client and server VM identifiers, submission source, detection status, verdict, analysis status, malware classification, malware family, HTTP domain, HTTP method, and user agent. These records capture the full analysis lifecycle, including file intercepted, verdict cache hit, local static analysis submission, cloud dynamic analysis submission, verdict obtained, and policy enforced events. In 9.1, the Malware Prevention Service can be configured to forward logs to a remote logging server using TLS encryption with mutual certificate authentication (requiring server CA certificate, client CA certificate, client certificate, and client key), providing an off-appliance copy of event records with in-transit protection.

Identity Firewall event log sources can be integrated with VCF Log Management for centralized log collection and monitoring, providing an additional path to off-appliance log preservation.

Protection of forwarded or archived logs from unauthorized access and modification at rest is outside vDefend's scope and depends on the receiving log management or SIEM platform's controls.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) contributes to this control through role-based log access controls, syslog forwarding to external platforms, and audit event generation that captures user identity and action details.

PNR generates audit events across a broad range of recovery and replication operations, including configuration changes, recovery plan executions, and protection group modifications. Each audit event record includes the event name, user identity, and source IP address from which the action was initiated. Login events include timestamps, session keys, and user identity information in a structured format. Events covering protection group and consistency group changes are logged at appropriate severity levels (Info or Error), and corresponding alarms can be configured to trigger notification when specific events occur.

PNR log files are designed to exclude sensitive data such as private keys and passwords. The vSphere Replication component maintains security-relevant audit logs at defined paths on the appliance, including authorization error messages, login events, and certificate verification errors, each recorded with timestamps and component information to support forensic review.

To move logs off the local appliance, PNR supports syslog forwarding from the PNR Appliance to a remote syslog server. The Clean Room Orchestrator supports forwarding events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, enabling integration with enterprise log management and security monitoring platforms. Event forwarding to VCF Log Management requires version 9.0 or later. Centralizing logs in an external platform removes them from local storage where an attacker with appliance access could otherwise modify or delete them.

PNR does not provide write-once or tamper-evident local log storage. Organizations should forward PNR logs to a centralized SIEM or write-once-read-many log repository to protect against modification or deletion at the storage layer.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) produces structured audit logs that record platform-level and gateway-level operations, and provides several mechanisms that contribute to protecting those logs from unauthorized access and loss.

At the platform level, DSM maintains gateway audit log files on the Provider VM at `/var/log/tdm/provider/audit/`, with individual files named using a timestamp format (`gateway-audit-timestamp.log`). Local retention covers the last five days of log files; once files are successfully uploaded to a configured S3 repository, DSM removes them from the local filesystem after five days. Each log entry captures structured fields including Component, Event Type, Event Details, Event Time (UTC), Status, and Source. The Source field records the email identifier of the user who initiated the operation, or "System" for events initiated by DSM without user intervention. The System Audit Events view, accessible through the Provider interface, is the designated location for reviewing non-database-related platform operations. Access to the Provider interface is scoped to the administrative role, restricting which users can read or interact with the system-level audit record.

DSM supports offloading audit logs to external storage as the primary mechanism for durable protection. When a default S3 provider log repository is configured, DSM periodically archives gateway audit log files to an S3 subpath named "gateway audit." DSM does not delete audit logs stored in the S3 repository, which means the archived log record persists beyond the five-day local retention window. Externalizing audit logs to S3 separates the log record from the Provider VM that generated it, reducing the risk that a compromise or failure of the Provider VM affects the integrity or availability of the audit trail. Organizations apply bucket-level access controls and retention policies on the S3 repository to restrict who can read, modify, or delete the archived logs.

DSM supports log forwarding, allowing DSM logs to be sent to a centralized log management or security information and event management (SIEM) platform via the System Logs capability. Forwarding logs to an external system provides a second copy of the audit record under access controls and integrity protections that are independent of the DSM platform itself.

For SQL Server databases provisioned through DSM, the SQL Server data service uses server-level DDL triggers to restrict the file paths available for audit logs, limiting where audit log files can be written. DSM supports enabling audit logging for SQL Server with configurable levels of auditing for system logins and a configurable log retention period. DSM can automatically create a simple audit for login events based on the Login Auditing option selected during cluster creation. For custom audit requirements, the standard T-SQL `CREATE AUDIT` and `CREATE AUDIT SPECIFICATION` DDL statements are available.

DSM can generate and download log bundles that aggregate relevant logs from database VMs, supporting diagnosis and out-of-band preservation of the operational log record.

Audit events can be exported from the System Audit Events view in CSV or XLSX format using the ACTIONS menu. Exports include all events visible to the authenticated user regardless of pagination, supporting external archival and out-of-band preservation of the audit record.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer supports the protection of event logs and audit tools through real-time log forwarding to external systems, structured audit record content, and access controls on the Controller's audit interfaces. The 9.1 release adds License Hub audit logging capabilities that are always active and optionally forwarded to external syslog.

The primary off-system protection mechanism is the Syslog-Audit-Persistence feature, configured under Alert Actions in the Avi Controller. When enabled, audit events stream to one or more external syslog servers in real time; once forwarded, the records reside outside the Controller where local administrative access cannot modify or remove them. The Controller supports syslog delivery over TCP in addition to UDP, and syslog server targets are specified in Controller Settings. Any compatible syslog receiver, including VCF Log Management configured as a log forwarder, can serve as a destination.

An important architectural boundary applies: Avi Load Balancer debug logs and Event Logs are not forwarded to remote syslog servers through the OS-level syslog configuration. Debug logs are accessible only through Tech Support generation. Event Logs require a separate API pull or a scripted push from the Controller to a remote logging system, which means organizations should configure explicit export or retrieval processes for off-system preservation.

The Avi Controller's Event Logs provide detailed records of system activities, configuration changes, and operational events, including an audit trail that identifies who made each change and when. Object-specific event logs are accessible via the Events tab on detail pages for Virtual Services, Pools, Service Engines, and Controllers, automatically filtered to the relevant object. The API supports querying events over extended periods, including a one-year lookback using the CONFIG_DELETE endpoint with the appropriate duration parameter.

Avi WAF generates audit log records for matched security events, such as cross-site scripting detection, capturing the matched variable name and content when audit log parts are configured to include event data (ctl:auditLogParts=+E). This extends event log coverage to L7 application protection events beyond configuration and access activity.

In 9.1, the License Hub provides dedicated audit logging that records all access events and cannot be disabled. License Hub can be configured to transmit log messages to a remote syslog server. A built-in Audit local user account with the auditor role provides dedicated access to APIs and services for system auditing, separate from the administrative account.

Both the Controller and Service Engines log delivery failures when transmitting to Events, Syslog, and Splunk targets, including failed trusted channel initiations and function failures. Disruptions to the log forwarding pipeline are captured as auditable events in their own right.

Control C1.c

Generating Alerts: Evidence of potential security incidents contained in your monitoring data is reliably identified and where appropriate triggers alerts.

SCF Controls: MON-01.4

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides a layered alerting infrastructure across VMware vCenter and VCF Operations that generates system alerts based on defined conditions, correlates related alerts through intelligent grouping, and forwards them to external management systems through multiple outbound channels. These capabilities address the cybersecurity and data protection dimensions of this control, though the physical and supply chain alert domains require organizational processes and tooling outside of VCF.

At the vCenter layer, the built-in alarm system monitors objects in the virtual infrastructure and triggers alerts when defined conditions are met. vCenter includes an SNMP agent that sends traps when the system starts or when alarms fire. The SNMP agent supports SNMP v1 and v2c traps as well as SNMP v3 traps with all security levels; when configured for v1 or v2c, the agent also handles incoming GET requests, supporting both push-based alerting and poll-based monitoring from management systems. Alarm notifications can also be delivered via email with configurable recipient addresses and subject lines. Alarm rules are configured per event, so administrators must create individual rules for each event type they wish to monitor. VCF PowerCLI supports programmatic creation of SNMP alarm actions using the `New-AlarmAction -Snmpp` parameter, enabling automation of alert configuration across managed vCenter instances. VMware vCenter High Availability can also be configured to send SNMP trap notifications for vCenter HA cluster events, extending alert coverage to vCenter availability and failover scenarios.

VCF Operations provides a more extensive alerting framework built on symptom-based alert definitions. Alerts are generated when collected metric or property data is compared against alert definitions and the defined symptom conditions evaluate as true. Each alert definition includes configurable impact and criticality metadata so administrators can prioritize responses. When an alert triggers, it presents the triggering symptoms alongside recommendations for resolution, giving operators the context they need to act. Administrators can attach recommendations to alert definitions so that engineers have documented remediation steps when alerts fire. Alert definitions support best practices such as consistent naming, actionable recommendations, and appropriate severity levels. The Wait Cycle setting, which defaults to 1, controls how many collection cycles a symptom condition must persist before an alert is generated, and should be adjusted based on the environment's tolerance for repeated alerts on recurring conditions. Administrators can create alert definitions with tighter symptom parameters to track alerts and identify problems before users encounter further issues.

The Alerts data grid in VCF Operations lists all generated alerts and their status. Generated alerts feed the top-level Health, Risk, and Efficiency badges, providing a consolidated operational view across the monitored environment. Alerts can be added by adapters, users, or the VCF Operations system itself. The system supports self-monitoring through internal metrics such as analytics operation counts, threshold check durations, and incoming observation sizes, allowing administrators to verify that the monitoring platform is functioning correctly.

For alert correlation, VCF Operations includes intelligent alert clustering, which groups related alerts together based on their creation time and topology distance. Each alert cluster includes a graphical timeline and an object-relationship chart, helping administrators trace root causes across related infrastructure objects rather than investigating each alert in isolation. This reduces alert noise and helps operators identify underlying root causes.

VCF Operations supports alert definitions based on log events from monitored systems. VCF Log Management collects logs from all VCF components and provides pre-built content packs with dashboards, alerts, and queries for common operational and security scenarios. An NSX-specific content pack includes alerts for NSX environment monitoring. Log-based alert definitions allow administrators to trigger notifications when specific log patterns appear, connecting log analysis with the broader alerting framework. VCF Operations and VCF Log Management must be integrated to implement the centralized log collection architecture.

For alert distribution and external integration, VCF Operations supports multiple outbound notification plug-in types. Notification options can be configured to specify which alerts are sent through each channel. Supported outbound plug-in types include Standard Email, SNMP Trap, Webhook Notification (for REST-based integration with external systems), Slack, Log File, and ServiceNow Notification. Payload templates are available for each plug-in type, allowing administrators to customize the alert content delivered to each destination. At least one instance of the relevant outbound plug-in must be configured and running before notifications can be sent.

SNMP trap notifications can be sent to up to four configurable destinations, and notification rules support filtering to control which alerts are forwarded to which destinations. VCF Operations for Networks also supports SNMP trap forwarding to up to four destinations. VCF Operations can log alerts to an existing SNMP Trap server in the environment. The Management Pack for SNMP plug-in can receive events from vCenter over the SNMP protocol, enabling centralized collection of alerts from across the VCF stack. VCF Operations generates a critical alert when no SNMP targets are configured, helping ensure that outbound notification paths remain active.

The Management Pack for ServiceNow provides alert-sync functionality that synchronizes alerts between VCF Operations and ServiceNow. It creates ServiceNow alerts for VCF Operations alerts and associates them with their Configuration Item if present in the CMDB. Sample configurations allow alerts to be sent to ServiceNow as alerts, events, or incidents without applying filters, and each alerting configuration supports a callerId parameter that identifies the caller for ServiceNow integration. The Slack plugin supports forwarding alerts to Slack channels for notification and troubleshooting purposes.

Cloud proxy instances can be configured to generate their own alerts and notifications. It is recommended to create notification rules for cloud proxy alerts so that remediation steps can be taken promptly when connectivity or service health issues arise. An alert is displayed in VCF Operations when one or more services on a cloud proxy are down.

Out-of-the-box customizable alerts and reports are included with predefined dashboards to assist with operational awareness from initial deployment. Administrators can also create custom dashboards with alert-related widgets to monitor alerts for specific object groups.

At the VMware Kubernetes Service (VKS) layer, the Prometheus standard package provides a built-in alerting stack for containerized workloads. When installed on a VKS cluster, it deploys Prometheus AlertManager as a StatefulSet with multiple replicas in the `tanzu-system-monitoring` namespace. Prometheus instances on VKS clusters send alerts to AlertManager via HTTP on the configured web port. The AlertManagerConfig custom resource definition specifies how alerts are grouped, inhibited, and forwarded to external notification systems; the default-receiver routing configuration applies a group wait of 10 seconds, group interval of 5 minutes, and a repeat interval of 3 hours. Administrators can extend these notifications to external incident management systems through AlertManager receiver configurations. AlertManager instances are deployed with a securityContext that enforces non-root execution, running as user and group 65534. VCF Automation provides an Alerts tab on deployment resources that surfaces active alerts sourced from VCF Operations, and Grafana Operator is available alongside Prometheus for visualization of cluster-level monitoring data.

For supply chain integrity alerting, VKS supports configuring Kubernetes admission controllers to verify container image signatures at deploy time. The sigstore policy-controller admission controller validates image authenticity and integrity before workloads are scheduled, blocking or flagging images that fail signature checks. Harbor Registry, available as a standard package on VKS clusters, signs images as trusted to provide image authenticity verification. When copying VKS images to a private registry, the `imgpkg copy` command supports the `--cosign-signatures` flag to verify and transfer Cosign signatures alongside images, preserving supply chain traceability. The VCF Consumption CLI binary integrity can be verified using a SHA256 checksum file available for download from the VCF Automation Tenant Portal. Admission policy violations are recorded in the Kubernetes audit log, generating traceable security events that can be forwarded to external monitoring or SIEM platforms.

To achieve the integrated situational awareness described in this control, organizations should configure outbound notification plug-ins from vCenter, VCF Operations, and AlertManager on VKS clusters to forward alerts to a centralized security information and event management (SIEM) or network management platform. Alert definitions should be tuned following the built-in best practices guidance, outbound plug-in instances should be configured and verified as active, and container image

signature verification should be enabled on VKS admission controllers to surface supply chain integrity events. The physical security domain of this control and the full cross-domain correlation function require processes and systems outside of VCF's scope.

VMware vDefend (Contributes)

VMware vDefend contributes to cybersecurity alert generation and monitoring within its network security domain but does not cover physical security, supply chain, or data protection alerting.

The Distributed IDS/IPS generates alerts based on configurable threshold conditions, tracking events by source with a count threshold and time period so that alerts fire only after a minimum number of matching events occur within a defined window. Alert logs capture source IP, source port, destination IP, destination port, IP protocol, and timestamp for each triggered event. Signature severity levels are adjustable, allowing tuning of which events generate alerts based on organizational security requirements. To manage alert volume, IDS/IPS supports a Limit option that caps alert generation per host within a specified time frame and a Both threshold type that applies thresholding and rate limiting simultaneously to reduce flooding from high-volume signature matches.

The Threat Event Monitoring dashboard in vDefend provides visibility into the current state of security issues across the data center, helping security teams understand network activity and prioritize focus areas. An alarm triggers and remains active until dropped events are no longer detected, keeping administrators aware of ongoing event-drop conditions beyond the initial notification banner.

Security Services Platform (SSP) generates alarms when allocated resources exceed predetermined threshold values, with deployment status and platform alarms visible in the System Dashboard. SSP alarm records include detailed descriptions, recommended actions, and the date and time each alarm triggered. Alarms can be acknowledged, suppressed, or resolved to manage the alert lifecycle, and the entity ID that caused each alarm is available for correlation. The License Hub dashboard within SSP highlights platform-related alarms displaying system alerts and critical errors requiring attention. SSP also generates alarms on the Bare Metal Server page when certificate updates fail, providing operational awareness of certificate lifecycle issues on bare metal infrastructure.

Security Intelligence continuously monitors for new traffic flows between environments and alerts administrators to unauthorized or unexpected traffic, supporting ongoing policy adjustment. The Monitor and Plan Overview dashboard displays high-level information about the most recent state of network activities managed by Security Intelligence, while the Environments Monitoring view provides traffic flow analysis with protection status summaries for selected environment pairs across configurable time ranges.

Network Detection and Response (NDR) integrates with external SIEM systems to send security-related event logs about network infrastructure, generating and forwarding logs both when a detection event occurs and when an existing detection is updated. Security teams can investigate individual threat events and correlated campaigns through the SSP interface to assess impact, identify root causes, and take appropriate mitigation actions.

Physical security, supply chain monitoring, and data protection alerts are outside vDefend's scope and require complementary controls to achieve integrated situational awareness.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides alert generation and notification capabilities for data protection activities, integrating with the VMware vCenter alarm framework and supporting outbound notification to external response systems.

PNR extends vCenter's alarm system with recovery-specific alarm types. Alarms are generated automatically when connectivity issues are encountered or when protection groups and recovery plans enter an error state. PNR logs events and triggers corresponding alarms to track system health and address potential issues before they affect protection. Administrators can define and configure the action taken by each alarm type.

Alarm notifications can be configured to send email, SNMP traps, or run scripts on the vCenter host when an alarm triggers. For email notifications to function, Mail settings must be configured in vCenter Settings. PNR requires an administrator email

address to be configured during appliance registration with vCenter. Licensing event alerts can also be configured so that licensing administrators receive email notifications when licensing compliance issues occur.

vSphere Replication supports configurable alarms for replication events. Administrators can define and edit alarms so that specific replication events, such as after configuring a virtual machine for replication, trigger notifications.

In 9.1, the unified PNR appliance includes the Clean Room Orchestrator, which adds a distinct alerting surface for cyber recovery operations. The Clean Room Orchestrator sends email alerts to configured recipients when the status of recovery environment components changes, such as when the Orchestrator or connector moves from good to warning status. PNR maintains an Alarms list for the clean room showing a history of all notifications requiring attention, with search and filtering by severity. PNR also supports configuration of email alerts for critical events to notify users of important recovery operations and system events.

The Protection and Recovery Overview Dashboard displays alerts with severity levels of Critical, Immediate, and Warning for snapshots, protection groups, recovery plans, and deployment settings. Through the VCF Protection and Recovery Cloud Management Pack integration with VCF Operations, administrators receive health alerts for protection groups, recovery plans, cloud file systems, recovery SDDCs, and protected sites.

For environments using PNR's Cyber Recovery capability, PNR supports integration with CrowdStrike, which provides CrowdScore for Incident Detections. CrowdScore measures the real-time threat level to recovery endpoints on a scale of 0 to 100, calculated using factors including frequency, severity, and correlation of security alerts, giving administrators a data protection-scoped view of security conditions relevant to recovery readiness.

These PNR-native alerting mechanisms contribute to situational awareness for data protection activities. Physical infrastructure alerting, network security alerting, and supply chain alerting fall outside PNR's scope and depend on the broader VCF platform and supplementary tools.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) generates system alerts for conditions within its operational scope, covering database engine health, infrastructure connectivity, cybersecurity events, and data protection activities. The Dashboard displays Global Alerts at a glance, and a dedicated Global Alerts page, accessible from both the plug-in UI within vSphere Client and the standalone UI, provides a consolidated view of non-catastrophic alerts and overall system status. An Alerts pane in the Monitoring tab gives administrators a database-scoped view of active conditions for individual instances.

DSM categorizes alert conditions at three severity levels: OK, WARNING, and CRITICAL. Named alert types include `INFRASTRUCTURE_POLICY_VC_ALARMS`, triggered when one or more infrastructure resource alarms found in VMware vCenter (vCenter) are active; `VCENTER_CONNECTIVITY`, triggered when vCenter connectivity fails; `DATABASE_ENGINE_HEALTH_ALERT`, triggered when the database engine service is experiencing problems or disruptions; and alerts for vCenterBinding API status and LicensingNotUpdated conditions. DSM also generates alerts for authentication failures, backup and restore corruptions, and certificate errors. When critical alarms are active for vCenter hosts, DSM surfaces guidance to avoid create, upgrade, and scale operations to reduce the risk of failures during degraded infrastructure states. Each alert includes resolution suggestions that give operators actionable steps to resolve conditions without disrupting database services. Alert notification settings and threshold values for database alerts are configurable.

To support integration with broader monitoring and incident response workflows, DSM can forward alerts as email notifications or as webhook notifications to external systems. Named integration targets include Slack channels and ServiceNow. Webhooks support customizable payload templates and AlertLevel filtering, restricting delivery to CRITICAL or WARNING conditions as appropriate for the operational model. Alert payloads include the alert name, alert level, alert description, trigger timestamp, alert message, database cluster identifier, cluster name, triggered user email, task status, previous status, and task type. At the individual database level, administrators can configure alert notifications to route to Email, Slack, or ServiceNow endpoints. This mechanism supports routing DSM-generated alerts into enterprise monitoring platforms, SIEM systems, or ticketing workflows.

DSM integrates with VCF Operations to surface monitoring data for database services, providing an additional visibility channel for triggered or active alerts scoped to individual nodes or the overall cluster within the broader VCF observability stack.

DSM's alert coverage is scoped to the database-as-a-service layer: database instance health, infrastructure policy compliance, connectivity to platform components, authentication events, and backup operation outcomes. Physical security, network-level cybersecurity events, and supply chain activities are outside DSM's scope and require monitoring through the broader VCF platform and organizational tooling. Correlating DSM alerts with alerts from other platform components, and implementing a coordinated response workflow that spans physical, cybersecurity, data protection, and supply chain domains, requires organizational processes and enterprise monitoring capabilities beyond what DSM provides on its own.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer has a native alerting subsystem that generates, routes, and responds to alerts from application delivery and cybersecurity events. Alert Configurations define the conditions under which alerts are generated, drawing from system events or metrics as the configurable source, with parameters specifying when an alert should fire and what actions to take. When conditions are met, Avi executes the configured Action Groups that trigger notifications for new alerts. The Alert Manager captures alert details across the system, including information for Service Engines, Virtual Services, and Pools, along with event identifiers and cloud-specific metadata such as Service Engine VM UUIDs.

For alert routing, the Avi Controller supports four notification destinations: the local Controller UI (visible under Operations > Alerts > All Alerts, categorized by configured Alert Level), email, syslog, and SNMP traps. SNMP trap support covers both SNMPv2c and SNMPv3 protocols. In 9.1, SNMP notifications can additionally be configured with TLS encryption and strict certificate verification for secure transport to external SNMP servers, and multiple SNMP servers can be specified for notification delivery to support redundancy. Syslog Audit Persistence forwards alert events to remote syslog servers for centralized monitoring and audit trail collection. All destinations are configured through Operations > Notifications in the Controller UI. The Controller cluster leader issues SNMP trap notifications based on system events, and event-based traps can include status-change events such as virtual-service-down conditions. Local alert notifications are generated by default in addition to any configured external alert actions.

For automated response, Avi Alert Actions support ControlScripts: Python scripts executed on the Controller that receive the triggering alert's `EVENT_DESCRIPTION` as an environment variable and full alert details as JSON. Alert Actions can be associated with specific system events and can trigger email, Syslog, SNMP Trap, or ControlScript responses. Avi logs configured alerts and their execution status in the Alert Actions tab under Operations > Alerts. Custom Alert Actions can be created alongside or in place of the default system alert actions (such as System-Alert-Level-High), allowing organizations to tailor alerting and automated response to their operational and security requirements.

For VCF-integrated deployments in 9.1, the Avi Load Balancer Observability Management Pack provides unified alert reporting across multiple Avi instances, giving VCF platform operators a consolidated view of alerting state across the Avi deployment.

Auditors should verify that Alert Configurations and Alert Actions are configured under Operations in the Avi Controller UI, that syslog or SNMP trap destinations are set to route events to the organization's centralized monitoring platform, and that alert thresholds reflect the cybersecurity and application availability events within the Avi scope. The organization is responsible for routing Avi alerts into the broader monitoring stack and for establishing the cross-domain correlation required to achieve integrated situational awareness across physical, data protection, and supply chain domains.

Control C1.d

Triage of Security Alerts: You contextualise alerts with knowledge of the threat and your systems, to identify security incidents as well as responding to all alerts appropriately.

SCF Controls: MON-17

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides log analysis, event triage, and incident tracking capabilities through VCF Operations and VCF Log Management that give administrators the technical foundation to build event log review processes integrated with organizational incident response workflows.

VCF Log Management is the centralized log aggregation and analysis platform. It can be configured to pull tasks, events, and alerts from VMware vCenter instances and receive syslog feeds from VMware ESX hosts through Log Collections configuration. The audit log in VCF Operations is integrated with syslog, and the syslog collector can be configured to collect all audit logs from across the infrastructure. Once logs are centralized, the Analyze page provides a Logs tab where administrators can search and filter log events and create queries to extract events based on timestamp, text, source, and fields within log entries. Each log event includes structured data: timestamp, thread identifier, source IP address, log level, component class name, and event message content.

For trend analysis and anomaly detection, VCF Operations provides the Event Trends tab, where administrators can construct and run queries using search text and filters, then compare query results against the same time period immediately prior. This comparison capability supports triage by highlighting deviations from normal patterns. The Log Analysis Widget allows further customization of the visual representation of events through aggregation queries, enabling teams to build dashboards tailored to their review processes.

VCF Operations supports log-based alerting that can trigger automated triage workflows. Alert definitions support log-based symptoms configured through the Symptom Definitions card in Infrastructure Operations, under Configurations. Log-based conditions can also be created as alternatives to symptom-based approaches, giving flexibility in how events are flagged for review. Event auditing provides visibility into platform interaction changes across the VCF infrastructure and surfaces insights into suspicious access events and policy violations.

The platform includes incident tracking capabilities that align with structured triage and response processes. VCF Operations incident tracking captures state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation. During incident investigation, administrators can flag specific metrics and mark them as root cause, supporting structured triage. The Troubleshooting Incident Page displays incident information including status, root cause metrics, closing remarks, and creation timestamps, providing an audit trail for each investigated event. Diagnostic Findings consolidates a list of log-based and property-based findings with specific resolution rules, integrating VCF Log Management to provide depth and flexibility in troubleshooting. It displays affected objects, recommendations for resolution, and links to knowledge base articles for each finding.

At the infrastructure layer, the vCenter events and alarms framework provides real-time event monitoring. vCenter includes preconfigured alarms to monitor the operations of vSphere inventory objects, and administrators can create custom alarms for specific event conditions. vCenter syslog forwarding can be configured through the vCenter Management API to forward syslog messages to remote servers; event streaming to a remote syslog server is enabled by setting the ``vpxd.event.syslog.enabled`` option in the vCenter Management Interface, and each forwarded event record includes the `eventId`, `partInfo`, `createdTime`, `eventType`, `severity`, `user`, `target`, `chainId`, and `description` fields. ESX hosts can also be configured to send syslog messages to remote log servers using the `esxcli` command line, and audit records specifically can be directed to a remote host by enabling the ``Syslog.global.auditRecord.remote`` parameter, which forwards audit records to the host specified by ``Syslog.global.logHost``.

Across the VCF stack, audit logs are generated for security-relevant events including logon, logoff, and resource access. NSX logs all auditable events related to security and compliance requirements, with each audit log entry containing the timestamp, source, result, and a description of the event. NSX syslog and audit log messages include timestamps generated by an NTP server when configured. Auditable events required by global compliance frameworks are logged by the platform.

VCF Automation creates audit logs when reportable actions are performed, such as deploying a blueprint or catalog item, performing Day 2 actions on resources or deployments, or creating, deleting, or updating property groups. Each audit log entry can contain the timestamp, message, user name, project name, and trace ID value. Each reportable action type creates an initial log entry with a Submitted status, followed by an additional entry showing Successful, Failed, or Canceled status. VCF Operations audit logging can filter data by User ID, User Name, Auth Source, Session, Client IP, Category, and Message, with date range filtering spanning hours to years.

Log Assist can generate log bundles and automatically attach property-based diagnostic findings to accelerate resolution of support cases, bridging the gap between internal triage and vendor escalation. vSphere Supervisor logs can be forwarded to external syslog servers through Fluent Bit configuration using RFC 5424 syslog format.

Organizations deploying VCF should establish formal log review schedules, define triage criteria that map to their incident response plans, and configure VCF Operations alerting rules to surface events that require immediate attention. The platform provides the analysis, alerting, and tracking tools, but the review cadence, triage decision trees, escalation procedures, and integration with external incident response systems such as SIEM platforms and SOC workflows are organizational responsibilities.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides several mechanisms that support event log analysis and triage at the application delivery layer, contributing to the organization's broader incident response capability.

Avi Event Logs provide detailed records of system activities, configuration changes, and operational events, including an audit trail that tracks who made configuration changes and when. Administrators can retrieve event data using the `/api/analytics/logs`` analytics API endpoint, which supports filtering by event type, duration, page size, and end time to query logs across specific time periods up to one year. When an event log query returns more than 10,000 entries, Avi documentation recommends querying shorter time periods via the analytics API to avoid memory-intensive operations. Event logs are not forwarded to remote syslog servers through OS-level syslog configuration; they require the Syslog-Audit-Persistence alert action template for external export. Similarly, virtual service logs are not pushed to syslog by default and must be pulled via the API or scripted for forwarding to a remote log aggregation system.

Avi supports Syslog-Audit-Persistence, a built-in alert action template that streams audit events to external syslog servers for audit compliance. The Controller's alert feature processes system events and metrics against user-defined rules and generates alert actions such as syslog messages, email notifications, or SNMP traps. The Avi Controller and Avi Service Engine log audit record failures to Events, Syslog, and Splunk, including trusted channel initiation and termination failures, certificate validation failures, client authentication failures, and SSH session establishment failures. The Avi License Hub can also be configured to transmit log messages to a remote syslog server.

The Avi Controller supports integration with VCF Log Management for centralized event logging and monitoring, enabling Fluent Bit and JSON parsing for log aggregation and downstream analysis. The Controller also logs denial-of-service attack events with structured event details including event ID, attack count, threshold values, and alert level, supporting triage of volumetric threats at the load balancer layer.

At the application layer, VMware Avi Web Application Firewall (WAF) App Log Analytics captures events when Application Rules are triggered, containing information about the type of attack detected, including matched variable names and content for rules such as XSS detection. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation, and administrators are directed to review application logs and analytics to distinguish genuine threats from false positives before creating WAF exceptions.

Integrating these capabilities with the organization's established incident response processes requires organizational IR procedures, SIEM or log aggregation configuration, and defined triage playbooks that Avi cannot itself define or operate. Organizations should configure Syslog-Audit-Persistence or VCF Log Management integration, define alert thresholds and notification routing, and map WAF and audit events into IR workflow tooling to fulfill this control.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control C1.e

Personnel Skills for Monitoring and Detection: Monitoring and detection personnel skills and roles, including those outsourced, reflect governance and reporting requirements, expected threats and the complexities of the network or system data they need to use. Monitoring and detection personnel have sufficient knowledge of network and information systems and the essential function(s) they need to protect.

SCF Controls: HRS-03.2

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control C1.f

Understanding User's and System's Behaviour, and Threat Intelligence (within Security Monitoring): Threats to the operation of network and information systems, and corresponding user and system behaviour, are sufficiently understood. These are used to detect cyber security incidents.

SCF Controls: IRO-03, MON-16, THR-09

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several monitoring, alerting, and network analysis capabilities that contribute to an organization's ability to define and detect Indicators of Compromise (IOC), though fully operationalizing IOC management requires integration with external threat intelligence platforms and organizational processes.

VCF Operations includes a Security Operations dashboard that provides a consolidated view of the security posture across the managed infrastructure. This dashboard brings together user and infrastructure security elements, helping operators identify areas that might require attention based on security exposure. By centralizing security-relevant telemetry in a single pane, the dashboard supports detection of anomalous conditions that could signal a cybersecurity event.

VCF Operations continuously monitors infrastructure by evaluating collected data against defined policies. Each object or group receives a compliance score based on how well it adheres to those policies, and alerts are triggered when deviations occur. Organizations can create custom compliance benchmarks that monitor specific alert definitions and policies, allowing security teams to codify their own detection criteria and receive notifications when infrastructure drifts from expected baselines. This policy-based alerting mechanism supports operationalizing certain classes of IOCs, particularly those related to configuration drift, unauthorized changes, or compliance violations.

VCF Operations supports custom alert definitions that can combine metric-based and log-based symptoms, allowing administrators to define conditions that flag suspicious activity. Alert definitions can incorporate Smart Early Warning conditions and log event patterns from monitored systems. Alert definition Impact settings can be configured to Risk to indicate potential problems that require attention in the near future, providing an early-warning mechanism that organizations can incorporate into incident detection workflows. Problem alerts are logged to syslog, and outbound notification plug-ins (SNMP Trap, webhook, email) allow alerts to be forwarded to external security tools for correlation and triage. VCF Log Management enables log-based symptom definitions that can match patterns across aggregated log data from across the VCF environment.

At the network layer, NSX provides flow-based observability capabilities. NSX flow queries support filtering and analysis of VTEP traffic, management traffic, and extended L2 network traffic for monitoring and audit purposes. NSX Traceflow provides traffic analysis by specifying source and destination information and returning tables of observed packets. These capabilities help surface unusual communication patterns that organizations can correlate with defined IOCs.

Log forwarding across VCF components supports IOC operationalization. VMware vCenter, NSX, and VMware ESX hosts can all forward syslog data to external SIEM platforms, where IOC matching and correlation typically occur. NSX audit logs include structured syslog fields that identify security-relevant events, and remote logging can be filtered by severity level and message categories including MONITORING, SECURITY, and SYSTEM.

For full threat intelligence correlation and signature-based IOC detection, VMware vDefend is a separate product that extends NSX networking with security-specific capabilities: IDS/IPS with support for importing custom and third-party threat intelligence signatures, custom signature bundle management for tailored IOC definitions, Malicious IP Feed integration that downloads known-malicious IP lists from the NTICS cloud service for use in network policy, virtual Deep Packet Inspection (vDPI) for payload pattern matching, and Advanced Threat Prevention combining IDS/IPS with network sandboxing, Network Traffic Analysis (NTA), and Network Detection and Response (NDR) correlation engines.

To fully satisfy this control, organizations need to supplement VCF's built-in monitoring with processes for defining, curating, and updating IOC libraries. This typically involves integrating third-party threat intelligence feeds, establishing procedures for

translating threat intelligence into detection rules across VCF Operations and network policy, and deploying a SIEM or endpoint detection platform to correlate VCF's telemetry with broader IOC databases.

VMware vDefend (Contributes)

VMware vDefend (vDefend) provides IOC detection and visualization mechanisms through its Security Services Platform and Security Intelligence components. The Network Detection and Response (NDR) feature correlates related events into campaigns, organizes threat events within a campaign into a timeline for security analyst triage, and maps threats to the tactics and techniques described in the MITRE ATT&CK framework, giving analysts structured context for identifying signs of compromise.

The Security Services Platform Campaign Blueprint provides an interactive graphical view of correlated security events and key actors for incident investigation. Campaign graph nodes show "IOC for Threat" relationships connecting a specific Indicator of Compromise to a threat, and "Affected by an IOC" relationships identifying workloads affected by a given IOC. IOC Summary panels surface details for File IOC (file score, verdict, SHA hashes, and a View Reports link) and for Malware IOC (impact score, detection details, and malware family details). A workload summary panel within the Blueprint shows the workload's maximum impact score, IP address or UUID, and lists threats in which the workload acts as an attacker or is targeted.

Campaign Correlation Rules calculate an impact score based on detection types, threat severity, and the count of affected workloads, enabling prioritization of IOC-driven investigations. Security Intelligence categorizes detected suspicious traffic events by impact type (Critical, High, Medium, and Low) to further support response prioritization. The Security Overview Dashboard Threat Event Monitoring displays the number of intrusions detected in each severity category for unique intrusion signatures, giving security teams a current view of network activity.

Security teams can investigate individual threat events and correlated campaigns through the Security Services Platform interface to assess impact, identify root causes, and take appropriate mitigation actions. The organizational process of formally defining and managing an IOC program, including sourcing, vetting, and curating IOCs, is a governance activity that vDefend's detection capabilities support but do not replace.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides application-layer anomaly detection mechanisms that contribute to meeting this control. The Anomalies Overlay feature, available in Virtual Service Analytics, Service Engine Analytics, and Pool Analytics, flags statistical deviations in traffic metrics as anomaly events when a specific metric deviates from the historical norm by more than four sigma during the anomaly period. Monitored metrics include CPU utilization, bandwidth, disk I/O, server response time, and connection rates. Each anomaly event is identified by entity name, entity type (Virtual Machine, Virtual Service, or Service Engine), and metric value, with a timestamp indicating when the deviation occurred. Anomaly detection operates against a moving-average baseline calculated from recent historical traffic. The Pool Anomalies Overlay also displays prediction interval upper and lower bounds alongside the anomalous value. Administrators can adjust detection granularity by changing the statistics time interval, and can configure alert filter sensitivity to tune the threshold for new alert generation. Note that anomaly recording is disabled when the statistics interval is set to Real Time; a non-real-time statistics interval is required for anomaly capture to function.

The Bot Management module adds a behavioral detection layer focused on credential stuffing and web attack patterns at the application proxy boundary. Bot Management detects malicious bots responsible for online fraud and credential stuffing attacks. The IP Reputation service extends detection by maintaining a database of categorized IP addresses and identifying anomalous traffic patterns, including DoS and DDoS activity and anomalous SYN floods.

For authentication-related anomalous behavior, Avi provides the `AUDIT_COMPLIANCE_EVENT` mechanism to log authentication failures for audit purposes, persisting them via the alerts infrastructure. The Web Application Firewall (WAF) App Log Analytics component captures events whenever a WAF application rule is triggered, recording the type of attack detected. Service Engines generate `DOS_ATTACK` alert events that include attack type, source IP addresses, virtual service UUID and name, and a report timestamp, supporting audit and forensic analysis of detected attacks. Avi also supports

DataScripts for custom identification of suspicious traffic and execution of appropriate mitigation actions, enabling organizations to define custom behavioral detection logic beyond the built-in statistical baselines.

Avi monitors over 500 real-time metrics to support DDoS detection and attack visibility. Alerts from any of these mechanisms can be forwarded proactively to email, syslog, SNMP, or custom APIs, enabling integration with a central SIEM or security operations platform. Avi integrates with Splunk via the Avi Load Balancer Splunk Add-on, generating events that serve as an audit trail for user logins, configuration changes, and runtime state changes.

These capabilities operate at the application delivery and load balancing layer. An organization requires a dedicated UEBA or UAM platform to fulfill the full scope of this control, including identity-level behavioral baselines, user session correlation, and cross-system entity analytics that extend beyond application traffic visible to Avi.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control C2

Principle C2 Threat Hunting: The organisation proactively seeks to detect, within networks and information systems, adverse activity affecting, or with the potential to affect, the operation of essential functions even when the activity evades standard security prevent / detect solutions (or when standard solutions are not deployable).

SCF Controls: THR-07

Aggregate Coverage: Contributes

VMware vDefend (Contributes)

VMware vDefend supports threat hunting at the network layer through Network Detection and Response (NDR), Security Intelligence campaign correlation, and IDS/IPS detection capabilities.

NDR correlates related detection events into campaigns and organizes threat events into a timeline that security analysts can view and triage by correlating threat signals. A campaign provides a view of a threat by correlating detection events to identify the different stages of an attack, and security teams can investigate individual threat events and correlated campaigns to assess impact, identify root causes, and take appropriate mitigation actions.

The Campaign Blueprint graph in Security Intelligence visualizes IoC relationships as directed connections, displaying node information that includes Threats, Custom IDS Signatures, and Indicators of Compromise (IOC). Nodes represent relationships such as "IOC for Threat" (a connection from an Indicator of Compromise to a threat) and "Source of Threat" (traffic flowing from a workload to a threat, indicating the workload is the origin). Campaign Correlation Rules assign impact scores ranging from 0 through 100, with 100 indicating highest severity, and can escalate combinations of lower-severity detections based on correlation logic, enabling analysts to prioritize their investigation queue.

The Security Intelligence blast radius view helps analysts determine whether a detection represents a targeted attack on specific systems or a widespread campaign affecting multiple parts of the infrastructure. The threat visualization canvas supports rapid threat containment, compromised asset identification, and microsegmentation policy adjustment. IDS/IPS events and NDR findings support date range filtering for temporal analysis of security events and intrusion attempts.

Custom IDS/IPS signatures can be added to profiles and applied to Distributed Firewall or Gateway Firewall rules to encode known IoC patterns directly into detection policy. The signature language supports DNP3 application data object matching for industrial control system threat detection. Threat Event Monitoring provides visibility into intrusions detected based on custom signatures, and the IDS/IPS Monitoring page lets administrators view details of actions taken when rules are triggered. IDS/IPS logs include the category of the detected threat along with other structured metadata for analyst triage.

The Security Overview Dashboard includes a Threat Event Monitoring view that provides insights about the current state of security issues in the data center, helping security teams understand network activity and focus investigation areas. Suspicious Traffic detection through Network Traffic Analysis detectors is part of the vDefend Advanced Threat Prevention capability set.

vDefend contributes the network-layer visibility, detection, and correlation capabilities for threat hunting; broader orchestration, endpoint telemetry, and analyst workflows remain outside its scope.

Not applicable for this control: VCF, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control C2.a (point 1)

Threat Hunting: You understand the resources required to perform threat hunting and these are deployed as part of business as usual.

SCF Controls: THR-07

Aggregate Coverage: Contributes

VMware vDefend (Contributes)

VMware vDefend supports threat hunting at the network layer through Network Detection and Response (NDR), Security Intelligence campaign correlation, and IDS/IPS detection capabilities.

NDR correlates related detection events into campaigns and organizes threat events into a timeline that security analysts can view and triage by correlating threat signals. A campaign provides a view of a threat by correlating detection events to identify the different stages of an attack, and security teams can investigate individual threat events and correlated campaigns to assess impact, identify root causes, and take appropriate mitigation actions.

The Campaign Blueprint graph in Security Intelligence visualizes IoC relationships as directed connections, displaying node information that includes Threats, Custom IDS Signatures, and Indicators of Compromise (IOC). Nodes represent relationships such as "IOC for Threat" (a connection from an Indicator of Compromise to a threat) and "Source of Threat" (traffic flowing from a workload to a threat, indicating the workload is the origin). Campaign Correlation Rules assign impact scores ranging from 0 through 100, with 100 indicating highest severity, and can escalate combinations of lower-severity detections based on correlation logic, enabling analysts to prioritize their investigation queue.

The Security Intelligence blast radius view helps analysts determine whether a detection represents a targeted attack on specific systems or a widespread campaign affecting multiple parts of the infrastructure. The threat visualization canvas supports rapid threat containment, compromised asset identification, and microsegmentation policy adjustment. IDS/IPS events and NDR findings support date range filtering for temporal analysis of security events and intrusion attempts.

Custom IDS/IPS signatures can be added to profiles and applied to Distributed Firewall or Gateway Firewall rules to encode known IoC patterns directly into detection policy. The signature language supports DNP3 application data object matching for industrial control system threat detection. Threat Event Monitoring provides visibility into intrusions detected based on custom signatures, and the IDS/IPS Monitoring page lets administrators view details of actions taken when rules are triggered.

IDS/IPS logs include the category of the detected threat along with other structured metadata for analyst triage.

The Security Overview Dashboard includes a Threat Event Monitoring view that provides insights about the current state of security issues in the data center, helping security teams understand network activity and focus investigation areas. Suspicious Traffic detection through Network Traffic Analysis detectors is part of the vDefend Advanced Threat Prevention capability set.

vDefend contributes the network-layer visibility, detection, and correlation capabilities for threat hunting; broader orchestration, endpoint telemetry, and analyst workflows remain outside its scope.

Not applicable for this control: VCF, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control C2.a (point 2)

Threat Hunting: You deploy threat hunting resources at a frequency that matches the risks posed to network and information systems supporting your essential function(s).

SCF Controls: THR-07

Aggregate Coverage: Contributes

VMware vDefend (Contributes)

VMware vDefend supports threat hunting at the network layer through Network Detection and Response (NDR), Security Intelligence campaign correlation, and IDS/IPS detection capabilities.

NDR correlates related detection events into campaigns and organizes threat events into a timeline that security analysts can view and triage by correlating threat signals. A campaign provides a view of a threat by correlating detection events to identify the different stages of an attack, and security teams can investigate individual threat events and correlated campaigns to assess impact, identify root causes, and take appropriate mitigation actions.

The Campaign Blueprint graph in Security Intelligence visualizes IoC relationships as directed connections, displaying node information that includes Threats, Custom IDS Signatures, and Indicators of Compromise (IOC). Nodes represent relationships such as "IOC for Threat" (a connection from an Indicator of Compromise to a threat) and "Source of Threat" (traffic flowing from a workload to a threat, indicating the workload is the origin). Campaign Correlation Rules assign impact scores ranging from 0 through 100, with 100 indicating highest severity, and can escalate combinations of lower-severity detections based on correlation logic, enabling analysts to prioritize their investigation queue.

The Security Intelligence blast radius view helps analysts determine whether a detection represents a targeted attack on specific systems or a widespread campaign affecting multiple parts of the infrastructure. The threat visualization canvas supports rapid threat containment, compromised asset identification, and microsegmentation policy adjustment. IDS/IPS events and NDR findings support date range filtering for temporal analysis of security events and intrusion attempts.

Custom IDS/IPS signatures can be added to profiles and applied to Distributed Firewall or Gateway Firewall rules to encode known IoC patterns directly into detection policy. The signature language supports DNP3 application data object matching for industrial control system threat detection. Threat Event Monitoring provides visibility into intrusions detected based on custom signatures, and the IDS/IPS Monitoring page lets administrators view details of actions taken when rules are triggered.

IDS/IPS logs include the category of the detected threat along with other structured metadata for analyst triage.

The Security Overview Dashboard includes a Threat Event Monitoring view that provides insights about the current state of security issues in the data center, helping security teams understand network activity and focus investigation areas. Suspicious Traffic detection through Network Traffic Analysis detectors is part of the vDefend Advanced Threat Prevention capability set.

vDefend contributes the network-layer visibility, detection, and correlation capabilities for threat hunting; broader orchestration, endpoint telemetry, and analyst workflows remain outside its scope.

Not applicable for this control: VCF, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control C2.a (point 3)

Threat Hunting: Your threat hunts follow pre-determined and documented methods (e.g. hypothesis driven, data driven, entity driven) designed to identify adverse activity not detected by automated detections.

SCF Controls: THR-07

Aggregate Coverage: Contributes

VMware vDefend (Contributes)

VMware vDefend supports threat hunting at the network layer through Network Detection and Response (NDR), Security Intelligence campaign correlation, and IDS/IPS detection capabilities.

NDR correlates related detection events into campaigns and organizes threat events into a timeline that security analysts can view and triage by correlating threat signals. A campaign provides a view of a threat by correlating detection events to identify the different stages of an attack, and security teams can investigate individual threat events and correlated campaigns to assess impact, identify root causes, and take appropriate mitigation actions.

The Campaign Blueprint graph in Security Intelligence visualizes IoC relationships as directed connections, displaying node information that includes Threats, Custom IDS Signatures, and Indicators of Compromise (IOC). Nodes represent relationships such as "IOC for Threat" (a connection from an Indicator of Compromise to a threat) and "Source of Threat" (traffic flowing from a workload to a threat, indicating the workload is the origin). Campaign Correlation Rules assign impact scores ranging from 0 through 100, with 100 indicating highest severity, and can escalate combinations of lower-severity detections based on correlation logic, enabling analysts to prioritize their investigation queue.

The Security Intelligence blast radius view helps analysts determine whether a detection represents a targeted attack on specific systems or a widespread campaign affecting multiple parts of the infrastructure. The threat visualization canvas supports rapid threat containment, compromised asset identification, and microsegmentation policy adjustment. IDS/IPS events and NDR findings support date range filtering for temporal analysis of security events and intrusion attempts.

Custom IDS/IPS signatures can be added to profiles and applied to Distributed Firewall or Gateway Firewall rules to encode known IoC patterns directly into detection policy. The signature language supports DNP3 application data object matching for industrial control system threat detection. Threat Event Monitoring provides visibility into intrusions detected based on custom signatures, and the IDS/IPS Monitoring page lets administrators view details of actions taken when rules are triggered.

IDS/IPS logs include the category of the detected threat along with other structured metadata for analyst triage.

The Security Overview Dashboard includes a Threat Event Monitoring view that provides insights about the current state of security issues in the data center, helping security teams understand network activity and focus investigation areas. Suspicious Traffic detection through Network Traffic Analysis detectors is part of the vDefend Advanced Threat Prevention capability set.

vDefend contributes the network-layer visibility, detection, and correlation capabilities for threat hunting; broader orchestration, endpoint telemetry, and analyst workflows remain outside its scope.

Not applicable for this control: VCF, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control C2.a (point 4)

Threat Hunting: You turn threat hunts into automated detections and alerting where appropriate.

SCF Controls: THR-07

Aggregate Coverage: Contributes

VMware vDefend (Contributes)

VMware vDefend supports threat hunting at the network layer through Network Detection and Response (NDR), Security Intelligence campaign correlation, and IDS/IPS detection capabilities.

NDR correlates related detection events into campaigns and organizes threat events into a timeline that security analysts can view and triage by correlating threat signals. A campaign provides a view of a threat by correlating detection events to identify the different stages of an attack, and security teams can investigate individual threat events and correlated campaigns to assess impact, identify root causes, and take appropriate mitigation actions.

The Campaign Blueprint graph in Security Intelligence visualizes IoC relationships as directed connections, displaying node information that includes Threats, Custom IDS Signatures, and Indicators of Compromise (IOC). Nodes represent relationships such as "IOC for Threat" (a connection from an Indicator of Compromise to a threat) and "Source of Threat" (traffic flowing from a workload to a threat, indicating the workload is the origin). Campaign Correlation Rules assign impact scores ranging from 0 through 100, with 100 indicating highest severity, and can escalate combinations of lower-severity detections based on correlation logic, enabling analysts to prioritize their investigation queue.

The Security Intelligence blast radius view helps analysts determine whether a detection represents a targeted attack on specific systems or a widespread campaign affecting multiple parts of the infrastructure. The threat visualization canvas supports rapid threat containment, compromised asset identification, and microsegmentation policy adjustment. IDS/IPS events and NDR findings support date range filtering for temporal analysis of security events and intrusion attempts.

Custom IDS/IPS signatures can be added to profiles and applied to Distributed Firewall or Gateway Firewall rules to encode known IoC patterns directly into detection policy. The signature language supports DNP3 application data object matching for industrial control system threat detection. Threat Event Monitoring provides visibility into intrusions detected based on custom signatures, and the IDS/IPS Monitoring page lets administrators view details of actions taken when rules are triggered. IDS/IPS logs include the category of the detected threat along with other structured metadata for analyst triage.

The Security Overview Dashboard includes a Threat Event Monitoring view that provides insights about the current state of security issues in the data center, helping security teams understand network activity and focus investigation areas. Suspicious Traffic detection through Network Traffic Analysis detectors is part of the vDefend Advanced Threat Prevention capability set.

vDefend contributes the network-layer visibility, detection, and correlation capabilities for threat hunting; broader orchestration, endpoint telemetry, and analyst workflows remain outside its scope.

Not applicable for this control: VCF, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control C2.a (point 5)

Threat Hunting: You routinely record details of previous threat hunts and post hunt activities. You use these to drive improvements in your threat hunting and security posture.

SCF Controls: THR-07

Aggregate Coverage: Contributes

VMware vDefend (Contributes)

VMware vDefend supports threat hunting at the network layer through Network Detection and Response (NDR), Security Intelligence campaign correlation, and IDS/IPS detection capabilities.

NDR correlates related detection events into campaigns and organizes threat events into a timeline that security analysts can view and triage by correlating threat signals. A campaign provides a view of a threat by correlating detection events to identify the different stages of an attack, and security teams can investigate individual threat events and correlated campaigns to assess impact, identify root causes, and take appropriate mitigation actions.

The Campaign Blueprint graph in Security Intelligence visualizes IoC relationships as directed connections, displaying node information that includes Threats, Custom IDS Signatures, and Indicators of Compromise (IOC). Nodes represent relationships such as "IOC for Threat" (a connection from an Indicator of Compromise to a threat) and "Source of Threat" (traffic flowing from a workload to a threat, indicating the workload is the origin). Campaign Correlation Rules assign impact scores ranging from 0 through 100, with 100 indicating highest severity, and can escalate combinations of lower-severity detections based on correlation logic, enabling analysts to prioritize their investigation queue.

The Security Intelligence blast radius view helps analysts determine whether a detection represents a targeted attack on specific systems or a widespread campaign affecting multiple parts of the infrastructure. The threat visualization canvas supports rapid threat containment, compromised asset identification, and microsegmentation policy adjustment. IDS/IPS events and NDR findings support date range filtering for temporal analysis of security events and intrusion attempts.

Custom IDS/IPS signatures can be added to profiles and applied to Distributed Firewall or Gateway Firewall rules to encode known IoC patterns directly into detection policy. The signature language supports DNP3 application data object matching for industrial control system threat detection. Threat Event Monitoring provides visibility into intrusions detected based on custom signatures, and the IDS/IPS Monitoring page lets administrators view details of actions taken when rules are triggered.

IDS/IPS logs include the category of the detected threat along with other structured metadata for analyst triage.

The Security Overview Dashboard includes a Threat Event Monitoring view that provides insights about the current state of security issues in the data center, helping security teams understand network activity and focus investigation areas. Suspicious Traffic detection through Network Traffic Analysis detectors is part of the vDefend Advanced Threat Prevention capability set.

vDefend contributes the network-layer visibility, detection, and correlation capabilities for threat hunting; broader orchestration, endpoint telemetry, and analyst workflows remain outside its scope.

Not applicable for this control: VCF, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control C2.a (point 6)

Threat Hunting: You have justified confidence in the effectiveness of your threat hunts and the threat hunting process is reviewed and updated to match the risks posed to network and information systems supporting your essential function(s).

SCF Controls: THR-07

Aggregate Coverage: Contributes

VMware vDefend (Contributes)

VMware vDefend supports threat hunting at the network layer through Network Detection and Response (NDR), Security Intelligence campaign correlation, and IDS/IPS detection capabilities.

NDR correlates related detection events into campaigns and organizes threat events into a timeline that security analysts can view and triage by correlating threat signals. A campaign provides a view of a threat by correlating detection events to identify the different stages of an attack, and security teams can investigate individual threat events and correlated campaigns to assess impact, identify root causes, and take appropriate mitigation actions.

The Campaign Blueprint graph in Security Intelligence visualizes IoC relationships as directed connections, displaying node information that includes Threats, Custom IDS Signatures, and Indicators of Compromise (IOC). Nodes represent relationships such as "IOC for Threat" (a connection from an Indicator of Compromise to a threat) and "Source of Threat" (traffic flowing from a workload to a threat, indicating the workload is the origin). Campaign Correlation Rules assign impact scores ranging from 0 through 100, with 100 indicating highest severity, and can escalate combinations of lower-severity detections based on correlation logic, enabling analysts to prioritize their investigation queue.

The Security Intelligence blast radius view helps analysts determine whether a detection represents a targeted attack on specific systems or a widespread campaign affecting multiple parts of the infrastructure. The threat visualization canvas supports rapid threat containment, compromised asset identification, and microsegmentation policy adjustment. IDS/IPS events and NDR findings support date range filtering for temporal analysis of security events and intrusion attempts.

Custom IDS/IPS signatures can be added to profiles and applied to Distributed Firewall or Gateway Firewall rules to encode known IoC patterns directly into detection policy. The signature language supports DNP3 application data object matching for industrial control system threat detection. Threat Event Monitoring provides visibility into intrusions detected based on custom signatures, and the IDS/IPS Monitoring page lets administrators view details of actions taken when rules are triggered. IDS/IPS logs include the category of the detected threat along with other structured metadata for analyst triage.

The Security Overview Dashboard includes a Threat Event Monitoring view that provides insights about the current state of security issues in the data center, helping security teams understand network activity and focus investigation areas. Suspicious Traffic detection through Network Traffic Analysis detectors is part of the vDefend Advanced Threat Prevention capability set.

vDefend contributes the network-layer visibility, detection, and correlation capabilities for threat hunting; broader orchestration, endpoint telemetry, and analyst workflows remain outside its scope.

Not applicable for this control: VCF, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control C2.a (point 7)

Threat Hunting: You leverage automation to improve threat hunts where appropriate (e.g. some stages of the threat hunting process are automated).

SCF Controls: THR-07

Aggregate Coverage: Contributes

VMware vDefend (Contributes)

VMware vDefend supports threat hunting at the network layer through Network Detection and Response (NDR), Security Intelligence campaign correlation, and IDS/IPS detection capabilities.

NDR correlates related detection events into campaigns and organizes threat events into a timeline that security analysts can view and triage by correlating threat signals. A campaign provides a view of a threat by correlating detection events to identify the different stages of an attack, and security teams can investigate individual threat events and correlated campaigns to assess impact, identify root causes, and take appropriate mitigation actions.

The Campaign Blueprint graph in Security Intelligence visualizes IoC relationships as directed connections, displaying node information that includes Threats, Custom IDS Signatures, and Indicators of Compromise (IOC). Nodes represent relationships such as "IOC for Threat" (a connection from an Indicator of Compromise to a threat) and "Source of Threat" (traffic flowing from a workload to a threat, indicating the workload is the origin). Campaign Correlation Rules assign impact scores ranging from 0 through 100, with 100 indicating highest severity, and can escalate combinations of lower-severity detections based on correlation logic, enabling analysts to prioritize their investigation queue.

The Security Intelligence blast radius view helps analysts determine whether a detection represents a targeted attack on specific systems or a widespread campaign affecting multiple parts of the infrastructure. The threat visualization canvas supports rapid threat containment, compromised asset identification, and microsegmentation policy adjustment. IDS/IPS events and NDR findings support date range filtering for temporal analysis of security events and intrusion attempts.

Custom IDS/IPS signatures can be added to profiles and applied to Distributed Firewall or Gateway Firewall rules to encode known IoC patterns directly into detection policy. The signature language supports DNP3 application data object matching for industrial control system threat detection. Threat Event Monitoring provides visibility into intrusions detected based on custom signatures, and the IDS/IPS Monitoring page lets administrators view details of actions taken when rules are triggered.

IDS/IPS logs include the category of the detected threat along with other structured metadata for analyst triage.

The Security Overview Dashboard includes a Threat Event Monitoring view that provides insights about the current state of security issues in the data center, helping security teams understand network activity and focus investigation areas. Suspicious Traffic detection through Network Traffic Analysis detectors is part of the vDefend Advanced Threat Prevention capability set.

vDefend contributes the network-layer visibility, detection, and correlation capabilities for threat hunting; broader orchestration, endpoint telemetry, and analyst workflows remain outside its scope.

Not applicable for this control: VCF, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control C2.a (point 8)

Threat Hunting: Your threat hunts focus on the tactics, techniques and procedures (TTPs) of threats over atomic IoCs (e.g. hashes, IP addresses, domain names etc).

SCF Controls: THR-07

Aggregate Coverage: Contributes

VMware vDefend (Contributes)

VMware vDefend supports threat hunting at the network layer through Network Detection and Response (NDR), Security Intelligence campaign correlation, and IDS/IPS detection capabilities.

NDR correlates related detection events into campaigns and organizes threat events into a timeline that security analysts can view and triage by correlating threat signals. A campaign provides a view of a threat by correlating detection events to identify the different stages of an attack, and security teams can investigate individual threat events and correlated campaigns to assess impact, identify root causes, and take appropriate mitigation actions.

The Campaign Blueprint graph in Security Intelligence visualizes IoC relationships as directed connections, displaying node information that includes Threats, Custom IDS Signatures, and Indicators of Compromise (IOC). Nodes represent relationships such as "IOC for Threat" (a connection from an Indicator of Compromise to a threat) and "Source of Threat" (traffic flowing from a workload to a threat, indicating the workload is the origin). Campaign Correlation Rules assign impact scores ranging from 0 through 100, with 100 indicating highest severity, and can escalate combinations of lower-severity detections based on correlation logic, enabling analysts to prioritize their investigation queue.

The Security Intelligence blast radius view helps analysts determine whether a detection represents a targeted attack on specific systems or a widespread campaign affecting multiple parts of the infrastructure. The threat visualization canvas supports rapid threat containment, compromised asset identification, and microsegmentation policy adjustment. IDS/IPS events and NDR findings support date range filtering for temporal analysis of security events and intrusion attempts.

Custom IDS/IPS signatures can be added to profiles and applied to Distributed Firewall or Gateway Firewall rules to encode known IoC patterns directly into detection policy. The signature language supports DNP3 application data object matching for industrial control system threat detection. Threat Event Monitoring provides visibility into intrusions detected based on custom signatures, and the IDS/IPS Monitoring page lets administrators view details of actions taken when rules are triggered.

IDS/IPS logs include the category of the detected threat along with other structured metadata for analyst triage.

The Security Overview Dashboard includes a Threat Event Monitoring view that provides insights about the current state of security issues in the data center, helping security teams understand network activity and focus investigation areas. Suspicious Traffic detection through Network Traffic Analysis detectors is part of the vDefend Advanced Threat Prevention capability set.

vDefend contributes the network-layer visibility, detection, and correlation capabilities for threat hunting; broader orchestration, endpoint telemetry, and analyst workflows remain outside its scope.

Not applicable for this control: VCF, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control D1

Principle D1 Response and Recovery Planning: There are well-defined and tested incident management processes in place, that aim to ensure continuity of essential function(s) in the event of system or service failure. Mitigation activities designed to contain or limit the impact of compromise are also in place.

SCF Controls: IRO-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides technical capabilities that support an organization's incident response operations, though it does not govern organization-wide incident response processes or maintain incident response documentation. VCF Operations is the primary platform for detecting, tracking, and investigating infrastructure-level incidents across the VCF environment.

VCF Operations includes a dedicated incident management system that displays all incidents with their current status and key metadata. Each incident record tracks state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation. Operators can edit, share, and delete incidents directly from the incident list interface, and the system maintains an audit trail of who created each incident and when. This structured tracking provides the documentation trail that incident response processes require.

For incident investigation, VCF Operations provides root cause analysis tooling through its Troubleshooting Incident Page. This interface displays information about the affected entity, including traffic and flow data, any past incidents created for the same entity, and root cause metrics. Investigators can flag individual metrics and mark specific metrics as the root cause of an incident. The system also allows drill-down into related entities to view detailed metrics for problem investigation, supporting a methodical approach to identifying the source and scope of an issue. A summary view displays the count of in-progress incidents, entity counts, and top root causes, which supports situational awareness during active incident response and helps teams prioritize efforts across multiple concurrent issues.

For detection, VCF Operations performs event correlation across monitored systems, correlating a subset of published events and delivering them as faults. The platform maps events from target systems into the VCF Operations severity model, with event severity ranked from Info to Immediate. This automated correlation and severity classification helps operations teams identify incidents that require immediate response. Notification rules can be configured to trigger actions based on incident state changes, with configurable fields including incident state, resolution code, on-hold reason, impact, urgency, priority, assignment group, assigned-to person, severity, approval actions, related problems, and change cause. VCF Operations also supports defining fault symptoms and metric event symptoms based on thresholds and conditions reported by monitored systems, which can be combined into alert definitions that surface conditions requiring operator attention.

At the VMware vCenter level, alarms can execute scripts, send SNMP traps, or call APIs when infrastructure conditions match defined thresholds. The SNMP agent included with vCenter sends traps when alarms are triggered, and VCF PowerCLI provides programmatic access to alarm management through cmdlets that support creation of script-based and SNMP alarm actions. These capabilities provide automated event detection and alerting that feed into broader incident response processes.

To integrate with broader organizational incident response workflows, VCF Operations supports a ServiceNow Notifications plug-in that creates incidents directly in a ServiceNow ticketing system. The integration is configurable with fields including caller ID, incident category, sub-category, business service, contact type, and propagation settings for alert updates. This integration enables VCF-detected incidents to flow into an organization's established incident response and ticketing processes.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a physical machine failure. Proactive HA integrates with hardware vendor health monitoring to evacuate workloads before failures occur. vSphere cluster HA

configuration supports multiple remediation modes, including quarantine mode, maintenance mode, and mixed mode. These recovery capabilities can be exercised ad hoc or incorporated into existing playbooks and runbooks.

VMware vDefend (a separate product that extends VCF's networking foundation) adds automated threat detection and containment through IDS/IPS and network detection features, including quarantine policies that isolate affected VMs while preserving forensic access.

This control requires organization-wide incident response governance, documented processes, and cross-functional coordination that go beyond what any infrastructure platform provides on its own. VCF delivers incident tracking, investigation tooling, event correlation, automated alerting, ITSM integration, and infrastructure recovery capabilities that form a technical foundation for incident response, but organizations must build their own incident response plans, escalation procedures, communication protocols, and training programs around these capabilities.

VMware vDefend (Contributes)

VMware vDefend contributes to incident response operations by providing integrated threat detection, investigation, correlation, and remediation capabilities within the network security layer of VCF. Security Services Platform defines a Security Operator role specifically for monitoring security systems and responding to security incidents, providing a built-in responsibility model for incident response activities at the network security layer.

Security teams can investigate individual threat events and correlated campaigns through the Security Services Platform interface to assess impact, identify root causes, and take appropriate mitigation actions. The Campaign Blueprint feature visualizes correlated security events and key actors within a campaign, simplifying triage and investigation to reduce mean time to detection. Campaign correlation surfaces multi-stage attack patterns: a drive-by infection event followed by a command-and-control event on the same workload is linked into a single campaign view. Security Intelligence categorizes detected suspicious traffic events by impact type (Critical, High, Medium, and Low) to help prioritize response actions.

Network Detection and Response (NDR) provides security analysts with capabilities to understand security events, triage them, and remediate by creating policies. NDR includes Suspicious Traffic detectors that collect and display suspicious traffic detections as events. Each detection event receives an impact score calculated from Confidence and Severity; informational events with scores from 1 to 24 indicate activity that is not essentially malicious and help teams focus attention on higher-priority events.

Security Services Platform generates Security Segmentation Reports and Blast Radius Reports that break down at-risk workloads, communication chains, and flows, helping teams assess the potential scope and lateral spread of an incident. The Rule Analysis feature generates downloadable CSV reports of anomaly analysis results, with separate files for each detected anomaly type. Security Services Platform provides metrics for Malware Prevention Service events, including malware family, non-benign indicators, process inspection events, and process state data, accessible through the API.

For remediation, the Response and Remediation feature in Security Services Platform performs automated policy creation based on user role and permissions. Intelligent Assist supports two remediation strategies, Targeted (surgical, with potentially lower breadth) and Comprehensive (broader scope), allowing teams to select the appropriate approach for each incident. Security Services Platform collects IDS policies, rules, and security profiles created by Intelligent Assist as part of remediation operations. Objects generated during NDR remediation that encounter errors require manual cleanup in Intelligent Assist.

These capabilities support detection, investigation, and remediation phases of an incident response lifecycle at the network security layer. vDefend does not govern organization-wide incident response processes, maintain incident response documentation, or manage incident tracking and status coordination functions. Those organizational and process governance functions fall outside the scope of a network security product.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides data protection incident response capabilities through structured recovery plans, non-disruptive testing, and automated failover orchestration. Recovery plans define documented, repeatable response procedures that specify VM recovery sequences and reprotect operations following a recovery event, with reprotect process states displayed in the recovery plan user interface so operators can observe operation status. Test failover and planned

migration operations validate response readiness before an incident, and disaster recovery failover handles unplanned events when the protected site is unavailable.

PNR's event logging and alarm framework detects conditions that may indicate a data protection incident, including site connectivity loss, replication failures, and interrupted reprotect operations. PNR captures audit events that record user actions, including configuration changes and recovery plan executions, with the event name, user identity, and source IP address where the event was initiated. The PlanExecReprotectEnd event is signaled on the recovery site when a reprotect operation completes, supporting closure of the response lifecycle. Protection and Recovery Dashboards in VCF Operations provide consolidated visibility across vCenters, vSAN snapshot and replication sites, VCF Protection and Recovery Cloud regions, and protection and recovery site pairs to help incident responders see protection status at a glance.

For cyber-incident scenarios, PNR includes Cyber Recovery with a clean room at the recovery site to isolate recovered workloads during ransomware analysis. Cyber Recovery integrates with Carbon Black and CrowdStrike for security and vulnerability analysis: results include risk score details, environmental impact, CrowdScore severity (a CrowdScore of 100 indicates a critical threat level), and recommended remediation actions to support response decisions. When a disaster affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so organization users can return to running their workloads.

Not applicable for this control: VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control D1.a

Response Plan: You have an up-to-date incident response plan that is grounded in a thorough risk assessment that takes account of network and information systems supporting the operation of your essential function(s) and covers a range of incident scenarios.

SCF Controls: IRO-04

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control D1.b

Response and Recovery Capability: You have the capability to enact your incident response plan, including effective limitation of impact on the operation of your essential function(s). During an incident, you have access to timely information on which to base your response decisions.

SCF Controls: IRO-02

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides technical capabilities that support several phases of the incident handling lifecycle, though the organizational preparation, process governance, and manual intake elements require processes and structures outside the platform.

For preparation, VCF Operations supports the configuration of notification rules with detailed incident field mappings, including incident state, resolution codes, impact, urgency, priority, severity levels, and assignment groups. The ServiceNow Management Pack can be configured with parameters such as `callerId`, `propagateAlertUpdates`, `retrieveIncidentUpdates`, and `incidentReopenState`, allowing organizations to establish incident handling workflows before events occur. These configuration options allow teams to define how incidents are categorized, prioritized, and routed in advance of any actual incident.

For automated event detection, VCF Operations correlates events from monitored infrastructure components and delivers them as faults. Events are ranked by severity from Info through Warning, Critical, and Immediate, and notification rules trigger actions based on incident state changes. VCF Operations can automatically create incidents in ServiceNow through the Service-Now Notifications plug-in, with structured information including the caller, category, subcategory, and business service. This integration bridges the gap between infrastructure monitoring and organizational incident tracking systems. VCF Operations also combines Diagnostic Findings with VCF Health to detect and predict issues, which helps reduce mean time to resolution. VMware vCenter alarms provide additional automated detection, triggering script execution, SNMP traps, email notifications, or API calls when infrastructure conditions exceed defined thresholds.

For analysis, the Troubleshooting Incident Page displays information related to the entity under investigation, including traffic and flows on the entity, past incidents created for that entity, status, root cause metrics, and closing remarks. Operators can flag metrics and mark specific metrics as root cause during investigation. The Notes section on each incident allows users to add observations that are visible to anyone who opens the session, which supports collaborative analysis across team members. vCenter Events record user and system actions on inventory objects and can be used for forensic analysis and auditing of activity in the virtual environment, providing an audit trail for incident investigation. Diagnostic Findings consolidates log-based and property-based findings with specific resolution recommendations and links to knowledge base articles, helping analysts identify known issues by matching log patterns and property-based signatures against a library of diagnostic rules. Log Assist can generate log bundles and automatically attach property-based diagnostic findings data to support cases. VCF Operations also integrates with ServiceNow, allowing incidents to flow into existing ITSM workflows for structured triage.

For containment, vCenter supports isolating affected workloads through VM power state changes and network reconfiguration. VMware vDefend (a separate product that extends VCF's networking foundation) provides more targeted containment through quarantine policies that automatically isolate VMs based on security events while preserving forensic access for investigation. Physical containment, network isolation decisions, and cross-system coordination during active incidents depend on processes and authority structures that exist outside the platform.

For eradication, VCF Operations maps out-of-the-box workflows to recommendations and associates them with specific alerts, enabling automated remediation of known conditions. Diagnostic Findings helps operators find and resolve known issues using diagnostic rules and signatures, with recommended fixes based on industry-standard best practices.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a host failure, with admission control policies that reserve capacity for failover. Proactive HA integrates with hardware vendor monitoring to detect degrading components and

evacuate workloads before failure occurs. vSphere Fault Tolerance provides continuous availability for workloads that require zero-downtime protection during failover. VCF Operations maintains a summary view of all incidents with status tracking, entity counts for in-progress incidents, and counts of top root causes for visibility into the overall state of incident resolution.

VCF Operations also provides a centralized incident list displaying all incidents with their status and key details, with edit, share, and delete actions for incident lifecycle management. Incident tracking captures state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation, which is a structured audit trail for each incident. The Guided Network Troubleshooting feature automatically maintains a list of the 20 most recently modified incidents within a selected scope for continuity across investigation sessions.

While VCF Operations provides tooling for detection, analysis, and remediation of infrastructure incidents, several aspects of the six-phase incident handling lifecycle require organizational processes beyond what the platform provides. Preparation requires documented incident response plans, team roles, and communication procedures. Manual incident report intake requires organizational channels and triage processes. Containment decisions require human judgment and authority structures. A formal incident response program that incorporates VCF's technical capabilities into broader organizational processes is necessary to address all six phases.

VMware vDefend (Contributes)

VMware vDefend (VMware vDefend and Advanced Threat Protection) contributes to multiple phases of the incident handling lifecycle through network-layer detection, multi-signal analysis, and automated containment capabilities.

For detection and event intake, Security Intelligence categorizes detected suspicious traffic events by impact type, assigning Critical, High, Medium, or Low severity to help teams prioritize response. Security Intelligence also maps detections to MITRE ATT&CK tactics and techniques and records occurrence counts over configurable time windows, providing the structured event context that analysis workflows require.

For analysis, Malware Prevention generates File Analysis Reports and Process Analysis Reports that detail the types of activities detected during artifact inspection. File Analysis Reports classify detected behaviors across categories including Autostart, Disable, Evasion, File, Memory, Network, Reputation, Settings, Signature, Steal, Stealth, and Silenced, and include an ATT&CK TECHNIQUES field that records observed malicious actions or tools. Process Analysis Reports document in-memory script buffer inspection results and carry an Analyst UUID to track individual inspection events. Malware Prevention Service event logs capture file type, file size, inspection timestamp, client VM ID, submission source, detection status, verdict, and analysis status for each inspected file. The Malware Prevention Dashboard aggregates file and process event details and inspection results for operator review. Network Detection and Response (NDR) Campaign Correlation Rules correlate labeled file and process detections, including AV labels and PCAP matches, with matching IDS events on the same compute, supporting multi-signal analysis during investigation. The Security Services Platform assigns a Security Operator role dedicated to monitoring security systems and responding to security incidents.

For containment and eradication, Intelligent Assist supports remediation by allowing selection of a Targeted Strategy for surgical, focused containment or a Comprehensive Strategy for broader remediation across potentially affected workloads. The Security Segmentation Report's Overview section summarizes inter-environment policies and rules, providing traffic flow context that can inform containment scope. Security Explorer's ratio of detected versus prevented events helps operators assess how effectively controls are operating during active response.

A limitation applies to automated remediation: objects generated during Intelligent Assist or NDR remediation that encounter errors require manual cleanup, so recovery activities may require human intervention beyond automated policy actions. vDefend IDS/IPS also applies a severity-based prioritization under memory pressure, dropping lower-severity events (Low and Informational) first before Medium, High, and Critical, which operators should account for when assessing detection completeness during an investigation.

Preparation and full organizational recovery rely on processes and tooling outside vDefend's scope.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides technical mechanisms that support the recovery, containment, and detection phases of incident handling through recovery plans, isolated cyber-recovery workflows, structured event logging, and integration with security monitoring platforms.

Recovery plans define ordered procedures for recovering protected workloads at a recovery site, including custom recovery steps. PNR handles custom command failures in recovery plans based on the type of command, allowing operators to control how the plan continues when steps fail. When a disaster event affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so that users can recover workloads. After execution, PNR provides the ability to view and export reports about each run of a recovery plan, test of a recovery plan, or test cleanup, producing documented evidence for after-action review.

For containment and eradication, the Clean Room Orchestrator enables triage and analysis of recovered workloads in an isolated environment. PNR monitors a global collection of clean room events, tasks, and alarms for recovery operations, with Clean Room Orchestrator events classified at severity levels of Info, Warning, Error, and Emergency. This isolated environment supports analysis of suspect workloads in parallel to site-level recovery actions.

For detection and analysis, PNR logs events and triggers corresponding alarms to track system health, with event records including timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. PNR tracks Site Status events that provide information about the status of protected and recovery sites and the connection between them. PNR can forward Clean Room Orchestrator events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, supporting integration with broader security monitoring and incident response platforms.

PNR Health findings classify status into Error, Warning, and Info categories and are visible through Protection and Recovery dashboards in VCF Operations. Deployment topology with separate management domains for each region is designed to contain the impact of a disaster event to one particular region, supporting preparation by limiting blast radius.

VMware Avi Load Balancer (Contributes)

Avi Load Balancer contributes to the incident handling lifecycle by providing application-layer detection, analysis, automated alerting, and recovery capabilities within its role as an application delivery controller.

For preparation, the Controller's alert and event framework supports pre-configured response actions. ControlScripts, defined under Alert Actions in the Controller UI, allow administrators to specify automated responses that fire when defined alert conditions are met. The Alert feature processes system events and metrics against user-defined rules and generates notifications via email, syslog message, or SNMP trap. The Syslog-Audit-Persistence alert action streams audit compliance events to external syslog servers, enabling incident response tooling to receive Avi event data in real time.

For automated event detection, the Controller's System Events Overlay records event codes that provide high-level definitions of system status, including SERVER_HEALTH_DEGRADED, POOL_HEALTH_DEGRADED, and VS_UP. The Avi Service Engine logs events when WAF matches a transaction, and logs audit record failures to Events, Syslog, and Splunk, covering initiation and termination of trusted channels, certificate validation failures, client authentication failures, and SSH session establishment failures. The Application Security Report provides an executive summary alongside WAF statistics, including ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking source IP addresses, and trend summaries of total and flagged request volumes.

For analysis, Avi Service Engine health monitoring records failure details for each monitored server, including failure type, failure count, average response time, and minimum and maximum response times. The Service Engine analytics page displays the list of failed health monitors per server in a pool, enabling investigation of health patterns. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation, enabling more accurate signal analysis during an investigation. Support bundles collect diagnostic data, logs, and configuration information from the system to assist in troubleshooting and resolving issues.

For containment, WAF policies block application-layer requests that match defined rules or anomaly score thresholds, and WAF Policies can attach a Positive Security group to apply learned data and define hit/miss actions for fine-grained control. ControlScripts can trigger automated containment actions in response to alert events.

For recovery, the Avi for VCF rollback procedure supports validation of the operational status of all VIPs and pools, followed by end-to-end health checks on the VS-App environment. GSLB services with the priority algorithm support a manual resume option for controlled failover and recovery management.

The full incident handling program, including organizational preparation procedures, eradication processes for removing attacker footholds across the broader environment, cross-team coordination, and end-to-end recovery governance, requires processes and tooling beyond what Avi provides within its application delivery scope.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control D1.c

Testing and Exercising: Your organisation carries out exercises to test response plans, using past incidents that affected your (and other) organisation, and scenarios that draw on threat intelligence and your risk assessment.

SCF Controls: IRO-06

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control D2

Principle D2 Lessons Learned: When an incident occurs, steps are taken to understand its causes and to ensure remediating action is taken to protect against future incidents.

SCF Controls: IRO-13

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control D2.a

Post Incident Analysis: When an incident occurs, your organisation takes steps to understand its causes, informing appropriate remediating action.

SCF Controls: IRO-13

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control D2.b

Using Incidents to Drive Improvements: Your organisation uses lessons learned from incidents to improve your security measures.

SCF Controls: IRO-13

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

